

Evidence pack

Every answer in this round, with the passages it is drawn from.

Customer	Northwind Traders (journey)
Review	rev-673ce276597e
Round	1 (rev-673ce276597e-r1)
Framework	caiq
Data residency	us
Review state	drafting
Questions	312
Answered	239
Answers with citations	219 of 239
Sendable	133
Approved by a human	0
Generated	2026-08-17T19:06:24+00:00
Produced by	attestor-control-plane attestor-control-plane-00008-9m2 · attestor-505506 · us-central1

Release rule

Every question is listed and nothing is omitted. An answer marked approved was signed off by a named human. An answer marked drafted with citations is grounded in retrieved evidence and was not individually reviewed — the passages it relies on are listed beside it, with the document, section and relevance score, so the claim can be checked rather than trusted. An answer marked held, no evidence, quarantined or rejected must not be sent to a customer as an answer.

Yes — drafted with citations, not individually reviewed	133
No — held for a human	86
No — not answered in this round	73
No — no supporting evidence found	18
No — quarantined by the guardrail	2

Answers and evidence

1. Are passwords subject to a forced rotation schedule?

security · Q1 · Vendor Security Review row 2

Passwords are not subject to a forced rotation schedule, aligned with NIST SP 800-63B guidance. Instead, rotation is enforced upon evidence of compromise. Additionally, where passwords are used, they must have a minimum length of 14 characters and are checked against the Have I Been Pwned breached-password corpus at the time of creation (Access Control Standard, Section 9: Password requirements).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] access-control-standard — 9. Password requirements — relevance 0.69

9. Password requirements

Where a password is used, minimum length is 14 characters, checked against the Have I Been Pwned breached-password corpus at set time. Rotation is not forced on a schedule, in line with NIST SP 800-63B guidance; rotation is forced on evidence of compromise.

gs://attestor-505506-corporus/security/access-control-standard.txt

[2] access-control-standard — 1. Identity provider — relevance 0.60

1. Identity provider

All Kestrel Data systems authenticate through Okta (tenant `kestreldata.okta.com`). Local accounts on production systems are prohibited except for two documented break-glass accounts held in a sealed 1Password vault, whose use triggers a PagerDuty alert to the CISO. Both break-glass credentials were last rotated on 3 January 2026 and last used on 14 August 2025 during the

gs://attestor-505506-corporus/security/access-control-standard.txt

[3] access-control-standard — 2. Multi-factor authentication — relevance 0.58

2. Multi-factor authentication

Hardware-backed MFA (WebAuthn / FIDO2, YubiKey 5 series) is mandatory for every human account. SMS and TOTP were removed as acceptable factors on 30 June 2025 following the RISK-2025-0031 treatment plan. Coverage is 100% of the 187 active employee accounts and 100% of the 24 active contractor accounts, verified continuously by Vanta control AC-07.

gs://attestor-505506-corporus/security/access-control-standard.txt

[4] access-control-standard — 3. Role-based access — relevance 0.56

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix (`SEC-GOV/access-matrix`), which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is just-in-time.

gs://attestor-505506-corporus/security/access-control-standard.txt

[5] access-control-standard — 6. Joiners, movers, leavers — relevance 0.56

6. Joiners, movers, leavers

Joiners are provisioned via Okta Lifecycle Management from Rippling (HRIS); no access is granted before the background check clears. Movers have entitlements recalculated on role change, with the previous role revoked within 1 business day. Leavers have all access revoked automatically on the HRIS termination event: the target is 1 hour, and the measured median for

gs://attestor-505506-corporus/security/access-control-standard.txt

2. Are confidentiality obligations imposed on personnel, and do they survive termination?

legal · Q2 · Vendor Security Review row 3

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

3. Do you offer a single-tenant or dedicated instance deployment?

engineering · Q3 · Vendor Security Review row 4

No, Kestrel Insight is a multi-tenant platform with logical isolation; we do not offer per-customer infrastructure, single-tenant deployment options, or customer-VPC deployments (`infrastructure-architecture-overview`, Section 5 "Tenant isolation"). Tenant isolation is enforced across three layers: - **Database:** PostgreSQL row-level security policies keyed on `tenant\_id` are applied at the connection level from authenticated session variables, with no application query able to opt out (`infrastructure-architecture-overview`, Section 5 "Tenant isolation"). - **Application:** Every request carries a validated tenant claim, and the repository base class enforces that the data access layer refuses any query lacking a tenant predicate (`infrastructure-architecture-overview`, Section 5 "Tenant isolation"). - **Storage:** S3 object keys are tenant-prefixed, with IAM policies constraining access by prefix (`infrastructure-architecture-overview`, Section 5 "Tenant isolation").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (5)

[1] infrastructure-architecture-overview — 3. Compute — relevance 0.62

3. Compute

Amazon EKS (Kubernetes 1.31) with managed node groups spanning three availability zones. Workloads run as containers built from distroless base images, as non-root, with read-only root filesystems and dropped Linux capabilities. Pod Security Standards are enforced at the `restricted` level.

Node images are immutable; nodes are recycled with a maximum age of 30 days rather than pa

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[2] infrastructure-architecture-overview — 6. Network — relevance 0.60

6. Network

Private subnets for all compute and data. No public IP addresses on workload instances. Ingress is exclusively through Cloudflare, then an AWS Application Load Balancer, then the Istio ingress gateway. Egress is through NAT gateways with an allowlist for known destinations.

Security groups are managed in Terraform and default-deny. There are no `0.0.0.0/0` ingress rules in produc

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[3] infrastructure-architecture-overview — 5. Tenant isolation — relevance 0.60

5. Tenant isolation

Kestrel Insight is **multi-tenant** with logical isolation. There is no per-customer infrastructure, no single-tenant deployment option, and no customer-VPC option.

Isolation is enforced at three layers:

1. **Database** - PostgreSQL row-level security policies keyed on `tenant\_id`, applied at the connection level from an authenticated session variable. No application

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[4] data-flow-and-shared-responsibility — 1. Data flow, end to end — relevance 0.57

1. Data flow, end to end

1. **Ingress.** A customer's browser or API client resolves `app.kestreldata.com` or `api.kestreldata.com` to Cloudflare, which terminates TLS 1.3 (1.2 minimum) and applies WAF and rate limiting.
2. **Instance selection.** DNS and tenant routing send the request to the instance chosen at contract signature: `us-east-1` or `eu-west-1`. **A tenant's requests never c**

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[5] data-flow-and-shared-responsibility — 6. Where processing occurs — relevance 0.56

6. Where processing occurs

Processing occurs in AWS `us-east-1` (US instance) and AWS `eu-west-1` (EU instance), by personnel located in the United States, the European Union, the United Kingdom, and Canada, under the access controls in KD-SEC-002. ****No processing occurs outside the stated regions****, and no support is subcontracted to a third-party provider in another jurisdiction.

gs://attestor-505506-corpus/engineering/data-flow-and-shared-responsibility.txt

4. Do you scan source code for committed secrets?

security · Q4 · Vendor Security Review row 5

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

5. Has your organisation been subject to a regulatory enforcement action?

legal · Q5 · Vendor Security Review row 6

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] legal-and-regulatory-history — 2. Regulatory enforcement — relevance 0.59

2. Regulatory enforcement

****Kestrel Data has never been subject to a regulatory enforcement action, fine, consent decree, undertaking, or formal investigation**** by any data protection authority, sectoral regulator, or competition authority. No supervisory authority has issued Kestrel a reprimand, order, or corrective measure under Article 58 of the GDPR.

Kestrel has never made a personal data bre

gs://attestor-505506-corpus/legal/legal-and-regulatory-history.txt

[2] legal-and-regulatory-history — 3. Complaints — relevance 0.57

3. Complaints

Two data subject complaints have been received directly since 2019, both from individuals whose employers were Kestrel customers, and both resolved by directing the complainant to their employer as controller with an explanation of the roles. Neither complainant escalated to a supervisory authority.

gs://attestor-505506-corpus/legal/legal-and-regulatory-history.txt

[3] legal-and-regulatory-history — 7. Regulatory scope — relevance 0.55

7. Regulatory scope

Kestrel is not a regulated financial institution, is not a covered entity or business associate under HIPAA (see KD-LEG-014 §4), is not a federal contractor, and is not subject to sectoral supervision. Its obligations arise from general data protection law, its contracts, and the certifications it chooses to maintain.

gs://attestor-505506-corpus/legal/legal-and-regulatory-history.txt

[4] legal-and-regulatory-history — 8. Statements in this document — relevance 0.55

8. Statements in this document

Every statement above is confirmed by the General Counsel as at the approval date and is restated at each annual review. Where a customer requires a contemporaneous confirmation, the General Counsel will provide one in writing at the point of contracting; several customers require this annually and it is provided as a matter of course.

gs://attestor-505506-corpus/legal/legal-and-regulatory-history.txt

[5] legal-and-regulatory-history — 6. Legal hold — relevance 0.53

6. Legal hold

Kestrel operates a documented legal hold process, owned by the General Counsel. On becoming aware of reasonably anticipated litigation or an investigation, the General Counsel issues a written hold notice identifying custodians and data sources, and suspension of the ordinary retention schedule is applied in Google Vault and by disabling the relevant retention jobs. Holds are reviewed

gs://attestor-505506-corporus/legal/legal-and-regulatory-history.txt

6. Were any exceptions noted in your most recent SOC 2 report?

security · Q6 · Vendor Security Review row 7

No exceptions were noted in Kestrel Data's most recent SOC 2 Type II report. According to the **SOC 2 Control Matrix** (`soc2-control-matrix`, section **SOC 2 Control Matrix**), our independent auditor, Prescient Assurance LLP, issued an unqualified opinion with no exceptions noted for the reporting period covering 1 January through 31 December 2025 (report issued 14 March 2026). The report evaluates the Security, Availability, and Confidentiality Trust Services Criteria.

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] soc2-control-matrix — SOC 2 Control Matrix — relevance 0.70

SOC 2 Control Matrix

Document ID: KD-SEC-012 · **Version:** 2.1

Report period: 1 January - 31 December 2025 · **Report issued:** 14 March 2026

Auditor: Prescient Assurance LLP · **Opinion:** Unqualified, no exceptions noted

Trust Services Criteria in scope: Security, Availability, Confidentiality

Privacy and Processing Integrity are **not** in scope for the current report. Ke

gs://attestor-505506-corporus/security/soc2-control-matrix.txt

[2] risk-management-and-governance — 9. Exceptions — relevance 0.68

9. Exceptions

Exceptions to policy require: a written business justification, a compensating control, CISO approval, and an expiry date no later than 90 days out. Exceptions above residual score 12 additionally require Security Steering Group approval. Two exceptions were open as of 1 February 2026.

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[3] access-control-standard — 5. Customer data access — relevance 0.66

5. Customer data access

Kestrel personnel do not access customer production data as a matter of routine. Access for support purposes requires explicit per-incident customer authorisation recorded in Zendesk, is limited to the specific tenant, and expires after 24 hours.

Between 1 January and 31 December 2025 there were 19 such authorised accesses across 7 customers, each evidenced in the SOC

gs://attestor-505506-corporus/security/access-control-standard.txt

[4] risk-management-and-governance — Risk Management and Security Governance — relevance 0.66

Risk Management and Security Governance

Document ID: KD-SEC-018 · **Version:** 3.0 · **Owner:** Marcus Oyelaran, CISO

Approved: 26 January 2026 · **Next review:** 26 January 2027

Maps to: SOC 2 CC1.1, CC1.2, CC1.3, CC3.1, CC3.2, CC3.4 · ISO 27001:2022 A.5.1–A.5.4, Clauses 5–6, 9

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[5] soc2-control-matrix — Complementary user entity controls — relevance 0.66

Complementary user entity controls

The report identifies 6 controls that remain the customer responsibility, including managing their own user accounts and entitlements within the Kestrel tenant, configuring

SSO correctly, protecting API credentials issued to them, and reviewing their own audit logs. These are reproduced in full in Section 4 of the SOC 2 report.

gs://attestor-505506-corporus/security/soc2-control-matrix.txt

7. Do you operate a bug bounty programme?

security · Q7 · Vendor Security Review row 8

Kestrel Data does not currently operate a paid bug bounty programme. Instead, external vulnerability reports are managed through a responsible disclosure process. Kestrel publishes a security contact at `kestreldata.com/.well-known/security.txt`, commits to acknowledging submissions within two business days, and provides safe harbour ensuring researchers acting in good faith under the policy will not face legal action (*Vulnerability Management Policy*, Section 5: Responsible disclosure).

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by SecurityAgent

Evidence (5)

[1] vulnerability-management-policy — 5. Responsible disclosure — relevance 0.67

5. Responsible disclosure

Kestrel publishes a security contact at `kestreldata.com/.well-known/security.txt` and commits to acknowledging reports within 2 business days. Researchers acting in good faith under the published policy will not be pursued legally.

****Kestrel does not currently operate a paid bug bounty programme.**** Reports are handled through the responsible disclosure process above

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[2] vulnerability-management-policy — 4. Penetration testing — relevance 0.57

4. Penetration testing

An independent penetration test is commissioned ****annually**** at minimum, and additionally before any significant architectural change. The most recent was performed by Include Security from 3 to 14 February 2026 (engagement INSEC-2026-0219). See the Penetration Test Executive Summary (KD-SEC-007).

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[3] company-and-security-programme-overview — 3. Security programme in summary — relevance 0.57

3. Security programme in summary

The programme is built on four commitments, each evidenced elsewhere in this corpus rather than asserted here:

1. ****Independent verification.**** SOC 2 Type II (Prescient Assurance LLP, report issued 14 March 2026 covering 1 January – 31 December 2025, ****no exceptions****) and ISO 27001:2022 (BSI certificate `IS-2025-44817`, issued 22 September 2025, valid to 21

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[4] vulnerability-management-policy — 2. Scanning coverage — relevance 0.57

2. Scanning coverage

| Layer | Tool | Cadence |

|---|---|---|

| Dependencies (SCA) | Snyk Open Source | Every pull request, plus daily on `main` |

| Static analysis (SAST) | Semgrep + GitHub CodeQL | Every pull request |

| Container images | Amazon ECR enhanced scanning (Inspector) | On push, plus continuous rescan |

| Infrastructure | AWS Inspector, AWS Security Hub | Continuous |

| IaC | C

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[5] company-and-security-programme-overview — Company and Security Programme Overview — relevance 0.56

Company and Security Programme Overview

****Document ID:**** KD-SEC-021 · ****Version:**** 4.2 · ****Owner:**** Marcus Oyelaran, CISO

****Approved:**** 6 February 2026 · ****Next review:**** 6 February 2027

****Maps to:**** SOC 2 CC1.1, CC1.2, CC2.1, CC2.3 · ISO 27001:2022 Clauses 4–5

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

8. Provide your data retention schedule.

legal · Q8 · Vendor Security Review row 9

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] data-retention-schedule — Data Retention Schedule — relevance 0.74

Data Retention Schedule

Document ID: KD-LEG-004 · **Version:** 3.2 · **Owner:** Priya Raghunathan, DPO

Approved: 15 January 2026 · **Next review:** 15 January 2027

Maps to: GDPR Art. 5(1)(e) · SOC 2 C1.2 · ISO 27001:2022 A.5.33, A.8.10

gs://attestor-505506-corporus/legal/data-retention-schedule.txt

[2] data-retention-schedule — 6. Exceptions — relevance 0.71

6. Exceptions

Where a retention period conflicts with a customer contractual requirement, the shorter period applies unless law requires otherwise. Longer retention requires DPO approval, which has not been granted for any customer data class to date.

gs://attestor-505506-corporus/legal/data-retention-schedule.txt

[3] data-processing-agreement — 2. Scope and duration — relevance 0.69

2. Scope and duration

Processing continues for the term of the Agreement plus the retention periods in Annex 2. Kestrel processes Personal Data only on documented instructions from Customer. The Agreement, this DPA, and Customer configuration of the Service constitute those instructions.

If Kestrel is required by Union or Member State law to process beyond those instructions, it will inform

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[4] data-processing-agreement — 8. Deletion and return — relevance 0.67

8. Deletion and return

On termination, Customer may export its data through the Service for **30 days**. After that period Kestrel deletes Customer Personal Data within **90 days**, save where storage is required by law. Backups containing deleted data expire on the standard backup cycle, a maximum of **35 days** after deletion from primary storage. Certification of deletion is provided on wri

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[5] privacy-policy — 2. What we collect as controller — relevance 0.67

2. What we collect as controller

| Category | Examples | Lawful basis | Retention |

| ---|---|---|---|

| Account data | Name, work email, job title, company | Contract (Art. 6(1)(b)) | Term + 3 years |

| Billing data | Billing contact, VAT number, payment method token | Contract; legal obligation | 7 years (tax) |

| Product telemetry | Feature usage, page views, error events | Legitimate interest

gs://attestor-505506-corporus/legal/privacy-policy.txt

9. Have you experienced a customer data breach in the last 3 years?

security · Q9 · Vendor Security Review row 10

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

10. Please confirm: Were any exceptions noted in your most recent SOC 2 report?

security · Q10 · Vendor Security Review row 11

No exceptions were noted in Kestrel Data's most recent SOC 2 report. For the report period covering 1 January through 31 December 2025 (issued 14 March 2026), our auditor, Prescient Assurance LLP, issued an unqualified opinion with no exceptions noted across the in-scope Trust Services Criteria of Security, Availability, and Confidentiality (soc2-control-matrix, section "SOC 2 Control Matrix").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] soc2-control-matrix — SOC 2 Control Matrix — relevance 0.70

SOC 2 Control Matrix

Document ID: KD-SEC-012 · **Version:** 2.1

Report period: 1 January - 31 December 2025 · **Report issued:** 14 March 2026

Auditor: Prescient Assurance LLP · **Opinion:** Unqualified, no exceptions noted

Trust Services Criteria in scope: Security, Availability, Confidentiality

Privacy and Processing Integrity are **not** in scope for the current report. Ke

gs://attestor-505506-corporus/security/soc2-control-matrix.txt

[2] risk-management-and-governance — 9. Exceptions — relevance 0.68

9. Exceptions

Exceptions to policy require: a written business justification, a compensating control, CISO approval, and an expiry date no later than 90 days out. Exceptions above residual score 12 additionally require Security Steering Group approval. Two exceptions were open as of 1 February 2026.

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[3] access-control-standard — 5. Customer data access — relevance 0.66

5. Customer data access

Kestrel personnel do not access customer production data as a matter of routine. Access for support purposes requires explicit per-incident customer authorisation recorded in Zendesk, is limited to the specific tenant, and expires after 24 hours.

Between 1 January and 31 December 2025 there were 19 such authorised accesses across 7 customers, each evidenced in the SOC

gs://attestor-505506-corporus/security/access-control-standard.txt

[4] risk-management-and-governance — Risk Management and Security Governance — relevance 0.66

Risk Management and Security Governance

Document ID: KD-SEC-018 · **Version:** 3.0 · **Owner:** Marcus Oyelaran, CISO

Approved: 26 January 2026 · **Next review:** 26 January 2027

Maps to: SOC 2 CC1.1, CC1.2, CC1.3, CC3.1, CC3.2, CC3.4 · ISO 27001:2022 A.5.1–A.5.4, Clauses 5–6, 9

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[5] soc2-control-matrix — Complementary user entity controls — relevance 0.66

Complementary user entity controls

The report identifies 6 controls that remain the customer responsibility, including managing their own user accounts and entitlements within the Kestrel tenant, configuring SSO correctly, protecting API credentials issued to them, and reviewing their own audit logs. These are reproduced in full in Section 4 of the SOC 2 report.

gs://attestor-505506-corporus/security/soc2-control-matrix.txt

11. For each applicable system: Describe the data flow for customer data through your platform.

engineering · Q11 · Vendor Security Review row 12

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (11)

[1] data-flow-and-shared-responsibility — Data Flow and Shared Responsibility Model — relevance 0.70

Data Flow and Shared Responsibility Model

Document ID: KD-ENG-011 · **Version:** 2.0 · **Owner:** Dana Whitfield, VP Engineering

Approved: 2 February 2026 · **Next review:** 2 February 2027

Maps to: SOC 2 CC2.3, CC3.2, CC6.1 · ISO 27001:2022 A.5.2, A.5.8, A.8.9 · GDPR Article 28

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[2] infrastructure-architecture-overview — 4. Data layer — relevance 0.67

4. Data layer

| Store | Technology | Purpose |

|---|---|---|

| Primary OLTP | Amazon RDS PostgreSQL 16, Multi-AZ | Application state |

| Analytics | Snowflake | Customer analytics workloads |

| Object storage | Amazon S3 | Uploads, exports, backups |

| Cache | Amazon ElastiCache (Redis 7) | Session and query cache |

| Search | OpenSearch 2.13 | In-product search |

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[3] data-flow-and-shared-responsibility — 1. Data flow, end to end — relevance 0.67

1. Data flow, end to end

1. **Ingress.** A customer's browser or API client resolves `app.kestreldata.com` or `api.kestreldata.com` to Cloudflare, which terminates TLS 1.3 (1.2 minimum) and applies WAF and rate limiting.

2. **Instance selection.** DNS and tenant routing send the request to the instance chosen at contract signature: `us-east-1` or `eu-west-1`. A tenant's requests never c

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[4] infrastructure-architecture-overview — Infrastructure Architecture Overview — relevance 0.63

Infrastructure Architecture Overview

Document ID: KD-ENG-003 · **Version:** 3.4 · **Owner:** Dana Whitfield, VP Engineering

Last updated: 5 February 2026 · **Classification:** Confidential, NDA required

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[5] data-flow-and-shared-responsibility — 3. The shared responsibility model — relevance 0.63

3. The shared responsibility model

Security of the platform is Kestrel's. Security of what the customer does with it is the customer's. The line is drawn here rather than left implicit, because an unstated boundary is where a breach lands on whoever is less able to argue.

Kestrel is responsible for:

* physical and environmental security of the infrastructure (through AWS), and the cloud co

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[6] infrastructure-architecture-overview — 6. Network — relevance 0.61

6. Network

Private subnets for all compute and data. No public IP addresses on workload instances. Ingress is exclusively through Cloudflare, then an AWS Application Load Balancer, then the Istio ingress gateway. Egress is through NAT gateways with an allowlist for known destinations.

Security groups are managed in Terraform and default-deny. There are no `0.0.0.0/0` ingress rules in produc

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[7] infrastructure-architecture-overview — 7. Observability — relevance 0.60

7. Observability

Datadog for metrics, logs, APM, and security monitoring. Distributed tracing uses W3C Trace Context propagated across all services. Every log line carries `tenant\_id` and `request\_id`.

gs://attestor-505506-corporate-engineering/infrastructure-architecture-overview.txt

[8] data-flow-and-shared-responsibility — 2. What crosses a boundary, and what does not — relevance 0.57

2. What crosses a boundary, and what does not

| Data | Leaves the tenant's region? |

|---|---|

| Customer-uploaded analytics datasets | ****No**** |

| Backups of customer content | ****No**** |

| Account identity data (EU tenants) | Only for support access, under §4 of KD-SEC-002 |

| Pseudonymised product telemetry | Yes — aggregated to the US, assessed in KD-LEG-010 |

| Operational logs (content-redacted)

gs://attestor-505506-corporate-engineering/data-flow-and-shared-responsibility.txt

[9] data-flow-and-shared-responsibility — 6. Where processing occurs — relevance 0.56

6. Where processing occurs

Processing occurs in AWS `us-east-1` (US instance) and AWS `eu-west-1` (EU instance), by personnel located in the United States, the European Union, the United Kingdom, and Canada, under the access controls in KD-SEC-002. ****No** processing occurs outside the stated regions, and no support is subcontracted to a third-party provider in another jurisdiction.

gs://attestor-505506-corporate-engineering/data-flow-and-shared-responsibility.txt

[10] data-flow-and-shared-responsibility — 4. Complementary user entity controls — relevance 0.50

4. Complementary user entity controls

The SOC 2 report lists these as complementary user entity controls; they are restated here because a customer reading only this document should still see them. If a customer does not operate the controls in the second list, Kestrel's controls in the first do not compensate: Kestrel cannot detect that a departed employee of the customer still holds a valid session.

gs://attestor-505506-corporate-engineering/data-flow-and-shared-responsibility.txt

[11] data-flow-and-shared-responsibility — 5. Categories of customer data — relevance 0.46

5. Categories of customer data

The four categories the platform processes are defined in KD-SEC-004 §2 and mirrored in the Records of Processing Activities (KD-LEG-004). Kestrel does not process payment card data: Stripe collects card details directly and Kestrel holds a token and the last four digits.

gs://attestor-505506-corporate-engineering/data-flow-and-shared-responsibility.txt

12. Describe the security controls applied to your cloud service provider accounts.

security · Q12 · Vendor Security Review row 13

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

13. How is uptime measured, and by whom?

engineering · Q13 · Vendor Security Review row 14

Uptime is measured as the percentage of minutes in a calendar month during which the service is available, calculated using the formula:
$$\text{Uptime \%} = \left(\frac{\text{Total Minutes} - \text{Downtime Minutes}}{\text{Total Minutes}} \right) \times 100$$
 Downtime is defined as any minute in which all requests to the production API from the external monitoring network return a 5xx error or fail to connect (excluding degraded performance that does not produce errors). Measurement is conducted independently by a third-party monitoring service (Checkly) across 7 global locations at 30-second intervals, rather than through internal instrumentation. This monitoring data is available to

customers upon request (Availability Service Level Agreement, Section 2. Definitions).

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (5)

[1] availability-sla — 2. Definitions — relevance 0.63

2. Definitions

Uptime is the percentage of minutes in a calendar month during which the Service is Available, calculated as:

$$\text{Uptime \%} = ((\text{Total Minutes} - \text{Downtime Minutes}) / \text{Total Minutes}) \times 100$$

Downtime is any minute during which all requests to the production API from the external monitoring network return a 5xx error or fail to connect. Measurement is by independent third-p

gs://attestor-505506-corporus/engineering/availability-sla.txt

[2] availability-sla — 5. Historical performance — relevance 0.60

5. Historical performance

| Year | Measured availability | Months below 99.9% | Credits issued |

|---|---|---|---|

| 2025 | 99.97% | 0 | 0 |

| 2024 | 99.94% | 1 (March, 99.87%) | 1 customer, 10% |

| 2023 | 99.91% | 1 (August, 99.82%) | 3 customers, 10% |

gs://attestor-505506-corporus/engineering/availability-sla.txt

[3] availability-sla — 4. Service credits — relevance 0.59

4. Service credits

| Monthly uptime | Credit (% of monthly fee) |

|---|---|

| Below 99.9% but at or above 99.0% | 10% |

| Below 99.0% but at or above 95.0% | 25% |

| Below 95.0% | 50% |

Credits are the sole and exclusive remedy for failure to meet this SLA. A claim must be submitted within **30 days** of the end of the affected month, with supporting detail.

Credits are applied to the nex

gs://attestor-505506-corporus/engineering/availability-sla.txt

[4] availability-sla — 3. Exclusions — relevance 0.56

3. Exclusions

Downtime does not include unavailability caused by:

- Scheduled maintenance, notified at least 7 days in advance, in the window Sundays 04:00-06:00 UTC, capped at 4 hours per month.

- Emergency maintenance to address a security vulnerability, notified as soon as practicable.

- Customer configuration, customer code, or customer exceeding documented rate limits.

- Failure o

gs://attestor-505506-corporus/engineering/availability-sla.txt

[5] availability-sla — Availability Service Level Agreement — relevance 0.56

Availability Service Level Agreement

Document ID: KD-ENG-007 · **Version:** 3.0 · **Owner:** Aaron Feldstein, General Counsel

Effective: 1 January 2026 · Forms part of the Master Subscription Agreement

gs://attestor-505506-corporus/engineering/availability-sla.txt

14. Will you provide an SBOM on request?

engineering · Q14 · Vendor Security Review row 15

No supporting evidence was found in the corpus for this question.

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

15. Where is your service status published?

engineering · Q15 · Vendor Security Review row 16

Kestrel Data publishes its service status at `status.kestreldata.com`. The status page is hosted via Statuspage on infrastructure independent of Kestrel's own environment to ensure availability during outages. It provides per-component status for both US and EU instances, current and historical incident details, and scheduled maintenance notices. Customers can subscribe to updates via email, SMS, RSS, and webhooks (`service-operations-and-support`, Section 1: "Status page").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] service-operations-and-support — 1. Status page — relevance 0.72

1. Status page

Service status is published at `status.kestreldata.com`, hosted by Statuspage on infrastructure independent of Kestrel's own — a status page that shares a failure domain with the service is worthless during exactly the event it exists for. The page shows per-component status for the US and EU instances, current and historical incidents, and scheduled maintenance. Customers may s

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[2] availability-sla — 5. Historical performance — relevance 0.61

5. Historical performance

Year	Measured availability	Months below 99.9%	Credits issued
2025	99.97%	0	0
2024	99.94%	1 (March, 99.87%)	1 customer, 10%
2023	99.91%	1 (August, 99.82%)	3 customers, 10%

gs://attestor-505506-corporus/engineering/availability-sla.txt

[3] availability-sla — Availability Service Level Agreement — relevance 0.61

Availability Service Level Agreement

Document ID: KD-ENG-007 · **Version:** 3.0 · **Owner:** Aaron Feldstein, General Counsel
Effective: 1 January 2026 · Forms part of the Master Subscription Agreement

gs://attestor-505506-corporus/engineering/availability-sla.txt

[4] availability-sla — 2. Definitions — relevance 0.61

2. Definitions

Uptime is the percentage of minutes in a calendar month during which the Service is Available, calculated as:

$$\text{Uptime \%} = ((\text{Total Minutes} - \text{Downtime Minutes}) / \text{Total Minutes}) \times 100$$

Downtime is any minute during which all requests to the production API from the external monitoring network return a 5xx error or fail to connect. Measurement is by independent third-p

gs://attestor-505506-corporus/engineering/availability-sla.txt

[5] service-operations-and-support — 7. Incident communication to customers — relevance 0.60

7. Incident communication to customers

Customer-facing incident communication is owned by the incident commander and follows the commitments in KD-SEC-008 §4. In practice: status page inside 15 minutes, direct email to affected tenant administrators inside 60 minutes for a Sev 1, and a written post-incident review within 5 business days for any Sev 1 or Sev 2, shared with affected customers on req

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

16. Do you run simulated phishing exercises? Provide the most recent click rate.

security · Q16 · Vendor Security Review row 17

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] personnel-security-and-training — 5. Simulated phishing — relevance 0.71

5. Simulated phishing

Kestrel runs simulated phishing exercises **quarterly** through Curricula, targeting all personnel with a Kestrel mailbox. Results for 2025:

	Quarter	Sent	Click rate	Credential submission	Reported to security
	Q1 2025	198	6.1%	1.0%	41%
	Q2 2025	203	4.4%	0.5%	52%
	Q3 2025	208	3.4%	0.0%	58%
	Q4 2025	211			

gs://attestor-505506-corpus/security/personnel-security-and-training.txt

[2] personnel-security-and-training — 4. Security awareness training — relevance 0.58

4. Security awareness training

Security awareness training is **mandatory** for all personnel, annually, plus at onboarding within the first 14 days. Training is delivered through Curricula and runs approximately 45 minutes, covering phishing, credential handling, data classification, secure remote working, and incident reporting.

Measured completion for the 2025 cycle was **99.5%** (210 of 211 i

gs://attestor-505506-corpus/security/personnel-security-and-training.txt

[3] information-security-policy — 6. Personnel security — relevance 0.56

6. Personnel security

All employees and contractors undergo background screening appropriate to jurisdiction before their start date, conducted by Checkr. Screening covers identity verification, right to work, criminal records where lawful, and employment history for the preceding seven years.

Security awareness training is delivered through Curricula at onboarding and annually thereafter. Comple

gs://attestor-505506-corpus/security/information-security-policy.txt

[4] personnel-security-and-training — 6. Secure development training — relevance 0.54

6. Secure development training

Engineers complete role-specific secure development training annually, in addition to the general awareness training. The 2025 curriculum was Secure Code Warrior's OWASP Top 10 path plus an internal module on tenant isolation written by the platform team after the INSEC-2026-0219 penetration test. Completion for the 63 engineers in scope was 100% as of 19 December 20

gs://attestor-505506-corpus/security/personnel-security-and-training.txt

[5] personnel-security-and-training — 3. Acceptable use and policy acknowledgement — relevance 0.53

3. Acceptable use and policy acknowledgement

Personnel acknowledge the Acceptable Use Policy (KD-SEC-005) and this standard at onboarding and annually thereafter. Acknowledgement is tracked in Vanta; the 2025 annual cycle closed on 30 November 2025 at **100%** completion across 187 employees and 24 contractors.

gs://attestor-505506-corpus/security/personnel-security-and-training.txt

17. How long do backups containing deleted customer data persist?

Backups containing deleted customer data expire automatically on their normal lifecycle, persisting for a maximum of 35 days following live data deletion (`backup-restore-procedure`, section "6. Backup deletion"; `cloud-exit-and-portability-plan`, section "6. Customer's own exit from Kestrel"). Kestrel does not perform selective surgical deletions of tenant records from historical backup images; rather, all backup copies containing that data age out and expire automatically within this 35-day window (`backup-restore-procedure`, section "6. Backup deletion").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] backup-restore-procedure — 6. Backup deletion — relevance 0.72

6. Backup deletion

Backups expire automatically. When a customer terminates and the tenant purge runs, backups containing that data expire on the normal cycle, a maximum of ****35 days**** later. Kestrel does not selectively surgically remove a tenant from historical backup images, and says so rather than implying otherwise.

gs://attestor-505506-corpus/engineering/backup-restore-procedure.txt

[2] backup-restore-procedure — 5. Tenant-scoped restore — relevance 0.67

5. Tenant-scoped restore

A single customer can be restored without affecting others, by restoring to an isolated account and exporting that tenant rows back. This was exercised once in production, on 22 September 2025, at a customer request following an erroneous bulk delete on their side. Time to complete was 5 hours 10 minutes.

gs://attestor-505506-corpus/engineering/backup-restore-procedure.txt

[3] backup-restore-procedure — 1. What is backed up — relevance 0.67

1. What is backed up

Asset	Method	Frequency	Retention
RDS PostgreSQL	Automated snapshots + WAL archiving (PITR)	Continuous	**35 days**
RDS logical dump	`pg_dump` to S3, encrypted with a separate CMK	Daily 03:00 UTC	90 days
S3 objects	Versioning + cross-region replication	Continuous	90 days for non-current versions
Snowflake	Time Tr		

gs://attestor-505506-corpus/engineering/backup-restore-procedure.txt

[4] cloud-exit-and-portability-plan — 6. Customer's own exit from Kestrel — relevance 0.62

6. Customer's own exit from Kestrel

Distinct from Kestrel's exit from AWS, and more likely to be what a reviewer is asking about. A customer may leave at any time and take their data with them:

- * full self-service export of all customer-uploaded datasets in their original format, plus account identity data and usage events as JSON or CSV;
- * the same through the public API, with no volume charge

gs://attestor-505506-corpus/engineering/cloud-exit-and-portability-plan.txt

[5] backup-restore-procedure — 2. Encryption and location — relevance 0.61

2. Encryption and location

All backups are encrypted with AES-256 using AWS KMS. The daily logical dump uses a ****separate CMK**** from the primary database, so that compromise of the primary key does not compromise the backups.

Cross-region replication stays inside the residency boundary: `us-east-1` replicates to `us-west-2`, `eu-west-1` replicates to `eu-central-1`. EU customer data never le

gs://attestor-505506-corpus/engineering/backup-restore-procedure.txt

18. What security events are logged and for how long are they retained?

Kestrel Data logs the following security and operational events across its systems: * **Authentication:** Every Okta event, including sign-in successes and failures, MFA challenges, factor enrolments, and administrative actions (*logging-monitoring-standard*, Section 1. "What is logged"). * **Authorisation:** Every just-in-time (JIT) production access elevation, approval, and expiry (*logging-monitoring-standard*, Section 1. "What is logged"). * **Data Access:** All queries against customer data in Snowflake, captured via `ACCESS\_HISTORY`, detailing the querying identity and touched objects (*logging-monitoring-standard*, Section 1. "What is logged"). * **Infrastructure:** AWS CloudTrail across all accounts in the Organization, covering management events and S3 data events for buckets containing customer data (*logging-monitoring-standard*, Section 1. "What is logged"). * **Application:** Structured JSON logs containing `tenant\_id` and `request\_id` per line, with automated redaction of sensitive attributes and secrets prior to emission (*logging-monitoring-standard*, Section 1. "What is logged"). * **Network:** VPC Flow Logs, AWS WAF logs, and Cloudflare HTTP logs (*logging-monitoring-standard*, Section 1. "What is logged"). Log retention periods are defined by log class (*logging-monitoring-standard*, Section 2. "Retention"): * **Security and Audit Logs** (CloudTrail, Okta): Retained for a total of 7 years (90 days hot and searchable in Datadog, followed by archival in S3 Glacier). * **Snowflake ACCESS_HISTORY:** Retained for a total of 7 years (365 days native, followed by archival in S3). * **Application Logs:** Retained for a total of 1 year (30 days hot in Datadog, followed by archival in S3). * **Network Logs** (VPC Flow / WAF): Retained for a total of 1 year (30 days hot, followed by archival for the remainder of the year).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] logging-monitoring-standard — 2. Retention — relevance 0.69

2. Retention

| Log class | Hot (searchable) | Archive | Total |

|---|---|---|---|

| Security and audit (CloudTrail, Okta) | 90 days in Datadog | 7 years in S3 Glacier | **7 years** |

| Application | 30 days in Datadog | 1 year in S3 | 1 year |

| Snowflake ACCESS_HISTORY | 365 days native | 7 years in S3 | 7 years |

| VPC Flow / WAF | 30 days | 1 year | 1 year |

gs://attestor-505506-corporus/security/logging-monitoring-standard.txt

[2] logging-monitoring-standard — 6. Customer access to logs — relevance 0.66

6. Customer access to logs

Enterprise-tier customers can retrieve tenant-scoped audit events for their own organisation through the Audit API (`GET /v2/audit/events`), covering the previous 365 days. Kestrel does not expose its own infrastructure logs to customers; relevant extracts are provided during incident response on request.

gs://attestor-505506-corporus/security/logging-monitoring-standard.txt

[3] logging-monitoring-standard — 1. What is logged — relevance 0.66

1. What is logged

- **Authentication** - every Okta event: sign-in success and failure, MFA challenge, factor enrolment, admin action.

- **Authorisation** - every JIT production elevation, approval, and expiry.

- **Data access** - all queries against customer data in Snowflake, captured via `ACCESS\_HISTORY`, including the querying identity and the objects touched.

- **Infrastructure** - A

gs://attestor-505506-corporus/security/logging-monitoring-standard.txt

[4] logging-monitoring-standard — 5. Time synchronisation — relevance 0.64

5. Time synchronisation

All hosts synchronise to the Amazon Time Sync Service. Log timestamps are recorded in UTC in RFC 3339 format. Clock drift beyond 1 second triggers a SEV3.

gs://attestor-505506-corporus/security/logging-monitoring-standard.txt

[5] incident-response-runbook — 3. Lifecycle — relevance 0.63

3. Lifecycle

Detect, triage, contain, eradicate, recover, learn.

Detection sources are Datadog Security Monitoring, AWS GuardDuty, AWS Security Hub, Okta

ThreatInsight, Snyk, customer reports to `security@kestreldata.com`, and the disclosure address published at `kestreldata.com/well-known/security.txt`.

Triage target is 15 minutes from alert to severity assignment for SEV1 and SEV2, measures:
gs://attestor-505506-corporus/security/incident-response-runbook.txt

19. Are key administrators and key users separated?

security · Q19 · Vendor Security Review row 20

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

20. Is the service directed at children under 16?

legal · Q20 · Vendor Security Review row 21

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

21. Please confirm: Do you publish a modern slavery or supply chain labour statement?

legal · Q21 · Vendor Security Review row 22

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (6)

[1] security-addendum — 4. Incident notification — relevance 0.53

4. Incident notification

- Personal data breach: notification within **72 hours** of confirmation.
- Confirmed unauthorised access to customer production data: **24 hours**.
- Notification content as set out in the DPA Section 7.

gs://attestor-505506-corporus/legal/security-addendum.txt

[2] security-addendum — no section recorded — relevance 0.51

****Owner:**** Marcus Oyelaran, CISO ****Effective:**** 1 February 2026 · Forms part of the Master Subscription Agreement This addendum states the security commitments ...

gs://attestor-505506-corporus/legal/security-addendum.txt

[3] security-addendum — 1. Certifications maintained — relevance 0.50

1. Certifications maintained

Kestrel will maintain, for the term of the Agreement, a SOC 2 Type II report covering Security, Availability, and Confidentiality, and ISO/IEC 27001:2022 certification. Current reports are made available annually within 30 days of issuance.

If a certification lapses or an audit opinion is qualified, Kestrel will notify affected customers within **10 business days

gs://attestor-505506-corporus/legal/security-addendum.txt

[4] security-addendum — Security Addendum — relevance 0.49

Security Addendum

****Document ID:**** KD-LEG-008 · ****Version:**** 3.1 · ****Owner:**** Marcus Oyelaran, CISO ****Effective:**** 1 February 2026 · Forms part of the Master Subscription Agreement

This addendum states the security commitments Kestrel makes contractually. It is

deliberately narrower than the Information Security Policy: everything here is an obligation, not an aspiration.

gs://attestor-505506-corporus/legal/security-addendum.txt

[5] security-addendum — 3. Access commitments — relevance 0.48

3. Access commitments

- Multi-factor authentication mandatory for all Kestrel personnel with production access.
- Production access on a least-privilege, just-in-time basis, expiring within 8 hours.
- No routine Kestrel access to customer production data; support access requires per-incident customer authorisation.
- Access revoked within 24 hours of personnel departure. Measured median in 2

gs://attestor-505506-corporus/legal/security-addendum.txt

[6] security-addendum — 8. Changes — relevance 0.47

8. Changes

Kestrel may update this addendum, provided that no update materially reduces the commitments during a paid term. Material changes are notified 30 days in advance.

gs://attestor-505506-corporus/legal/security-addendum.txt

22. What is your API deprecation policy?

engineering · Q22 · Vendor Security Review row 23

Kestrel Data versions its API in the URL path (e.g., ``v1``, ``v2``), and backwards-incompatible changes are introduced only in a new version (``api-and-integration-standard``, Section 7). Our API deprecation policy requires: * **Whole API versions:** A minimum of 12 months' advance notice, during which the deprecated version remains fully available (``api-and-integration-standard``, Section 7; ``change-management-procedure``, Section 6). * **Individual endpoints or fields:** A minimum of 90 days' advance notice (``api-and-integration-standard``, Section 7). Deprecation notices are communicated via: * Direct email notifications to tenant administrators * ``Deprecation`` and ``Sunset`` HTTP response headers * The public developer changelog (``api-and-integration-standard``, Section 7).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] change-management-procedure — 6. Customer notification — relevance 0.73

6. Customer notification

Customers are notified at least **7 days** in advance of any change expected to cause degraded service or to require action on their part. Breaking API changes follow the deprecation policy: minimum **12 months** notice, with the deprecated version remaining available throughout.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[2] api-and-integration-standard — 7. Versioning and deprecation — relevance 0.71

7. Versioning and deprecation

The API is versioned in the path (``v1``, ``v2``). Backwards-incompatible changes are made only in a new version.

The deprecation policy is 12 months' notice for a whole API version and **90 days' notice** for an individual endpoint or field, delivered by email to tenant administrators, by a ``Deprecation`` and ``Sunset`` response header, and on the developer changelog

gs://attestor-505506-corporus/engineering/api-and-integration-standard.txt

[3] api-and-integration-standard — 2. Customer control of API credentials — relevance 0.59

2. Customer control of API credentials

Customers create, scope, rotate, and revoke their own API credentials from the tenant administrator console, without involving Kestrel support. A credential can be limited to read-only, to specific datasets, and to a source IP allowlist. Revocation takes effect within 30 seconds across all regions.

Kestrel support cannot recover a customer API key. K

gs://attestor-505506-corporate-engineering/api-and-integration-standard.txt

[4] api-and-integration-standard — 3. Rate limiting — relevance 0.57

3. Rate limiting

Rate limits are enforced at Cloudflare, ahead of application code:

Surface	Limit
Public API, per tenant	120 requests/minute
Bulk export endpoint, per tenant	6 requests/minute
Authentication endpoints, per source address	10 attempts/5 minutes
Password reset, per account	5 attempts/hour (added 27 February 2026)

Exceeding a limit returns HTTP

gs://attestor-505506-corporate-engineering/api-and-integration-standard.txt

[5] api-and-integration-standard — API, Authentication and Integration Standard — relevance 0.56

API, Authentication and Integration Standard

Document ID: KD-ENG-005 · **Version:** 2.6 · **Owner:** Dana Whitfield, VP Engineering

Approved: 21 January 2026 · **Next review:** 21 January 2027

Maps to: SOC 2 CC6.1, CC6.6, CC8.1 · ISO 27001:2022 A.5.15, A.8.5, A.8.26

gs://attestor-505506-corporate-engineering/api-and-integration-standard.txt

23. Describe your security incident classification scheme. Provide supporting evidence.

security · Q23 · Vendor Security Review row 24

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

24. What is your post-quantum cryptography readiness posture?

security · Q24 · Vendor Security Review row 25

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] encryption-standard — 6. Post-quantum posture — relevance 0.70

6. Post-quantum posture

Kestrel completed a cryptographic inventory (`SEC-GOV/crypto-inventory`, 19 January 2026)

as the first step toward post-quantum readiness. TLS connections terminated at Cloudflare already negotiate the hybrid X25519MLKEM768 key agreement where the client supports it.

No migration commitment date has been set for internal services.

gs://attestor-505506-corporate-engineering/security/encryption-standard.txt

[2] encryption-standard — Encryption Standard — relevance 0.57

Encryption Standard

Document ID: KD-SEC-003 · **Version:** 2.4 · **Owner:** Marcus Oyelaran, CISO

Approved: 8 January 2026 · **Next review:** 8 January 2027

Maps to: SOC 2 CC6.7 · ISO 27001:2022 A.8.24 · GDPR Art. 32(1)(a)

gs://attestor-505506-corporate-engineering/security/encryption-standard.txt

[3] encryption-standard — 5. Algorithm policy — relevance 0.54

5. Algorithm policy

Approved: AES-256-GCM, AES-256-CBC (legacy read paths only), RSA-2048 and above, ECDSA

P-256 and P-384, SHA-256 and above, Argon2id and bcrypt (cost factor 12 or higher) for password hashing.

Prohibited: DES, 3DES, RC4, MD5 and SHA-1 for any security purpose, RSA below 2048 bits, and any custom cryptographic construction. Kestrel does not implement its own cryptographic

gs://attestor-505506-corporus/security/encryption-standard.txt

[4] encryption-standard — 2. Data in transit — relevance 0.53

2. Data in transit

****TLS 1.3**** is the default for all external connections. TLS 1.2 remains enabled solely for one legacy customer SFTP integration (INT-LEGACY-0004), scheduled for decommission in Q3 2026 and tracked as RISK-2025-0088. TLS 1.0 and 1.1 were disabled across all endpoints on 12 April 2024.

Cipher suites are restricted to the Mozilla Intermediate profile. HSTS is enabled with

gs://attestor-505506-corporus/security/encryption-standard.txt

[5] encryption-standard — 3. Key management — relevance 0.52

3. Key management

Customer-facing encryption keys are AWS KMS Customer Managed Keys. Key policies restrict use to named service roles. Key administrators and key users are disjoint sets: no individual holds both roles, enforced by a Service Control Policy at the AWS Organization level.

Automatic annual rotation is enabled on all CMKs. Manual rotation is triggered on suspected compromise. Ke

gs://attestor-505506-corporus/security/encryption-standard.txt

25. For which data are you the controller?

legal · Q25 · Vendor Security Review row 26

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] data-processing-agreement — 1. Roles — relevance 0.69

1. Roles

Customer is ****Controller****. Kestrel Data, Inc. is ****Processor****. Where Customer is itself a processor for its own customers, Kestrel is sub-processor and the same obligations apply down the chain.

Kestrel is ****Controller**** for a limited set of data it determines the purposes of: account administrator contact details, billing records, and product telemetry described in Annex 3.

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[2] data-subject-rights-procedure — 1. Which rights, and against whom — relevance 0.68

1. Which rights, and against whom

For customer content, Kestrel is the ****processor**** and the customer is the controller. A data subject who approaches Kestrel directly about customer content is redirected to the relevant customer without undue delay and, where Kestrel can identify the customer, within ****3 business days****. Kestrel does not respond substantively on the controller's behalf.

For data

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[3] privacy-policy — 2. What we collect as controller — relevance 0.67

2. What we collect as controller

| Category | Examples | Lawful basis | Retention |

|---|---|---|---|
| Account data | Name, work email, job title, company | Contract (Art. 6(1)(b)) | Term + 3 years |
| Billing data | Billing contact, VAT number, payment method token | Contract; legal obligation | 7 years (tax) |
| Product telemetry | Feature usage, page views, error events | Legitimate interest

gs://attestor-505506-corpus/legal/privacy-policy.txt

[4] gdpr-records-of-processing — Part A - Kestrel as Processor (Art. 30(2)) — relevance 0.66

Part A - Kestrel as Processor (Art. 30(2))

****Controller:**** each Kestrel customer, as identified in the applicable Order Form.

****Processor:**** Kestrel Data, Inc.

****DPO:**** Priya Raghunathan, `dpo@kestreldata.com`

| # | Processing activity | Categories of data subject | Categories of personal data | Transfers | Retention |
|---|---|---|---|---|
| P1 | Hosting and operating the Kestrel Insig

gs://attestor-505506-corpus/legal/gdpr-records-of-processing.txt

[5] gdpr-records-of-processing — Part B - Kestrel as Controller (Art. 30(1)) — relevance 0.65

Part B - Kestrel as Controller (Art. 30(1))

| # | Purpose | Lawful basis | Data subjects | Personal data | Retention |

|---|---|---|---|---|

| C1 | Account administration | Art. 6(1)(b) contract | Customer administrators | Name, work email, job title | Term + 3 years |

| C2 | Billing and tax | Art. 6(1)(b), 6(1)(c) | Billing contacts | Name, email, VAT, payment token | 7 years |

| C3 | Pro

gs://attestor-505506-corpus/legal/gdpr-records-of-processing.txt

26. Please confirm: What service credits apply if the availability commitment is missed?

legal · Q26 · Vendor Security Review row 27

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

27. Do you use organisation-level guardrails to enforce security configuration?

security · Q27 · Vendor Security Review row 28

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

28. Do engineers receive secure development training?

engineering · Q28 · Vendor Security Review row 29

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

29. Describe your API authentication mechanism.

engineering · Q29 · Vendor Security Review row 30

Kestrel Data's public API (`https://api.kestreldata.com/v2`) requires authentication on every request and maintains no anonymous surface aside from the status endpoint and OpenAPI documentation. Requests without valid credentials return a `401` response with no information regarding whether the tenant or resource exists. The API supports two credential types: * ****OAuth 2.0 bearer tokens:**** Issued through the client-credentials flow, valid for 60 minutes, and scoped to a single tenant as well as an explicit permission set. This is the recommended integration path. * ****API**

keys:** Designed for simple server-to-server use, presented as a bearer token, and scoped in the same manner. Customers create, scope, rotate, and revoke their own API credentials directly through the tenant administrator console without requiring support involvement. Credentials can be restricted to read-only access, limited to specific datasets, and bound to a source IP allowlist. Revocations propagate and take effect within 30 seconds across all regions. Plaintext keys are displayed only once at creation and cannot be recovered by Kestrel Data (*API, Authentication and Integration Standard*, Section 1: "API authentication" and Section 2: "Customer control of API credentials").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] api-and-integration-standard — 1. API authentication — relevance 0.69

1. API authentication

The public API at `https://api.kestreldata.com/v2` accepts two credential types:

* **OAuth 2.0 bearer tokens** issued through the client-credentials flow, valid for 60 minutes, scoped to a single tenant and to an explicit permission set. This is the recommended integration path.

* **API keys** for simple server-to-server use, presented as a bearer token, scoped the same

gs://attestor-505506-corporus/engineering/api-and-integration-standard.txt

[2] secrets-management-standard — 6. Customer-issued API credentials — relevance 0.63

6. Customer-issued API credentials

API keys issued to customers are stored as Argon2id hashes; Kestrel cannot recover the plaintext of a customer API key and will not do so on request. Keys are displayed once at creation. Customers can create, scope, and revoke keys through the console, and each key carries a last-used timestamp so stale keys are visible.

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

[3] api-and-integration-standard — API, Authentication and Integration Standard — relevance 0.63

API, Authentication and Integration Standard

Document ID: KD-ENG-005 · **Version:** 2.6 · **Owner:** Dana Whitfield, VP Engineering

Approved: 21 January 2026 · **Next review:** 21 January 2027

Maps to: SOC 2 CC6.1, CC6.6, CC8.1 · ISO 27001:2022 A.5.15, A.8.5, A.8.26

gs://attestor-505506-corporus/engineering/api-and-integration-standard.txt

[4] api-and-integration-standard — 2. Customer control of API credentials — relevance 0.63

2. Customer control of API credentials

Customers create, scope, rotate, and revoke their own API credentials from the tenant administrator console, without involving Kestrel support. A credential can be limited to read-only, to specific datasets, and to a source IP allowlist. Revocation takes effect within 30 seconds across all regions.

Kestrel support cannot recover a customer API key. K

gs://attestor-505506-corporus/engineering/api-and-integration-standard.txt

[5] api-and-integration-standard — 9. Integration security review — relevance 0.61

9. Integration security review

A new first-party integration is reviewed against this standard before release, covering credential handling, scope minimisation, rate limiting, and audit event emission. The review is recorded in the pull request and is a required check on the `kd-api` repository.

gs://attestor-505506-corporus/engineering/api-and-integration-standard.txt

30. Is your organisation subject to any pending litigation relating to data protection?

legal · Q30 · Vendor Security Review row 31

Kestrel Data is not a party to any pending litigation relating to data protection, privacy, or information security, and has not been involved in any such litigation since incorporation in 2019 (Legal, Regulatory and Corporate History, §1. Litigation).

Evidence (5)

[1] legal-and-regulatory-history — 1. Litigation — relevance 0.66

1. Litigation

****Kestrel Data is not a party to any pending litigation relating to data protection, privacy, or information security**, and has not been since incorporation in 2019.**

The company has been party to two commercial disputes in total, neither involving personal data, security, or availability:

Matter	Year	Nature	Outcome
---	---	---	---
Kestrel Data, Inc. v. Northbeam Anal			

gs://attestor-505506-corpus/legal/legal-and-regulatory-history.txt

[2] legal-and-regulatory-history — 6. Legal hold — relevance 0.63

6. Legal hold

Kestrel operates a documented legal hold process, owned by the General Counsel. On becoming aware of reasonably anticipated litigation or an investigation, the General Counsel issues a written hold notice identifying custodians and data sources, and suspension of the ordinary retention schedule is applied in Google Vault and by disabling the relevant retention jobs. Holds are reviewe

gs://attestor-505506-corpus/legal/legal-and-regulatory-history.txt

[3] legal-and-regulatory-history — 2. Regulatory enforcement — relevance 0.61

2. Regulatory enforcement

****Kestrel Data has never been subject to a regulatory enforcement action, fine, consent decree, undertaking, or formal investigation** by any data protection authority, sectoral regulator, or competition authority. No supervisory authority has issued Kestrel a reprimand, order, or corrective measure under Article 58 of the GDPR.**

Kestrel has never made a personal data bre

gs://attestor-505506-corpus/legal/legal-and-regulatory-history.txt

[4] legal-and-regulatory-history — 3. Complaints — relevance 0.57

3. Complaints

Two data subject complaints have been received directly since 2019, both from individuals whose employers were Kestrel customers, and both resolved by directing the complainant to their employer as controller with an explanation of the roles. Neither complainant escalated to a supervisory authority.

gs://attestor-505506-corpus/legal/legal-and-regulatory-history.txt

[5] legal-and-regulatory-history — Legal, Regulatory and Corporate History — relevance 0.56

Legal, Regulatory and Corporate History

****Document ID:** KD-LEG-013 · ****Version:** 1.4 · ****Owner:** Aaron Feldstein, General Counsel****
****Approved:** 4 February 2026 · ****Next review:** 4 February 2027****
****Maps to:** SOC 2 CC2.3, CC3.4 · ISO 27001:2022 A.5.31, A.5.34, A.5.36****

gs://attestor-505506-corpus/legal/legal-and-regulatory-history.txt

31. Provide evidence that your security controls are independently verified.

security · Q31 · Vendor Security Review row 32

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] company-and-security-programme-overview — 8. How to obtain evidence — relevance 0.67

8. How to obtain evidence

The SOC 2 Type II report, the ISO 27001 certificate, the penetration test executive summary, and the standard DPA are available to customers and prospects under NDA through the account team, usually within two business days. The certificate and the trust page are available without an NDA.

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[2] soc2-control-matrix — Common Criteria — relevance 0.64

Common Criteria

| Control | Description | Evidence | Test result |

|---|---|---|---|

| CC1.1 | Board oversight of security; Audit and Risk Committee meets quarterly | Committee minutes, 4 meetings in 2025 | No exceptions

|

| CC1.4 | Security awareness training at hire and annually | Curricula completion records, 100% of active staff | No exceptions |

| CC2.1 | Internal communication of security

gs://attestor-505506-corporus/security/soc2-control-matrix.txt

[3] risk-management-and-governance — 7. Internal audit — relevance 0.64

7. Internal audit

Kestrel is too small to maintain a separate internal audit function, and says so rather than claiming one. Independent assurance comes from the annual SOC 2 Type II examination (Prescient Assurance LLP), the ISO 27001 surveillance audits (BSI), and the annual penetration test (Include Security). Control operation is monitored continuously by Vanta across 187 automated checks, with

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[4] company-and-security-programme-overview — 3. Security programme in summary — relevance 0.63

3. Security programme in summary

The programme is built on four commitments, each evidenced elsewhere in this corpus rather than asserted here:

1. **Independent verification.** SOC 2 Type II (Prescient Assurance LLP, report issued 14 March 2026 covering 1 January – 31 December 2025, **no exceptions**) and ISO 27001:2022 (BSI certificate `IS-2025-44817`, issued 22 September 2025, valid to 21

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[5] risk-management-and-governance — Risk Management and Security Governance — relevance 0.62

Risk Management and Security Governance

Document ID: KD-SEC-018 · **Version:** 3.0 · **Owner:** Marcus Oyelaran, CISO

Approved: 26 January 2026 · **Next review:** 26 January 2027

Maps to: SOC 2 CC1.1, CC1.2, CC1.3, CC3.1, CC3.2, CC3.4 · ISO 27001:2022 A.5.1–A.5.4, Clauses 5–6, 9

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

32. Is your platform multi-tenant or single-tenant?

engineering · Q32 · Vendor Security Review row 33

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] infrastructure-architecture-overview — 5. Tenant isolation — relevance 0.67

5. Tenant isolation

Kestrel Insight is **multi-tenant** with logical isolation. There is no per-customer infrastructure, no single-tenant deployment option, and no customer-VPC option.

Isolation is enforced at three layers:

1. **Database** - PostgreSQL row-level security policies keyed on `tenant\_id`, applied at the connection level from an authenticated session variable. No application

gs://attestor-505506-corporate-engineering/infrastructure-architecture-overview.txt

[2] data-flow-and-shared-responsibility — 3. The shared responsibility model — relevance 0.63

3. The shared responsibility model

Security of the platform is Kestrel's. Security of what the customer does with it is the customer's. The line is drawn here rather than left implicit, because an unstated boundary is where a breach lands on whoever is less able to argue.

Kestrel is responsible for:

* physical and environmental security of the infrastructure (through AWS), and the cloud co

gs://attestor-505506-corporate-engineering/data-flow-and-shared-responsibility.txt

[3] api-and-integration-standard — 4. Single sign-on — relevance 0.62

4. Single sign-on

SAML 2.0 and OpenID Connect single sign-on are supported on all paid tiers, at no additional charge — SSO is a security control, not an upsell. Kestrel has verified integrations with Okta, Microsoft Entra ID, Google Workspace, OneLogin, and Ping Identity, and supports any conforming IdP through generic metadata exchange.

Tenant administrators may enforce SSO-only login, disa

gs://attestor-505506-corporate-engineering/api-and-integration-standard.txt

[4] infrastructure-architecture-overview — 1. Cloud footprint — relevance 0.62

1. Cloud footprint

Kestrel runs on **Amazon Web Services**. There are two independent production instances:

| Instance | Region | Serves |

|---|---|---|

| US | `us-east-1` (3 AZs) | North America, and customers with no residency requirement |

| EU | `eu-west-1` (3 AZs) | EEA, UK, and Swiss customers electing EU residency |

Backup replication targets `us-west-2` and `eu-central-1` respecti

gs://attestor-505506-corporate-engineering/infrastructure-architecture-overview.txt

[5] data-flow-and-shared-responsibility — 1. Data flow, end to end — relevance 0.61

1. Data flow, end to end

1. **Ingress.** A customer's browser or API client resolves `app.kestreldata.com` or `api.kestreldata.com` to Cloudflare, which terminates TLS 1.3 (1.2 minimum) and applies WAF and rate limiting.

2. **Instance selection.** DNS and tenant routing send the request to the instance chosen at contract signature: `us-east-1` or `eu-west-1`. **A tenant's requests never c**

gs://attestor-505506-corporate-engineering/data-flow-and-shared-responsibility.txt

33. What open source licences are prohibited in your codebase? Provide supporting evidence.

engineering · Q33 · Vendor Security Review row 34

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

34. Were any Critical or High findings identified in the most recent test?

security · Q34 · Vendor Security Review row 35

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

35. Have TLS 1.0 and TLS 1.1 been disabled across all endpoints? If not, describe compensating controls.

security · Q35 · Vendor Security Review row 36

Yes, TLS 1.0 and TLS 1.1 were disabled across all endpoints on 12 April 2024. TLS 1.3 is the default protocol for all external connections, and TLS 1.2 remains enabled solely for a single legacy customer SFTP integration (INT-LEGACY-0004), which is scheduled for decommissioning in Q3 2026 and tracked under RISK-2025-0088 (*Encryption Standard*, Section 2: "Data in transit"; *Information Security Policy*, Section 8: "Cryptography").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] encryption-standard — 2. Data in transit — relevance 0.65

2. Data in transit

TLS 1.3 is the default for all external connections. TLS 1.2 remains enabled solely for one legacy customer SFTP integration (INT-LEGACY-0004), scheduled for decommission in Q3 2026 and tracked as RISK-2025-0088. TLS 1.0 and 1.1 were disabled across all endpoints on 12 April 2024.

Cipher suites are restricted to the Mozilla Intermediate profile. HSTS is enabled with

gs://attestor-505506-corporus/security/encryption-standard.txt

[2] information-security-policy — 8. Cryptography — relevance 0.62

8. Cryptography

Data at rest is encrypted with AES-256-GCM. Data in transit is protected with TLS 1.3; TLS 1.0 and 1.1 were disabled on 12 April 2024 and TLS 1.2 remains enabled only for a single legacy integration scheduled for removal in Q3 2026. Key management is described in the Encryption Standard (KD-SEC-003) and the Secrets Management Standard (KD-ENG-006).

gs://attestor-505506-corporus/security/information-security-policy.txt

[3] encryption-standard — Encryption Standard — relevance 0.58

Encryption Standard

Document ID: KD-SEC-003 · **Version:** 2.4 · **Owner:** Marcus Oyelaran, CISO
Approved: 8 January 2026 · **Next review:** 8 January 2027
Maps to: SOC 2 CC6.7 · ISO 27001:2022 A.8.24 · GDPR Art. 32(1)(a)

gs://attestor-505506-corporus/security/encryption-standard.txt

[4] encryption-standard — 1. Data at rest — relevance 0.58

1. Data at rest

All customer data at rest is encrypted using **AES-256-GCM**. No customer data is stored unencrypted at any tier.

| Store | Mechanism | Key custody |

|---|---|---|

| Amazon RDS (PostgreSQL 16) | Storage-level encryption | AWS KMS CMK, per-environment |

| Amazon S3 | SSE-KMS | AWS KMS CMK, per-bucket |

| Snowflake | Native encryption, Tri-Secret Secure | Customer-managed key

gs://attestor-505506-corporus/security/encryption-standard.txt

[5] encryption-standard — 6. Post-quantum posture — relevance 0.58

6. Post-quantum posture

Kestrel completed a cryptographic inventory (`SEC-GOV/crypto-inventory`, 19 January 2026) as the first step toward post-quantum readiness. TLS connections terminated at Cloudflare already negotiate the hybrid X25519MLKEM768 key agreement where the client supports it. No migration commitment date has been set for internal services.

gs://attestor-505506-corporus/security/encryption-standard.txt

36. Does the CISO have a reporting line independent of executive management?

security · Q36 · Vendor Security Review row 37

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

37. Was cross-tenant data access achieved during penetration testing?

security · Q37 · Vendor Security Review row 38

No cross-tenant data access was achieved during penetration testing. Tenant isolation held across every tested condition, including direct object reference manipulation, JWT tenant-claim tampering, and GraphQL alias-based enumeration (pen-test-executive-summary, Section 3. Findings summary).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] pen-test-executive-summary — 3. Findings summary — relevance 0.75

3. Findings summary
| Severity | Found | Remediated | Retest verified |
|---|---|---|---|
| Critical | 0 | - | - |
| High | 1 | 1 | 18 March 2026 |
| Medium | 4 | 4 | 18 March 2026 |
| Low | 7 | 5 | 18 March 2026 |
| Informational | 9 | Accepted / tracked | - |

****No cross-tenant data access was achieved.**** Tenant isolation held under every tested condition, including direct object refere

gs://attestor-505506-corpus/security/pen-test-executive-summary.txt

[2] pen-test-executive-summary — 1. Scope — relevance 0.67

1. Scope
- Kestrel Insight web application (`app.kestreldata.com`), authenticated and unauthenticated surfaces
- Public REST API v2 (`api.kestreldata.com`), 89 endpoints
- Multi-tenant isolation testing across 3 seeded tenant accounts
- AWS cloud configuration review (IAM, S3, VPC, EKS)
- Authentication and session management, including the Okta SAML integration

Out of scope: physical se

gs://attestor-505506-corpus/security/pen-test-executive-summary.txt

[3] pen-test-executive-summary — 2. Methodology — relevance 0.67

2. Methodology
Grey-box testing against OWASP ASVS 4.0 Level 2 and the OWASP API Security Top 10.
Testers were given standard-tier and admin-tier credentials for each seeded tenant plus API documentation. 74 person-hours across two testers.

gs://attestor-505506-corpus/security/pen-test-executive-summary.txt

[4] pen-test-executive-summary — Penetration Test Executive Summary — relevance 0.66

Penetration Test Executive Summary
****Document ID:**** KD-SEC-007 · ****Engagement:**** INSEC-2026-0219
****Tester:**** Include Security, Inc. · ****Dates:**** 3-14 February 2026
****Report issued:**** 24 February 2026 · ****Retest completed:**** 18 March 2026
****Classification:**** Confidential - shareable with customers under NDA

gs://attestor-505506-corpus/security/pen-test-executive-summary.txt

[5] pen-test-executive-summary — 7. Tester statement — relevance 0.66

7. Tester statement
****Kestrel Data demonstrates a mature security posture for an organisation of its size.**
Tenant isolation is well implemented and defence in depth is evident throughout the platform. The single High finding was an availability and privacy concern rather than a

confidentiality one."* - Include Security, 24 February 2026

gs://attestor-505506-corporus/security/pen-test-executive-summary.txt

38. What encryption algorithm and key length is used for data at rest?

security · Q38 · Vendor Security Review row 39

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

39. Provide your current list of subprocessors. Provide supporting evidence.

legal · Q39 · Vendor Security Review row 40

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

40. Confirm whether any customer data is processed outside the stated regions.

legal · Q40 · Vendor Security Review row 41

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (9)

[1] data-processing-agreement — 10. International transfers — relevance 0.72

10. International transfers

Where Personal Data is transferred out of the EEA, UK, or Switzerland, the parties enter into the ****2021 EU Standard Contractual Clauses**** (Commission Implementing Decision 2021/914), Module Two (Controller to Processor) or Module Three (Processor to Sub-processor) as applicable, incorporated by reference. The UK International Data Transfer Addendum and the Swiss An

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[2] subprocessor-list — EU data residency — relevance 0.71

EU data residency

Customers on the EU instance have their data processed exclusively within the EEA for the infrastructure subprocessors above. Kestrel does ****not**** currently offer a UK-only, Swiss-only, Canadian, or Australian data residency option. Requests for those are recorded but not committed to.

gs://attestor-505506-corporus/legal/subprocessor-list.txt

[3] transfer-impact-assessment — 5. Supplementary measures relied on — relevance 0.71

5. Supplementary measures relied on
Technical:

1. ****Data residency by default**** — EU customer content, including backups and the replicated log ship, never leaves `eu-west-1`.
2. ****Encryption in transit**** — TLS 1.3 (1.2 minimum) on every hop, including between Kestrel and each sub-processor.
3. ****Encryption at rest**** — AES-256-GCM with keys in AWS KMS. Keys for the EU instance are held i

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

[4] transfer-impact-assessment — 2. The transfers assessed — relevance 0.70

2. The transfers assessed

| # | Transfer | Exporter | Importer | Country | Data |

|---|---|---|---|---|---|

| T1 | EU tenant support access | Kestrel EU instance | Kestrel Data, Inc. | United States | Account identity data, support correspondence |

| T2 | Product telemetry aggregation | Kestrel EU instance | Kestrel Data, Inc. | United States | Pseudonymised usage events |

| T3 | Error monitoring

gs://attestor-505506-corpus/legal/transfer-impact-assessment.txt

[5] subprocessor-list — Infrastructure subprocessors — relevance 0.70

Infrastructure subprocessors

| Subprocessor | Purpose | Location of processing | Transfer mechanism | Engaged since |

|---|---|---|---|---|

| Amazon Web Services, Inc. | Cloud hosting, compute, storage, database | US (`us-east-1`, `us-west-2`); EU (`eu-west-1`, `eu-central-1`)

| SCCs + AWS DPA; EU data stays in EU | Mar 2019 |

| Snowflake Inc. | Analytics data warehouse | US (AWS `us-east-1`);

gs://attestor-505506-corpus/legal/subprocessor-list.txt

[6] transfer-impact-assessment — 6. Conclusion — relevance 0.69

6. Conclusion

For T1 and T2 the residual risk to data subjects is assessed as **low**: the data transferred is limited, pseudonymised where possible, encrypted with keys held outside the importer's jurisdiction, and unaccompanied by any customer content. For T3 and T4 the residual risk is **low** on the same basis, with the additional point that no customer content is transferred at all.

The asse

gs://attestor-505506-corpus/legal/transfer-impact-assessment.txt

[7] data-processing-agreement — 2. Scope and duration — relevance 0.68

2. Scope and duration

Processing continues for the term of the Agreement plus the retention periods in Annex 2. Kestrel processes Personal Data only on documented instructions from Customer. The Agreement, this DPA, and Customer configuration of the Service constitute those instructions.

If Kestrel is required by Union or Member State law to process beyond those instructions, it will inform

gs://attestor-505506-corpus/legal/data-processing-agreement.txt

[8] standard-contractual-clauses-summary — 2. UK and Switzerland — relevance 0.68

2. UK and Switzerland

- **UK** - the ICO International Data Transfer Addendum (version B1.0, in force 21 March 2022) is appended to the EU SCCs. UK GDPR references replace EU GDPR references; the competent authority is the ICO.

- **Switzerland** - the Swiss Annex applies. The FDPIC is the competent authority, and references to Member State law are read as references to Swiss law. The SCC

gs://attestor-505506-corpus/legal/standard-contractual-clauses-summary.txt

[9] transfer-impact-assessment — 3. Transfer mechanism — relevance 0.68

3. Transfer mechanism

The 2021 **Standard Contractual Clauses, Module Two (controller to processor)** apply between the customer and Kestrel, and **Module Three (processor to sub-processor)** between Kestrel and its US sub-processors. The **UK International Data Transfer Addendum** is incorporated for UK exports, and for Switzerland the SCCs are applied with the adaptations published by the Swiss

gs://attestor-505506-corpus/legal/transfer-impact-assessment.txt

41. Can an engineer deploy directly to production, bypassing the pipeline?

engineering · Q41 · Vendor Security Review row 42

No engineer can deploy directly to production or bypass the automated pipeline. As outlined in the ****sdlc-policy**** (Section 7, "Separation of duties"), no human has the ability to push container images directly to the production registry. The deployment role is exclusively held by the CI service identity, which authenticates via OIDC and maintains no long-lived credentials. Furthermore, changes must go through the pull request and automated testing process, and administrator bypass of branch protection is disabled (****sdlc-policy****, Section 1, "Branching and review").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] sdlc-policy — 7. Separation of duties — relevance 0.67

7. Separation of duties

Engineers cannot deploy their own change to production without the automated pipeline: no human has the ability to push a container image to the production registry directly. The deployment role is held by the CI service identity, which authenticates through OIDC and holds no long-lived credentials.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[2] sdlc-policy — 4. Security in the pipeline — relevance 0.61

4. Security in the pipeline

Static analysis (Semgrep, CodeQL), dependency scanning (Snyk), IaC scanning (Checkov), and secret scanning (Gitleaks pre-commit plus GitHub push protection) all run on every pull request. A Critical or High dependency finding blocks the merge.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[3] sdlc-policy — 6. Release — relevance 0.59

6. Release

Releases are continuous: merge to `main` triggers a deployment to staging, an automated verification suite, and then a progressive rollout to production. Rollout is canary-based: 5% of traffic for 15 minutes, then 25%, then 100%, with automatic rollback on error-rate or latency regression.

Median lead time from merge to production in 2025 was ****34 minutes****. Change failure rate w

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[4] sdlc-policy — 1. Branching and review — relevance 0.57

1. Branching and review

`main` is protected and always releasable. All work happens on short-lived branches merged by pull request. `main` requires:

- At least ****one approving review**** from an engineer other than the author. Self-approval is blocked at the platform level.
- Two approvals for changes touching authentication, authorisation, tenant isolation, or cryptography. These paths ar

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[5] sdlc-policy — 2. Environments — relevance 0.56

2. Environments

| Environment | Purpose | Data |

|---|---|---|

| `local` | Developer machines | Synthetic fixtures only |

| `ci` | Automated testing | Synthetic fixtures only |

| `staging` | Pre-production verification | Synthetic and anonymised data |

| `production` | Live service | Customer data |

****Production data is never copied to a lower environment.**** Staging fixtures are generated

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

42. Do you address Swiss FADP requirements? If not, describe compensating controls.

security · Q42 · Vendor Security Review row 43

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] information-security-policy — 3. Certifications and attestations — relevance 0.63

3. Certifications and attestations

| Framework | Status | Evidence |

|---|---|---|

| SOC 2 Type II | Current | Report issued 14 March 2026 by Prescient Assurance LLP, covering 1 January – 31 December 2025. No exceptions noted. |

| ISO/IEC 27001:2022 | Certified | Certificate IS-2025-44817, issued by BSI on 22 September 2025, valid to 21 September 2028 |

| ISO/IEC 27701:2019 | Certified | Extension

gs://attestor-505506-corporus/security/information-security-policy.txt

[2] company-and-security-programme-overview — 8. How to obtain evidence — relevance 0.62

8. How to obtain evidence

The SOC 2 Type II report, the ISO 27001 certificate, the penetration test executive summary, and the standard DPA are available to customers and prospects under NDA through the account team, usually within two business days. The certificate and the trust page are available without an NDA.

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[3] company-and-security-programme-overview — 6. Scope of certification — relevance 0.59

6. Scope of certification

The ISO 27001 certificate scope statement reads: *"The information security management system supporting the development, operation, and support of the Kestrel Insight analytics platform, including supporting corporate functions, at Austin, Texas and for remote personnel."* The SOC 2 report covers the Security, Availability, and Confidentiality Trust Services Criteria. Pr

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[4] vendor-risk-management-policy — 2. Onboarding requirements — relevance 0.59

2. Onboarding requirements

No Tier 1 vendor is engaged without: a current SOC 2 Type II report or ISO 27001 certificate reviewed by the Security team; an executed DPA including the 2021 EU Standard Contractual Clauses where personal data leaves the EEA; documented data flows and retention; and a recorded exit plan.

Reviews are recorded in Vanta with the reviewer, date, evidence reviewed, and

gs://attestor-505506-corporus/security/vendor-risk-management-policy.txt

[5] vendor-risk-management-policy — Vendor Risk Management Policy — relevance 0.59

Vendor Risk Management Policy

Document ID: KD-SEC-008 · **Version:** 2.0 · **Owner:** Aaron Feldstein, General Counsel

Approved: 4 February 2026 · **Next review:** 4 February 2027

Maps to: SOC 2 CC9.2 · ISO 27001:2022 A.5.19-A.5.22 · GDPR Art. 28

gs://attestor-505506-corporus/security/vendor-risk-management-policy.txt

43. Who is your lead supervisory authority?

legal · Q43 · Vendor Security Review row 44

Kestrel Data's lead supervisory authority is the Irish Data Protection Commission (Privacy Policy, Section 1: Controller and contact; Data Protection Impact Assessment Register, Section 2: Completed assessments).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] privacy-policy — 1. Controller and contact — relevance 0.61

1. Controller and contact
Kestrel Data, Inc., 1401 Lavaca Street, Suite 210, Austin, TX 78701, USA.
EU representative under Art. 27 GDPR: Instant EU Rep Ltd, Dublin, Ireland.
Data Protection Officer: Priya Raghunathan, `dpo@kestreldata.com`.
Lead supervisory authority: Irish Data Protection Commission.

gs://attestor-505506-corporus/legal/privacy-policy.txt

[2] dpia-register — 2. Completed assessments — relevance 0.60

2. Completed assessments

****Four DPIAs have been completed**, all reviewed and signed off by the DPO:**

| ID | Subject | Completed | Residual risk | Outcome |

|---|---|---|---|---|

| DPIA-2024-01 | Product telemetry collection and retention | 14 May 2024 | Low | Proceed. Event allowlist introduced; free-text fields excluded; retention set to 13 months |

| DPIA-2025-01 | EU instance and residency arc

gs://attestor-505506-corporus/legal/dpia-register.txt

[3] dpia-register — Data Protection Impact Assessment Register — relevance 0.60

Data Protection Impact Assessment Register

****Document ID:** KD-LEG-011 · ****Version:** 1.9 · ****Owner:** Priya Raghunathan, DPO******

****Approved:** 16 January 2026 · ****Next review:** 16 January 2027****

****Maps to:** GDPR Articles 35, 36, 9, 8, 22**

gs://attestor-505506-corporus/legal/dpia-register.txt

[4] dpia-register — 1. When Kestrel performs a DPIA — relevance 0.59

1. When Kestrel performs a DPIA

A DPIA is performed where processing is likely to result in a high risk to data subjects, and in every case triggered by the Article 35(3) list or the lead supervisory authority's own list. In practice Kestrel triggers an assessment for: a new machine learning feature processing customer data, a new sub-processor receiving customer content, a change to the residency

gs://attestor-505506-corporus/legal/dpia-register.txt

[5] privacy-policy — 2. What we collect as controller — relevance 0.57

2. What we collect as controller

| Category | Examples | Lawful basis | Retention |

|---|---|---|---|

| Account data | Name, work email, job title, company | Contract (Art. 6(1)(b)) | Term + 3 years |

| Billing data | Billing contact, VAT number, payment method token | Contract; legal obligation | 7 years (tax) |

| Product telemetry | Feature usage, page views, error events | Legitimate interest

gs://attestor-505506-corporus/legal/privacy-policy.txt

44. What audit rights do you grant customers? If not, describe compensating controls.

legal · Q44 · Vendor Security Review row 45

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

45. What test coverage threshold is enforced in CI?

engineering · Q45 · Vendor Security Review row 46

Kestrel enforces a unit test coverage gate of 80% on changed lines in continuous integration (CI) (sdlc-policy, Section 3. Testing requirements).

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (5)

[1] sdlc-policy — 3. Testing requirements — relevance 0.61

3. Testing requirements

- Unit test coverage gate at **80%** on changed lines, enforced in CI.
- Integration tests run against ephemeral infrastructure provisioned per pull request.
- Tenant isolation tests run on every build: a suite of 84 assertions attempting cross-tenant reads through every public API surface.
- Load tests before any release expected to change the performance profile.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[2] sdlc-policy — 6. Release — relevance 0.50

6. Release

Releases are continuous: merge to `main` triggers a deployment to staging, an automated verification suite, and then a progressive rollout to production. Rollout is canary-based: 5% of traffic for 15 minutes, then 25%, then 100%, with automatic rollback on error-rate or latency regression.

Median lead time from merge to production in 2025 was **34 minutes**. Change failure rate w

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[3] sdlc-policy — 4. Security in the pipeline — relevance 0.49

4. Security in the pipeline

Static analysis (Semgrep, CodeQL), dependency scanning (Snyk), IaC scanning (Checkov), and secret scanning (Gitleaks pre-commit plus GitHub push protection) all run on every pull request. A Critical or High dependency finding blocks the merge.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[4] sdlc-policy — Secure Software Development Lifecycle Policy — relevance 0.49

Secure Software Development Lifecycle Policy

Document ID: KD-ENG-001 · **Version:** 4.1 · **Owner:** Dana Whitfield, VP Engineering

Approved: 20 January 2026 · **Next review:** 20 January 2027

Maps to: SOC 2 CC8.1 · ISO 27001:2022 A.8.25-A.8.31

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[5] sdlc-policy — 1. Branching and review — relevance 0.49

1. Branching and review

`main` is protected and always releasable. All work happens on short-lived branches merged by pull request. `main` requires:

- At least **one approving review** from a engineer other than the author. Self-approval is blocked at the platform level.
- Two approvals for changes touching authentication, authorisation, tenant isolation, or cryptography. These paths ar

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

46. Provide an overview of your information security programme.

security · Q46 · Vendor Security Review row 47

Kestrel Data's information security programme is built on four core commitments

(*company-and-security-programme-overview*, Section "3. Security programme in summary"): 1. **Independent verification:** We maintain a SOC 2 Type II report issued by Prescient Assurance LLP on 14 March 2026 (covering 1 January – 31 December 2025 with no exceptions) and an ISO 27001:2022 certification from BSI (certificate `IS-2025-44817`, issued 22 September 2025 and valid through 21 September 2028). 2. **Least privilege by construction:** Access is managed through federated identity, mandatory hardware MFA for 100% of personnel, just-in-time production access expiring after 8 hours, and an architecture with no long-lived cloud access keys. 3. **Immutable audit evidence:** System logs and configuration histories are sent to a separate AWS account protected under object lock, ensuring evidence cannot be modified. 4. **Independent third-party testing:** We conduct annual external penetration testing. Our most recent assessment by Include Security (`INSEC-2026-0219`, conducted 3–14 February 2026) identified 0 Critical findings and 1 High finding, which was fully remediated on 27 February 2026. **Governance and Risk Management:** The Chief Information Security Officer (CISO) reports directly to the CEO and

presents quarterly to the Board of Directors. A dedicated Security Steering Group convenes monthly to oversee security operations and strategy. The organization maintains an active risk register of 41 open risks, which is reviewed monthly and re-scored on a quarterly basis (*company-and-security-programme-overview*, Section "4. Governance"). Furthermore, all security policies are reviewed at least annually or upon material change (*risk-management-and-governance*, Section "8. Policy management").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] company-and-security-programme-overview — 3. Security programme in summary — relevance 0.69

3. Security programme in summary

The programme is built on four commitments, each evidenced elsewhere in this corpus rather than asserted here:

1. ****Independent verification:**** SOC 2 Type II (Prescient Assurance LLP, report issued 14 March 2026 covering 1 January – 31 December 2025, ****no exceptions****) and ISO 27001:2022 (BSI certificate 'IS-2025-44817', issued 22 September 2025, valid to 21

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[2] company-and-security-programme-overview — Company and Security Programme Overview — relevance 0.69

Company and Security Programme Overview

****Document ID:**** KD-SEC-021 · ****Version:**** 4.2 · ****Owner:**** Marcus Oyelaran, CISO

****Approved:**** 6 February 2026 · ****Next review:**** 6 February 2027

****Maps to:**** SOC 2 CC1.1, CC1.2, CC2.1, CC2.3 · ISO 27001:2022 Clauses 4–5

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[3] company-and-security-programme-overview — 4. Governance — relevance 0.67

4. Governance

The CISO reports to the CEO and to the board quarterly. A Security Steering Group meets monthly. The risk register holds 41 open risks and is reviewed monthly and re-scored quarterly. Full detail is in KD-SEC-018.

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[4] risk-management-and-governance — 8. Policy management — relevance 0.67

8. Policy management

All security policies carry a document ID, a version, a named owner, an approval date, and a review date. Policies are reviewed at least annually and on material change. The 2026 review cycle covered 14 policies between 8 January and 12 February 2026; three were revised, and the changes were communicated at the February all-hands and through the annual acknowledgement cycle.

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[5] personnel-security-and-training — Personnel Security and Security Training Programme — relevance 0.65

Personnel Security and Security Training Programme

****Document ID:**** KD-SEC-013 · ****Version:**** 2.1 · ****Owner:**** Sofia Brenner, Head of IT

****Approved:**** 22 January 2026 · ****Next review:**** 22 January 2027

****Maps to:**** SOC 2 CC1.1, CC1.4, CC2.1, CC6.2 · ISO 27001:2022 A.6.1, A.6.2, A.6.3, A.6.6

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

47. Have you appointed a Data Protection Officer? Provide contact details. Provide supporting evidence.

legal · Q47 · Vendor Security Review row 48

Yes, Kestrel Data has appointed a Data Protection Officer (DPO). ****Contact Details:**** * ****Data Protection Officer:**** Priya Raghunathan * ****Email:**** `dpo@kestreldata.com` * ****Address:**** Kestrel Data, Inc., 1401 Lavaca Street, Suite 210, Austin, TX 78701, USA ****Supporting Evidence:**** * ****Privacy Policy** (`privacy-policy.txt`), Section 1 ("Controller and contact") ****** and header metadata.

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] privacy-policy — 1. Controller and contact — relevance 0.65

1. Controller and contact

Kestrel Data, Inc., 1401 Lavaca Street, Suite 210, Austin, TX 78701, USA.
EU representative under Art. 27 GDPR: Instant EU Rep Ltd, Dublin, Ireland.
Data Protection Officer: Priya Raghunathan, `dpo@kestreldata.com`.
Lead supervisory authority: Irish Data Protection Commission.

gs://attestor-505506-corpus/legal/privacy-policy.txt

[2] privacy-policy — 7. Complaints — relevance 0.64

7. Complaints

Complaints may be made to the Irish Data Protection Commission or to the supervisory authority of the data subject habitual residence.

gs://attestor-505506-corpus/legal/privacy-policy.txt

[3] data-processing-agreement — 3. Confidentiality — relevance 0.61

3. Confidentiality

Kestrel ensures that personnel authorised to process Personal Data are bound by confidentiality obligations surviving termination of employment. All staff execute a confidentiality agreement at onboarding.

gs://attestor-505506-corpus/legal/data-processing-agreement.txt

[4] privacy-policy — Privacy Policy — relevance 0.61

Privacy Policy

Document ID: KD-LEG-003 · **Version:** 4.0 · **Owner:** Priya Raghunathan, DPO
Effective: 15 January 2026 · **Published at:** `kestreldata.com/privacy`

This policy describes how Kestrel Data, Inc. handles personal data where Kestrel is the **controller**. Where Kestrel processes personal data on behalf of a business customer, that customer is the controller and its own

gs://attestor-505506-corpus/legal/privacy-policy.txt

[5] privacy-policy — 2. What we collect as controller — relevance 0.60

2. What we collect as controller

| Category | Examples | Lawful basis | Retention |

|---|---|---|---|

| Account data | Name, work email, job title, company | Contract (Art. 6(1)(b)) | Term + 3 years |

| Billing data | Billing contact, VAT number, payment method token | Contract; legal obligation | 7 years (tax) |

| Product telemetry | Feature usage, page views, error events | Legitimate interest

gs://attestor-505506-corpus/legal/privacy-policy.txt

48. Provide your current list of subprocessors.

legal · Q48 · Vendor Security Review row 49

Kestrel Data maintains the following list of authorized subprocessors: **### Infrastructure Subprocessors** * **Amazon Web Services, Inc. (AWS):** Cloud hosting, compute, storage, and database services. Processing occurs in the US (`us-east-1`, `us-west-2`) and EU (`eu-west-1`, `eu-central-1`) under Standard Contractual Clauses (SCCs) and the AWS Data Processing Addendum (DPA), with EU customer data maintained within the EU (`subprocessor-list`, "Infrastructure subprocessors"). * **Snowflake Inc.:** Analytics data warehouse. Processing occurs in the US (AWS `us-east-1`) and EU (AWS `eu-west-1`) under SCCs, with dedicated EU deployment for EU customers (`subprocessor-list`, "Infrastructure subprocessors"). * **Cloudflare, Inc.:** Content Delivery Network (CDN), Web Application Firewall (WAF), DDoS protection, and zero-trust access. Processing is handled via global edge locations, with EU traffic terminated in the EU under Regional Services and governed by SCCs and the Cloudflare DPA (`subprocessor-list`, "Infrastructure subprocessors"). **### Operational Subprocessors** * **Datadog, Inc.:** Observability, logging, and application performance monitoring (APM). Located in the US and the EU (`datadoghq.eu` for EU customers) under SCCs (`subprocessor-list`, "Operational subprocessors"). * **Okta, Inc.:** Identity and access management. Located in the US and the EU (EU cell for EU customers) under SCCs (`subprocessor-list`, "Operational subprocessors"). * **Twilio SendGrid:** Transactional email delivery. Located in the US under SCCs (`subprocessor-list`, "Operational subprocessors"). * **Zendesk, Inc.:** Customer support ticketing. Located in the US

with an EU data center option enabled, under SCCs (`subprocessor-list`, "Operational subprocessors"). * **Stripe, Inc.**: Payment processing (billing contacts only). Located in the US and Ireland under SCCs (`subprocessor-list`, "Operational subprocessors"). Kestrel provides 30 days' advance notice of any subprocessor changes (`subprocessor-list`, "Subprocessor List").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] subprocessor-list — Subprocessor List — relevance 0.76

Subprocessor List

Document ID: KD-LEG-002 · **Version:** 6.4 · **Owner:** Priya Raghunathan, DPO

Last updated: 1 February 2026 · **Published at:** `kestreldata.com/subprocessors`

Change notice: 30 days, subscribe at `kestreldata.com/subprocessors/subscribe`

gs://attestor-505506-corporate/legal/subprocessor-list.txt

[2] subprocessor-list — Infrastructure subprocessors — relevance 0.70

Infrastructure subprocessors

| Subprocessor | Purpose | Location of processing | Transfer mechanism | Engaged since |

|---|---|---|---|

| Amazon Web Services, Inc. | Cloud hosting, compute, storage, database | US (`us-east-1`, `us-west-2`); EU (`eu-west-1`, `eu-central-1`)

| SCCs + AWS DPA; EU data stays in EU | Mar 2019 |

| Snowflake Inc. | Analytics data warehouse | US (AWS `us-east-1`);

gs://attestor-505506-corporate/legal/subprocessor-list.txt

[3] subprocessor-list — Operational subprocessors — relevance 0.66

Operational subprocessors

| Subprocessor | Purpose | Location | Transfer mechanism | Engaged since |

|---|---|---|---|

| Datadog, Inc. | Observability, logs, APM | US; EU site (`datadoghq.eu`) for EU customers | SCCs | Jun 2020 |

| Okta, Inc. | Identity and access management | US; EU cell for EU customers | SCCs | Feb 2021 |

| Twilio SendGrid | Transactional email delivery | US | SCCs | Ma

gs://attestor-505506-corporate/legal/subprocessor-list.txt

[4] subprocessor-list — Changes in the last 12 months — relevance 0.55

Changes in the last 12 months

| Date | Change | Notice given |

|---|---|---|

| 12 Nov 2025 | Added Cloudflare Zero Trust (existing vendor, new purpose) | 30 days, no objections |

| 4 Jun 2025 | Removed Segment, Inc. (product analytics discontinued) | N/A, removal |

| 18 Feb 2025 | Added Snowflake EU deployment for EU instance | 30 days, no objections |

gs://attestor-505506-corporate/legal/subprocessor-list.txt

[5] subprocessor-list — EU data residency — relevance 0.54

EU data residency

Customers on the EU instance have their data processed exclusively within the EEA for the infrastructure subprocessors above. Kestrel does **not** currently offer a UK-only, Swiss-only, Canadian, or Australian data residency option. Requests for those are recorded but not committed to.

gs://attestor-505506-corporate/legal/subprocessor-list.txt

49. Do you offer on-premises or self-hosted deployment?

engineering · Q49 · Vendor Security Review row 50

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] infrastructure-architecture-overview — Infrastructure Architecture Overview — relevance 0.64

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[2] infrastructure-architecture-overview — 6. Network — relevance 0.62

6. Network

Private subnets for all compute and data. No public IP addresses on workload instances. Ingress is exclusively through Cloudflare, then an AWS Application Load Balancer, then the Istio ingress gateway. Egress is through NAT gateways with an allowlist for known destinations.

Security groups are managed in Terraform and default-deny. There are no `0.0.0.0/0` ingress rules in produc

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[3] infrastructure-architecture-overview — 7. Observability — relevance 0.62

7. Observability

Datadog for metrics, logs, APM, and security monitoring. Distributed tracing uses W3C Trace Context propagated across all services. Every log line carries `tenant\_id` and `request\_id`.

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[4] infrastructure-architecture-overview — 1. Cloud footprint — relevance 0.61

1. Cloud footprint

Kestrel runs on **Amazon Web Services**. There are two independent production instances:

Instance	Region	Serves
US	`us-east-1` (3 AZs)	North America, and customers with no residency requirement
EU	`eu-west-1` (3 AZs)	EEA, UK, and Swiss customers electing EU residency

Backup replication targets `us-west-2` and `eu-central-1` respecti

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[5] infrastructure-architecture-overview — 4. Data layer — relevance 0.61

4. Data layer

Store	Technology	Purpose
Primary OLTP	Amazon RDS PostgreSQL 16, Multi-AZ	Application state
Analytics	Snowflake	Customer analytics workloads
Object storage	Amazon S3	Uploads, exports, backups
Cache	Amazon ElastiCache (Redis 7)	Session and query cache
Search	OpenSearch 2.13	In-product search

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

50. Please confirm: What controls remain the responsibility of the customer?

engineering · Q50 · Vendor Security Review row 51

Under Kestrel Data's shared responsibility model and complementary user entity controls, the customer remains responsible for the following controls: **Data Governance and Lawfulness:** Deciding what data is uploaded and ensuring its lawfulness (Kestrel does not inspect customer data). **Identity and Authentication:** Configuring SSO and enforcing multi-factor authentication (MFA) at their own identity provider (IdP). **User and Access Management:** Managing their own users, roles, and permissions, including the timely de-provisioning and removal of leavers. **API Credential Management:** Managing the scope, secure storage, and rotation of the API credentials they create. **Audit Review:** Reviewing their own audit logs, which Kestrel retains and makes available for 13 months. **Data Privacy and Controller Duties:** Acting as the data controller for data subject requests concerning their content, as well as notifying their own data subjects and regulators where applicable. **Endpoint Security:** Maintaining device and endpoint security for the users accessing the platform. (Citations: Data Flow and Shared Responsibility Model, KD-ENG-011, Section 3 "The shared responsibility model" and Section 4 "Complementary user

entity controls")*

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (4)

[1] data-flow-and-shared-responsibility — Data Flow and Shared Responsibility Model — relevance 0.62

Data Flow and Shared Responsibility Model

Document ID: KD-ENG-011 · **Version:** 2.0 · **Owner:** Dana Whitfield, VP Engineering

Approved: 2 February 2026 · **Next review:** 2 February 2027

Maps to: SOC 2 CC2.3, CC3.2, CC6.1 · ISO 27001:2022 A.5.2, A.5.8, A.8.9 · GDPR Article 28

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[2] data-flow-and-shared-responsibility — 3. The shared responsibility model — relevance 0.60

3. The shared responsibility model

Security of the platform is Kestrel's. Security of what the customer does with it is the customer's. The line is drawn here rather than left implicit, because an unstated boundary is where a breach lands on whoever is less able to argue.

Kestrel is responsible for:

* physical and environmental security of the infrastructure (through AWS), and the cloud
co

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[3] data-flow-and-shared-responsibility — 4. Complementary user entity controls — relevance 0.57

4. Complementary user entity controls

The SOC 2 report lists these as complementary user entity controls; they are restated here because a customer reading only this document should still see them. If a customer does not operate the controls in the second list, Kestrel's controls in the first do not compensate: Kestrel cannot detect that a departed employee of the customer still holds a valid sess

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[4] secrets-management-standard — Secrets Management Standard — relevance 0.50

Secrets Management Standard

Document ID: KD-ENG-006 · **Version:** 2.1 · **Owner:** Dana Whitfield, VP Engineering

Approved: 22 January 2026 · **Maps to:** SOC 2 CC6.1 · ISO 27001:2022 A.8.24

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

51. How are secrets stored and rotated?

security · Q51 · Vendor Security Review row 52

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

52. Are manual production console changes permitted?

engineering · Q52 · Vendor Security Review row 53

Manual changes through the AWS console are strictly prohibited in production. All infrastructure is managed exclusively via Terraform in the `kestrel-infra` repository, and automated drift detection runs every 6 hours, raising a SEV3 alert upon detecting any unmanaged change (`change-management-procedure`, Section 4: Infrastructure changes).

Release status: No — held for a human · confidence low · drafted by EngineeringAgent

Evidence (5)

[1] change-management-procedure — 3. Emergency changes — relevance 0.54

3. Emergency changes

An Emergency change may bypass the Change Advisory step but never bypasses code review or

CI. The Incident Commander authorises it, and a retrospective record is filed within one business day covering what changed, why the normal path was bypassed, and whether the change should be reworked.

All 9 Emergency changes in 2025 have completed retrospectives on file.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[2] change-management-procedure — 1. Change classes — relevance 0.54

1. Change classes

| Class | Definition | Approval | Example |

|---|---|---|---|

| **Standard** | Pre-approved, low risk, automated | PR review + CI | Application code, config change through IaC |

| **Normal** | Material risk or customer-visible | PR review + Change Advisory sign-off | Schema migration, dependency major version |

| **Emergency** | Fixing an active SEV1/SEV2 | Retrospective with

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[3] change-management-procedure — Change Management Procedure — relevance 0.53

Change Management Procedure

Document ID: KD-ENG-002 · **Version:** 3.0 · **Owner:** Dana Whitfield, VP Engineering

Approved: 20 January 2026 · **Maps to:** SOC 2 CC8.1 · ISO 27001:2022 A.8.32

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[4] change-management-procedure — 2. Normal change requirements — relevance 0.53

2. Normal change requirements

A Normal change additionally requires a written rollback plan, a customer-impact assessment, and sign-off from the Change Advisory group (VP Engineering plus one SRE). Schema migrations must be backward compatible for at least one release, so that a rollback does not require a data migration.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[5] change-management-procedure — 4. Infrastructure changes — relevance 0.50

4. Infrastructure changes

Infrastructure is managed exclusively through Terraform in the `kestrel-infra` repository. Manual changes through the AWS console are prohibited in production; drift detection runs every 6 hours and raises a SEV3 on any unmanaged change. Drift was detected 4 times in 2025, all traced to AWS-initiated maintenance rather than human action.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

53. What is your contractual availability commitment?

engineering · Q53 · Vendor Security Review row 54

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] availability-sla — 2. Definitions — relevance 0.72

2. Definitions

Uptime is the percentage of minutes in a calendar month during which the Service is Available, calculated as:

$$\text{Uptime \%} = ((\text{Total Minutes} - \text{Downtime Minutes}) / \text{Total Minutes}) \times 100$$

Downtime is any minute during which all requests to the production API from the external monitoring network return a 5xx error or fail to connect. Measurement is by independent third-p

gs://attestor-505506-corporus/engineering/availability-sla.txt

[2] availability-sla — 4. Service credits — relevance 0.70

4. Service credits
| Monthly uptime | Credit (% of monthly fee) |
|---|---|
| Below 99.9% but at or above 99.0% | 10% |
| Below 99.0% but at or above 95.0% | 25% |
| Below 95.0% | 50% |

Credits are the sole and exclusive remedy for failure to meet this SLA. A claim must be submitted within **30 days** of the end of the affected month, with supporting detail. Credits are applied to the next

gs://attestor-505506-corporate/engineering/availability-sla.txt

[3] availability-sla — Availability Service Level Agreement — relevance 0.69

Availability Service Level Agreement

Document ID: KD-ENG-007 · **Version:** 3.0 · **Owner:** Aaron Feldstein, General Counsel

Effective: 1 January 2026 · Forms part of the Master Subscription Agreement

gs://attestor-505506-corporate/engineering/availability-sla.txt

[4] availability-sla — 1. Commitment — relevance 0.67

1. Commitment

Kestrel commits to **99.9% monthly uptime** for the Kestrel Insight platform on the Enterprise and Growth tiers.

The **Starter tier** carries no availability commitment. It is offered on a reasonable efforts basis and is excluded from service credits.

gs://attestor-505506-corporate/engineering/availability-sla.txt

[5] availability-sla — 5. Historical performance — relevance 0.67

5. Historical performance

| Year | Measured availability | Months below 99.9% | Credits issued |

|---|---|---|---|

| 2025 | 99.97% | 0 | 0 |

| 2024 | 99.94% | 1 (March, 99.87%) | 1 customer, 10% |

| 2023 | 99.91% | 1 (August, 99.82%) | 3 customers, 10% |

gs://attestor-505506-corporate/engineering/availability-sla.txt

54. Does the availability commitment apply to all pricing tiers?

legal · Q54 · Vendor Security Review row 55

No, the availability commitment does not apply to all pricing tiers. According to the Security Addendum (Section 6, "Availability commitment"), the 99.9% monthly uptime commitment applies specifically to the Enterprise and Growth tiers, while no availability SLA applies to the Starter tier.

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] security-addendum — 6. Availability commitment — relevance 0.74

6. Availability commitment

99.9% monthly uptime for Enterprise and Growth tiers, with service credits as set out in the Availability SLA (KD-ENG-007). No availability SLA applies to the Starter tier.

gs://attestor-505506-corporate/legal/security-addendum.txt

[2] master-agreement-summary — 10. Service levels — relevance 0.71

10. Service levels

The availability commitment, service credits, and support response targets are in the Availability SLA (KD-ENG-001). Service credits are the sole remedy for missed availability, with a termination right if the monthly commitment is missed in three consecutive months.

gs://attestor-505506-corporate/legal/master-agreement-summary.txt

[3] security-addendum — 8. Changes — relevance 0.63

8. Changes

Kestrel may update this addendum, provided that no update materially reduces the commitments during a paid term. Material changes are notified 30 days in advance.

gs://attestor-505506-corporus/legal/security-addendum.txt

[4] security-addendum — 2. Encryption commitments — relevance 0.61

2. Encryption commitments

- Customer data encrypted at rest using AES-256 or stronger.
- Customer data encrypted in transit using TLS 1.2 or higher; TLS 1.3 is the default.
- Encryption keys managed in a dedicated key management service with role separation.

gs://attestor-505506-corporus/legal/security-addendum.txt

[5] security-addendum — 5. Testing commitments — relevance 0.60

5. Testing commitments

- Independent penetration test at least **annually**; executive summary available under NDA.
- Vulnerability remediation to the SLAs in KD-SEC-006: Critical 7 days, High 30 days.
- Disaster recovery restore tested at least **quarterly**.

gs://attestor-505506-corporus/legal/security-addendum.txt

55. Do you impose equivalent data protection obligations on subprocessors?

legal · Q55 · Vendor Security Review row 56

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

56. Do you act as a service provider under the CCPA?

legal · Q56 · Vendor Security Review row 57

Yes, Kestrel acts as a service provider under the CCPA/CPRA in respect of customer content. Kestrel's Data Processing Agreement (DPA) includes the required statutory service provider terms, committing not to sell personal data, not to share it for cross-context behavioral advertising, not to retain or use it outside the specified business purpose, and not to combine it with data from other sources (Data Subject Rights Procedure, Section 8, "California and other US state rights").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] data-subject-rights-procedure — 8. California and other US state rights — relevance 0.68

8. California and other US state rights

Kestrel acts as a **service provider** under the CCPA/CPRA in respect of customer content, and the DPA contains the required service provider terms: no sale, no sharing for cross-context behavioural advertising, no retention or use outside the business purpose, and no combining with data from other sources. The same terms are applied for the Virginia, Colora

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[2] data-processing-agreement — 1. Roles — relevance 0.64

1. Roles

Customer is **Controller**. Kestrel Data, Inc. is **Processor**. Where Customer is itself a processor for its own customers, Kestrel is sub-processor and the same obligations apply down the chain.

Kestrel is **Controller** for a limited set of data it determines the purposes of: account administrator contact details, billing records, and product telemetry described in Annex 3.

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[3] data-subject-rights-procedure — Data Subject Rights Procedure — relevance 0.63

Data Subject Rights Procedure

Document ID: KD-LEG-007 · **Version:** 2.3 · **Owner:** Priya Raghunathan, DPO

Approved: 20 January 2026 · **Next review:** 20 January 2027

Maps to: GDPR Articles 12, 15–22, 28(3)(e) · CCPA/CPRA §1798.100–130

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[4] data-subject-rights-procedure — 1. Which rights, and against whom — relevance 0.62

1. Which rights, and against whom

For customer content, Kestrel is the **processor** and the customer is the controller. A data subject who approaches Kestrel directly about customer content is redirected to the relevant customer without undue delay and, where Kestrel can identify the customer, within **3 business days**. Kestrel does not respond substantively on the controller's behalf.

For data

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[5] subprocessor-list — Operational subprocessors — relevance 0.62

Operational subprocessors

| Subprocessor | Purpose | Location | Transfer mechanism | Engaged since |

|---|---|---|---|---|

| Datadog, Inc. | Observability, logs, APM | US; EU site (`datadoghq.eu`) for EU customers | SCCs | Jun 2020 |

| Okta, Inc. | Identity and access management | US; EU cell for EU customers | SCCs | Feb 2021 |

| Twilio SendGrid | Transactional email delivery | US | SCCs | Mar

gs://attestor-505506-corporus/legal/subprocessor-list.txt

57. Will you sign a Business Associate Agreement under HIPAA?

legal · Q57 · Vendor Security Review row 58

Kestrel does not sign Business Associate Agreements (BAAs) and does not accept Protected Health Information (PHI). Kestrel Insight is not designed for PHI and is not HITECH-configured, and the Acceptable Use terms explicitly prohibit uploading PHI (Master Agreement Summary, Section 4: "HIPAA and Business Associate Agreements"). Furthermore, Kestrel is not a covered entity or business associate under HIPAA, and zero BAAs are executed across our customer base (Master Agreement Summary, Section 4: "HIPAA and Business Associate Agreements"; Legal and Regulatory History, Section 7: "Regulatory scope"). Customers whose use cases require processing PHI should not select Kestrel for those workloads.

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by LegalAgent

Evidence (5)

[1] master-agreement-summary — 4. HIPAA and Business Associate Agreements — relevance 0.67

4. HIPAA and Business Associate Agreements

Kestrel does not sign Business Associate Agreements and does not accept protected health information. Kestrel Insight is not designed for PHI, is not HITECH-configured, and the Acceptable Use terms prohibit uploading it. **Zero BAAs are currently executed.** A customer whose use case requires PHI should not select Kestrel for that workload, and Kestrel

gs://attestor-505506-corporus/legal/master-agreement-summary.txt

[2] legal-and-regulatory-history — 7. Regulatory scope — relevance 0.57

7. Regulatory scope

Kestrel is not a regulated financial institution, is not a covered entity or business associate under HIPAA (see KD-LEG-014 §4), is not a federal contractor, and is not subject to sectoral supervision. Its obligations arise from general data protection law, its contracts, and the certifications it chooses to maintain.

gs://attestor-505506-corporus/legal/legal-and-regulatory-history.txt

[3] legal-and-regulatory-history — 8. Statements in this document — relevance 0.56

8. Statements in this document

Every statement above is confirmed by the General Counsel as at the approval date and is restated at each annual review. Where a customer requires a contemporaneous confirmation,

the General Counsel will provide one in writing at the point of contracting; several customers require this annually and it is provided as a matter of course.

gs://attestor-505506-corporus/legal/legal-and-regulatory-history.txt

[4] master-agreement-summary — 8. Assignment and change of control — relevance 0.55

8. Assignment and change of control

Neither party may assign without the other's consent, except to a successor in a merger or sale of substantially all assets, subject to notice. Where the acquirer is a competitor of the customer, the customer may terminate within 30 days of notice.

gs://attestor-505506-corporus/legal/master-agreement-summary.txt

[5] master-agreement-summary — 9. Subcontracting — relevance 0.55

9. Subcontracting

Sub-processing is governed by the DPA: a public list (KD-LEG-006), **30 days' notice** before adding or replacing a sub-processor, a right to object on reasonable data protection grounds, and termination without penalty if the objection cannot be resolved.

gs://attestor-505506-corporus/legal/master-agreement-summary.txt

58. Provide your public privacy policy.

legal · Q58 · Vendor Security Review row 59

Kestrel Data's public Privacy Policy is published and accessible online at `kestreldata.com/privacy` (Document: privacy-policy, Section: Privacy Policy). This policy (KD-LEG-003, Version 4.0, effective January 15, 2026) outlines how Kestrel Data handles personal data in its capacity as a data controller. Where Kestrel processes personal data on behalf of a business customer, the customer acts as the controller governed by its own privacy notice and Kestrel's Data Processing Agreement (Document: privacy-policy, Section: Privacy Policy).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] privacy-policy — Privacy Policy — relevance 0.63

Privacy Policy

Document ID: KD-LEG-003 · **Version:** 4.0 · **Owner:** Priya Raghunathan, DPO
Effective: 15 January 2026 · **Published at:** `kestreldata.com/privacy`

This policy describes how Kestrel Data, Inc. handles personal data where Kestrel is the **controller**. Where Kestrel processes personal data on behalf of a business customer, that customer is the controller and its own

gs://attestor-505506-corporus/legal/privacy-policy.txt

[2] privacy-policy — 6. International transfers — relevance 0.61

6. International transfers

Personal data is processed in the United States and the European Union. Transfers out of the EEA rely on the 2021 Standard Contractual Clauses with supplementary measures described in the Transfer Impact Assessment (KD-LEG-006).

gs://attestor-505506-corporus/legal/privacy-policy.txt

[3] privacy-policy — 4. Cookies — relevance 0.61

4. Cookies

The marketing site uses strictly necessary cookies plus, with consent, analytics cookies (Plausible, which is cookieless, and Google Analytics 4 where consent is given). The application uses only strictly necessary cookies: a session cookie and a CSRF token. A consent banner meeting EDPB guidance is served to EEA, UK, and Swiss visitors, with reject as prominent as accept.

gs://attestor-505506-corporus/legal/privacy-policy.txt

[4] privacy-policy — 1. Controller and contact — relevance 0.61

1. Controller and contact

Kestrel Data, Inc., 1401 Lavaca Street, Suite 210, Austin, TX 78701, USA.

EU representative under Art. 27 GDPR: Instant EU Rep Ltd, Dublin, Ireland.
Data Protection Officer: Priya Raghunathan, `dpo@kestreldata.com`.
Lead supervisory authority: Irish Data Protection Commission.

gs://attestor-505506-corporus/legal/privacy-policy.txt

[5] privacy-policy — 5. Your rights — relevance 0.61

5. Your rights

Data subjects in the EEA, UK, and Switzerland have rights of access, rectification, erasure, restriction, portability, and objection, and the right to withdraw consent. California residents have rights under the CCPA as amended by the CPRA, including the right to know, delete, correct, and opt out of sharing.

Requests to `privacy@kestreldata.com` are acknowledged within 5 busi

gs://attestor-505506-corporus/legal/privacy-policy.txt

59. How many government data requests did you receive last year?

legal · Q59 · Vendor Security Review row 60

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] government-requests-and-transparency-report — Government Requests Policy and Transparency Report — relevance 0.64

Government Requests Policy and Transparency Report

Document ID: KD-LEG-012 · **Version:** 2.0 · **Owner:** Aaron Feldstein, General Counsel

Approved: 2 February 2026 · **Next review:** 2 February 2027

Maps to: GDPR Articles 48, 28(3)(a) · SOC 2 CC2.3 · ISO 27001:2022 A.5.5, A.5.31, A.5.34

gs://attestor-505506-corporus/legal/government-requests-and-transparency-report.txt

[2] government-requests-and-transparency-report — 3. Transparency report — relevance 0.64

3. Transparency report

Kestrel publishes a transparency report annually at `trust.kestreldata.com/transparency`.

Figures for the calendar year 2025:

| Category | Received | Data produced |

| ---|---|---|

| US law enforcement — subpoena | 2 | 0 |

| US law enforcement — search warrant | 0 | 0 |

| US national security process (NSL, FISA) | **0** | 0 |

| Non-US government requests | 1 | 0 |

| Civil di

gs://attestor-505506-corporus/legal/government-requests-and-transparency-report.txt

[3] government-requests-and-transparency-report — 6. Records — relevance 0.62

6. Records

The government request register is retained for ten years and is available to the auditors and, in redacted form, to a customer exercising audit rights. Retention is longer than the ordinary schedule deliberately: the value of this record is precisely that it goes back further than anyone's memory.

gs://attestor-505506-corporus/legal/government-requests-and-transparency-report.txt

[4] data-subject-rights-procedure — 9. Records — relevance 0.59

9. Records

Every request, its route, and its resolution date are recorded in the DSR register held by the DPO and retained for three years. The register is available to auditors and, in redacted form, to customers exercising their audit rights under the DPA.

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[5] data-subject-rights-procedure — 4. Access requests (Article 15) — relevance 0.58

4. Access requests (Article 15)

Where Kestrel acts as controller, an access request is acknowledged within 5 business days and answered within ****30 calendar days****, extendable by a further 60 days for complex requests with notice to the data subject. Identity is verified through the requester's registered email address plus one additional factor; where identity cannot be established, the request i

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

60. Was cross-tenant data access achieved during penetration testing? If not, describe compensating controls.

security · Q60 · Vendor Security Review row 61

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

61. What is your notification window for confirmed unauthorised access to production data?

security · Q61 · Vendor Security Review row 62

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

62. For each applicable system: Who holds the encryption keys for customer data?

engineering · Q62 · Vendor Security Review row 63

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] data-flow-and-shared-responsibility — 1. Data flow, end to end — relevance 0.68

1. Data flow, end to end

- **Ingress.**** A customer's browser or API client resolves `app.kestreldata.com` or `api.kestreldata.com` to Cloudflare, which terminates TLS 1.3 (1.2 minimum) and applies WAF and rate limiting.
- **Instance selection.**** DNS and tenant routing send the request to the instance chosen at contract signature: `us-east-1` or `eu-west-1`. ****A tenant's requests never c**

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[2] secrets-management-standard — 6. Customer-issued API credentials — relevance 0.67

6. Customer-issued API credentials

API keys issued to customers are stored as Argon2id hashes; Kestrel cannot recover the plaintext of a customer API key and will not do so on request. Keys are displayed once at creation. Customers can create, scope, and revoke keys through the console, and each key carries a last-used timestamp so stale keys are visible.

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

[3] data-flow-and-shared-responsibility — 3. The shared responsibility model — relevance 0.65

3. The shared responsibility model

Security of the platform is Kestrel's. Security of what the customer does with it is the customer's. The line is drawn here rather than left implicit, because an unstated boundary is where a breach lands on whoever is less able to argue.

****Kestrel is responsible for:****

* physical and environmental security of the infrastructure (through AWS), and the cloud
co

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[4] data-flow-and-shared-responsibility — 6. Where processing occurs — relevance 0.63

6. Where processing occurs

Processing occurs in AWS `us-east-1` (US instance) and AWS `eu-west-1` (EU instance), by personnel located in the United States, the European Union, the United Kingdom, and Canada, under the access controls in KD-SEC-002. ****No processing occurs outside the stated regions**, and no support is subcontracted to a third-party provider in another jurisdiction.**

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[5] secrets-management-standard — 1. Where secrets live — relevance 0.62

1. Where secrets live

| Secret class | Store | Rotation |

|---|---|---|

| Application secrets, API keys | AWS Secrets Manager | 90 days, automated |

| Database credentials | AWS Secrets Manager with RDS-managed rotation | 30 days, automated |

| Encryption keys | AWS KMS (key material never leaves KMS) | Annual, automated |

| TLS certificates | AWS Certificate Manager | Automatic before expiry

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

63. Do you deploy endpoint detection and response on all company devices?

security · Q63 · Vendor Security Review row 64

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] endpoint-protection-standard — 2. Endpoint detection and response — relevance 0.65

2. Endpoint detection and response

****CrowdStrike Falcon is deployed on 100% of managed endpoints and on all production compute nodes.**** Coverage is reconciled nightly against the Kandji and AWS inventories, and a device present in inventory but absent from Falcon raises a ticket to the Head of IT within one business day. The reconciliation found two gaps during 2025, both new contractor laptops, b

gs://attestor-505506-corporus/security/endpoint-protection-standard.txt

[2] acceptable-use-policy — 1. Company devices — relevance 0.65

1. Company devices

All laptops are company-owned and managed through Kandji (macOS) or Intune (Windows). Personal devices may not access Restricted or Confidential data. BYOD is permitted only for calendar and chat through managed applications with app-level containerisation.

Required device posture, enforced continuously and checked at every Cloudflare Access authentication: full-disk encry

gs://attestor-505506-corporus/security/acceptable-use-policy.txt

[3] endpoint-protection-standard — Endpoint Protection and Data Loss Prevention Standard — relevance 0.61

Endpoint Protection and Data Loss Prevention Standard

****Document ID:**** KD-SEC-015 · ****Version:**** 2.2 · ****Owner:**** Sofia Brenner, Head of IT

****Approved:**** 19 January 2026 · ****Next review:**** 19 January 2027

****Maps to:**** SOC 2 CC6.6, CC6.8, CC7.1 · ISO 27001:2022 A.8.1, A.8.7, A.8.12, A.8.16

gs://attestor-505506-corporus/security/endpoint-protection-standard.txt

[4] endpoint-protection-standard — 8. Patching of endpoints — relevance 0.61

8. Patching of endpoints

Operating system updates are enforced within 14 days of release for standard updates and 72 hours for updates addressing a Critical vulnerability, with a Kandji deferral window that cannot be extended by the user. Measured compliance at the last audit point (1 February 2026) was 168 of 174 devices within policy, the remaining six being on extended leave with access suspend

gs://attestor-505506-corporus/security/endpoint-protection-standard.txt

[5] endpoint-protection-standard — 4. Disk encryption — relevance 0.60

4. Disk encryption

FileVault 2 is enforced on all macOS devices, with recovery keys held in Kandji custody; LUKS is enforced on Linux workstations. Compliance is 100% of 174 devices, verified continuously by Vanta control DE-03.

gs://attestor-505506-corporus/security/endpoint-protection-standard.txt

64. Can customers export their data in a machine-readable format?

engineering · Q64 · Vendor Security Review row 65

Yes. Customers can export their data in machine-readable formats through full self-service export or via the public API with no volume charge. Customer-uploaded datasets are returned in their original, non-proprietary formats (what was loaded is what comes back), while account identity data and usage events are exportable in JSON or CSV format. Additionally, customers are provided with 30 days of post-termination access to complete data exports, which can be extended by agreement (`cloud-exit-and-portability-plan`, Section 6). Bulk exports are delivered securely via pre-signed URLs (`data-flow-and-shared-responsibility`, Section 1).

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (5)

[1] cloud-exit-and-portability-plan — 6. Customer's own exit from Kestrel — relevance 0.60

6. Customer's own exit from Kestrel

Distinct from Kestrel's exit from AWS, and more likely to be what a reviewer is asking about. A customer may leave at any time and take their data with them:

* full self-service export of all customer-uploaded datasets in their original format, plus account identity data and usage events as JSON or CSV;

* the same through the public API, with no volume charge

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[2] data-flow-and-shared-responsibility — 2. What crosses a boundary, and what does not — relevance 0.58

2. What crosses a boundary, and what does not

| Data | Leaves the tenant's region? |

|---|---|

| Customer-uploaded analytics datasets | **No** |

| Backups of customer content | **No** |

| Account identity data (EU tenants) | Only for support access, under §4 of KD-SEC-002 |

| Pseudonymised product telemetry | Yes — aggregated to the US, assessed in KD-LEG-010 |

| Operational logs (content-redacted)

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[3] data-flow-and-shared-responsibility — 1. Data flow, end to end — relevance 0.58

1. Data flow, end to end

1. **Ingress.** A customer's browser or API client resolves `app.kestreldata.com` or `api.kestreldata.com` to Cloudflare, which terminates TLS 1.3 (1.2 minimum) and applies WAF and rate limiting.

2. **Instance selection.** DNS and tenant routing send the request to the instance chosen at contract signature: `us-east-1` or `eu-west-1`. A tenant's requests never c

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[4] backup-restore-procedure — 5. Tenant-scoped restore — relevance 0.57

5. Tenant-scoped restore

A single customer can be restored without affecting others, by restoring to an isolated account and exporting that tenant rows back. This was exercised once in production, on 22 September 2025, at a customer request following an erroneous bulk delete on their side. Time to complete was 5 hours 10 minutes.

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[5] backup-restore-procedure — 2. Encryption and location — relevance 0.55

2. Encryption and location

All backups are encrypted with AES-256 using AWS KMS. The daily logical dump uses a **separate CMK** from the primary database, so that compromise of the primary key does not compromise the backups.

Cross-region replication stays inside the residency boundary: `us-east-1` replicates to `us-west-2`, `eu-west-1` replicates to `eu-central-1`. EU customer data never le

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

65. In which cloud regions is the production platform hosted?

legal · Q65 · Vendor Security Review row 66

Kestrel Data's production platform infrastructure is hosted in Amazon Web Services (AWS) across the following regions: **United States:** `us-east-1` and `us-west-2` **European Union:** `eu-west-1` and `eu-central-1` Additionally, analytics data warehousing via Snowflake is hosted in AWS `us-east-1` for US customers and AWS `eu-west-1` for EU customers (`subprocessor-list`, "Infrastructure subprocessors"). For customers on the EU instance, data is processed exclusively within the EEA (`subprocessor-list`, "EU data residency").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by LegalAgent

Evidence (5)

[1] subprocessor-list — EU data residency — relevance 0.65

EU data residency

Customers on the EU instance have their data processed exclusively within the EEA for the infrastructure subprocessors above. Kestrel does **not** currently offer a UK-only, Swiss-only, Canadian, or Australian data residency option. Requests for those are recorded but not committed to.

gs://attestor-505506-corporus/legal/subprocessor-list.txt

[2] subprocessor-list — Infrastructure subprocessors — relevance 0.59

Infrastructure subprocessors

Subprocessor	Purpose	Location of processing	Transfer mechanism	Engaged since
--------------	---------	------------------------	--------------------	---------------

---	---	---	---	---
-----	-----	-----	-----	-----

Amazon Web Services, Inc.	Cloud hosting, compute, storage, database	US (`us-east-1`, `us-west-2`); EU (`eu-west-1`, `eu-central-1`)		
---------------------------	---	---	--	--

SCCs + AWS DPA; EU data stays in EU	Mar 2019			
-------------------------------------	----------	--	--	--

Snowflake Inc.	Analytics data warehouse	US (AWS `us-east-1`);		
----------------	--------------------------	-----------------------	--	--

gs://attestor-505506-corporus/legal/subprocessor-list.txt

[3] security-addendum — 6. Availability commitment — relevance 0.58

6. Availability commitment

99.9% monthly uptime for Enterprise and Growth tiers, with service credits as set out in the Availability SLA (KD-ENG-007). No availability SLA applies to the Starter tier.

gs://attestor-505506-corporus/legal/security-addendum.txt

[4] security-addendum — 2. Encryption commitments — relevance 0.57

2. Encryption commitments

- Customer data encrypted at rest using AES-256 or stronger.
- Customer data encrypted in transit using TLS 1.2 or higher; TLS 1.3 is the default.
- Encryption keys managed in a dedicated key management service with role separation.

gs://attestor-505506-corporus/legal/security-addendum.txt

[5] subprocessor-list — Changes in the last 12 months — relevance 0.56

Changes in the last 12 months
Date	Change	Notice given
12 Nov 2025	Added Cloudflare Zero Trust (existing vendor, new purpose)	30 days, no objections
4 Jun 2025	Removed Segment, Inc. (product analytics discontinued)	N/A, removal
18 Feb 2025	Added Snowflake EU deployment for EU instance	30 days, no objections

gs://attestor-505506-corporus/legal/subprocessor-list.txt

66. Is there board-level oversight of information security?

security · Q66 · Vendor Security Review row 67

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

67. Do you publish a transparency report of government data requests?

legal · Q67 · Vendor Security Review row 68

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] government-requests-and-transparency-report — Government Requests Policy and Transparency Report — relevance 0.66

Government Requests Policy and Transparency Report
Document ID: KD-LEG-012 · **Version:** 2.0 · **Owner:** Aaron Feldstein, General Counsel
Approved: 2 February 2026 · **Next review:** 2 February 2027
Maps to: GDPR Articles 48, 28(3)(a) · SOC 2 CC2.3 · ISO 27001:2022 A.5.5, A.5.31, A.5.34

gs://attestor-505506-corporus/legal/government-requests-and-transparency-report.txt

[2] government-requests-and-transparency-report — 3. Transparency report — relevance 0.65

3. Transparency report
Kestrel publishes a transparency report annually at `trust.kestreldata.com/transparency`.
Figures for the calendar year 2025:

Category	Received	Data produced
US law enforcement — subpoena	2	0
US law enforcement — search warrant	0	0
US national security process (NSL, FISA)	**0**	0
Non-US government requests	1	0
Civil di		

gs://attestor-505506-corporus/legal/government-requests-and-transparency-report.txt

[3] government-requests-and-transparency-report — 6. Records — relevance 0.63

6. Records
The government request register is retained for ten years and is available to the auditors and, in redacted form, to a customer exercising audit rights. Retention is longer than the ordinary schedule deliberately: the value of this record is precisely that it goes back further than anyone's memory.

gs://attestor-505506-corporus/legal/government-requests-and-transparency-report.txt

[4] data-subject-rights-procedure — 9. Records — relevance 0.60

9. Records
Every request, its route, and its resolution date are recorded in the DSR register held by the DPO and retained for three years. The register is available to auditors and, in redacted form, to customers exercising their audit rights under the DPA.

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[5] government-requests-and-transparency-report — 1. Who may receive a request — relevance 0.60

1. Who may receive a request

All law enforcement, regulatory, and national security requests for customer data must be directed to the General Counsel at `legal@kestreldata.com`. No other person at Kestrel is authorised to accept service or to disclose customer data to a government authority. Support, sales, and engineering personnel are trained to route any such approach to the General Counsel wi

gs://attestor-505506-corporus/legal/government-requests-and-transparency-report.txt

68. Can a developer approve their own pull request?

engineering · Q68 · Vendor Security Review row 69

No, developers cannot approve their own pull requests. Under Kestrel Data's SDLC Policy (`sdlc-policy`, Section 1, "Branching and review"), pull requests merging into the protected `main` branch require at least one approving review from an engineer other than the author, and self-approval is blocked at the platform level. Changes touching sensitive paths—such as authentication, authorization, tenant isolation, or cryptography—require two approvals enforced via `CODEOWNERS`. Furthermore, administrator bypass of branch protection is disabled.

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (5)

[1] sdlc-policy — 1. Branching and review — relevance 0.64

1. Branching and review

`main` is protected and always releasable. All work happens on short-lived branches merged by pull request. `main` requires:

- At least **one approving review** from a engineer other than the author. Self-approval is blocked at the platform level.
- Two approvals for changes touching authentication, authorisation, tenant isolation, or cryptography. These paths ar

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[2] sdlc-policy — 4. Security in the pipeline — relevance 0.59

4. Security in the pipeline

Static analysis (Semgrep, CodeQL), dependency scanning (Snyk), IaC scanning (Checkov), and secret scanning (Gitleaks pre-commit plus GitHub push protection) all run on every pull request. A Critical or High dependency finding blocks the merge.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[3] sdlc-policy — 5. Dependency policy — relevance 0.57

5. Dependency policy

New third-party dependencies require review against the Third-Party Library Policy (KD-ENG-008). Lockfiles are committed. Renovate opens automated upgrade pull requests weekly; security patches are auto-merged when CI is green and the change is a patch-level bump.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[4] sdlc-policy — 7. Separation of duties — relevance 0.54

7. Separation of duties

Engineers cannot deploy their own change to production without the automated pipeline: no human has the ability to push a container image to the production registry directly. The deployment role is held by the CI service identity, which authenticates through OIDC and holds no long-lived credentials.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[5] sdlc-policy — 3. Testing requirements — relevance 0.52

3. Testing requirements

- Unit test coverage gate at **80%** on changed lines, enforced in CI.
- Integration tests run against ephemeral infrastructure provisioned per pull request.
- Tenant isolation tests run on every build: a suite of 84 assertions attempting

cross-tenant reads through every public API surface.
- Load tests before any release expected to change the performance profile.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

69. What is the governing law of your standard agreement?

legal · Q69 · Vendor Security Review row 70

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

70. Do you undergo independent audit of your security controls?

security · Q70 · Vendor Security Review row 71

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

71. Please confirm: Do you maintain Records of Processing Activities under Article 30?

legal · Q71 · Vendor Security Review row 72

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (7)

[1] gdpr-records-of-processing — GDPR Records of Processing Activities (Art. 30) — relevance 0.74

GDPR Records of Processing Activities (Art. 30)

****Document ID:**** KD-LEG-005 · ****Version:**** 3.0 · ****Owner:**** Priya Raghunathan, DPO

****Last updated:**** 20 January 2026 · ****Next review:**** 20 July 2026

Maintained under Art. 30(1) where Kestrel is controller and Art. 30(2) where Kestrel is processor. Available to supervisory authorities on request.

gs://attestor-505506-corporus/legal/gdpr-records-of-processing.txt

[2] gdpr-records-of-processing — Part A - Kestrel as Processor (Art. 30(2)) — relevance 0.68

Part A - Kestrel as Processor (Art. 30(2))

****Controller:**** each Kestrel customer, as identified in the applicable Order Form.

****Processor:**** Kestrel Data, Inc.

****DPO:**** Priya Raghunathan, `dpo@kestreldata.com`

| # | Processing activity | Categories of data subject | Categories of personal data | Transfers | Retention |

| ---|---|---|---|---|---|

| P1 | Hosting and operating the Kestrel Insig

gs://attestor-505506-corporus/legal/gdpr-records-of-processing.txt

[3] data-subject-rights-procedure — 9. Records — relevance 0.66

9. Records

Every request, its route, and its resolution date are recorded in the DSR register held by the DPO and retained for three years. The register is available to auditors and, in redacted form, to customers exercising their audit rights under the DPA.

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[4] data-processing-agreement — 1. Roles — relevance 0.66

1. Roles

Customer is ****Controller****. Kestrel Data, Inc. is ****Processor****. Where Customer is itself

a processor for its own customers, Kestrel is sub-processor and the same obligations apply down the chain.

Kestrel is **Controller** for a limited set of data it determines the purposes of: account administrator contact details, billing records, and product telemetry described in Annex 3.

gs://attestor-505506-corpus/legal/data-processing-agreement.txt

[5] gdpr-records-of-processing — Part B - Kestrel as Controller (Art. 30(1)) — relevance 0.65

Part B - Kestrel as Controller (Art. 30(1))

| # | Purpose | Lawful basis | Data subjects | Personal data | Retention |

| ---|---|---|---|---|

| C1 | Account administration | Art. 6(1)(b) contract | Customer administrators | Name, work email, job title | Term + 3 years |

| C2 | Billing and tax | Art. 6(1)(b), 6(1)(c) | Billing contacts | Name, email, VAT, payment token | 7 years |

| C3 | Pro

gs://attestor-505506-corpus/legal/gdpr-records-of-processing.txt

[6] dpia-register — 6. Review cadence — relevance 0.62

6. Review cadence

Each completed DPIA is reviewed annually, and immediately on a material change to the processing it covers. The 2026 review cycle for all four assessments completed on 16 January 2026, with no changes to the residual risk ratings.

gs://attestor-505506-corpus/legal/dpia-register.txt

[7] dpia-register — Data Protection Impact Assessment Register — relevance 0.60

Data Protection Impact Assessment Register

Document ID: KD-LEG-011 · **Version:** 1.9 · **Owner:** Priya Raghunathan, DPO

Approved: 16 January 2026 · **Next review:** 16 January 2027

Maps to: GDPR Articles 35, 36, 9, 8, 22

gs://attestor-505506-corpus/legal/dpia-register.txt

72. How many changes were deployed to production in the last year?

engineering · Q72 · Vendor Security Review row 73

In 2025, a total of 3,917 changes were processed across all change classes, comprising 3,847 Standard changes, 61 Normal changes, and 9 Emergency changes (‘change-management-procedure’, “1. Change classes”). Furthermore, Kestrel Data executed 1,412 production deployments throughout 2025 (‘service-operations-and-support’, “2. Scheduled maintenance”).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] sdlc-policy — 6. Release — relevance 0.66

6. Release

Releases are continuous: merge to `main` triggers a deployment to staging, an automated verification suite, and then a progressive rollout to production. Rollout is canary-based: 5% of traffic for 15 minutes, then 25%, then 100%, with automatic rollback on error-rate or latency regression.

Median lead time from merge to production in 2025 was **34 minutes**. Change failure rate w

gs://attestor-505506-corpus/engineering/sdlc-policy.txt

[2] change-management-procedure — 1. Change classes — relevance 0.66

1. Change classes

| Class | Definition | Approval | Example |

| ---|---|---|---|

| **Standard** | Pre-approved, low risk, automated | PR review + CI | Application code, config change through IaC |

| **Normal** | Material risk or customer-visible | PR review + Change Advisory sign-off | Schema migration, dependency major version |

| **Emergency** | Fixing an active SEV1/SEV2 | Retrospective with

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[3] service-operations-and-support — 2. Scheduled maintenance — relevance 0.63

2. Scheduled maintenance

The standard maintenance window is **Sundays 06:00–10:00 UTC**. Most changes do not use it: deployments are rolling and zero-downtime, and 2025 saw 1,412 production deployments with no customer-visible downtime.

Customers receive at least 7 days' notice of scheduled maintenance expected to be customer-affecting, and 30 days' notice where the change requires customer a

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[4] change-management-procedure — 4. Infrastructure changes — relevance 0.62

4. Infrastructure changes

Infrastructure is managed exclusively through Terraform in the `kestrel-infra` repository. Manual changes through the AWS console are prohibited in production; drift detection runs every 6 hours and raises a SEV3 on any unmanaged change. Drift was detected 4 times in 2025, all traced to AWS-initiated maintenance rather than human action.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[5] change-management-procedure — 2. Normal change requirements — relevance 0.62

2. Normal change requirements

A Normal change additionally requires a written rollback plan, a customer-impact assessment, and sign-off from the Change Advisory group (VP Engineering plus one SRE). Schema migrations must be backward compatible for at least one release, so that a rollback does not require a data migration.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

73. Describe your network segmentation approach.

security · Q73 · Vendor Security Review row 74

Kestrel Data enforces strict network segmentation primarily through AWS account isolation and multi-tier VPC design ('network-security-standard', Section 3. Segmentation):

- Account-Level Environment Isolation:** Each environment operates within a dedicated AWS account inside the AWS Organization ('kd-prod-us', 'kd-prod-eu', 'kd-staging', 'kd-dev', 'kd-security', and 'kd-shared-services'). Production and non-production environments have no VPC peering and no transit gateway routes between them, establishing an immutable account-level boundary rather than relying on editable firewall rules.
- Subnet Tiering:** Within each production VPC, network architecture is segmented into three distinct subnet tiers:
 - Public:** Restricted to load balancers only.
 - Private Application:** Houses application services.
 - Private Data:** Dedicated to data stores.
- Security Group Configuration:** Access controls between tiers are managed by security groups referencing other security groups directly rather than using broad CIDR blocks, preventing rules from silently expanding when IP addresses are reused.

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by SecurityAgent

Evidence (5)

[1] network-security-standard — 3. Segmentation — relevance 0.61

3. Segmentation

Each environment is a separate AWS account inside the AWS Organization ('kd-prod-us', 'kd-prod-eu', 'kd-staging', 'kd-dev', 'kd-security', 'kd-shared-services'). There is **no VPC peering and no transit gateway route between production and non-production**; the boundary is an account boundary, not a firewall rule that can be edited.

Within a production VPC there are three subnet t

gs://attestor-505506-corporus/security/network-security-standard.txt

[2] network-security-standard — 8. Wireless — relevance 0.58

8. Wireless

The Austin office wireless network is WPA3-Enterprise with certificate-based authentication for the corporate SSID and a fully segregated guest SSID that routes

straight to the internet. Neither network grants any access to production; production is reached the same way from the office as from a coffee shop, which is deliberate.

gs://attestor-505506-corporus/security/network-security-standard.txt

[3] network-security-standard — 5. Egress — relevance 0.56

5. Egress

Production workloads egress through NAT gateways with a domain allowlist enforced by AWS Network Firewall. The allowlist contains 23 destinations, each with a named owner and a business justification. An attempted connection to a destination outside the allowlist is blocked and alerted; 61 such alerts in 2025 were all traced to dependency mirrors being retired upstream.

gs://attestor-505506-corporus/security/network-security-standard.txt

[4] network-security-standard — Network Security Standard — relevance 0.55

Network Security Standard

Document ID: KD-SEC-016 · **Version:** 2.0 · **Owner:** Dana Whitfield, VP Engineering

Approved: 5 February 2026 · **Next review:** 5 February 2027

Maps to: SOC 2 CC6.6, CC6.7, CC7.1 · ISO 27001:2022 A.8.20, A.8.21, A.8.22, A.8.23

gs://attestor-505506-corporus/security/network-security-standard.txt

[5] network-security-standard — 6. Internal application access — relevance 0.54

6. Internal application access

There is no traditional VPN. Internal applications are published through Cloudflare Access with device posture and Okta identity required on every request. This is a zero-trust model in the practical sense: there is no network position that grants access, and being "inside" confers nothing.

gs://attestor-505506-corporus/security/network-security-standard.txt

74. Will EU customer data ever be processed outside the EEA, including backups?

legal · Q74 · Vendor Security Review row 75

For customers on the EU instance, customer content—including backups, replicated log ships, and customer-uploaded analytics datasets—never leaves the `eu-west-1` region and is not transferred or processed outside the EEA (Transfer Impact Assessment, Section 2: The transfers assessed; Section 5: Supplementary measures relied on). Infrastructure subprocessors process EU customer data exclusively within the EEA (Subprocessor List, Section: EU data residency). Certain limited categories of non-content operational and administrative data are transferred outside the EEA to the United States subject to Standard Contractual Clauses (SCCs) and supplementary technical measures (Transfer Impact Assessment, Section 2: The transfers assessed; Section 5: Supplementary measures relied on): - **EU tenant support access:** Account identity data and support correspondence accessed by Kestrel Data, Inc. in the US. - **Product telemetry aggregation:** Pseudonymised usage events transferred to Kestrel Data, Inc. in the US. - **Error monitoring:** Operational logs containing no customer content sent to Datadog, Inc. - **Transactional email:** Recipient email addresses processed by Twilio SendGrid.

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] transfer-impact-assessment — 5. Supplementary measures relied on — relevance 0.68

5. Supplementary measures relied on

Technical:

- Data residency by default** — EU customer content, including backups and the replicated log ship, never leaves `eu-west-1`.
- Encryption in transit** — TLS 1.3 (1.2 minimum) on every hop, including between Kestrel and each sub-processor.
- Encryption at rest** — AES-256-GCM with keys in AWS KMS. Keys for the EU instance are held i

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

[2] transfer-impact-assessment — 2. The transfers assessed — relevance 0.67

2. The transfers assessed

#	Transfer	Exporter	Importer	Country	Data
---	----------	----------	----------	---------	------

---	---	---	---	---	---
-----	-----	-----	-----	-----	-----

T1	EU tenant support access	Kestrel EU instance	Kestrel Data, Inc.	United States	Account identity data, support correspondence
----	--------------------------	---------------------	--------------------	---------------	---

T2	Product telemetry aggregation	Kestrel EU instance	Kestrel Data, Inc.	United States	Pseudonymised usage events
----	-------------------------------	---------------------	--------------------	---------------	----------------------------

T3	Error monitoring				
----	------------------	--	--	--	--

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

[3] subprocessor-list — EU data residency — relevance 0.64

EU data residency

Customers on the EU instance have their data processed exclusively within the EEA for the infrastructure subprocessors above. Kestrel does **not** currently offer a UK-only, Swiss-only, Canadian, or Australian data residency option. Requests for those are recorded but not committed to.

gs://attestor-505506-corporus/legal/subprocessor-list.txt

[4] subprocessor-list — Infrastructure subprocessors — relevance 0.64

Infrastructure subprocessors

Subprocessor	Purpose	Location of processing	Transfer mechanism	Engaged since
--------------	---------	------------------------	--------------------	---------------

---	---	---	---	---
-----	-----	-----	-----	-----

Amazon Web Services, Inc.	Cloud hosting, compute, storage, database	US (`us-east-1`, `us-west-2`); EU (`eu-west-1`, `eu-central-1`)		
---------------------------	---	---	--	--

SCCs + AWS DPA; EU data stays in EU	Mar 2019			
-------------------------------------	----------	--	--	--

Snowflake Inc.	Analytics data warehouse	US (AWS `us-east-1`);		
----------------	--------------------------	-----------------------	--	--

gs://attestor-505506-corporus/legal/subprocessor-list.txt

[5] subprocessor-list — Operational subprocessors — relevance 0.64

Operational subprocessors

Subprocessor	Purpose	Location	Transfer mechanism	Engaged since
--------------	---------	----------	--------------------	---------------

---	---	---	---	---
-----	-----	-----	-----	-----

Datadog, Inc.	Observability, logs, APM	US; EU site (`datadoghq.eu`) for EU customers	SCCs	Jun 2020
---------------	--------------------------	---	------	----------

Okta, Inc.	Identity and access management	US; EU cell for EU customers	SCCs	Feb 2021
------------	--------------------------------	------------------------------	------	----------

Twilio SendGrid	Transactional email delivery	US	SCCs	Ma
-----------------	------------------------------	----	------	----

gs://attestor-505506-corporus/legal/subprocessor-list.txt

75. Please confirm: Provide the results of your most recent disaster recovery test.

engineering · Q75 · Vendor Security Review row 76

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] backup-restore-procedure — 4. Test results — relevance 0.70

4. Test results

Restore is tested **quarterly**, and the test is a real restore, not a backup-listing check.

Quarter	Date	Duration	Assertions	Outcome
---------	------	----------	------------	---------

---	---	---	---	---
-----	-----	-----	-----	-----

Q1 2026	17 Jan 2026	2h 41m	1,240 / 1,240	Pass
---------	-------------	--------	---------------	------

Q4 2025	11 Oct 2025	3h 02m	1,238 / 1,240	Pass, 2 known-stale fixtures corrected
---------	-------------	--------	---------------	--

Q3 2025	19 Jul 2025	3h 20m	1,240 / 1,240	Pass
---------	-------------	--------	---------------	------

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[2] backup-restore-procedure — 5. Tenant-scoped restore — relevance 0.61

5. Tenant-scoped restore

A single customer can be restored without affecting others, by restoring to an isolated account and exporting that tenant rows back. This was exercised once in production, on 22 September 2025, at a customer request following an erroneous bulk delete on their side. Time to complete was 5 hours 10 minutes.

gs://attestor-505506-corporate-engineering/backup-restore-procedure.txt

[3] backup-restore-procedure — 3. Restore procedure — relevance 0.58

3. Restore procedure

1. Declare the restore scope: point in time, and whether tenant-scoped or full.
2. Provision an isolated restore account from the Terraform module `restore-target`.
3. Restore the RDS snapshot or PITR target into the isolated account.
4. Run the integrity suite: 1,240 assertions covering row counts, referential integrity, tenant isolation invariants, and known-value spo

gs://attestor-505506-corporate-engineering/backup-restore-procedure.txt

[4] backup-restore-procedure — Backup and Restore Procedure — relevance 0.57

Backup and Restore Procedure

Document ID: KD-ENG-004 · **Version:** 2.5 · **Owner:** Sofia Brenner, Head of IT
Approved: 29 January 2026 · **Maps to:** SOC 2 A1.2 · ISO 27001:2022 A.8.13

gs://attestor-505506-corporate-engineering/backup-restore-procedure.txt

[5] backup-restore-procedure — 1. What is backed up — relevance 0.55

1. What is backed up

| Asset | Method | Frequency | Retention |

|---|---|---|---|

| RDS PostgreSQL | Automated snapshots + WAL archiving (PITR) | Continuous | **35 days** |

| RDS logical dump | `pg\_dump` to S3, encrypted with a separate CMK | Daily 03:00 UTC | 90 days |

| S3 objects | Versioning + cross-region replication | Continuous | 90 days for non-current versions |

| Snowflake | Time Tr

gs://attestor-505506-corporate-engineering/backup-restore-procedure.txt

76. Are shared or team accounts permitted?

security · Q76 · Vendor Security Review row 77

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

77. How do you detect configuration drift in production infrastructure?

engineering · Q77 · Vendor Security Review row 78

Production infrastructure is managed exclusively through Terraform within the `kestrel-infra` repository, and manual changes via the AWS console are prohibited in production environments. Automated drift detection runs every 6 hours and automatically raises a SEV3 alert upon discovering any unmanaged change (`change-management-procedure`, Section 4, "Infrastructure changes").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (5)

[1] change-management-procedure — 4. Infrastructure changes — relevance 0.66

4. Infrastructure changes

Infrastructure is managed exclusively through Terraform in the `kestrel-infra` repository. Manual changes through the AWS console are prohibited in production; drift detection runs every 6 hours and raises a SEV3 on any unmanaged change. Drift was detected 4 times in 2025, all traced to AWS-initiated maintenance rather than human action.

gs://attestor-505506-corporate-engineering/change-management-procedure.txt

[2] change-management-procedure — Change Management Procedure — relevance 0.54

Change Management Procedure

Document ID: KD-ENG-002 · **Version:** 3.0 · **Owner:** Dana Whitfield, VP Engineering
Approved: 20 January 2026 · **Maps to:** SOC 2 CC8.1 · ISO 27001:2022 A.8.32

gs://attestor-505506-corporate-engineering/change-management-procedure.txt

[3] change-management-procedure — 1. Change classes — relevance 0.53

1. Change classes

| Class | Definition | Approval | Example |

|---|---|---|---|

| **Standard** | Pre-approved, low risk, automated | PR review + CI | Application code, config change through IaC |

| **Normal** | Material risk or customer-visible | PR review + Change Advisory sign-off | Schema migration, dependency major version |

| **Emergency** | Fixing an active SEV1/SEV2 | Retrospective with

gs://attestor-505506-corpus/engineering/change-management-procedure.txt

[4] change-management-procedure — 2. Normal change requirements — relevance 0.53

2. Normal change requirements

A Normal change additionally requires a written rollback plan, a customer-impact assessment, and sign-off from the Change Advisory group (VP Engineering plus one SRE). Schema migrations must be backward compatible for at least one release, so that a rollback does not require a data migration.

gs://attestor-505506-corpus/engineering/change-management-procedure.txt

[5] change-management-procedure — 5. Database changes — relevance 0.53

5. Database changes

Migrations run through Atlas with a plan-and-approve step. Destructive operations (column drop, table drop) require a two-phase deployment separated by at least one release: the column is first stopped being read, then dropped in a later release.

gs://attestor-505506-corpus/engineering/change-management-procedure.txt

78. For each applicable system: Do you undergo independent audit of your security controls?

security · Q78 · Vendor Security Review row 79

Yes. Kestrel Data undergoes regular independent audits and third-party assessments of its security controls across its in-scope systems: * **SOC 2 Type II Examination:** An annual independent SOC 2 Type II examination is performed by Prescient Assurance LLP covering the Security, Availability, and Confidentiality Trust Services Criteria ('risk-management-and-governance', '7. Internal audit'; 'soc2-control-matrix', 'SOC 2 Control Matrix'). The most recent report covers the period from 1 January to 31 December 2025 (issued 14 March 2026) with an unqualified opinion and no exceptions noted ('soc2-control-matrix', 'SOC 2 Control Matrix'; 'company-and-security-programme-overview', '3. Security programme in summary'). * **ISO/IEC 27001:2022 Certification & Surveillance Audits:** Kestrel maintains ISO 27001:2022 certification audited by BSI (Certificate 'IS-2025-44817', issued 22 September 2025 and valid through 21 September 2028), subject to regular surveillance audits ('risk-management-and-governance', '7. Internal audit'; 'company-and-security-programme-overview', '3. Security programme in summary'). The scope encompasses the information security management system supporting the development, operation, and support of the Kestrel Insight analytics platform, including supporting corporate functions ('company-and-security-programme-overview', '6. Scope of certification'). * **Independent Penetration Testing:** An external penetration test is conducted annually at minimum by Include Security (most recently completed 3–14 February 2026, engagement 'INSEC-2026-0219') ('risk-management-and-governance', '7. Internal audit'; 'vulnerability-management-policy', '4. Penetration testing'). In addition to external third-party audits, control operation is continuously monitored through 187 automated checks in Vanta ('risk-management-and-governance', '7. Internal audit'). Independent audit reports, certificates, and penetration test executive summaries are available under NDA ('company-and-security-programme-overview', '8. How to obtain evidence').

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (8)

[1] risk-management-and-governance — 7. Internal audit — relevance 0.64

7. Internal audit

Kestrel is too small to maintain a separate internal audit function, and says so rather than claiming one. Independent assurance comes from the annual SOC 2 Type II examination (Prescient Assurance LLP), the ISO 27001 surveillance audits (BSI), and the annual penetration test (Include Security). Control operation is monitored continuously by Vanta across 187 automated checks, wit

gs://attestor-505506-corpus/security/risk-management-and-governance.txt

[2] soc2-control-matrix — SOC 2 Control Matrix — relevance 0.64

SOC 2 Control Matrix

Document ID: KD-SEC-012 · **Version:** 2.1

Report period: 1 January - 31 December 2025 · **Report issued:** 14 March 2026

Auditor: Prescient Assurance LLP · **Opinion:** Unqualified, no exceptions noted

Trust Services Criteria in scope: Security, Availability, Confidentiality

Privacy and Processing Integrity are **not** in scope for the current report. Ke

gs://attestor-505506-corporus/security/soc2-control-matrix.txt

[3] risk-management-and-governance — Risk Management and Security Governance — relevance 0.64

Risk Management and Security Governance

Document ID: KD-SEC-018 · **Version:** 3.0 · **Owner:** Marcus Oyelaran, CISO

Approved: 26 January 2026 · **Next review:** 26 January 2027

Maps to: SOC 2 CC1.1, CC1.2, CC1.3, CC3.1, CC3.2, CC3.4 · ISO 27001:2022 A.5.1–A.5.4, Clauses 5–6, 9

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[4] company-and-security-programme-overview — 6. Scope of certification — relevance 0.64

6. Scope of certification

The ISO 27001 certificate scope statement reads: "The information security management system supporting the development, operation, and support of the Kestrel Insight analytics platform, including supporting corporate functions, at Austin, Texas and for remote personnel." The SOC 2 report covers the Security, Availability, and Confidentiality Trust Services Criteria. Pr

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[5] company-and-security-programme-overview — 8. How to obtain evidence — relevance 0.63

8. How to obtain evidence

The SOC 2 Type II report, the ISO 27001 certificate, the penetration test executive summary, and the standard DPA are available to customers and prospects under NDA through the account team, usually within two business days. The certificate and the trust page are available without an NDA.

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[6] vendor-risk-management-policy — 2. Onboarding requirements — relevance 0.62

2. Onboarding requirements

No Tier 1 vendor is engaged without: a current SOC 2 Type II report or ISO 27001 certificate reviewed by the Security team; an executed DPA including the 2021 EU Standard Contractual Clauses where personal data leaves the EEA; documented data flows and retention; and a recorded exit plan.

Reviews are recorded in Vanta with the reviewer, date, evidence reviewed, and

gs://attestor-505506-corporus/security/vendor-risk-management-policy.txt

[7] vulnerability-management-policy — 4. Penetration testing — relevance 0.60

4. Penetration testing

An independent penetration test is commissioned **annually** at minimum, and additionally before any significant architectural change. The most recent was performed by Include Security from 3 to 14 February 2026 (engagement INSEC-2026-0219). See the Penetration Test Executive Summary (KD-SEC-007).

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[8] company-and-security-programme-overview — 3. Security programme in summary — relevance 0.59

3. Security programme in summary

The programme is built on four commitments, each evidenced elsewhere in this corpus rather than asserted here:

1. **Independent verification.** SOC 2 Type II (Prescient Assurance LLP, report issued 14 March 2026 covering 1 January – 31 December 2025, **no exceptions**) and ISO 27001:2022 (BSI certificate 'IS-2025-44817', issued 22 September 2025, valid to 21

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

79. Have TLS 1.0 and TLS 1.1 been disabled across all endpoints?

security · Q79 · Vendor Security Review row 80

Yes. TLS 1.0 and TLS 1.1 were disabled across all endpoints on 12 April 2024 (*Encryption Standard*, Section 2, "Data in transit"). TLS 1.3 is the default for all external connections, with TLS 1.2 remaining enabled solely for a single legacy customer SFTP integration (INT-LEGACY-0004) scheduled for decommission in Q3 2026.

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by SecurityAgent

Evidence (5)

[1] encryption-standard — 2. Data in transit — relevance 0.68

2. Data in transit

****TLS 1.3**** is the default for all external connections. TLS 1.2 remains enabled solely for one legacy customer SFTP integration (INT-LEGACY-0004), scheduled for decommission in Q3 2026 and tracked as RISK-2025-0088. TLS 1.0 and 1.1 were disabled across all endpoints on 12 April 2024.

Cipher suites are restricted to the Mozilla Intermediate profile. HSTS is enabled with
,

gs://attestor-505506-corporus/security/encryption-standard.txt

[2] encryption-standard — 6. Post-quantum posture — relevance 0.59

6. Post-quantum posture

Kestrel completed a cryptographic inventory (``SEC-GOV/crypto-inventory``, 19 January 2026) as the first step toward post-quantum readiness. TLS connections terminated at Cloudflare already negotiate the hybrid X25519MLKEM768 key agreement where the client supports it. No migration commitment date has been set for internal services.

gs://attestor-505506-corporus/security/encryption-standard.txt

[3] encryption-standard — 5. Algorithm policy — relevance 0.57

5. Algorithm policy

Approved: AES-256-GCM, AES-256-CBC (legacy read paths only), RSA-2048 and above, ECDSA P-256 and P-384, SHA-256 and above, Argon2id and bcrypt (cost factor 12 or higher) for password hashing.

Prohibited: DES, 3DES, RC4, MD5 and SHA-1 for any security purpose, RSA below 2048 bits, and any custom cryptographic construction. Kestrel does not implement its own cryptographic

gs://attestor-505506-corporus/security/encryption-standard.txt

[4] encryption-standard — Encryption Standard — relevance 0.55

Encryption Standard

****Document ID:**** KD-SEC-003 · ****Version:**** 2.4 · ****Owner:**** Marcus Oyelaran, CISO

****Approved:**** 8 January 2026 · ****Next review:**** 8 January 2027

****Maps to:**** SOC 2 CC6.7 · ISO 27001:2022 A.8.24 · GDPR Art. 32(1)(a)

gs://attestor-505506-corporus/security/encryption-standard.txt

[5] encryption-standard — 1. Data at rest — relevance 0.54

1. Data at rest

All customer data at rest is encrypted using ****AES-256-GCM****. No customer data is stored unencrypted at any tier.

| Store | Mechanism | Key custody |

|---|---|---|

| Amazon RDS (PostgreSQL 16) | Storage-level encryption | AWS KMS CMK, per-environment |

| Amazon S3 | SSE-KMS | AWS KMS CMK, per-bucket |

| Snowflake | Native encryption, Tri-Secret Secure | Customer-managed key

gs://attestor-505506-corporus/security/encryption-standard.txt

80. In which jurisdictions is customer data processed?

legal · Q80 · Vendor Security Review row 81

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

81. What is the maximum age of a production compute node?

engineering · Q81 · Vendor Security Review row 82

Production compute node images are immutable and are recycled with a maximum age of 30 days rather than patched in place (infrastructure-architecture-overview, Section 3. Compute).

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (5)

[1] infrastructure-architecture-overview — 3. Compute — relevance 0.62

3. Compute

Amazon EKS (Kubernetes 1.31) with managed node groups spanning three availability zones. Workloads run as containers built from distroless base images, as non-root, with read-only root filesystems and dropped Linux capabilities. Pod Security Standards are enforced at the `restricted` level.

Node images are immutable; nodes are recycled with a maximum age of 30 days rather than patched in place.

gs://attestor-505506-corporate-engineering/infrastructure-architecture-overview.txt

[2] infrastructure-architecture-overview — 6. Network — relevance 0.56

6. Network

Private subnets for all compute and data. No public IP addresses on workload instances. Ingress is exclusively through Cloudflare, then an AWS Application Load Balancer, then the Istio ingress gateway. Egress is through NAT gateways with an allowlist for known destinations.

Security groups are managed in Terraform and default-deny. There are no `0.0.0.0/0` ingress rules in production.

gs://attestor-505506-corporate-engineering/infrastructure-architecture-overview.txt

[3] infrastructure-architecture-overview — 2. Account structure — relevance 0.53

2. Account structure

AWS Organizations with 9 accounts: `management`, `security-tooling`, `log-archive`, `shared-services`, `prod-us`, `prod-eu`, `staging`, `dev`, `sandbox`. Service Control Policies enforce guardrails at the Organization level, including mandatory EBS encryption, denial of root user actions, and denial of CloudTrail or GuardDuty disablement.

The `log-archive` account has no

gs://attestor-505506-corporate-engineering/infrastructure-architecture-overview.txt

[4] infrastructure-architecture-overview — 1. Cloud footprint — relevance 0.53

1. Cloud footprint

Kestrel runs on **Amazon Web Services**. There are two independent production instances:

| Instance | Region | Serves |

|---|---|---|

| US | `us-east-1` (3 AZs) | North America, and customers with no residency requirement |

| EU | `eu-west-1` (3 AZs) | EEA, UK, and Swiss customers electing EU residency |

Backup replication targets `us-west-2` and `eu-central-1` respectively.

gs://attestor-505506-corporate-engineering/infrastructure-architecture-overview.txt

[5] infrastructure-architecture-overview — 7. Observability — relevance 0.52

7. Observability

Datadog for metrics, logs, APM, and security monitoring. Distributed tracing uses W3C Trace Context propagated across all services. Every log line carries `tenant\_id` and `request\_id`.

gs://attestor-505506-corporate-engineering/infrastructure-architecture-overview.txt

82. Will you execute a Data Processing Agreement?

legal · Q82 · Vendor Security Review row 83

Yes. Kestrel Data provides and executes a Data Processing Agreement (DPA, KD-LEG-001) as part of every engagement where Kestrel processes Personal Data on behalf of the customer. The DPA—along with its Annex 2 technical measures (KD-LEG-003) and the Security Addendum (KD-LEG-005)—is incorporated directly into the Master Subscription Agreement and is not an optional add-on negotiated on a case-by-case basis (*Master Subscription Agreement Summary, Section 1: Structure*; *Data Processing Agreement Template*). Where applicable, the DPA also incorporates the 2021 EU Standard Contractual Clauses (SCCs), the UK International Data Transfer Addendum, and the Swiss Annex to support international data transfers (*Data Processing Agreement, Section 10: International transfers*).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (9)

[1] data-processing-agreement — 11. Liability — relevance 0.72

11. Liability

Liability under this DPA is subject to the limitations in the Master Subscription Agreement, save that nothing limits liability that cannot be limited under applicable data protection law.

gs://attestor-505506-corporate/legal/data-processing-agreement.txt

[2] data-processing-agreement — 5. Sub-processing — relevance 0.71

5. Sub-processing

Customer grants general authorisation for the sub-processors listed at `kestreldata.com/subprocessors`. Kestrel gives **30 days** notice before adding or replacing a sub-processor. Customer may object on reasonable data-protection grounds within that period; if the objection cannot be resolved, Customer may terminate the affected Service without penalty for the remainder of t

gs://attestor-505506-corporate/legal/data-processing-agreement.txt

[3] master-agreement-summary — Master Subscription Agreement — Summary of Key Terms — relevance 0.70

Master Subscription Agreement — Summary of Key Terms

Document ID: KD-LEG-014 · **Version:** 3.2 · **Owner:** Aaron Feldstein, General Counsel
Approved: 28 January 2026 · **Next review:** 28 January 2027
Maps to: SOC 2 CC2.3, CC9.1 · GDPR Article 28

*A summary for review purposes. The executed agreement governs; where this summary and an executed contract differ, the contract prevails.

gs://attestor-505506-corporate/legal/master-agreement-summary.txt

[4] data-processing-agreement — Data Processing Agreement (Template) — relevance 0.69

Data Processing Agreement (Template)

Document ID: KD-LEG-001 · **Version:** 5.1 · **Owner:** Aaron Feldstein, General Counsel
Effective: 1 February 2026 · **Supersedes:** v4.3 of 12 May 2025
Governing law: Delaware, USA, save where the SCCs specify otherwise

This DPA forms part of the Kestrel Data Master Subscription Agreement and applies where Kestrel processes Personal Data on

gs://attestor-505506-corporate/legal/data-processing-agreement.txt

[5] master-agreement-summary — 1. Structure — relevance 0.69

1. Structure

A Kestrel engagement comprises the Master Subscription Agreement, an Order Form, the Data

Processing Agreement (KD-LEG-001) with its Annex 2 technical measures (KD-LEG-003), and the Security Addendum (KD-LEG-005). The DPA and Security Addendum are incorporated by reference into every agreement; they are not optional extras negotiated case by case.

gs://attestor-505506-corporus/legal/master-agreement-summary.txt

[6] data-processing-agreement — 10. International transfers — relevance 0.67

10. International transfers

Where Personal Data is transferred out of the EEA, UK, or Switzerland, the parties enter into the ****2021 EU Standard Contractual Clauses**** (Commission Implementing Decision 2021/914), Module Two (Controller to Processor) or Module Three (Processor to Sub-processor) as applicable, incorporated by reference. The UK International Data Transfer Addendum and the Swiss An

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[7] master-agreement-summary — 9. Subcontracting — relevance 0.66

9. Subcontracting

Sub-processing is governed by the DPA: a public list (KD-LEG-006), ****30 days' notice**** before adding or replacing a sub-processor, a right to object on reasonable data protection grounds, and termination without penalty if the objection cannot be resolved.

gs://attestor-505506-corporus/legal/master-agreement-summary.txt

[8] data-processing-agreement — 2. Scope and duration — relevance 0.66

2. Scope and duration

Processing continues for the term of the Agreement plus the retention periods in Annex 2. Kestrel processes Personal Data only on documented instructions from Customer. The Agreement, this DPA, and Customer configuration of the Service constitute those instructions.

If Kestrel is required by Union or Member State law to process beyond those instructions, it will inform

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[9] gdpr-records-of-processing — Part A - Kestrel as Processor (Art. 30(2)) — relevance 0.66

Part A - Kestrel as Processor (Art. 30(2))

****Controller:**** each Kestrel customer, as identified in the applicable Order Form.

****Processor:**** Kestrel Data, Inc.

****DPO:**** Priya Raghunathan, `dpo@kestreldata.com`

| # | Processing activity | Categories of data subject | Categories of personal data | Transfers | Retention |

| ---|---|---|---|---|

| P1 | Hosting and operating the Kestrel Insig

gs://attestor-505506-corporus/legal/gdpr-records-of-processing.txt

83. Do engineers receive secure development training? Provide supporting evidence.

engineering · Q83 · Vendor Security Review row 84

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

84. For each applicable system: Describe your process for responding to government requests for customer data.

legal · Q84 · Vendor Security Review row 85

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (7)

[1] government-requests-and-transparency-report — Government Requests Policy and Transparency Report — relevance 0.68

Government Requests Policy and Transparency Report

Document ID: KD-LEG-012 · **Version:** 2.0 · **Owner:** Aaron Feldstein, General Counsel

Approved: 2 February 2026 · **Next review:** 2 February 2027

Maps to: GDPR Articles 48, 28(3)(a) · SOC 2 CC2.3 · ISO 27001:2022 A.5.5, A.5.31, A.5.34

gs://attestor-505506-corporus/legal/government-requests-and-transparency-report.txt

[2] government-requests-and-transparency-report — 1. Who may receive a request — relevance 0.68

1. Who may receive a request

All law enforcement, regulatory, and national security requests for customer data must be directed to the General Counsel at `legal@kestreldata.com`. No other person at Kestrel is authorised to accept service or to disclose customer data to a government authority.

Support, sales, and engineering personnel are trained to route any such approach to the General Counsel wi

gs://attestor-505506-corporus/legal/government-requests-and-transparency-report.txt

[3] government-requests-and-transparency-report — 2. How a request is handled — relevance 0.66

2. How a request is handled

1. **Log.** The request is recorded in the government request register on the day of receipt, with the requesting authority, the legal instrument, and the data sought.

2. **Validate.** The General Counsel, with outside counsel where warranted, assesses whether the instrument is valid, whether it is binding on Kestrel in the jurisdiction concerned, and whether i

gs://attestor-505506-corporus/legal/government-requests-and-transparency-report.txt

[4] government-requests-and-transparency-report — 6. Records — relevance 0.66

6. Records

The government request register is retained for ten years and is available to the auditors and, in redacted form, to a customer exercising audit rights. Retention is longer than the ordinary schedule deliberately: the value of this record is precisely that it goes back further than anyone's memory.

gs://attestor-505506-corporus/legal/government-requests-and-transparency-report.txt

[5] data-subject-rights-procedure — 9. Records — relevance 0.64

9. Records

Every request, its route, and its resolution date are recorded in the DSR register held by the DPO and retained for three years. The register is available to auditors and, in redacted form, to customers exercising their audit rights under the DPA.

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[6] government-requests-and-transparency-report — 5. Emergency disclosure requests — relevance 0.58

5. Emergency disclosure requests

An emergency request citing an imminent risk to life is escalated to the General Counsel immediately, at any hour, through the `legal-oncall` PagerDuty rotation. Disclosure in those circumstances is limited to what is necessary to address the emergency, is documented in the register, and the customer is notified afterwards unless prohibited. No emergency request ha

gs://attestor-505506-corporus/legal/government-requests-and-transparency-report.txt

[7] government-requests-and-transparency-report — 3. Transparency report — relevance 0.56

3. Transparency report

Kestrel publishes a transparency report annually at `trust.kestreldata.com/transparency`. Figures for the calendar year 2025:

| Category | Received | Data produced |

|---|---|---|

| US law enforcement — subpoena | 2 | 0 |

| US law enforcement — search warrant | 0 | 0 |

| US national security process (NSL, FISA) | **0** | 0 |

gs://attestor-505506-corporus/legal/government-requests-and-transparency-report.txt

85. Do you have a documented exit plan from your cloud provider?

engineering · Q85 · Vendor Security Review row 86

Yes, Kestrel Data maintains a documented **Cloud Exit and Portability Plan** (`KD-ENG-010`, approved by the VP of Engineering and aligned with SOC 2, ISO 27001:2022, and EBA/DORA requirements) (`cloud-exit-and-portability-plan`, "Cloud Exit and Portability Plan"). Key elements of the documented exit plan include: **Exit Triggers:** The plan is designed to be invoked under specific conditions, including sustained material degradation of AWS services, commercial breakdown or unacceptable pricing changes, regulatory instructions, or an uncompensable security failure at the provider (`cloud-exit-and-portability-plan`, "2. Exit triggers"). **Portability by Design:** The architecture minimizes lock-in by utilizing portable components such as standard Kubernetes manifests on EKS, OCI container images, Snowflake (available across major cloud providers), standard S3-compatible object storage APIs, PostgreSQL wire-compatible Aurora instances migratable via logical replication, and Terraform-defined infrastructure. In addition, critical edge services (Cloudflare) and identity management (Okta) are operated independently outside of AWS (`cloud-exit-and-portability-plan`, "3. Portability by design"). **Execution Timeline:** Based on tabletop exercises, the estimated migration timeline across five phases—covering landing zone setup, Terraform/CI/CD adjustments, data migration, KMS re-encryption, and parallel validation/cutover—is approximately 5 to 6 months (`cloud-exit-and-portability-plan`, "4. Estimated exit timeline"). **Customer Continuity and Data Residency:** Migrations are executed instance-by-instance, cut over separately between EU and US environments to ensure strict adherence to data residency commitments (e.g., EU tenant data moves directly to an EU region of the target provider). Customers are provided a minimum of 90 days' advance notice for planned provider transitions and maintain continuous data export rights throughout (`cloud-exit-and-portability-plan`, "5. Customer-facing continuity during an exit").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (6)

[1] `cloud-exit-and-portability-plan` — Cloud Exit and Portability Plan — relevance 0.76

Cloud Exit and Portability Plan

Document ID: KD-ENG-010 · **Version:** 1.7 · **Owner:** Dana Whitfield, VP Engineering

Approved: 30 January 2026 · **Next review:** 30 January 2027

Maps to: SOC 2 A1.2, CC9.1 · ISO 27001:2022 A.5.19, A.5.21, A.5.30 · EBA/DORA-aligned

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[2] `cloud-exit-and-portability-plan` — 2. Exit triggers — relevance 0.72

2. Exit triggers

The plan would be invoked on: sustained material degradation of AWS service, a commercial breakdown or unacceptable pricing change, a regulatory instruction, or a security failure at the provider that could not be compensated for.

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[3] `cloud-exit-and-portability-plan` — 4. Estimated exit timeline — relevance 0.68

4. Estimated exit timeline

The tabletop exercise produced these estimates, which are planning figures rather than commitments:

| Phase | Work | Estimate |

|---|---|---|

| 1 | Target selection, landing zone, network and identity foundation | 4–6 weeks |

| 2 | Terraform provider rewrite, CI/CD retargeting | 6–8 weeks |

| 3 | Data migration — Snowflake region move, PostgreSQL logical replication, ob

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[4] `cloud-exit-and-portability-plan` — 5. Customer-facing continuity during an exit — relevance 0.67

5. Customer-facing continuity during an exit

An exit would be executed instance by instance, with EU and US cut over separately, and ****data residency commitments would be honoured throughout****: an EU tenant would move to an EU region of the target provider, never transiting a US region. Customers would be given a minimum of 90 days' notice of a planned provider change and would retain their export

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[5] cloud-exit-and-portability-plan — 3. Portability by design — relevance 0.66

3. Portability by design

The architecture is deliberately biased toward portable components, and the exceptions are listed rather than glossed over:

| Layer | Technology | Portability |

|---|---|---|

| Compute | Kubernetes (EKS) | High — standard manifests, no EKS-specific APIs in workloads |

| Container images | OCI in ECR | High — registry is a copy operation |

| Data warehouse | Snowflake | Hi

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[6] cloud-exit-and-portability-plan — 6. Customer's own exit from Kestrel — relevance 0.60

6. Customer's own exit from Kestrel

Distinct from Kestrel's exit from AWS, and more likely to be what a reviewer is asking about. A customer may leave at any time and take their data with them:

* full self-service export of all customer-uploaded datasets in their original format, plus account identity data and usage events as JSON or CSV;

* the same through the public API, with no volume charge

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

86. Have you appointed an EU representative under Article 27?

legal · Q86 · Vendor Security Review row 87

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

87. What is your Recovery Point Objective?

engineering · Q87 · Vendor Security Review row 88

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

88. What is your remediation SLA for Critical severity vulnerabilities?

security · Q88 · Vendor Security Review row 89

According to our ****Vulnerability Management Policy (§1. Remediation SLAs)****, Kestrel Data enforces a remediation SLA of ****7 days**** for Critical severity vulnerabilities (CVSS 9.0–10.0). Severity is determined using the CVSS v3.1 base score, adjusted for exploitability and exposure, with internet-facing findings automatically escalated by one level. In 2025, Kestrel achieved 100% compliance with this SLA across all 11 identified Critical findings.

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] vulnerability-management-policy — 1. Remediation SLAs — relevance 0.78

1. Remediation SLAs

Severity is assigned from CVSS v3.1 base score, adjusted for exploitability and exposure. Internet-facing findings are escalated one level.

Severity	CVSS	Remediation SLA	Measured 2025 compliance
Critical	9.0-10.0	**7 days**	100% (11 of 11)
High	7.0-8.9	**30 days**	96% (74 of 77)
Medium	4.0-6.9	**90 days**	91%

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[2] vulnerability-management-policy — 6. Exceptions — relevance 0.71

6. Exceptions

A finding that cannot be remediated within SLA requires a documented exception approved by the CISO, with a compensating control and an expiry date not exceeding 180 days.

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[3] cloud-security-posture-standard — 6. Handling a vulnerability with no upstream fix — relevance 0.66

6. Handling a vulnerability with no upstream fix

Where no upstream fix exists, the finding is recorded in the risk register with a named owner and the mitigation is chosen from: removing the affected component, blocking the attack path at the network or WAF layer, or applying a vendored patch maintained by Kestrel (see KD-ENG-007 §7). The vulnerability is re-reviewed weekly until an upstream fix
|

gs://attestor-505506-corporus/security/cloud-security-posture-standard.txt

[4] incident-response-runbook — 1. Severity definitions — relevance 0.66

1. Severity definitions

| Sev | Definition | Page | Exec notify |

|---|---|---|---|

| **SEV1** | Confirmed unauthorised access to customer production data, or full platform outage | Immediate, 24/7 | CEO + CISO within 30 min |

| **SEV2** | Suspected compromise, partial outage affecting more than 10% of tenants, or confirmed data integrity fault | Immediate, 24/7 | CISO within 1 hour |

| **SEV3

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[5] incident-response-runbook — 8. Post-incident review — relevance 0.66

8. Post-incident review

Every SEV1 and SEV2 requires a blameless post-incident review within 5 business days, published internally, with action items tracked to closure in Jira. Reviews are shared with affected customers on request.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

89. Describe your approach to environmental sustainability and carbon reporting.

unassigned · Q89 · Vendor Security Review row 90

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

90. How much notice is given before scheduled maintenance?

engineering · Q90 · Vendor Security Review row 91

Customers receive at least 7 days' advance notice for any scheduled maintenance expected to be customer-affecting, and at least 30 days' notice when a change requires customer action (Service Operations, Maintenance and Support, Section 2: Scheduled maintenance). Notifications are delivered via email to tenant administrators and posted on the status page. In the case of emergency maintenance (such as an urgent security fix), notifications are sent as soon as the change is scheduled. Additionally, breaking API changes follow a deprecation policy requiring a minimum of 12 months' advance notice (Change Management Procedure, Section 6: Customer notification).

Evidence (5)

[1] service-operations-and-support — 2. Scheduled maintenance — relevance 0.67

2. Scheduled maintenance

The standard maintenance window is **Sundays 06:00–10:00 UTC**. Most changes do not use it: deployments are rolling and zero-downtime, and 2025 saw 1,412 production deployments with no customer-visible downtime.

Customers receive at least 7 days' notice of scheduled maintenance expected to be customer-affecting, and 30 days' notice where the change requires customer a

gs://attestor-505506-corpus/engineering/service-operations-and-support.txt

[2] service-operations-and-support — Service Operations, Maintenance and Support — relevance 0.60

Service Operations, Maintenance and Support

Document ID: KD-ENG-009 · **Version:** 2.2 · **Owner:** Dana Whitfield, VP Engineering

Approved: 23 January 2026 · **Next review:** 23 January 2027

Maps to: SOC 2 A1.1, A1.2, CC7.3, CC8.1 · ISO 27001:2022 A.5.29, A.8.6, A.8.32

gs://attestor-505506-corpus/engineering/service-operations-and-support.txt

[3] change-management-procedure — 6. Customer notification — relevance 0.60

6. Customer notification

Customers are notified at least **7 days** in advance of any change expected to cause degraded service or to require action on their part. Breaking API changes follow the deprecation policy: minimum **12 months** notice, with the deprecated version remaining available throughout.

gs://attestor-505506-corpus/engineering/change-management-procedure.txt

[4] change-management-procedure — Change Management Procedure — relevance 0.57

Change Management Procedure

Document ID: KD-ENG-002 · **Version:** 3.0 · **Owner:** Dana Whitfield, VP Engineering

Approved: 20 January 2026 · **Maps to:** SOC 2 CC8.1 · ISO 27001:2022 A.8.32

gs://attestor-505506-corpus/engineering/change-management-procedure.txt

[5] change-management-procedure — 3. Emergency changes — relevance 0.57

3. Emergency changes

An Emergency change may bypass the Change Advisory step but never bypasses code review or CI. The Incident Commander authorises it, and a retrospective record is filed within one business day covering what changed, why the normal path was bypassed, and whether the change should be reworked.

All 9 Emergency changes in 2025 have completed retrospectives on file.

gs://attestor-505506-corpus/engineering/change-management-procedure.txt

91. For each applicable system: How do workloads authenticate to cloud services?

engineering · Q91 · Vendor Security Review row 92

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (17)

[1] infrastructure-architecture-overview — 2. Account structure — relevance 0.62

2. Account structure

AWS Organizations with 9 accounts: `management`, `security-tooling`, `log-archive`, `shared-services`, `prod-us`, `prod-eu`, `staging`, `dev`, `sandbox`. Service Control Policies enforce guardrails at the Organization level, including mandatory EBS encryption, denial of root user actions, and denial of CloudTrail or GuardDuty disablement.

The `log-archive` account has no

gs://attestor-505506-corporis/engineering/infrastructure-architecture-overview.txt

[2] secrets-management-standard — 4. Runtime access — relevance 0.61

4. Runtime access

Workloads obtain secrets at runtime through the AWS Secrets Manager CSI driver, mounted as in-memory `tmpfs` volumes. Secrets are never written to disk, never baked into container images, and never passed as environment variables where they could leak into a crash dump or a process listing.

gs://attestor-505506-corporis/engineering/secrets-management-standard.txt

[3] secrets-management-standard — 1. Where secrets live — relevance 0.59

1. Where secrets live

| Secret class | Store | Rotation |

---|---|---

| Application secrets, API keys | AWS Secrets Manager | 90 days, automated |

| Database credentials | AWS Secrets Manager with RDS-managed rotation | 30 days, automated |

| Encryption keys | AWS KMS (key material never leaves KMS) | Annual, automated |

| TLS certificates | AWS Certificate Manager | Automatic before expiry

gs://attestor-505506-corporis/engineering/secrets-management-standard.txt

[4] secrets-management-standard — 2. What is prohibited — relevance 0.59

2. What is prohibited

- Secrets in source code, including test fixtures, comments, and commit history.
- Secrets in environment files committed to a repository.
- Secrets in CI logs, container image layers, or Terraform state in plaintext.
- Long-lived static AWS access keys. The last was decommissioned 17 November 2024, and creation of a new one triggers an hourly detection that pages the o

gs://attestor-505506-corporis/engineering/secrets-management-standard.txt

[5] data-flow-and-shared-responsibility — 6. Where processing occurs — relevance 0.59

6. Where processing occurs

Processing occurs in AWS `us-east-1` (US instance) and AWS `eu-west-1` (EU instance), by personnel located in the United States, the European Union, the United Kingdom, and Canada, under the access controls in KD-SEC-002. **No processing occurs outside the stated regions**, and no support is subcontracted to a third-party provider in another jurisdiction.

gs://attestor-505506-corporis/engineering/data-flow-and-shared-responsibility.txt

[6] data-flow-and-shared-responsibility — 1. Data flow, end to end — relevance 0.59

1. Data flow, end to end

1. **Ingress.** A customer's browser or API client resolves `app.kestreldata.com` or `api.kestreldata.com` to Cloudflare, which terminates TLS 1.3 (1.2 minimum) and applies WAF and rate limiting.
2. **Instance selection.** DNS and tenant routing send the request to the instance chosen at contract signature: `us-east-1` or `eu-west-1`. **A tenant's requests never c**

gs://attestor-505506-corporis/engineering/data-flow-and-shared-responsibility.txt

[7] api-and-integration-standard — API, Authentication and Integration Standard — relevance 0.58

API, Authentication and Integration Standard

Document ID: KD-ENG-005 · **Version:** 2.6 · **Owner:** Dana Whitfield, VP Engineering

Approved: 21 January 2026 · **Next review:** 21 January 2027

Maps to: SOC 2 CC6.1, CC6.6, CC8.1 · ISO 27001:2022 A.5.15, A.8.5, A.8.26

gs://attestor-505506-corporis/engineering/api-and-integration-standard.txt

[8] api-and-integration-standard — 2. Customer control of API credentials — relevance 0.58

2. Customer control of API credentials

Customers create, scope, rotate, and revoke their own API credentials from the tenant administrator console, without involving Kestrel support. A credential can be limited to read-only, to specific datasets, and to a source IP allowlist. Revocation takes effect

within 30 seconds across all regions.

****Kestrel support cannot recover a customer API key.**** K

gs://attestor-505506-corporus/engineering/api-and-integration-standard.txt

[9] service-operations-and-support — Service Operations, Maintenance and Support — relevance 0.58

Service Operations, Maintenance and Support

****Document ID:**** KD-ENG-009 · ****Version:**** 2.2 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 23 January 2026 · ****Next review:**** 23 January 2027

****Maps to:**** SOC 2 A1.1, A1.2, CC7.3, CC8.1 · ISO 27001:2022 A.5.29, A.8.6, A.8.32

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[10] sdlc-policy — 5. Dependency policy — relevance 0.58

5. Dependency policy

New third-party dependencies require review against the Third-Party Library Policy (KD-ENG-008). Lockfiles are committed. Renovate opens automated upgrade pull requests weekly; security patches are auto-merged when CI is green and the change is a patch-level bump.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[11] sdlc-policy — Secure Software Development Lifecycle Policy — relevance 0.58

Secure Software Development Lifecycle Policy

****Document ID:**** KD-ENG-001 · ****Version:**** 4.1 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 20 January 2026 · ****Next review:**** 20 January 2027

****Maps to:**** SOC 2 CC8.1 · ISO 27001:2022 A.8.25-A.8.31

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[12] infrastructure-architecture-overview — 3. Compute — relevance 0.58

3. Compute

Amazon EKS (Kubernetes 1.31) with managed node groups spanning three availability zones. Workloads run as containers built from distroless base images, as non-root, with read-only root filesystems and dropped Linux capabilities. Pod Security Standards are enforced at the `restricted` level.

Node images are immutable; nodes are recycled with a maximum age of 30 days rather than pa

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[13] infrastructure-architecture-overview — 7. Observability — relevance 0.57

7. Observability

Datadog for metrics, logs, APM, and security monitoring. Distributed tracing uses W3C Trace Context propagated across all services. Every log line carries `tenant\_id` and `request\_id`.

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[14] infrastructure-architecture-overview — 6. Network — relevance 0.57

6. Network

Private subnets for all compute and data. No public IP addresses on workload instances. Ingress is exclusively through Cloudflare, then an AWS Application Load Balancer, then the Istio ingress gateway. Egress is through NAT gateways with an allowlist for known destinations.

Security groups are managed in Terraform and default-deny. There are no `0.0.0.0/0` ingress rules in produc

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[15] secrets-management-standard — Secrets Management Standard — relevance 0.57

Secrets Management Standard

****Document ID:**** KD-ENG-006 · ****Version:**** 2.1 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 22 January 2026 · ****Maps to:**** SOC 2 CC6.1 · ISO 27001:2022 A.8.24

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

[16] secrets-management-standard — 6. Customer-issued API credentials — relevance 0.56

6. Customer-issued API credentials

API keys issued to customers are stored as Argon2id hashes; Kestrel cannot recover the plaintext of a customer API key and will not do so on request. Keys are displayed once at creation. Customers can create, scope, and revoke keys through the console, and each key carries a last-used timestamp so stale keys are visible.

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

[17] infrastructure-architecture-overview — Infrastructure Architecture Overview — relevance 0.52

Infrastructure Architecture Overview

****Document ID:**** KD-ENG-003 · ****Version:**** 3.4 · ****Owner:**** Dana Whitfield, VP Engineering
****Last updated:**** 5 February 2026 · ****Classification:**** Confidential, NDA required

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

92. Do you support SCIM user provisioning?

security · Q92 · Vendor Security Review row 93

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] access-control-standard — 6. Joiners, movers, leavers — relevance 0.56

6. Joiners, movers, leavers

Joiners are provisioned via Okta Lifecycle Management from Rippling (HRIS); no access is granted before the background check clears. Movers have entitlements recalculated on role change, with the previous role revoked within 1 business day. Leavers have all access revoked automatically on the HRIS termination event: the target is 1 hour, and the measured median for

gs://attestor-505506-corporus/security/access-control-standard.txt

[2] access-control-standard — 3. Role-based access — relevance 0.56

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix (`SEC-GOV/access-matrix`), which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is just-in-time.

gs://attestor-505506-corporus/security/access-control-standard.txt

[3] access-control-standard — 1. Identity provider — relevance 0.54

1. Identity provider

All Kestrel Data systems authenticate through Okta (tenant `kestreldata.okta.com`). Local accounts on production systems are prohibited except for two documented break-glass accounts held in a sealed 1Password vault, whose use triggers a PagerDuty alert to the CISO. Both break-glass credentials were last rotated on 3 January 2026 and last used on 14 August 2025 during the

gs://attestor-505506-corporus/security/access-control-standard.txt

[4] access-control-standard — 8. Service accounts and machine identity — relevance 0.54

8. Service accounts and machine identity

Workloads authenticate using short-lived credentials: AWS IAM Roles for Service Accounts (IRSA) in EKS, and Workload Identity Federation for GCP components. Long-lived static access keys are prohibited; the last was decommissioned on 17 November 2024. Automated detection for newly created static keys runs hourly and pages the on-call SRE.

gs://attestor-505506-corporus/security/access-control-standard.txt

[5] access-control-standard — 9. Password requirements — relevance 0.53

9. Password requirements

Where a password is used, minimum length is 14 characters, checked against the Have I Been Pwned breached-password corpus at set time. Rotation is not forced on a schedule, in line with NIST SP 800-63B guidance; rotation is forced on evidence of compromise.

gs://attestor-505506-corporus/security/access-control-standard.txt

93. Please confirm: How do you detect prohibited licences?

engineering · Q93 · Vendor Security Review row 94

License compliance is checked automatically in CI on every pull request using FOSSA. If a prohibited license—such as GPL-2.0, GPL-3.0, AGPL-1.0, AGPL-3.0, SSPL, BUSL, Commons Clause, or any license without a clear grant—is detected, the build automatically fails (`third-party-library-policy`, Section 2. Licence policy). Additionally, when proposing a new direct dependency, engineers must document and verify the license against the allowlist during pull request review (`third-party-library-policy`, Section 1. Adding a dependency).

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (5)

[1] third-party-library-policy — 2. Licence policy — relevance 0.60

2. Licence policy

Allowed: MIT, BSD-2-Clause, BSD-3-Clause, Apache-2.0, ISC, Python Software Foundation, Unlicense, CC0.

Requires legal review: MPL-2.0, LGPL-2.1, LGPL-3.0, EPL-2.0.

Prohibited: GPL-2.0, GPL-3.0, AGPL-1.0, AGPL-3.0, SSPL, BUSL, Commons Clause, and any licence without a clear grant. AGPL and SSPL are prohibited because Kestrel distributes a network service.

L

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[2] third-party-library-policy — 1. Adding a dependency — relevance 0.54

1. Adding a dependency

A new direct dependency requires a pull request that documents:

1. Why an existing dependency or the standard library is insufficient.
2. The licence, checked against the allowlist below.
3. Maintenance signal: last release date, open critical issues, number of maintainers.
4. Transitive dependency count added.

Review is by any engineer other than the author. Depend

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[3] third-party-library-policy — 6. Unmaintained dependencies — relevance 0.50

6. Unmaintained dependencies

A dependency with no release in 24 months and no active maintainer is flagged for replacement. Three such dependencies were identified in the January 2026 review, all scheduled for replacement by Q3 2026.

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[4] third-party-library-policy — 7. Internal forks — relevance 0.50

7. Internal forks

Forking a third-party library requires VP Engineering approval and creates an obligation to track upstream security advisories manually. Kestrel currently maintains **zero** internal forks, deliberately.

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[5] third-party-library-policy — Third-Party Library Policy — relevance 0.49

Third-Party Library Policy

Document ID: KD-ENG-008 · **Version:** 1.4 · **Owner:** Dana Whitfield, VP Engineering

gs://attestor-505506-corporate-engineering/third-party-library-policy.txt

94. Do Kestrel personnel routinely access customer production data? Provide supporting evidence.

security · Q94 · Vendor Security Review row 95

Kestrel personnel do not access customer production data as a matter of routine. Any access required for support purposes is strictly controlled and requires explicit, per-incident customer authorization recorded in Zendesk. Furthermore, this access is restricted specifically to the relevant tenant and automatically expires after 24 hours. As evidence of this control in practice, between 1 January and 31 December 2025, there were 19 such authorized accesses across 7 customers, all of which are evidenced in Kestrel's SOC 2 Type II report under control CC6.1 (*Access Control Standard*, Section 5, "Customer data access").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] access-control-standard — 5. Customer data access — relevance 0.81

5. Customer data access

Kestrel personnel do not access customer production data as a matter of routine. Access for support purposes requires explicit per-incident customer authorisation recorded in Zendesk, is limited to the specific tenant, and expires after 24 hours.

Between 1 January and 31 December 2025 there were 19 such authorised accesses across 7 customers, each evidenced in the SOC

gs://attestor-505506-corporate-engineering/security/access-control-standard.txt

[2] incident-response-runbook — 4. Customer notification commitments — relevance 0.76

4. Customer notification commitments

These are contractual and are reproduced in the DPA (KD-LEG-001) and the Security Addendum (KD-LEG-008):

- ****Personal data breach**** - affected customers notified without undue delay and in any event ****within 72 hours**** of Kestrel confirming the breach.
- ****Confirmed unauthorised access to customer production data**** - affected customers notified ****within 24 hours****

gs://attestor-505506-corporate-engineering/security/incident-response-runbook.txt

[3] information-security-policy — 9. Incident response — relevance 0.76

9. Incident response

Security incidents are handled under the Incident Response Runbook (KD-SEC-005). Kestrel commits contractually to notifying affected customers within 72 hours of confirming a personal data breach, and within 24 hours for incidents involving confirmed unauthorised access to customer production data.

gs://attestor-505506-corporate-engineering/security/information-security-policy.txt

[4] information-security-policy — 1. Purpose and scope — relevance 0.74

1. Purpose and scope

This policy establishes how Kestrel Data, Inc. ("Kestrel") protects the confidentiality, integrity, and availability of information belonging to Kestrel and to customers of the Kestrel Insight platform.

It applies to all 187 employees and to all 24 contractors engaged as of 1 February 2026, to every system that processes Kestrel or customer data, and to all facilities including

gs://attestor-505506-corporate-engineering/security/information-security-policy.txt

[5] physical-and-environmental-security — 1. Production infrastructure — relevance 0.74

1. Production infrastructure

Kestrel Data operates ****no owned or leased data centre****. All production infrastructure runs in AWS: `us-east-1` for the US instance and `eu-west-1` for the EU instance.

Physical and environmental controls for those facilities — perimeter security, biometric access, CCTV, fire suppression, power redundancy, environmental monitoring, and media destruction — are AWS's re

gs://attestor-505506-corpus/security/physical-and-environmental-security.txt

95. Are you self-certified under the EU-US Data Privacy Framework? Provide supporting evidence.

legal · Q95 · Vendor Security Review row 96

Kestrel is not currently self-certified under the EU-US Data Privacy Framework (*standard-contractual-clauses-summary*, "3. EU-US Data Privacy Framework"; *transfer-impact-assessment*, "3. Transfer mechanism"). Instead, international data transfers rely on the Standard Contractual Clauses (SCCs) alongside technical, organizational, and contractual supplementary measures (*standard-contractual-clauses-summary*, "3. EU-US Data Privacy Framework"; *transfer-impact-assessment*, "3. Transfer mechanism"). Specifically: - The 2021 Standard Contractual Clauses, Module Two (controller to processor), apply between the customer and Kestrel, and Module Three (processor to sub-processor) applies between Kestrel and its US sub-processors (*transfer-impact-assessment*, "3. Transfer mechanism"). - The UK International Data Transfer Addendum is incorporated for UK data exports, and for Switzerland, the SCCs are applied with the adaptations published by the Swiss FDPIC (*transfer-impact-assessment*, "3. Transfer mechanism"). While self-certification under the EU-US Data Privacy Framework is under evaluation, no commitment date has been set (*standard-contractual-clauses-summary*, "3. EU-US Data Privacy Framework").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] standard-contractual-clauses-summary — 3. EU-US Data Privacy Framework — relevance 0.69

3. EU-US Data Privacy Framework

Kestrel is **not** currently self-certified under the EU-US Data Privacy Framework. Transfers rely on the SCCs plus the supplementary measures below. Self-certification is under evaluation but no commitment date has been set. This is stated plainly rather than implied.

gs://attestor-505506-corpus/legal/standard-contractual-clauses-summary.txt

[2] transfer-impact-assessment — 3. Transfer mechanism — relevance 0.63

3. Transfer mechanism

The 2021 **Standard Contractual Clauses, Module Two (controller to processor)** apply between the customer and Kestrel, and **Module Three (processor to sub-processor)** between Kestrel and its US sub-processors. The **UK International Data Transfer Addendum** is incorporated for UK exports, and for Switzerland the SCCs are applied with the adaptations published by the Swiss

gs://attestor-505506-corpus/legal/transfer-impact-assessment.txt

[3] transfer-impact-assessment — 5. Supplementary measures relied on — relevance 0.60

5. Supplementary measures relied on Technical:

- Data residency by default** — EU customer content, including backups and the replicated log ship, never leaves `eu-west-1`.
- Encryption in transit** — TLS 1.3 (1.2 minimum) on every hop, including between Kestrel and each sub-processor.
- Encryption at rest** — AES-256-GCM with keys in AWS KMS. Keys for the EU instance are held i

gs://attestor-505506-corpus/legal/transfer-impact-assessment.txt

[4] transfer-impact-assessment — 6. Conclusion — relevance 0.59

6. Conclusion

For T1 and T2 the residual risk to data subjects is assessed as **low**: the data transferred is limited, pseudonymised where possible, encrypted with keys held outside the importer's jurisdiction, and unaccompanied by any customer content. For T3 and T4 the residual risk is **low** on the same basis, with the additional point that no customer

content is transferred at all.

The asse

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

[5] dpia-register — 7. Availability — relevance 0.59

7. Availability

DPIA summaries are provided to customers under NDA on request through the account team.

The full assessments are not distributed, because they contain architectural detail that is itself Confidential, but the DPO will walk a customer's privacy team through an assessment on a call.

gs://attestor-505506-corporus/legal/dpia-register.txt

96. Provide evidence of your most recent user access review. If not, describe compensating controls.

security · Q96 · Vendor Security Review row 97

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] risk-management-and-governance — 9. Exceptions — relevance 0.65

9. Exceptions

Exceptions to policy require: a written business justification, a compensating control, CISO approval, and an expiry date no later than 90 days out. Exceptions above residual score 12 additionally require Security Steering Group approval. Two exceptions were open as of 1 February 2026.

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[2] access-control-standard — 7. Access reviews — relevance 0.65

7. Access reviews

Quarterly user access reviews cover all production systems, the AWS Organization, Snowflake, GitHub, and Okta itself. Reviews are performed by the system owner and attested in Vanta. The Q4 2025 review completed on 12 January 2026 and removed 23 entitlements, of which 9 were stale contractor accesses.

gs://attestor-505506-corporus/security/access-control-standard.txt

[3] soc2-control-matrix — Common Criteria — relevance 0.64

Common Criteria

| Control | Description | Evidence | Test result |

|---|---|---|---|

| CC1.1 | Board oversight of security; Audit and Risk Committee meets quarterly | Committee minutes, 4 meetings in 2025 | No exceptions |

| CC1.4 | Security awareness training at hire and annually | Curricula completion records, 100% of active staff | No exceptions |

| CC2.1 | Internal communication of securit

gs://attestor-505506-corporus/security/soc2-control-matrix.txt

[4] information-security-policy — 10. Exceptions — relevance 0.63

10. Exceptions

Exceptions to this policy require written approval from the CISO, a documented compensating control, and an expiry date not exceeding 180 days. Four exceptions are open as of 11 February 2026, all tracked in Vanta and all with expiry dates before 30 September 2026.

gs://attestor-505506-corporus/security/information-security-policy.txt

[5] risk-management-and-governance — 8. Policy management — relevance 0.63

8. Policy management

All security policies carry a document ID, a version, a named owner, an approval date, and a review date. Policies are reviewed at least annually and on material change. The 2026 review cycle covered 14 policies between 8 January and 12 February 2026; three were revised, and the changes were communicated at the February all-hands and through the annual acknowledgement cycle.

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

97. For each applicable system: Provide an overview of your information security programme.

security · Q97 · Vendor Security Review row 98

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (15)

[1] company-and-security-programme-overview — Company and Security Programme Overview — relevance 0.74

Company and Security Programme Overview

Document ID: KD-SEC-021 · **Version:** 4.2 · **Owner:** Marcus Oyelaran, CISO

Approved: 6 February 2026 · **Next review:** 6 February 2027

Maps to: SOC 2 CC1.1, CC1.2, CC2.1, CC2.3 · ISO 27001:2022 Clauses 4–5

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[2] company-and-security-programme-overview — 3. Security programme in summary — relevance 0.69

3. Security programme in summary

The programme is built on four commitments, each evidenced elsewhere in this corpus rather than asserted here:

1. **Independent verification.** SOC 2 Type II (Prescient Assurance LLP, report issued 14 March 2026 covering 1 January – 31 December 2025, **no exceptions**) and ISO 27001:2022 (BSI certificate 'IS-2025-44817', issued 22 September 2025, valid to 21

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[3] information-security-policy — 5. Information classification — relevance 0.68

5. Information classification

All information is classified into one of four tiers. Handling requirements are defined in the Data Handling Standard (KD-SEC-004).

- **Restricted** — customer production data, credentials, private keys, personal data.

Encrypted at rest and in transit, access logged, need-to-know only.

- **Confidential** — source code, architecture documents, contracts, financials.

gs://attestor-505506-corporus/security/information-security-policy.txt

[4] personnel-security-and-training — Personnel Security and Security Training Programme — relevance 0.68

Personnel Security and Security Training Programme

Document ID: KD-SEC-013 · **Version:** 2.1 · **Owner:** Sofia Brenner, Head of IT

Approved: 22 January 2026 · **Next review:** 22 January 2027

Maps to: SOC 2 CC1.1, CC1.4, CC2.1, CC6.2 · ISO 27001:2022 A.6.1, A.6.2, A.6.3, A.6.6

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[5] information-security-policy — Information Security Policy — relevance 0.68

Information Security Policy

Document ID: KD-SEC-001

Version: 4.2

Owner: Marcus Oyelaran, Chief Information Security Officer

Approved by: Board Audit & Risk Committee, 11 February 2026

Last review: 11 February 2026 · **Next review:** 11 February 2027

Classification: Internal — may be shared with customers under NDA

gs://attestor-505506-corporus/security/information-security-policy.txt

[6] company-and-security-programme-overview — 4. Governance — relevance 0.67

4. Governance

The CISO reports to the CEO and to the board quarterly. A Security Steering Group meets monthly. The risk register holds 41 open risks and is reviewed monthly and re-scored quarterly. Full detail is in KD-SEC-018.

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[7] risk-management-and-governance — 8. Policy management — relevance 0.66

8. Policy management

All security policies carry a document ID, a version, a named owner, an approval date, and a review date. Policies are reviewed at least annually and on material change. The 2026 review cycle covered 14 policies between 8 January and 12 February 2026; three were revised, and the changes were communicated at the February all-hands and through the annual acknowledgement cycle.

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[8] information-security-policy — 7. Access control — relevance 0.65

7. Access control

Access follows least privilege and is governed by the Access Control Standard (KD-SEC-002). Identity is federated through Okta with SAML 2.0. Hardware-backed multi-factor authentication (WebAuthn / FIDO2 security keys) is mandatory for all staff; SMS and TOTP were retired as authentication factors on 30 June 2025.

Production access requires a documented business justification, e

gs://attestor-505506-corporus/security/information-security-policy.txt

[9] information-security-policy — 6. Personnel security — relevance 0.64

6. Personnel security

All employees and contractors undergo background screening appropriate to jurisdiction before their start date, conducted by Checkr. Screening covers identity verification, right to work, criminal records where lawful, and employment history for the preceding seven years.

Security awareness training is delivered through Curricula at onboarding and annually thereafter. Comple

gs://attestor-505506-corporus/security/information-security-policy.txt

[10] network-security-standard — Network Security Standard — relevance 0.63

Network Security Standard

****Document ID:**** KD-SEC-016 · ****Version:**** 2.0 · ****Owner:**** Dana Whitfield, VP Engineering
****Approved:**** 5 February 2026 · ****Next review:**** 5 February 2027
****Maps to:**** SOC 2 CC6.6, CC6.7, CC7.1 · ISO 27001:2022 A.8.20, A.8.21, A.8.22, A.8.23

gs://attestor-505506-corporus/security/network-security-standard.txt

[11] risk-management-and-governance — Risk Management and Security Governance — relevance 0.63

Risk Management and Security Governance

****Document ID:**** KD-SEC-018 · ****Version:**** 3.0 · ****Owner:**** Marcus Oyelaran, CISO
****Approved:**** 26 January 2026 · ****Next review:**** 26 January 2027
****Maps to:**** SOC 2 CC1.1, CC1.2, CC1.3, CC3.1, CC3.2, CC3.4 · ISO 27001:2022 A.5.1–A.5.4, Clauses 5–6, 9

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[12] information-security-policy — 8. Cryptography — relevance 0.62

8. Cryptography

Data at rest is encrypted with AES-256-GCM. Data in transit is protected with TLS 1.3; TLS 1.0 and 1.1 were disabled on 12 April 2024 and TLS 1.2 remains enabled only for a single legacy integration scheduled for removal in Q3 2026. Key management is described in the Encryption Standard (KD-SEC-003) and the Secrets Management Standard (KD-ENG-006).

gs://attestor-505506-corporus/security/information-security-policy.txt

[13] company-and-security-programme-overview — 6. Scope of certification — relevance 0.61

6. Scope of certification

The ISO 27001 certificate scope statement reads: *"The information security management system supporting the development, operation, and support of the Kestrel Insight analytics platform, including supporting corporate functions, at Austin, Texas and for remote personnel."* The SOC 2 report covers the Security, Availability, and Confidentiality Trust Services Criteria. Pr

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[14] company-and-security-programme-overview — 8. How to obtain evidence — relevance 0.59

8. How to obtain evidence

The SOC 2 Type II report, the ISO 27001 certificate, the penetration test executive summary, and the standard DPA are available to customers and prospects under NDA through the account team, usually within two business days. The certificate and the trust page are available without an NDA.

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[15] information-security-policy — 9. Incident response — relevance 0.59

9. Incident response

Security incidents are handled under the Incident Response Runbook (KD-SEC-005). Kestrel commits contractually to notifying affected customers within 72 hours of confirming a personal data breach, and within 24 hours for incidents involving confirmed unauthorised access to customer production data.

gs://attestor-505506-corporus/security/information-security-policy.txt

98. How many employees and contractors does your organisation have?

unassigned · Q98 · Vendor Security Review row 99

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

99. Provide your Information Security Policy.

security · Q99 · Vendor Security Review row 100

Kestrel Data maintains a formalized **Information Security Policy** (Document ID: KD-SEC-001, Version 4.2), owned by Marcus Oyelaran, Chief Information Security Officer, and approved by the Board Audit & Risk Committee on 11 February 2026 (last reviewed 11 February 2026; next review scheduled for 11 February 2027)

(*information-security-policy*, Section "Information Security Policy"). **### Purpose and Scope** The policy defines how Kestrel protects the confidentiality, integrity, and availability of information belonging to Kestrel and to customers of the Kestrel Insight platform. The scope encompasses all 187 employees and 24 contractors (as of 1 February 2026), every system processing Kestrel or customer data, and all physical facilities, including the Austin, Texas headquarters and remote work locations, with no exemptions for engineering, executive, or contractor personnel

(*information-security-policy*, Section 1 "Purpose and scope"). **### Information Classification** Under the policy, information is classified into four tiers (*information-security-policy*, Section 5 "Information classification"): -

Restricted: Customer production data, credentials, private keys, and personal data (must be encrypted at rest and in transit, access-logged, and restricted on a need-to-know basis). - **Confidential:** Source code, architecture documents, contracts, and financial records. - **Internal:** Policies, runbooks, and meeting notes (the default classification). - **Public:** Marketing materials and published documentation. **### Governance and Policy**

Management All security policies carry a document ID, version, named owner, approval date, and review date, and undergo review at least annually or upon material changes (*risk-management-and-governance*, Section 8 "Policy management"). Policy exceptions require written approval from the CISO, a documented compensating control, and an expiration date not exceeding 180 days (*information-security-policy*, Section 10 "Exceptions"). The Information Security Policy is classified as Internal and may be shared in full with customers under a non-disclosure agreement (NDA) (*information-security-policy*, Section "Information Security Policy").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by SecurityAgent

Evidence (8)

[1] information-security-policy — Information Security Policy — relevance 0.69

Information Security Policy

****Document ID:**** KD-SEC-001

****Version:**** 4.2

****Owner:**** Marcus Oyelaran, Chief Information Security Officer

****Approved by:**** Board Audit & Risk Committee, 11 February 2026

****Last review:**** 11 February 2026 · ****Next review:**** 11 February 2027

****Classification:**** Internal — may be shared with customers under NDA

gs://attestor-505506-corporus/security/information-security-policy.txt

[2] network-security-standard — Network Security Standard — relevance 0.68

Network Security Standard

****Document ID:**** KD-SEC-016 · ****Version:**** 2.0 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 5 February 2026 · ****Next review:**** 5 February 2027

****Maps to:**** SOC 2 CC6.6, CC6.7, CC7.1 · ISO 27001:2022 A.8.20, A.8.21, A.8.22, A.8.23

gs://attestor-505506-corporus/security/network-security-standard.txt

[3] risk-management-and-governance — Risk Management and Security Governance — relevance 0.67

Risk Management and Security Governance

****Document ID:**** KD-SEC-018 · ****Version:**** 3.0 · ****Owner:**** Marcus Oyelaran, CISO

****Approved:**** 26 January 2026 · ****Next review:**** 26 January 2027

****Maps to:**** SOC 2 CC1.1, CC1.2, CC1.3, CC3.1, CC3.2, CC3.4 · ISO 27001:2022 A.5.1–A.5.4, Clauses 5–6, 9

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[4] information-security-policy — 5. Information classification — relevance 0.67

5. Information classification

All information is classified into one of four tiers. Handling requirements are defined in the Data Handling Standard (KD-SEC-004).

- ****Restricted**** — customer production data, credentials, private keys, personal data.

Encrypted at rest and in transit, access logged, need-to-know only.

- ****Confidential**** — source code, architecture documents, contracts, financials.

gs://attestor-505506-corporus/security/information-security-policy.txt

[5] risk-management-and-governance — 8. Policy management — relevance 0.67

8. Policy management

All security policies carry a document ID, a version, a named owner, an approval date, and a review date. Policies are reviewed at least annually and on material change. The 2026 review cycle covered 14 policies between 8 January and 12 February 2026; three were revised, and the changes were communicated at the February all-hands and through the annual acknowledgement cycle.

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[6] information-security-policy — 1. Purpose and scope — relevance 0.66

1. Purpose and scope

This policy establishes how Kestrel Data, Inc. ("Kestrel") protects the confidentiality, integrity, and availability of information belonging to Kestrel and to customers of the Kestrel Insight platform.

It applies to all 187 employees and to all 24 contractors engaged as of 1 February 2026, to every system that processes Kestrel or customer data, and to all facilities includi

gs://attestor-505506-corporus/security/information-security-policy.txt

[7] information-security-policy — 10. Exceptions — relevance 0.64

10. Exceptions

Exceptions to this policy require written approval from the CISO, a documented compensating control, and an expiry date not exceeding 180 days. Four exceptions are open as of 11 February 2026, all tracked in Vanta and all with expiry dates before 30 September 2026.

gs://attestor-505506-corporus/security/information-security-policy.txt

[8] personnel-security-and-training — Personnel Security and Security Training Programme — relevance 0.63

Personnel Security and Security Training Programme

****Document ID:**** KD-SEC-013 · ****Version:**** 2.1 · ****Owner:**** Sofia Brenner, Head of IT

****Approved:**** 22 January 2026 · ****Next review:**** 22 January 2027

****Maps to:**** SOC 2 CC1.1, CC1.4, CC2.1, CC6.2 · ISO 27001:2022 A.6.1, A.6.2, A.6.3, A.6.6

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

100. Which module of the 2021 Standard Contractual Clauses do you use?

legal · Q100 · Vendor Security Review row 101

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

101. How many security incidents were recorded in the last calendar year?

security · Q101 · Vendor Security Review row 102

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

102. Do you have a documented exit plan from your cloud provider? If not, describe compensating controls.

engineering · Q102 · Vendor Security Review row 103

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] cloud-exit-and-portability-plan — 2. Exit triggers — relevance 0.71

2. Exit triggers

The plan would be invoked on: sustained material degradation of AWS service, a commercial breakdown or unacceptable pricing change, a regulatory instruction, or a security failure at the provider that could not be compensated for.

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[2] cloud-exit-and-portability-plan — Cloud Exit and Portability Plan — relevance 0.68

Cloud Exit and Portability Plan

****Document ID:**** KD-ENG-010 · ****Version:**** 1.7 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 30 January 2026 · ****Next review:**** 30 January 2027

****Maps to:**** SOC 2 A1.2, CC9.1 · ISO 27001:2022 A.5.19, A.5.21, A.5.30 · EBA/DORA-aligned

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[3] cloud-exit-and-portability-plan — 5. Customer-facing continuity during an exit — relevance 0.64

5. Customer-facing continuity during an exit

An exit would be executed instance by instance, with EU and US cut over separately, and ****data residency commitments would be honoured throughout****: an EU tenant would move to an EU region of the target provider, never transiting a US region. Customers would be given a minimum of 90 days' notice of a planned provider change and would retain their export

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[4] cloud-exit-and-portability-plan — 4. Estimated exit timeline — relevance 0.62

4. Estimated exit timeline

The tabletop exercise produced these estimates, which are planning figures rather than commitments:

Phase	Work	Estimate
1	Target selection, landing zone, network and identity foundation	4–6 weeks
2	Terraform provider rewrite, CI/CD retargeting	6–8 weeks
3	Data migration — Snowflake region move, PostgreSQL logical replication, ob	

gs://attestor-505506-corporate/engineering/cloud-exit-and-portability-plan.txt

[5] cloud-exit-and-portability-plan — 8. Testing — relevance 0.58

8. Testing

The plan is exercised annually as a tabletop with the SRE team, the VP Engineering, and the CISO. The 19 November 2025 exercise identified two gaps — the SQS/SNS adapter was not in place, and the KMS re-encryption path was undocumented — and both were closed by 14 January 2026. The next exercise is scheduled for November 2026.

gs://attestor-505506-corporate/engineering/cloud-exit-and-portability-plan.txt

103. Do you operate a web application firewall?

security · Q103 · Vendor Security Review row 104

Yes. Kestrel Data operates Cloudflare WAF across all production hostnames. The deployment runs the Cloudflare Managed Ruleset, the OWASP Core Ruleset configured at paranoia level 2, and 14 Kestrel-authored custom rules. To prevent false positives from disrupting customer traffic, all rules are deployed in log mode for seven days prior to active enforcement. Additionally, edge rate limiting is enforced at 120 requests per minute per tenant on the public API and 10 authentication attempts per five minutes per source address (`network-security-standard`, Section 2, "Web application firewall").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] network-security-standard — 2. Web application firewall — relevance 0.67

2. Web application firewall

Cloudflare WAF is enabled on all production hostnames, running the Cloudflare Managed Ruleset, the OWASP Core Ruleset at paranoia level 2, and 14 Kestrel-authored rules. Rules are deployed in log mode for 7 days before enforcement so that a false positive is found before it blocks a customer. Blocked request volume averaged 41,000 per day during 2025, of which the I

gs://attestor-505506-corporate/security/network-security-standard.txt

[2] network-security-standard — 5. Egress — relevance 0.60

5. Egress

Production workloads egress through NAT gateways with a domain allowlist enforced by AWS Network Firewall. The allowlist contains 23 destinations, each with a named owner and a business justification. An attempted connection to a destination outside the allowlist is blocked and alerted; 61 such alerts in 2025 were all traced to dependency mirrors being retired upstream.

gs://attestor-505506-corporate/security/network-security-standard.txt

[3] network-security-standard — 4. Inbound rules — relevance 0.59

4. Inbound rules

There are no unrestricted inbound rules (`0.0.0.0/0`) in any production security group other than ports 80 and 443 on the load balancer security group, which are themselves restricted to Cloudflare ranges. SSH ingress is closed entirely; administrative access is through AWS Systems Manager Session Manager, which requires an IAM identity and produces a recorded session.

Config

gs://attestor-505506-corporate/security/network-security-standard.txt

[4] network-security-standard — 9. DDoS protection — relevance 0.59

9. DDoS protection

Cloudflare provides layer 3/4 and layer 7 DDoS protection. The largest mitigated event in 2025 peaked at 18 Gbps on 3 June 2025 and caused no measurable increase in application error rate.

gs://attestor-505506-corporus/security/network-security-standard.txt

[5] network-security-standard — 6. Internal application access — relevance 0.58

6. Internal application access

There is no traditional VPN. Internal applications are published through Cloudflare Access with device posture and Okta identity required on every request. This is a zero-trust model in the practical sense: there is no network position that grants access, and being "inside" confers nothing.

gs://attestor-505506-corporus/security/network-security-standard.txt

104. How do workloads authenticate to cloud services?

engineering · Q104 · Vendor Security Review row 105

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (9)

[1] api-and-integration-standard — 2. Customer control of API credentials — relevance 0.63

2. Customer control of API credentials

****Customers create, scope, rotate, and revoke their own API credentials**** from the tenant administrator console, without involving Kestrel support. A credential can be limited to read-only, to specific datasets, and to a source IP allowlist. Revocation takes effect within 30 seconds across all regions.

****Kestrel support cannot recover a customer API key.**** K

gs://attestor-505506-corporus/engineering/api-and-integration-standard.txt

[2] api-and-integration-standard — 1. API authentication — relevance 0.62

1. API authentication

The public API at `https://api.kestreldata.com/v2` accepts two credential types:

****OAuth 2.0 bearer tokens**** issued through the client-credentials flow, valid for 60 minutes, scoped to a single tenant and to an explicit permission set. This is the recommended integration path.

****API keys**** for simple server-to-server use, presented as a bearer token, scoped the same

gs://attestor-505506-corporus/engineering/api-and-integration-standard.txt

[3] data-flow-and-shared-responsibility — 1. Data flow, end to end — relevance 0.59

1. Data flow, end to end

1. ****Ingress.**** A customer's browser or API client resolves `app.kestreldata.com` or `api.kestreldata.com` to Cloudflare, which terminates TLS 1.3 (1.2 minimum) and applies WAF and rate limiting.

2. ****Instance selection.**** DNS and tenant routing send the request to the instance chosen at contract signature: `us-east-1` or `eu-west-1`. ****A tenant's requests never c**

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[4] infrastructure-architecture-overview — 2. Account structure — relevance 0.57

2. Account structure

AWS Organizations with 9 accounts: `management`, `security-tooling`, `log-archive`, `shared-services`, `prod-us`, `prod-eu`, `staging`, `dev`, `sandbox`. Service Control Policies enforce guardrails at the Organization level, including mandatory EBS encryption, denial of root user actions, and denial of CloudTrail or GuardDuty disablement.

The `log-archive` account has no

gs://attestor-505506-corporis/engineering/infrastructure-architecture-overview.txt

[5] api-and-integration-standard — 8. Webhooks — relevance 0.57

8. Webhooks

Outbound webhooks are signed with an HMAC-SHA256 signature over the raw body using a per-endpoint secret the customer can rotate. Delivery is retried with exponential backoff for 24 hours. Kestrel will not deliver a webhook to a plaintext HTTP endpoint.

gs://attestor-505506-corporis/engineering/api-and-integration-standard.txt

[6] api-and-integration-standard — 9. Integration security review — relevance 0.57

9. Integration security review

A new first-party integration is reviewed against this standard before release, covering credential handling, scope minimisation, rate limiting, and audit event emission. The review is recorded in the pull request and is a required check on the `kd-api` repository.

gs://attestor-505506-corporis/engineering/api-and-integration-standard.txt

[7] infrastructure-architecture-overview — 7. Observability — relevance 0.57

7. Observability

Datadog for metrics, logs, APM, and security monitoring. Distributed tracing uses W3C Trace Context propagated across all services. Every log line carries `tenant\_id` and `request\_id`.

gs://attestor-505506-corporis/engineering/infrastructure-architecture-overview.txt

[8] infrastructure-architecture-overview — 6. Network — relevance 0.57

6. Network

Private subnets for all compute and data. No public IP addresses on workload instances. Ingress is exclusively through Cloudflare, then an AWS Application Load Balancer, then the Istio ingress gateway. Egress is through NAT gateways with an allowlist for known destinations.

Security groups are managed in Terraform and default-deny. There are no `0.0.0.0/0` ingress rules in produc

gs://attestor-505506-corporis/engineering/infrastructure-architecture-overview.txt

[9] api-and-integration-standard — API, Authentication and Integration Standard — relevance 0.57

API, Authentication and Integration Standard

Document ID: KD-ENG-005 · **Version:** 2.6 · **Owner:** Dana Whitfield, VP Engineering

Approved: 21 January 2026 · **Next review:** 21 January 2027

Maps to: SOC 2 CC6.1, CC6.6, CC8.1 · ISO 27001:2022 A.5.15, A.8.5, A.8.26

gs://attestor-505506-corporis/engineering/api-and-integration-standard.txt

105. How do you detect prohibited licences?

engineering · Q105 · Vendor Security Review row 106

Licence compliance is checked automatically in CI using FOSSA on every pull request. If a prohibited licence (such as GPL-2.0, GPL-3.0, AGPL-1.0, AGPL-3.0, SSPL, BUSL, Commons Clause, or any licence lacking a clear grant) is detected, the build fails automatically (Third-Party Library Policy, Section 2: Licence policy). In addition, when adding a new direct dependency, engineers are required to verify and document the licence against the approved allowlist during pull request review (Third-Party Library Policy, Section 1: Adding a dependency).

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (5)

[1] third-party-library-policy — 2. Licence policy — relevance 0.59

2. Licence policy

Allowed: MIT, BSD-2-Clause, BSD-3-Clause, Apache-2.0, ISC, Python Software Foundation, Unlicense, CC0.

Requires legal review: MPL-2.0, LGPL-2.1, LGPL-3.0, EPL-2.0.

****Prohibited:**** GPL-2.0, GPL-3.0, AGPL-1.0, AGPL-3.0, SSPL, BUSL, Commons Clause, and any licence without a clear grant. AGPL and SSPL are prohibited because Kestrel distributes a network service.

L

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[2] third-party-library-policy — 1. Adding a dependency — relevance 0.50

1. Adding a dependency

A new direct dependency requires a pull request that documents:

1. Why an existing dependency or the standard library is insufficient.
2. The licence, checked against the allowlist below.
3. Maintenance signal: last release date, open critical issues, number of maintainers.
4. Transitive dependency count added.

Review is by any engineer other than the author. Depend

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[3] third-party-library-policy — Third-Party Library Policy — relevance 0.50

Third-Party Library Policy

****Document ID:**** KD-ENG-008 · ****Version:**** 1.4 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 22 January 2026 · ****Maps to:**** SOC 2 CC7.1 · ISO 27001:2022 A.8.28

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[4] third-party-library-policy — 6. Unmaintained dependencies — relevance 0.49

6. Unmaintained dependencies

A dependency with no release in 24 months and no active maintainer is flagged for replacement. Three such dependencies were identified in the January 2026 review, all scheduled for replacement by Q3 2026.

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[5] third-party-library-policy — 7. Internal forks — relevance 0.47

7. Internal forks

Forking a third-party library requires VP Engineering approval and creates an obligation to track upstream security advisories manually. Kestrel currently maintains ****zero**** internal forks, deliberately.

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

106. Do you sell personal data to third parties?

legal · Q106 · Vendor Security Review row 107

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] privacy-policy — 3. What we do not do — relevance 0.68

3. What we do not do

- We do not sell personal data, and have never done so.
- We do not share personal data with advertising networks.
- We do not use customer content to train machine learning models, our own or anyone else. This is stated contractually in the MSA and is not merely a policy statement.
- We do not engage in automated decision-making producing legal or similarly significant

gs://attestor-505506-corporus/legal/privacy-policy.txt

[2] data-subject-rights-procedure — 8. California and other US state rights — relevance 0.65

8. California and other US state rights

Kestrel acts as a **service provider** under the CCPA/CPRA in respect of customer content, and the DPA contains the required service provider terms: no sale, no sharing for cross-context behavioural advertising, no retention or use outside the business purpose, and no combining with data from other sources. The same terms are applied for the Virginia, Colora

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[3] privacy-policy — 2. What we collect as controller — relevance 0.63

2. What we collect as controller

| Category | Examples | Lawful basis | Retention |

|---|---|---|---|

| Account data | Name, work email, job title, company | Contract (Art. 6(1)(b)) | Term + 3 years |

| Billing data | Billing contact, VAT number, payment method token | Contract; legal obligation | 7 years (tax) |

| Product telemetry | Feature usage, page views, error events | Legitimate interest

gs://attestor-505506-corporus/legal/privacy-policy.txt

[4] privacy-policy — 5. Your rights — relevance 0.62

5. Your rights

Data subjects in the EEA, UK, and Switzerland have rights of access, rectification, erasure, restriction, portability, and objection, and the right to withdraw consent.

California residents have rights under the CCPA as amended by the CPRA, including the right to know, delete, correct, and opt out of sharing.

Requests to `privacy@kestreldata.com` are acknowledged within 5 busi

gs://attestor-505506-corporus/legal/privacy-policy.txt

[5] privacy-policy — 6. International transfers — relevance 0.61

6. International transfers

Personal data is processed in the United States and the European Union. Transfers out of the EEA rely on the 2021 Standard Contractual Clauses with supplementary measures described in the Transfer Impact Assessment (KD-LEG-006).

gs://attestor-505506-corporus/legal/privacy-policy.txt

107. Describe how tenant isolation is enforced.

engineering · Q107 · Vendor Security Review row 108

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] infrastructure-architecture-overview — 5. Tenant isolation — relevance 0.63

5. Tenant isolation

Kestrel Insight is **multi-tenant** with logical isolation. There is no per-customer infrastructure, no single-tenant deployment option, and no customer-VPC option.

Isolation is enforced at three layers:

1. **Database** - PostgreSQL row-level security policies keyed on `tenant\_id`, applied at the connection level from an authenticated session variable. No application

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[2] infrastructure-architecture-overview — 6. Network — relevance 0.59

6. Network

Private subnets for all compute and data. No public IP addresses on workload instances.

Ingress is exclusively through Cloudflare, then an AWS Application Load Balancer, then the Istio ingress gateway. Egress is through NAT gateways with an allowlist for known destinations.

Security groups are managed in Terraform and default-deny. There are no `0.0.0.0/0` ingress rules in produc

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[3] sdlc-policy — 3. Testing requirements — relevance 0.58

3. Testing requirements

- Unit test coverage gate at **80%** on changed lines, enforced in CI.
- Integration tests run against ephemeral infrastructure provisioned per pull request.
- Tenant isolation tests run on every build: a suite of 84 assertions attempting cross-tenant reads through every public API surface.
- Load tests before any release expected to change the performance profile.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[4] sdlc-policy — 7. Separation of duties — relevance 0.57

7. Separation of duties

Engineers cannot deploy their own change to production without the automated pipeline: no human has the ability to push a container image to the production registry directly. The deployment role is held by the CI service identity, which authenticates through OIDC and holds no long-lived credentials.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[5] data-flow-and-shared-responsibility — 3. The shared responsibility model — relevance 0.57

3. The shared responsibility model

Security of the platform is Kestrel's. Security of what the customer does with it is the customer's. The line is drawn here rather than left implicit, because an unstated boundary is where a breach lands on whoever is less able to argue.

****Kestrel is responsible for:****

* physical and environmental security of the infrastructure (through AWS), and the cloud
co

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

108. How long is product telemetry retained?

legal · Q108 · Vendor Security Review row 109

Product telemetry is pseudonymous and is retained for 24 months (`data-retention-schedule`, Section 2; `dpa-annex-2-technical-measures`, Section 6). Its retention is maintained on the basis of legitimate interests and reviewed annually (`data-retention-schedule`, Section 2; `gdpr-records-of-processing`, Part B).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] data-retention-schedule — 2. Kestrel-controlled data — relevance 0.70

2. Kestrel-controlled data

| Data class | Retention | Basis |

|---|---|---|

| Account and contact records | Term + 3 years | Contract, limitation periods |

| Billing and tax records | **7 years** | US and Irish tax law |

| Product telemetry | 24 months | Legitimate interests, reviewed annually |

| Support tickets | Term + 2 years | Contract |

| Marketing contacts | Until consent withdrawal +

gs://attestor-505506-corporus/legal/data-retention-schedule.txt

[2] data-retention-schedule — 1. Customer data — relevance 0.68

1. Customer data

| Data class | Active retention | Post-termination | Deletion mechanism |

|---|---|---|---|

| Customer records in the platform | Term of subscription | **30 days** export window, then deleted within **90 days** | Automated
`tenant-purge` job, nightly |

| Analytics warehouse (Snowflake) | Term | Deleted with tenant purge | Automated |
| Uploaded files (S3) | Term | Deleted with

gs://attestor-505506-corporus/legal/data-retention-schedule.txt

[3] dpa-annex-2-technical-measures — 6. Data minimisation — relevance 0.67

6. Data minimisation

The Service collects only data the customer chooses to provide. Kestrel product telemetry is pseudonymous and retained for 24 months. Kestrel does not use customer content to train machine learning models.

gs://attestor-505506-corporus/legal/dpa-annex-2-technical-measures.txt

[4] data-retention-schedule — 6. Exceptions — relevance 0.66

6. Exceptions

Where a retention period conflicts with a customer contractual requirement, the shorter period applies unless law requires otherwise. Longer retention requires DPO approval, which has not been granted for any customer data class to date.

gs://attestor-505506-corporus/legal/data-retention-schedule.txt

[5] gdpr-records-of-processing — Part B - Kestrel as Controller (Art. 30(1)) — relevance 0.65

Part B - Kestrel as Controller (Art. 30(1))

| # | Purpose | Lawful basis | Data subjects | Personal data | Retention |

|---|---|---|---|---|---|

| C1 | Account administration | Art. 6(1)(b) contract | Customer administrators | Name, work email, job title | Term + 3 years |

| C2 | Billing and tax | Art. 6(1)(b), 6(1)(c) | Billing contacts | Name, email, VAT, payment token | 7 years |

| C3 | Pro

gs://attestor-505506-corporus/legal/gdpr-records-of-processing.txt

109. How much notice do you provide before adding a subprocessor?

legal · Q109 · Vendor Security Review row 110

Kestrel provides **30 days** notice prior to adding or replacing any subprocessor (``data-processing-agreement``, Section 5, "Sub-processing"; ``subprocessor-list``, "Subprocessor List"). Customers may subscribe to change notifications at ``kestreldata.com/subprocessors/subscribe`` and have the right to object on reasonable data protection grounds within the 30-day notice period (``data-processing-agreement``, Section 5, "Sub-processing"; ``subprocessor-list``, "Subprocessor List"). If an objection cannot be resolved, the customer may terminate the affected service without penalty for the remainder of the prepaid term (``data-processing-agreement``, Section 5, "Sub-processing").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by LegalAgent

Evidence (5)

[1] data-processing-agreement — 5. Sub-processing — relevance 0.69

5. Sub-processing

Customer grants general authorisation for the sub-processors listed at ``kestreldata.com/subprocessors``. Kestrel gives **30 days** notice before adding or replacing a sub-processor. Customer may object on reasonable data-protection grounds within that period; if the objection cannot be resolved, Customer may terminate the affected Service without penalty for the remainder of t

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[2] subprocessor-list — Subprocessor List — relevance 0.66

Subprocessor List

Document ID: KD-LEG-002 · **Version:** 6.4 · **Owner:** Priya Raghunathan, DPO

Last updated: 1 February 2026 · **Published at:** ``kestreldata.com/subprocessors``

Change notice: 30 days, subscribe at ``kestreldata.com/subprocessors/subscribe``

gs://attestor-505506-corporus/legal/subprocessor-list.txt

[3] subprocessor-list — Infrastructure subprocessors — relevance 0.63

Infrastructure subprocessors
Subprocessor	Purpose	Location of processing	Transfer mechanism	Engaged since
Amazon Web Services, Inc.	Cloud hosting, compute, storage, database	US (`us-east-1`, `us-west-2`); EU (`eu-west-1`, `eu-central-1`)		
SCCs + AWS DPA; EU data stays in EU	Mar 2019			
Snowflake Inc.	Analytics data warehouse	US (AWS `us-east-1`);		

gs://attestor-505506-corpus/legal/subprocessor-list.txt

[4] data-processing-agreement — 1. Roles — relevance 0.61

1. Roles

Customer is **Controller**. Kestrel Data, Inc. is **Processor**. Where Customer is itself a processor for its own customers, Kestrel is sub-processor and the same obligations apply down the chain.

Kestrel is **Controller** for a limited set of data it determines the purposes of: account administrator contact details, billing records, and product telemetry described in Annex 3.

gs://attestor-505506-corpus/legal/data-processing-agreement.txt

[5] subprocessor-list — Operational subprocessors — relevance 0.61

Operational subprocessors

Subprocessor	Purpose	Location	Transfer mechanism	Engaged since
Datadog, Inc.	Observability, logs, APM	US; EU site (`datadoghq.eu`) for EU customers	SCCs	Jun 2020
Okta, Inc.	Identity and access management	US; EU cell for EU customers	SCCs	Feb 2021
Twilio SendGrid	Transactional email delivery	US	SCCs	Ma

gs://attestor-505506-corpus/legal/subprocessor-list.txt

110. Are you self-certified under the EU-US Data Privacy Framework?

legal · Q110 · Vendor Security Review row 111

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] standard-contractual-clauses-summary — 3. EU-US Data Privacy Framework — relevance 0.69

3. EU-US Data Privacy Framework

Kestrel is **not** currently self-certified under the EU-US Data Privacy Framework. Transfers rely on the SCCs plus the supplementary measures below. Self-certification is under evaluation but no commitment date has been set. This is stated plainly rather than implied.

gs://attestor-505506-corpus/legal/standard-contractual-clauses-summary.txt

[2] transfer-impact-assessment — 3. Transfer mechanism — relevance 0.63

3. Transfer mechanism

The 2021 **Standard Contractual Clauses, Module Two (controller to processor)** apply between the customer and Kestrel, and **Module Three (processor to sub-processor)** between Kestrel and its US sub-processors. The **UK International Data Transfer Addendum** is incorporated for UK exports, and for Switzerland the SCCs are applied with the adaptations published by the Swiss

gs://attestor-505506-corpus/legal/transfer-impact-assessment.txt

[3] transfer-impact-assessment — 5. Supplementary measures relied on — relevance 0.60

5. Supplementary measures relied on Technical:

1. **Data residency by default** — EU customer content, including backups and the replicated log ship, never leaves `eu-west-1`.
2. **Encryption in transit** — TLS 1.3 (1.2 minimum) on every hop, including between

Kestrel and each sub-processor.

3. **Encryption at rest** — AES-256-GCM with keys in AWS KMS. Keys for the EU instance are held i

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

[4] transfer-impact-assessment — 6. Conclusion — relevance 0.59

6. Conclusion

For T1 and T2 the residual risk to data subjects is assessed as **low**: the data transferred is limited, pseudonymised where possible, encrypted with keys held outside the importer's jurisdiction, and unaccompanied by any customer content. For T3 and T4 the residual risk is **low** on the same basis, with the additional point that no customer content is transferred at all.

The asse

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

[5] dpia-register — 7. Availability — relevance 0.59

7. Availability

DPIA summaries are provided to customers under NDA on request through the account team.

The full assessments are not distributed, because they contain architectural detail that is itself Confidential, but the DPO will walk a customer's privacy team through an assessment on a call.

gs://attestor-505506-corporus/legal/dpia-register.txt

111. Provide the technical and organisational measures annexed to your DPA. Provide supporting evidence.

legal · Q111 · Vendor Security Review row 112

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] dpia-annex-2-technical-measures — DPA Annex 2 - Technical and Organisational Measures — relevance 0.75

DPA Annex 2 - Technical and Organisational Measures

Document ID: KD-LEG-009 · **Version:** 4.0 · **Owner:** Marcus Oyelaran, CISO

Effective: 1 February 2026 · Annex to the DPA (KD-LEG-001)

Maps to: GDPR Art. 32

Measures are described at a level that allows a controller to assess adequacy under Art. 32 without exposing information that would itself create risk.

gs://attestor-505506-corporus/legal/dpia-annex-2-technical-measures.txt

[2] gdpr-records-of-processing — Data Protection Impact Assessments — relevance 0.64

Data Protection Impact Assessments

One DPIA is on file, covering the introduction of the anomaly detection feature

(`LEG-GOV/dpia-2025-01`, completed 8 September 2025). Conclusion: residual risk low, no prior consultation with the supervisory authority required.

gs://attestor-505506-corporus/legal/gdpr-records-of-processing.txt

[3] dpia-annex-2-technical-measures — 4. Regular testing and evaluation (Art. 32(1)(d)) — relevance 0.63

4. Regular testing and evaluation (Art. 32(1)(d))

| Activity | Frequency | Last performed |

|---|---|---|

| Independent penetration test | Annual minimum | 3-14 February 2026 |

| SOC 2 Type II audit | Annual | Period ended 31 December 2025 |

| ISO 27001 surveillance audit | Annual | 22 September 2025 |

| Disaster recovery restore test | Quarterly | 17 January 2026 |

| User access review | Qu

gs://attestor-505506-corpus/legal/dpa-annex-2-technical-measures.txt

[4] transfer-impact-assessment — 5. Supplementary measures relied on — relevance 0.63

5. Supplementary measures relied on
Technical:

1. **Data residency by default** — EU customer content, including backups and the replicated log ship, never leaves `eu-west-1`.
2. **Encryption in transit** — TLS 1.3 (1.2 minimum) on every hop, including between Kestrel and each sub-processor.
3. **Encryption at rest** — AES-256-GCM with keys in AWS KMS. Keys for the EU instance are held i

gs://attestor-505506-corpus/legal/transfer-impact-assessment.txt

[5] transfer-impact-assessment — Transfer Impact Assessment — relevance 0.63

Transfer Impact Assessment

Document ID: KD-LEG-010 · **Version:** 2.1 · **Owner:** Priya Raghunathan, DPO

Approved: 9 January 2026 · **Next review:** 9 January 2027

Maps to: GDPR Articles 44–49 · EDPB Recommendations 01/2020 · Schrems II (C-311/18)

gs://attestor-505506-corpus/legal/transfer-impact-assessment.txt

112. Is restore tested by performing an actual restore, or by verifying backup existence?

engineering · Q112 · Vendor Security Review row 113

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

113. Please confirm: Do you use customer content to train machine learning models?

legal · Q113 · Vendor Security Review row 114

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

114. Are you FedRAMP authorised?

security · Q114 · Vendor Security Review row 115

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

115. Do you permit use of generative AI tools with customer data?

legal · Q115 · Vendor Security Review row 116

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (10)

[1] data-processing-agreement — 11. Liability — relevance 0.67

11. Liability

Liability under this DPA is subject to the limitations in the Master Subscription

Agreement, save that nothing limits liability that cannot be limited under applicable data protection law.

gs://attestor-505506-corpus/legal/data-processing-agreement.txt

[2] master-agreement-summary — Master Subscription Agreement — Summary of Key Terms — relevance 0.65

Master Subscription Agreement — Summary of Key Terms

Document ID: KD-LEG-014 · **Version:** 3.2 · **Owner:** Aaron Feldstein, General Counsel

Approved: 28 January 2026 · **Next review:** 28 January 2027

Maps to: SOC 2 CC2.3, CC9.1 · GDPR Article 28

*A summary for review purposes. The executed agreement governs; where this summary and an executed contract differ, the contract prevails.

gs://attestor-505506-corporus/legal/master-agreement-summary.txt

[3] master-agreement-summary — 8. Assignment and change of control — relevance 0.63

8. Assignment and change of control

Neither party may assign without the other's consent, except to a successor in a merger or sale of substantially all assets, subject to notice. Where the acquirer is a competitor of the customer, the customer may terminate within 30 days of notice.

gs://attestor-505506-corporus/legal/master-agreement-summary.txt

[4] master-agreement-summary — 1. Structure — relevance 0.63

1. Structure

A Kestrel engagement comprises the Master Subscription Agreement, an Order Form, the Data Processing Agreement (KD-LEG-001) with its Annex 2 technical measures (KD-LEG-003), and the Security Addendum (KD-LEG-005). The DPA and Security Addendum are incorporated by reference into every agreement; they are not optional extras negotiated case by case.

gs://attestor-505506-corporus/legal/master-agreement-summary.txt

[5] master-agreement-summary — 10. Service levels — relevance 0.61

10. Service levels

The availability commitment, service credits, and support response targets are in the Availability SLA (KD-ENG-001). Service credits are the sole remedy for missed availability, with a termination right if the monthly commitment is missed in three consecutive months.

gs://attestor-505506-corporus/legal/master-agreement-summary.txt

[6] privacy-policy — 3. What we do not do — relevance 0.57

3. What we do not do

- We do not sell personal data, and have never done so.
- We do not share personal data with advertising networks.
- We do not use customer content to train machine learning models, our own or anyone else. This is stated contractually in the MSA and is not merely a policy statement.
- We do not engage in automated decision-making producing legal or similarly significant

gs://attestor-505506-corporus/legal/privacy-policy.txt

[7] privacy-policy — 2. What we collect as controller — relevance 0.55

2. What we collect as controller

| Category | Examples | Lawful basis | Retention |

|---|---|---|---|

| Account data | Name, work email, job title, company | Contract (Art. 6(1)(b)) | Term + 3 years |

| Billing data | Billing contact, VAT number, payment method token | Contract; legal obligation | 7 years (tax) |

| Product telemetry | Feature usage, page views, error events | Legitimate interest

gs://attestor-505506-corporus/legal/privacy-policy.txt

[8] privacy-policy — 1. Controller and contact — relevance 0.55

1. Controller and contact

Kestrel Data, Inc., 1401 Lavaca Street, Suite 210, Austin, TX 78701, USA.

EU representative under Art. 27 GDPR: Instant EU Rep Ltd, Dublin, Ireland.

Data Protection Officer: Priya Raghunathan, `dpo@kestreldata.com`.

Lead supervisory authority: Irish Data Protection Commission.

gs://attestor-505506-corporus/legal/privacy-policy.txt

[9] privacy-policy — 5. Your rights — relevance 0.55

5. Your rights

Data subjects in the EEA, UK, and Switzerland have rights of access, rectification, erasure, restriction, portability, and objection, and the right to withdraw consent. California residents have rights under the CCPA as amended by the CPRA, including the right to know, delete, correct, and opt out of sharing.

Requests to `privacy@kestreldata.com` are acknowledged within 5 busi

`gs://attestor-505506-corporus/legal/privacy-policy.txt`

[10] privacy-policy — Privacy Policy — relevance 0.55

Privacy Policy

Document ID: KD-LEG-003 · **Version:** 4.0 · **Owner:** Priya Raghunathan, DPO
Effective: 15 January 2026 · **Published at:** `kestreldata.com/privacy``

This policy describes how Kestrel Data, Inc. handles personal data where Kestrel is the **controller**. Where Kestrel processes personal data on behalf of a business customer, that customer is the controller and its own

`gs://attestor-505506-corporus/legal/privacy-policy.txt`

116. Can a privileged administrator delete or alter audit logs?

security · Q116 · Vendor Security Review row 117

No, privileged administrators cannot delete or alter audit logs. Kestrel Data enforces strict tamper resistance and log immutability controls: - **S3 Object Lock in Compliance Mode:** Audit logs stored in the security archive bucket are protected using Amazon S3 Object Lock in compliance mode, which cannot be disabled, altered, or shortened by any principal, including the AWS account root user (`logging-monitoring-standard``, §3 "Tamper resistance"). - **Isolated Security Account & Separation of Duties:** CloudTrail, VPC flow logs, GuardDuty findings, and AWS Config history are delivered directly to a dedicated `kd-security`` account where no engineering role possesses write permissions (`cloud-security-posture-standard``, §8 "Logging and evidence"). The archive account maintains no human standing access, and log writes arrive exclusively via the organization trail (`logging-monitoring-standard``, §3 "Tamper resistance"). - **Log Integrity Validation:** CloudTrail log file integrity validation is enabled to detect any modification or tampering (`logging-monitoring-standard``, §3 "Tamper resistance").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] logging-monitoring-standard — 6. Customer access to logs — relevance 0.62

6. Customer access to logs

Enterprise-tier customers can retrieve tenant-scoped audit events for their own organisation through the Audit API (`GET /v2/audit/events``), covering the previous 365 days. Kestrel does not expose its own infrastructure logs to customers; relevant extracts are provided during incident response on request.

`gs://attestor-505506-corporus/security/logging-monitoring-standard.txt`

[2] logging-monitoring-standard — 3. Tamper resistance — relevance 0.61

3. Tamper resistance

The security archive bucket uses S3 Object Lock in **compliance mode**, which cannot be disabled or shortened by any principal including the AWS account root. CloudTrail log file integrity validation is enabled. The archive account is a separate AWS account with no human standing access; writes arrive only through the organisation trail.

`gs://attestor-505506-corporus/security/logging-monitoring-standard.txt`

[3] cloud-security-posture-standard — 8. Logging and evidence — relevance 0.61

8. Logging and evidence

CloudTrail (all regions, all accounts), VPC flow logs, GuardDuty findings, and Config history are delivered to a dedicated `kd-security`` account that no engineering role can write to, with object lock set to 400 days. This is the arrangement that makes the audit trail defensible: the accounts that generate the evidence cannot alter it.

`gs://attestor-505506-corporus/security/cloud-security-posture-standard.txt`

[4] cloud-security-posture-standard — 3. Manual console changes — relevance 0.57

3. Manual console changes

****Manual changes in the production AWS console are not permitted.**** Human IAM principals in production accounts hold read-only permissions by default; write access is obtained through the just-in-time process in KD-SEC-002 §4, is time-boxed to 8 hours, and is intended for incident response rather than routine change.

Any write action taken by a human principal in product

gs://attestor-505506-corpus/security/cloud-security-posture-standard.txt

[5] logging-monitoring-standard — 2. Retention — relevance 0.57

2. Retention

| Log class | Hot (searchable) | Archive | Total |

|---|---|---|---|

| Security and audit (CloudTrail, Okta) | 90 days in Datadog | 7 years in S3 Glacier | ****7 years**** |

| Application | 30 days in Datadog | 1 year in S3 | 1 year |

| Snowflake ACCESS_HISTORY | 365 days native | 7 years in S3 | 7 years |

| VPC Flow / WAF | 30 days | 1 year | 1 year |

gs://attestor-505506-corpus/security/logging-monitoring-standard.txt

117. Does the platform incorporate any machine learning models that process customer data?

engineering · Q117 · Vendor Security Review row 118

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] data-flow-and-shared-responsibility — 5. Categories of customer data — relevance 0.59

5. Categories of customer data

The four categories the platform processes are defined in KD-SEC-004 §2 and mirrored in the Records of Processing Activities (KD-LEG-004). Kestrel does not process payment card data: Stripe collects card details directly and Kestrel holds a token and the last four digits.

gs://attestor-505506-corpus/engineering/data-flow-and-shared-responsibility.txt

[2] data-flow-and-shared-responsibility — 1. Data flow, end to end — relevance 0.53

1. Data flow, end to end

1. ****Ingress.**** A customer's browser or API client resolves `app.kestreldata.com` or `api.kestreldata.com` to Cloudflare, which terminates TLS 1.3 (1.2 minimum) and applies WAF and rate limiting.

2. ****Instance selection.**** DNS and tenant routing send the request to the instance chosen at contract signature: `us-east-1` or `eu-west-1`. ****A tenant's requests never c**

gs://attestor-505506-corpus/engineering/data-flow-and-shared-responsibility.txt

[3] data-flow-and-shared-responsibility — Data Flow and Shared Responsibility Model — relevance 0.52

Data Flow and Shared Responsibility Model

****Document ID:**** KD-ENG-011 · ****Version:**** 2.0 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 2 February 2026 · ****Next review:**** 2 February 2027

****Maps to:**** SOC 2 CC2.3, CC3.2, CC6.1 · ISO 27001:2022 A.5.2, A.5.8, A.8.9 · GDPR Article 28

gs://attestor-505506-corpus/engineering/data-flow-and-shared-responsibility.txt

[4] data-flow-and-shared-responsibility — 6. Where processing occurs — relevance 0.52

6. Where processing occurs

Processing occurs in AWS `us-east-1` (US instance) and AWS `eu-west-1` (EU instance), by personnel located in the United States, the European Union, the United Kingdom, and Canada, under the access controls in KD-SEC-002. ****No processing occurs outside the stated regions****, and no support is subcontracted to a third-party provider in another jurisdiction.

gs://attestor-505506-corpus/engineering/data-flow-and-shared-responsibility.txt

[5] data-flow-and-shared-responsibility — 3. The shared responsibility model — relevance 0.51

- * deciding what data they upload, and its lawfulness — Kestrel does not inspect it;
- * configuring SSO, and enforcing MFA at their own identity provider;
- * managing their own users, roles, and permissions, including timely removal of leavers;
- * the scope, storage, and rotation of the API credentials they create;
- * reviewing their own audit log, which Kestrel makes available for 13 months;
- * acting

gs://attestor-505506-corpus/engineering/data-flow-and-shared-responsibility.txt

118. What categories of customer data does the platform process?

legal · Q118 · Vendor Security Review row 119

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (8)

[1] data-processing-agreement — 1. Roles — relevance 0.68

1. Roles

Customer is **Controller**. Kestrel Data, Inc. is **Processor**. Where Customer is itself a processor for its own customers, Kestrel is sub-processor and the same obligations apply down the chain.

Kestrel is **Controller** for a limited set of data it determines the purposes of: account administrator contact details, billing records, and product telemetry described in Annex 3.

gs://attestor-505506-corpus/legal/data-processing-agreement.txt

[2] gdpr-records-of-processing — Part A - Kestrel as Processor (Art. 30(2)) — relevance 0.68

Part A - Kestrel as Processor (Art. 30(2))

Controller: each Kestrel customer, as identified in the applicable Order Form.

Processor: Kestrel Data, Inc.

DPO: Priya Raghunathan, `dpo@kestreldata.com`

| # | Processing activity | Categories of data subject | Categories of personal data | Transfers | Retention |
|---|---|---|---|---|
| P1 | Hosting and operating the Kestrel Insig

gs://attestor-505506-corpus/legal/gdpr-records-of-processing.txt

[3] privacy-policy — 2. What we collect as controller — relevance 0.67

2. What we collect as controller

| Category | Examples | Lawful basis | Retention |

|---|---|---|

| Account data | Name, work email, job title, company | Contract (Art. 6(1)(b)) | Term + 3 years |

| Billing data | Billing contact, VAT number, payment method token | Contract; legal obligation | 7 years (tax) |

| Product telemetry | Feature usage, page views, error events | Legitimate interest

gs://attestor-505506-corpus/legal/privacy-policy.txt

[4] gdpr-records-of-processing — Special category data — relevance 0.67

Special category data

Kestrel does **not** intentionally process special category data under Art. 9 in the course of providing the Service. Customers are contractually prohibited from uploading special category data without a prior written agreement; no such agreement is in force as of 20 January 2026.

gs://attestor-505506-corpus/legal/gdpr-records-of-processing.txt

[5] dpia-register — 3. Special category data — relevance 0.66

3. Special category data

Kestrel does not knowingly process special category personal data under Article 9. The platform is not designed for it, the Acceptable Use terms in the master agreement prohibit

uploading it, and no field in the data model is intended to hold it.

Kestrel cannot inspect customer-uploaded datasets — they are opaque by design — so the control is contractual and architect

gs://attestor-505506-corporus/legal/dpia-register.txt

[6] dpia-register — Data Protection Impact Assessment Register — relevance 0.64

Data Protection Impact Assessment Register

Document ID: KD-LEG-011 · **Version:** 1.9 · **Owner:** Priya Raghunathan, DPO

Approved: 16 January 2026 · **Next review:** 16 January 2027

Maps to: GDPR Articles 35, 36, 9, 8, 22

gs://attestor-505506-corporus/legal/dpia-register.txt

[7] data-processing-agreement — 11. Liability — relevance 0.63

11. Liability

Liability under this DPA is subject to the limitations in the Master Subscription

Agreement, save that nothing limits liability that cannot be limited under applicable data protection law.

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[8] gdpr-records-of-processing — Part B - Kestrel as Controller (Art. 30(1)) — relevance 0.63

Part B - Kestrel as Controller (Art. 30(1))

| # | Purpose | Lawful basis | Data subjects | Personal data | Retention |

|---|---|---|---|---|

| C1 | Account administration | Art. 6(1)(b) contract | Customer administrators | Name, work email, job title | Term + 3 years |

| C2 | Billing and tax | Art. 6(1)(b), 6(1)(c) | Billing contacts | Name, email, VAT, payment token | 7 years |

| C3 | Pro

gs://attestor-505506-corporus/legal/gdpr-records-of-processing.txt

119. How far back are customer-accessible audit logs available?

security · Q119 · Vendor Security Review row 120

Enterprise-tier customers can retrieve tenant-scoped audit events for their own organisation covering the previous 365 days via the Audit API (`GET /v2/audit/events`) (`logging-monitoring-standard`, Section 6: "Customer access to logs").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] logging-monitoring-standard — 6. Customer access to logs — relevance 0.70

6. Customer access to logs

Enterprise-tier customers can retrieve tenant-scoped audit events for their own organisation through the Audit API (`GET /v2/audit/events`), covering the previous 365 days. Kestrel does not expose its own infrastructure logs to customers; relevant extracts are provided during incident response on request.

gs://attestor-505506-corporus/security/logging-monitoring-standard.txt

[2] logging-monitoring-standard — 2. Retention — relevance 0.70

2. Retention

| Log class | Hot (searchable) | Archive | Total |

|---|---|---|---|

| Security and audit (CloudTrail, Okta) | 90 days in Datadog | 7 years in S3 Glacier | ****7 years**** |

| Application | 30 days in Datadog | 1 year in S3 | 1 year |

| Snowflake ACCESS_HISTORY | 365 days native | 7 years in S3 | 7 years |

| VPC Flow / WAF | 30 days | 1 year | 1 year |

gs://attestor-505506-corporus/security/logging-monitoring-standard.txt

[3] logging-monitoring-standard — 3. Tamper resistance — relevance 0.65

3. Tamper resistance

The security archive bucket uses S3 Object Lock in ****compliance mode****, which cannot be

disabled or shortened by any principal including the AWS account root. CloudTrail log file integrity validation is enabled. The archive account is a separate AWS account with no human standing access; writes arrive only through the organisation trail.

gs://attestor-505506-corporus/security/logging-monitoring-standard.txt

[4] cloud-security-posture-standard — 8. Logging and evidence — relevance 0.63

8. Logging and evidence

CloudTrail (all regions, all accounts), VPC flow logs, GuardDuty findings, and Config history are delivered to a dedicated `kd-security` account that no engineering role can write to, with object lock set to 400 days. This is the arrangement that makes the audit trail defensible: the accounts that generate the evidence cannot alter it.

gs://attestor-505506-corporus/security/cloud-security-posture-standard.txt

[5] logging-monitoring-standard — 1. What is logged — relevance 0.62

1. What is logged

- **Authentication** - every Okta event: sign-in success and failure, MFA challenge, factor enrolment, admin action.
- **Authorisation** - every JIT production elevation, approval, and expiry.
- **Data access** - all queries against customer data in Snowflake, captured via `ACCESS\_HISTORY`, including the querying identity and the objects touched.
- **Infrastructure** - A

gs://attestor-505506-corporus/security/logging-monitoring-standard.txt

120. Provide your public privacy policy. Provide supporting evidence.

legal · Q120 · Vendor Security Review row 121

Quarantined: Model Armor blocked this question.

Release status: No — quarantined by the guardrail · confidence low · drafted by ArmorGuard

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

121. For which data stores are customer-managed keys available?

engineering · Q121 · Vendor Security Review row 122

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] data-flow-and-shared-responsibility — 1. Data flow, end to end — relevance 0.67

1. Data flow, end to end

1. **Ingress** - A customer's browser or API client resolves `app.kestreldata.com` or `api.kestreldata.com` to Cloudflare, which terminates TLS 1.3 (1.2 minimum) and applies WAF and rate limiting.
2. **Instance selection** - DNS and tenant routing send the request to the instance chosen at contract signature: `us-east-1` or `eu-west-1`. A tenant's requests never c

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[2] backup-restore-procedure — 2. Encryption and location — relevance 0.66

2. Encryption and location

All backups are encrypted with AES-256 using AWS KMS. The daily logical dump uses a **separate CMK** from the primary database, so that compromise of the primary key does not compromise the backups.

Cross-region replication stays inside the residency boundary: `us-east-1` replicates to `us-west-2`, `eu-west-1` replicates to `eu-central-1`. EU customer data never le

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[3] secrets-management-standard — 6. Customer-issued API credentials — relevance 0.64

6. Customer-issued API credentials

API keys issued to customers are stored as Argon2id hashes; Kestrel cannot recover the plaintext of a customer API key and will not do so on request. Keys are displayed once at creation. Customers can create, scope, and revoke keys through the console, and each key carries a last-used timestamp so stale keys are visible.

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

[4] data-flow-and-shared-responsibility — 6. Where processing occurs — relevance 0.61

6. Where processing occurs

Processing occurs in AWS `us-east-1` (US instance) and AWS `eu-west-1` (EU instance), by personnel located in the United States, the European Union, the United Kingdom, and Canada, under the access controls in KD-SEC-002. ****No processing occurs outside the stated regions**, and no support is subcontracted to a third-party provider in another jurisdiction.**

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[5] data-flow-and-shared-responsibility — 3. The shared responsibility model — relevance 0.61

3. The shared responsibility model

Security of the platform is Kestrel's. Security of what the customer does with it is the customer's. The line is drawn here rather than left implicit, because an unstated boundary is where a breach lands on whoever is less able to argue.

****Kestrel is responsible for:****

* physical and environmental security of the infrastructure (through AWS), and the cloud
co

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

122. Do you encrypt data in transit, and which TLS versions do you support?

security · Q122 · Vendor Security Review row 123

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

123. Which MFA factors are permitted? Are SMS or TOTP still accepted?

security · Q123 · Vendor Security Review row 124

Hardware-backed MFA (WebAuthn / FIDO2, YubiKey 5 series) is mandatory for all human accounts across Kestrel Data (`access-control-standard`, Section 2. "Multi-factor authentication"). SMS and TOTP are no longer accepted; both factors were deprecated and removed on June 30, 2025, in accordance with the RISK-2025-0031 treatment plan (`access-control-standard`, Section 2. "Multi-factor authentication"). Hardware-backed MFA coverage is maintained at 100% across all 187 active employee accounts and 24 active contractor accounts, continuously verified via Vanta control AC-07.

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by SecurityAgent

Evidence (5)

[1] access-control-standard — 2. Multi-factor authentication — relevance 0.65

2. Multi-factor authentication

Hardware-backed MFA (WebAuthn / FIDO2, YubiKey 5 series) is mandatory for every human account. SMS and TOTP were removed as acceptable factors on 30 June 2025 following the RISK-2025-0031 treatment plan. Coverage is 100% of the 187 active employee accounts and 100% of the 24 active contractor accounts, verified continuously by Vanta control AC-07.

gs://attestor-505506-corporus/security/access-control-standard.txt

[2] access-control-standard — 9. Password requirements — relevance 0.58

9. Password requirements

Where a password is used, minimum length is 14 characters, checked against the Have I

Been Pwned breached-password corpus at set time. Rotation is not forced on a schedule, in line with NIST SP 800-63B guidance; rotation is forced on evidence of compromise.

gs://attestor-505506-corporus/security/access-control-standard.txt

[3] access-control-standard — 3. Role-based access — relevance 0.54

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix (`SEC-GOV/access-matrix`), which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is just-in-time.

gs://attestor-505506-corporus/security/access-control-standard.txt

[4] access-control-standard — 1. Identity provider — relevance 0.54

1. Identity provider

All Kestrel Data systems authenticate through Okta (tenant `kestreldata.okta.com`). Local accounts on production systems are prohibited except for two documented break-glass accounts held in a sealed 1Password vault, whose use triggers a PagerDuty alert to the CISO. Both break-glass credentials were last rotated on 3 January 2026 and last used on 14 August 2025 during the

gs://attestor-505506-corporus/security/access-control-standard.txt

[5] access-control-standard — 10. Remote access — relevance 0.51

10. Remote access

There is no traditional VPN. Access to internal applications is mediated by Cloudflare Access with device posture checks requiring disk encryption, a current OS, and an enrolled MDM profile (Kandji for macOS, 163 devices as of 1 February 2026).

gs://attestor-505506-corporus/security/access-control-standard.txt

124. Please confirm: In which cloud regions is the production platform hosted?

engineering · Q124 · Vendor Security Review row 125

Kestrel's production platform is hosted on Amazon Web Services (AWS) across two independent production instances:

* **US Instance:** Hosted in `us-east-1` across three availability zones, serving North America and customers with no specific data residency requirements, with backup replication targeting `us-west-2`. * **EU Instance:** Hosted in `eu-west-1` across three availability zones, serving EEA, UK, and Swiss customers electing EU data residency, with backup replication targeting `eu-central-1`. Backup replication remains strictly within each respective residency boundary (`infrastructure-architecture-overview`, Section 1: "Cloud footprint").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] infrastructure-architecture-overview — 1. Cloud footprint — relevance 0.63

1. Cloud footprint

Kestrel runs on **Amazon Web Services**. There are two independent production instances:

Instance	Region	Serves
----------	--------	--------

---	---	---
-----	-----	-----

US	`us-east-1` (3 AZs)	North America, and customers with no residency requirement
----	---------------------	--

EU	`eu-west-1` (3 AZs)	EEA, UK, and Swiss customers electing EU residency
----	---------------------	--

Backup replication targets `us-west-2` and `eu-central-1` respecti

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[2] infrastructure-architecture-overview — 3. Compute — relevance 0.62

3. Compute

Amazon EKS (Kubernetes 1.31) with managed node groups spanning three availability zones. Workloads run as containers built from distroless base images, as non-root, with read-only root filesystems and dropped Linux capabilities. Pod Security Standards are enforced at

the `restricted` level.

Node images are immutable; nodes are recycled with a maximum age of 30 days rather than pa

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[3] infrastructure-architecture-overview — 6. Network — relevance 0.61

6. Network

Private subnets for all compute and data. No public IP addresses on workload instances. Ingress is exclusively through Cloudflare, then an AWS Application Load Balancer, then the Istio ingress gateway. Egress is through NAT gateways with an allowlist for known destinations.

Security groups are managed in Terraform and default-deny. There are no `0.0.0.0/0` ingress rules in produc

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[4] infrastructure-architecture-overview — 7. Observability — relevance 0.58

7. Observability

Datadog for metrics, logs, APM, and security monitoring. Distributed tracing uses W3C Trace Context propagated across all services. Every log line carries `tenant\_id` and `request\_id`.

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[5] infrastructure-architecture-overview — 4. Data layer — relevance 0.58

4. Data layer

Store	Technology	Purpose
Primary OLTP	Amazon RDS PostgreSQL 16, Multi-AZ	Application state
Analytics	Snowflake	Customer analytics workloads
Object storage	Amazon S3	Uploads, exports, backups
Cache	Amazon ElastiCache (Redis 7)	Session and query cache
Search	OpenSearch 2.13	In-product search

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

125. Which transfer mechanism do you rely on for transfers out of the EEA?

legal · Q125 · Vendor Security Review row 126

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] standard-contractual-clauses-summary — 2. UK and Switzerland — relevance 0.73

2. UK and Switzerland

- **UK** - the ICO International Data Transfer Addendum (version B1.0, in force 21 March 2022) is appended to the EU SCCs. UK GDPR references replace EU GDPR references; the competent authority is the ICO.
- **Switzerland** - the Swiss Annex applies. The FDPIC is the competent authority, and references to Member State law are read as references to Swiss law. The SCC

gs://attestor-505506-corporus/legal/standard-contractual-clauses-summary.txt

[2] data-processing-agreement — 10. International transfers — relevance 0.72

10. International transfers

Where Personal Data is transferred out of the EEA, UK, or Switzerland, the parties enter into the **2021 EU Standard Contractual Clauses** (Commission Implementing Decision 2021/914), Module Two (Controller to Processor) or Module Three (Processor to Sub-processor) as applicable, incorporated by reference. The UK International Data Transfer Addendum and the Swiss An

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[3] transfer-impact-assessment — 3. Transfer mechanism — relevance 0.72

3. Transfer mechanism

The 2021 **Standard Contractual Clauses, Module Two (controller to processor)** apply between the customer and Kestrel, and **Module Three (processor to sub-processor)** between Kestrel and its US sub-processors. The **UK International Data Transfer Addendum** is incorporated for UK exports, and for Switzerland the SCCs are applied with the adaptations published by the Swiss

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

[4] privacy-policy — 6. International transfers — relevance 0.69

6. International transfers

Personal data is processed in the United States and the European Union. Transfers out of the EEA rely on the 2021 Standard Contractual Clauses with supplementary measures described in the Transfer Impact Assessment (KD-LEG-006).

gs://attestor-505506-corporus/legal/privacy-policy.txt

[5] transfer-impact-assessment — Transfer Impact Assessment — relevance 0.68

Transfer Impact Assessment

Document ID: KD-LEG-010 · **Version:** 2.1 · **Owner:** Priya Raghunathan, DPO

Approved: 9 January 2026 · **Next review:** 9 January 2027

Maps to: GDPR Articles 44–49 · EDPB Recommendations 01/2020 · Schrems II (C-311/18)

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

126. How frequently are Tier 1 vendors reassessed?

security · Q126 · Vendor Security Review row 127

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

127. Do you maintain a formal risk register? How frequently is it reviewed?

security · Q127 · Vendor Security Review row 128

Kestrel maintains a formal risk register, which is hosted in Vanta with a mirrored export preserved in the `SEC-GOV` repository. The risk register is reviewed monthly by the Security Steering Group and formally re-scored on a quarterly cadence. In addition, a full risk assessment is conducted annually, with ad-hoc assessments triggered by events such as material architecture changes, new subprocessors handling customer data, Sev-1 incidents, or high-severity findings from external testing (**Risk Management and Security Governance**, Section 4, "The risk register" and Section 6, "Risk assessment cadence").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] risk-management-and-governance — 4. The risk register — relevance 0.67

4. The risk register

Kestrel maintains a formal risk register, reviewed monthly by the Security Steering Group and formally re-scored quarterly. It is held in Vanta with a mirrored export in the `SEC-GOV` repository so that history is preserved even if the tooling changes.

Each risk carries an identifier (**RISK-YYYY-NNNN**), a description, an owner who is a named individual rather than a team,

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[2] information-security-policy — 4. Risk management — relevance 0.65

4. Risk management

Kestrel maintains a risk register in Vanta, reviewed monthly by the Security Council. Risks are scored on a 5×5 likelihood/impact matrix. Any risk scoring 15 or above requires

a documented treatment plan with a named owner and a due date, and is reported to the Board Audit & Risk Committee at the next quarterly meeting.

As of the February 2026 review the register holds 34 open

gs://attestor-505506-corporus/security/information-security-policy.txt

[3] risk-management-and-governance — 6. Risk assessment cadence — relevance 0.64

6. Risk assessment cadence

A full risk assessment is performed annually, most recently completed on 20 January 2026.

Additional assessments are triggered by: a new subprocessor handling customer data, a material architecture change, a Sev-1 incident, entry into a new regulated market, and any finding rated High or above from an external test.

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[4] risk-management-and-governance — Risk Management and Security Governance — relevance 0.62

Risk Management and Security Governance

Document ID: KD-SEC-018 · **Version:** 3.0 · **Owner:** Marcus Oyelaran, CISO

Approved: 26 January 2026 · **Next review:** 26 January 2027

Maps to: SOC 2 CC1.1, CC1.2, CC1.3, CC3.1, CC3.2, CC3.4 · ISO 27001:2022 A.5.1–A.5.4, Clauses 5–6, 9

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[5] risk-management-and-governance — 8. Policy management — relevance 0.62

8. Policy management

All security policies carry a document ID, a version, a named owner, an approval date, and a review date. Policies are reviewed at least annually and on material change. The 2026 review cycle covered 14 policies between 8 January and 12 February 2026; three were revised, and the changes were communicated at the February all-hands and through the annual acknowledgement cycle.

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

128. Can a single customer be restored without affecting other tenants?

engineering · Q128 · Vendor Security Review row 129

Yes, a single customer can be restored without affecting other tenants. Under the restore procedure, restorations are executed by first restoring the snapshot or point-in-time recovery target into an isolated restore account, after which only the specific tenant's data rows are exported back to production (`backup-restore-procedure`, Section 3: Restore procedure, and Section 5: Tenant-scoped restore).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] backup-restore-procedure — 5. Tenant-scoped restore — relevance 0.71

5. Tenant-scoped restore

A single customer can be restored without affecting others, by restoring to an isolated account and exporting that tenant rows back. This was exercised once in production, on 22 September 2025, at a customer request following an erroneous bulk delete on their side. Time to complete was 5 hours 10 minutes.

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[2] backup-restore-procedure — 3. Restore procedure — relevance 0.67

3. Restore procedure

1. Declare the restore scope: point in time, and whether tenant-scoped or full.
2. Provision an isolated restore account from the Terraform module `restore-target`.
3. Restore the RDS snapshot or PITR target into the isolated account.
4. Run the integrity suite: 1,240 assertions covering row counts, referential integrity, tenant isolation invariants, and known-value spo

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[3] backup-restore-procedure — 6. Backup deletion — relevance 0.62

6. Backup deletion

Backups expire automatically. When a customer terminates and the tenant purge runs, backups containing that data expire on the normal cycle, a maximum of **35 days** later. Kestrel does not selectively surgically remove a tenant from historical backup images, and says so rather than implying otherwise.

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[4] backup-restore-procedure — 4. Test results — relevance 0.59

4. Test results

Restore is tested **quarterly**, and the test is a real restore, not a backup-listing check.

Quarter	Date	Duration	Assertions	Outcome
Q1 2026	17 Jan 2026	2h 41m	1,240 / 1,240	Pass
Q4 2025	11 Oct 2025	3h 02m	1,238 / 1,240	Pass, 2 known-stale fixtures corrected
Q3 2025	19 Jul 2025	3h 20m	1,240 / 1,240	Pass

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[5] backup-restore-procedure — Backup and Restore Procedure — relevance 0.58

Backup and Restore Procedure

Document ID: KD-ENG-004 · **Version:** 2.5 · **Owner:** Sofia Brenner, Head of IT
Approved: 29 January 2026 · **Maps to:** SOC 2 A1.2 · ISO 27001:2022 A.8.13

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

129. Do you process special category personal data?

legal · Q129 · Vendor Security Review row 130

Kestrel Data does not intentionally or knowingly process special category personal data under Article 9 of the GDPR (`gdpr-records-of-processing`, "Special category data"; `dpia-register`, "3. Special category data"). The platform is not designed to hold special category data, and no field in the data model is intended for it (`dpia-register`, "3. Special category data"). Customers are contractually prohibited under the master agreement's Acceptable Use terms from uploading special category data without a prior written agreement with Kestrel's General Counsel, and no such agreement is in place (`gdpr-records-of-processing`, "Special category data"; `dpia-register`, "3. Special category data"). Because customer-uploaded datasets are opaque by design, Kestrel applies uniform encryption, access controls, and retention standards appropriate for sensitive data across all customer content (`dpia-register`, "3. Special category data").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] gdpr-records-of-processing — Special category data — relevance 0.71

Special category data

Kestrel does **not** intentionally process special category data under Art. 9 in the course of providing the Service. Customers are contractually prohibited from uploading special category data without a prior written agreement; no such agreement is in force as of 20 January 2026.

gs://attestor-505506-corporus/legal/gdpr-records-of-processing.txt

[2] dpia-register — 3. Special category data — relevance 0.70

3. Special category data

Kestrel does not knowingly process special category personal data under Article 9. The platform is not designed for it, the Acceptable Use terms in the master agreement prohibit uploading it, and no field in the data model is intended to hold it.

Kestrel cannot inspect customer-uploaded datasets — they are opaque by design — so the control is contractual and architect

gs://attestor-505506-corporus/legal/dpia-register.txt

[3] data-processing-agreement — 3. Confidentiality — relevance 0.63

3. Confidentiality

Kestrel ensures that personnel authorised to process Personal Data are bound by confidentiality obligations surviving termination of employment. All staff execute a confidentiality agreement at onboarding.

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[4] privacy-policy — 7. Complaints — relevance 0.63

7. Complaints

Complaints may be made to the Irish Data Protection Commission or to the supervisory authority of the data subject habitual residence.

gs://attestor-505506-corporus/legal/privacy-policy.txt

[5] gdpr-records-of-processing — Part A - Kestrel as Processor (Art. 30(2)) — relevance 0.62

Part A - Kestrel as Processor (Art. 30(2))

Controller: each Kestrel customer, as identified in the applicable Order Form.

Processor: Kestrel Data, Inc.

DPO: Priya Raghunathan, `dpo@kestreldata.com`

| # | Processing activity | Categories of data subject | Categories of personal data | Transfers | Retention |

|---|---|---|---|---|---|

| P1 | Hosting and operating the Kestrel Insig

gs://attestor-505506-corporus/legal/gdpr-records-of-processing.txt

130. Will you notify customers of a government request for their data?

legal · Q130 · Vendor Security Review row 131

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] government-requests-and-transparency-report — Government Requests Policy and Transparency Report — relevance 0.67

Government Requests Policy and Transparency Report

Document ID: KD-LEG-012 · **Version:** 2.0 · **Owner:** Aaron Feldstein, General Counsel

Approved: 2 February 2026 · **Next review:** 2 February 2027

Maps to: GDPR Articles 48, 28(3)(a) · SOC 2 CC2.3 · ISO 27001:2022 A.5.5, A.5.31, A.5.34

gs://attestor-505506-corporus/legal/government-requests-and-transparency-report.txt

[2] government-requests-and-transparency-report — 1. Who may receive a request — relevance 0.66

1. Who may receive a request

All law enforcement, regulatory, and national security requests for customer data must be directed to the General Counsel at `legal@kestreldata.com`. No other person at Kestrel is authorised to accept service or to disclose customer data to a government authority.

Support, sales, and engineering personnel are trained to route any such approach to the General Counsel with

gs://attestor-505506-corporus/legal/government-requests-and-transparency-report.txt

[3] government-requests-and-transparency-report — 6. Records — relevance 0.63

6. Records

The government request register is retained for ten years and is available to the auditors and, in redacted form, to a customer exercising audit rights. Retention is longer than the ordinary schedule deliberately: the value of this record is precisely that it goes back further than anyone's memory.

gs://attestor-505506-corporus/legal/government-requests-and-transparency-report.txt

[4] data-subject-rights-procedure — 9. Records — relevance 0.63

9. Records

Every request, its route, and its resolution date are recorded in the DSR register held by the DPO and retained for three years. The register is available to auditors and, in

redacted form, to customers exercising their audit rights under the DPA.

gs://attestor-505506-corpus/legal/data-subject-rights-procedure.txt

[5] data-subject-rights-procedure — Data Subject Rights Procedure — relevance 0.63

Data Subject Rights Procedure

Document ID: KD-LEG-007 · **Version:** 2.3 · **Owner:** Priya Raghunathan, DPO

Approved: 20 January 2026 · **Next review:** 20 January 2027

Maps to: GDPR Articles 12, 15–22, 28(3)(e) · CCPA/CPRA §1798.100–130

gs://attestor-505506-corpus/legal/data-subject-rights-procedure.txt

131. What is the export window available after termination?

legal · Q131 · Vendor Security Review row 132

Following termination, customers have an export window of 30 days to retrieve and export their data through the service (Data Processing Agreement, Section 8; Master Agreement Summary, Section 7; Data Retention Schedule, Section 1). After this 30-day export window closes, customer data is deleted from primary storage within 90 days, and backups containing deleted data expire on the standard backup cycle within a maximum of 35 days following primary deletion (Data Processing Agreement, Section 8; Data Retention Schedule, Section 1). Certification of deletion is provided upon written request (Data Processing Agreement, Section 8).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] data-processing-agreement — 8. Deletion and return — relevance 0.68

8. Deletion and return

On termination, Customer may export its data through the Service for **30 days**. After that period Kestrel deletes Customer Personal Data within **90 days**, save where storage is required by law. Backups containing deleted data expire on the standard backup cycle, a maximum of **35 days** after deletion from primary storage. Certification of deletion is provided on wri

gs://attestor-505506-corpus/legal/data-processing-agreement.txt

[2] master-agreement-summary — 7. Term, termination and transition — relevance 0.67

7. Term, termination and transition

The standard term is 12 months with automatic renewal on 30 days' notice of non-renewal. Either party may terminate for material breach uncured after 30 days, or immediately on the other's insolvency.

On termination the customer retains access to export their data for **30 days**, after which live data is deleted within 30 days and backups expire on the ordinar

gs://attestor-505506-corpus/legal/master-agreement-summary.txt

[3] data-retention-schedule — 4. Deletion verification — relevance 0.65

4. Deletion verification

The `tenant-purge` job emits a structured completion record listing every store touched and the row or object counts removed. That record is retained for 7 years as evidence of deletion and is the artefact provided when a customer requests certification of deletion.

Deletion was exercised 11 times in 2025 (customer churn). Median time from termination to completed pu

gs://attestor-505506-corpus/legal/data-retention-schedule.txt

[4] data-retention-schedule — 1. Customer data — relevance 0.64

1. Customer data

| Data class | Active retention | Post-termination | Deletion mechanism |

|---|---|---|---|

| Customer records in the platform | Term of subscription | **30 days** export window, then deleted within **90 days** | Automated `tenant-purge` job, nightly |

| Analytics warehouse (Snowflake) | Term | Deleted with tenant purge | Automated |

gs://attestor-505506-corporus/legal/data-retention-schedule.txt

[5] data-subject-rights-procedure — 5. Erasure (Article 17) — relevance 0.64

5. Erasure (Article 17)

Erasure of controller-side data is completed within 30 calendar days. Erasure of processor-side data is executed on customer instruction; deletion from live systems is immediate, and **encrypted backups containing the deleted data expire on the ordinary backup rotation within 35 days**. Kestrel does not selectively edit backups, and says so: surgical deletion inside an encr

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

132. Do you subscribe to threat intelligence feeds?

security · Q132 · Vendor Security Review row 133

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

133. Describe your privileged access management approach for production systems.

security · Q133 · Vendor Security Review row 134

Kestrel Data governs privileged access to production systems under the principle of least privilege, combining strict role-based controls, just-in-time (JIT) elevation, mandatory multi-factor authentication, and comprehensive session logging. **Identity Federation and Role-Based Access:** Identity is federated through Okta using SAML 2.0, and hardware-backed multi-factor authentication (WebAuthn / FIDO2 security keys) is mandatory for all staff (**information-security-policy**, Section 7: Access control). Human access to AWS is federated via IAM Identity Center, and no IAM users with long-lived access keys exist in any account (**cloud-security-posture-standard**, Section 7: Cloud identity). Privileges are assigned to Okta groups across 41 defined roles documented in the authoritative Access Matrix (**access-control-standard**, Section 3: Role-based access). **Restricted Standing Access:** Standing production access is restricted to 11 named Site Reliability Engineers (**access-control-standard**, Section 3: Role-based access). **Just-In-Time Elevation:** All other production access is provisioned on a just-in-time basis via a `/access`` Slack workflow. Each elevation request requires a written business justification, a linked incident or change ticket, and approval from a second engineer holding the SRE role, with self-approval strictly blocked (**access-control-standard**, Section 4: Just-in-time production access). The workflow also notifies the Security Council channel in real time (**information-security-policy**, Section 7: Access control). **Time Expiration and Session Auditing:** Granted production access automatically expires after 8 hours (**access-control-standard**, Section 4: Just-in-time production access; **information-security-policy**, Section 7: Access control). All commands executed during an elevated session are recorded via AWS Systems Manager Session Manager and shipped to an immutable log archive (**access-control-standard**, Section 4: Just-in-time production access).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] access-control-standard — 3. Role-based access — relevance 0.67

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix (`SEC-GOV/access-matrix``), which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is just-in-time.

gs://attestor-505506-corporus/security/access-control-standard.txt

[2] access-control-standard — 4. Just-in-time production access — relevance 0.65

4. Just-in-time production access

Engineers request elevated production access through the `/access`` Slack workflow. A request requires a written business justification, a linked incident or change ticket,

and approval from a second engineer holding the SRE role. Self-approval is blocked.

Granted access expires automatically after ****8 hours****. All commands executed in an elevated session are

gs://attestor-505506-corporus/security/access-control-standard.txt

[3] information-security-policy — 7. Access control — relevance 0.64

7. Access control

Access follows least privilege and is governed by the Access Control Standard (KD-SEC-002). Identity is federated through Okta with SAML 2.0. Hardware-backed multi-factor authentication (WebAuthn / FIDO2 security keys) is mandatory for all staff; SMS and TOTP were retired as authentication factors on 30 June 2025.

Production access requires a documented business justification, e

gs://attestor-505506-corporus/security/information-security-policy.txt

[4] cloud-security-posture-standard — 8. Logging and evidence — relevance 0.62

8. Logging and evidence

CloudTrail (all regions, all accounts), VPC flow logs, GuardDuty findings, and Config history are delivered to a dedicated `kd-security` account that no engineering role can write to, with object lock set to 400 days. This is the arrangement that makes the audit trail defensible: the accounts that generate the evidence cannot alter it.

gs://attestor-505506-corporus/security/cloud-security-posture-standard.txt

[5] cloud-security-posture-standard — 7. Cloud identity — relevance 0.61

7. Cloud identity

Human access to AWS is federated from Okta through IAM Identity Center; there are ****no IAM users with long-lived access keys in any account****, and the SCP set prevents their creation. Workloads use IAM Roles for Service Accounts. The last static access key in the estate was decommissioned on 17 November 2024.

gs://attestor-505506-corporus/security/cloud-security-posture-standard.txt

134. Do you support SAML or OIDC single sign-on?

security · Q134 · Vendor Security Review row 135

Kestrel Data supports single sign-on by federating identity through Okta using SAML 2.0 across all systems (Information Security Policy, Section 7, "Access control"; Access Control Standard, Section 1, "Identity provider"). In addition, mandatory hardware-backed multi-factor authentication (WebAuthn / FIDO2 security keys) is enforced for all staff, and local accounts on production systems are prohibited with the exception of two documented break-glass accounts (Information Security Policy, Section 7, "Access control"; Access Control Standard, Section 1, "Identity provider").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by SecurityAgent

Evidence (5)

[1] access-control-standard — 3. Role-based access — relevance 0.62

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix (`SEC-GOV/access-matrix`), which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is just-in-time.

gs://attestor-505506-corporus/security/access-control-standard.txt

[2] information-security-policy — 7. Access control — relevance 0.61

7. Access control

Access follows least privilege and is governed by the Access Control Standard (KD-SEC-002). Identity is federated through Okta with SAML 2.0. Hardware-backed multi-factor authentication (WebAuthn / FIDO2 security keys) is mandatory for all staff;

SMS and TOTP were retired as authentication factors on 30 June 2025.

Production access requires a documented business justification, e

gs://attestor-505506-corporus/security/information-security-policy.txt

[3] access-control-standard — Access Control Standard — relevance 0.58

Access Control Standard

****Document ID:**** KD-SEC-002 · ****Version:**** 3.1 · ****Owner:**** Sofia Brenner, Head of IT

****Approved:**** 8 January 2026 · ****Next review:**** 8 January 2027

****Maps to:**** SOC 2 CC6.1, CC6.2, CC6.3 · ISO 27001:2022 A.5.15, A.5.16, A.5.18, A.8.2

gs://attestor-505506-corporus/security/access-control-standard.txt

[4] access-control-standard — 9. Password requirements — relevance 0.57

9. Password requirements

Where a password is used, minimum length is 14 characters, checked against the Have I Been Pwned breached-password corpus at set time. Rotation is not forced on a schedule, in line with NIST SP 800-63B guidance; rotation is forced on evidence of compromise.

gs://attestor-505506-corporus/security/access-control-standard.txt

[5] access-control-standard — 1. Identity provider — relevance 0.56

1. Identity provider

All Kestrel Data systems authenticate through Okta (tenant `kestreldata.okta.com`). Local accounts on production systems are prohibited except for two documented break-glass accounts held in a sealed 1Password vault, whose use triggers a PagerDuty alert to the CISO. Both break-glass credentials were last rotated on 3 January 2026 and last used on 14 August 2025 during the

gs://attestor-505506-corporus/security/access-control-standard.txt

135. For each applicable system: Is your organisation subject to any pending litigation relating to data protection?

legal · Q135 · Vendor Security Review row 136

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

136. Provide your security awareness training completion rate.

security · Q136 · Vendor Security Review row 137

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] personnel-security-and-training — 4. Security awareness training — relevance 0.68

4. Security awareness training

Security awareness training is ****mandatory for all personnel, annually, plus at onboarding within the first 14 days****. Training is delivered through Curricula and runs approximately 45 minutes, covering phishing, credential handling, data classification, secure remote working, and incident reporting.

Measured completion for the 2025 cycle was ****99.5%**** (210 of 211 i

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[2] personnel-security-and-training — 5. Simulated phishing — relevance 0.62

5. Simulated phishing

Kestrel runs simulated phishing exercises ****quarterly**** through Curricula, targeting all

personnel with a Kestrel mailbox. Results for 2025:

Quarter	Sent	Click rate	Credential submission	Reported to security
Q1 2025	198	6.1%	1.0%	41%
Q2 2025	203	4.4%	0.5%	52%
Q3 2025	208	3.4%	0.0%	58%
Q4 2025	211	**2		

gs://attestor-505506-corpus/security/personnel-security-and-training.txt

[3] personnel-security-and-training — 6. Secure development training — relevance 0.59

6. Secure development training

Engineers complete role-specific secure development training annually, in addition to the general awareness training. The 2025 curriculum was Secure Code Warrior's OWASP Top 10 path plus an internal module on tenant isolation written by the platform team after the INSEC-2026-0219 penetration test. Completion for the 63 engineers in scope was 100% as of 19 December 20

gs://attestor-505506-corpus/security/personnel-security-and-training.txt

[4] personnel-security-and-training — 3. Acceptable use and policy acknowledgement — relevance 0.58

3. Acceptable use and policy acknowledgement

Personnel acknowledge the Acceptable Use Policy (KD-SEC-005) and this standard at onboarding and annually thereafter. Acknowledgement is tracked in Vanta; the 2025 annual cycle closed on 30 November 2025 at **100%** completion across 187 employees and 24 contractors.

gs://attestor-505506-corpus/security/personnel-security-and-training.txt

[5] information-security-policy — 6. Personnel security — relevance 0.58

6. Personnel security

All employees and contractors undergo background screening appropriate to jurisdiction before their start date, conducted by Checkr. Screening covers identity verification, right to work, criminal records where lawful, and employment history for the preceding seven years.

Security awareness training is delivered through Curricula at onboarding and annually thereafter. Comple

gs://attestor-505506-corpus/security/information-security-policy.txt

137. For each applicable system: Is restore tested by performing an actual restore, or by verifying backup existence?

engineering · Q137 · Vendor Security Review row 138

Restore is tested quarterly by performing an actual restore rather than merely verifying backup existence ('backup-restore-procedure', "4. Test results"). During testing, the restore target (such as an RDS snapshot or point-in-time recovery target) is restored into an isolated account provisioned via Terraform, followed by executing an integrity suite of 1,240 assertions covering row counts, referential integrity, tenant isolation invariants, and known-value spot checks to verify the restored data against the pre-incident state ('backup-restore-procedure', "3. Restore procedure" and "4. Test results").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] backup-restore-procedure — 4. Test results — relevance 0.71

4. Test results

Restore is tested **quarterly**, and the test is a real restore, not a backup-listing check.

Quarter	Date	Duration	Assertions	Outcome
Q1 2026	17 Jan 2026	2h 41m	1,240 / 1,240	Pass

| Q4 2025 | 11 Oct 2025 | 3h 02m | 1,238 / 1,240 | Pass, 2 known-stale fixtures corrected |
| Q3 2025 | 19 Jul 2025 | 3h 20m | 1,240 / 1,240 | Pass |

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[2] backup-restore-procedure — 3. Restore procedure — relevance 0.65

3. Restore procedure

1. Declare the restore scope: point in time, and whether tenant-scoped or full.
2. Provision an isolated restore account from the Terraform module `restore-target`.
3. Restore the RDS snapshot or PITR target into the isolated account.
4. Run the integrity suite: 1,240 assertions covering row counts, referential integrity, tenant isolation invariants, and known-value spo

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[3] backup-restore-procedure — 5. Tenant-scoped restore — relevance 0.65

5. Tenant-scoped restore

A single customer can be restored without affecting others, by restoring to an isolated account and exporting that tenant rows back. This was exercised once in production, on 22 September 2025, at a customer request following an erroneous bulk delete on their side. Time to complete was 5 hours 10 minutes.

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[4] backup-restore-procedure — Backup and Restore Procedure — relevance 0.61

Backup and Restore Procedure

Document ID: KD-ENG-004 · **Version:** 2.5 · **Owner:** Sofia Brenner, Head of IT
Approved: 29 January 2026 · **Maps to:** SOC 2 A1.2 · ISO 27001:2022 A.8.13

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[5] backup-restore-procedure — 1. What is backed up — relevance 0.54

1. What is backed up

| Asset | Method | Frequency | Retention |

|---|---|---|---|

RDS PostgreSQL	Automated snapshots + WAL archiving (PITR)	Continuous	****35 days****
RDS logical dump	`pg\_dump` to S3, encrypted with a separate CMK	Daily 03:00 UTC	90 days
S3 objects	Versioning + cross-region replication	Continuous	90 days for non-current versions
Snowflake	Time Tr		

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

138. Is production data ever copied to non-production environments?

engineering · Q138 · Vendor Security Review row 139

Production data is never copied to lower or non-production environments. Non-production environments utilize only synthetic fixtures and anonymized data: local developer machines and CI environments use synthetic fixtures, and staging fixtures are generated synthetically via automated tooling (`tools/gen\_fixtures.py`). Kestrel Data does not maintain or permit any sanitized production dump process (`sdlc-policy`, Section 2 "Environments").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] sdlc-policy — 2. Environments — relevance 0.72

2. Environments

| Environment | Purpose | Data |

|---|---|---|

`local`	Developer machines	Synthetic fixtures only
`ci`	Automated testing	Synthetic fixtures only
`staging`	Pre-production verification	Synthetic and anonymised data
`production`	Live service	Customer data

****Production data is never copied to a lower environment.**** Staging fixtures are generated

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[2] sdlc-policy — 3. Testing requirements — relevance 0.56

3. Testing requirements

- Unit test coverage gate at **80%** on changed lines, enforced in CI.
- Integration tests run against ephemeral infrastructure provisioned per pull request.
- Tenant isolation tests run on every build: a suite of 84 assertions attempting cross-tenant reads through every public API surface.
- Load tests before any release expected to change the performance profile.

gs://attestor-505506-corporate-engineering/sdlc-policy.txt

[3] sdlc-policy — 6. Release — relevance 0.56

6. Release

Releases are continuous: merge to `main` triggers a deployment to staging, an automated verification suite, and then a progressive rollout to production. Rollout is canary-based: 5% of traffic for 15 minutes, then 25%, then 100%, with automatic rollback on error-rate or latency regression.

Median lead time from merge to production in 2025 was **34 minutes**. Change failure rate w

gs://attestor-505506-corporate-engineering/sdlc-policy.txt

[4] sdlc-policy — Secure Software Development Lifecycle Policy — relevance 0.53

Secure Software Development Lifecycle Policy

Document ID: KD-ENG-001 · **Version:** 4.1 · **Owner:** Dana Whitfield, VP Engineering
Approved: 20 January 2026 · **Next review:** 20 January 2027
Maps to: SOC 2 CC8.1 · ISO 27001:2022 A.8.25-A.8.31

gs://attestor-505506-corporate-engineering/sdlc-policy.txt

[5] sdlc-policy — 7. Separation of duties — relevance 0.52

7. Separation of duties

Engineers cannot deploy their own change to production without the automated pipeline: no human has the ability to push a container image to the production registry directly. The deployment role is held by the CI service identity, which authenticates through OIDC and holds no long-lived credentials.

gs://attestor-505506-corporate-engineering/sdlc-policy.txt

139. Do you accept SOC 2 and ISO 27001 reports in place of a customer audit?

legal · Q139 · Vendor Security Review row 140

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

140. Do you monitor for anomalous data export volumes?

security · Q140 · Vendor Security Review row 141

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

141. Are backups encrypted, and with which keys?

engineering · Q141 · Vendor Security Review row 142

All backups are encrypted at rest with AES-256 using AWS Key Management Service (AWS KMS) (`backup-restore-procedure`, §2 "Encryption and location"). Specifically, daily logical database dumps are encrypted using a dedicated Customer Master Key (CMK) separate from the primary database key, ensuring that a compromise of the primary database key does not compromise backup data (`backup-restore-procedure`, §1 "What is backed up", §2 "Encryption and location").

Evidence (5)

[1] backup-restore-procedure — 2. Encryption and location — relevance 0.71

2. Encryption and location

All backups are encrypted with AES-256 using AWS KMS. The daily logical dump uses a **separate CMK** from the primary database, so that compromise of the primary key does not compromise the backups.

Cross-region replication stays inside the residency boundary: `us-east-1` replicates to `us-west-2`, `eu-west-1` replicates to `eu-central-1`. EU customer data never le

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[2] backup-restore-procedure — 1. What is backed up — relevance 0.66

1. What is backed up

| Asset | Method | Frequency | Retention |

|---|---|---|---|

| RDS PostgreSQL | Automated snapshots + WAL archiving (PITR) | Continuous | **35 days** |

| RDS logical dump | `pg\_dump` to S3, encrypted with a separate CMK | Daily 03:00 UTC | 90 days |

| S3 objects | Versioning + cross-region replication | Continuous | 90 days for non-current versions |

| Snowflake | Time Tr

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[3] backup-restore-procedure — Backup and Restore Procedure — relevance 0.62

Backup and Restore Procedure

Document ID: KD-ENG-004 · **Version:** 2.5 · **Owner:** Sofia Brenner, Head of IT

Approved: 29 January 2026 · **Maps to:** SOC 2 A1.2 · ISO 27001:2022 A.8.13

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[4] backup-restore-procedure — 4. Test results — relevance 0.61

4. Test results

Restore is tested **quarterly**, and the test is a real restore, not a backup-listing check.

| Quarter | Date | Duration | Assertions | Outcome |

|---|---|---|---|---|

| Q1 2026 | 17 Jan 2026 | 2h 41m | 1,240 / 1,240 | Pass |

| Q4 2025 | 11 Oct 2025 | 3h 02m | 1,238 / 1,240 | Pass, 2 known-stale fixtures corrected |

| Q3 2025 | 19 Jul 2025 | 3h 20m | 1,240 / 1,240 | Pass |

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[5] data-flow-and-shared-responsibility — 1. Data flow, end to end — relevance 0.59

1. Data flow, end to end

1. **Ingress.** A customer's browser or API client resolves `app.kestreldata.com` or `api.kestreldata.com` to Cloudflare, which terminates TLS 1.3 (1.2 minimum) and applies WAF and rate limiting.

2. **Instance selection.** DNS and tenant routing send the request to the instance chosen at contract signature: `us-east-1` or `eu-west-1`. **A tenant's requests never c**

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

142. Who is accountable for information security at executive level?

security · Q142 · Vendor Security Review row 143

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

143. Have you appointed a Data Protection Officer? Provide contact details.

legal · Q143 · Vendor Security Review row 144

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] privacy-policy — 1. Controller and contact — relevance 0.67

1. Controller and contact

Kestrel Data, Inc., 1401 Lavaca Street, Suite 210, Austin, TX 78701, USA.

EU representative under Art. 27 GDPR: Instant EU Rep Ltd, Dublin, Ireland.

Data Protection Officer: Priya Raghunathan, `dpo@kestreldata.com`.

Lead supervisory authority: Irish Data Protection Commission.

gs://attestor-505506-corporus/legal/privacy-policy.txt

[2] dpia-register — Data Protection Impact Assessment Register — relevance 0.65

Data Protection Impact Assessment Register

Document ID: KD-LEG-011 · **Version:** 1.9 · **Owner:** Priya Raghunathan, DPO

Approved: 16 January 2026 · **Next review:** 16 January 2027

Maps to: GDPR Articles 35, 36, 9, 8, 22

gs://attestor-505506-corporus/legal/dpia-register.txt

[3] privacy-policy — 7. Complaints — relevance 0.65

7. Complaints

Complaints may be made to the Irish Data Protection Commission or to the supervisory authority of the data subject habitual residence.

gs://attestor-505506-corporus/legal/privacy-policy.txt

[4] gdpr-records-of-processing — Part A - Kestrel as Processor (Art. 30(2)) — relevance 0.65

Part A - Kestrel as Processor (Art. 30(2))

Controller: each Kestrel customer, as identified in the applicable Order Form.

Processor: Kestrel Data, Inc.

DPO: Priya Raghunathan, `dpo@kestreldata.com`

| # | Processing activity | Categories of data subject | Categories of personal data | Transfers | Retention |

| ---|---|---|---|---|---|

| P1 | Hosting and operating the Kestrel Insig

gs://attestor-505506-corporus/legal/gdpr-records-of-processing.txt

[5] gdpr-records-of-processing — GDPR Records of Processing Activities (Art. 30) — relevance 0.64

GDPR Records of Processing Activities (Art. 30)

Document ID: KD-LEG-005 · **Version:** 3.0 · **Owner:** Priya Raghunathan, DPO

Last updated: 20 January 2026 · **Next review:** 20 July 2026

Maintained under Art. 30(1) where Kestrel is controller and Art. 30(2) where Kestrel is processor. Available to supervisory authorities on request.

gs://attestor-505506-corporus/legal/gdpr-records-of-processing.txt

144. How long is customer data retained after contract termination?

legal · Q144 · Vendor Security Review row 145

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] data-retention-schedule — 1. Customer data — relevance 0.75

1. Customer data

| Data class | Active retention | Post-termination | Deletion mechanism |

| ---|---|---|---|

| Customer records in the platform | Term of subscription | **30 days** export window, then deleted within **90 days** | Automated

`tenant-purge` job, nightly |
| Analytics warehouse (Snowflake) | Term | Deleted with tenant purge | Automated |
| Uploaded files (S3) | Term | Deleted with

gs://attestor-505506-corporus/legal/data-retention-schedule.txt

[2] master-agreement-summary — 7. Term, termination and transition — relevance 0.74

7. Term, termination and transition

The standard term is 12 months with automatic renewal on 30 days' notice of non-renewal. Either party may terminate for material breach uncured after 30 days, or immediately on the other's insolvency.

On termination the customer retains access to export their data for **30 days**, after which live data is deleted within 30 days and backups expire on the ordinar

gs://attestor-505506-corporus/legal/master-agreement-summary.txt

[3] data-retention-schedule — 6. Exceptions — relevance 0.74

6. Exceptions

Where a retention period conflicts with a customer contractual requirement, the shorter period applies unless law requires otherwise. Longer retention requires DPO approval, which has not been granted for any customer data class to date.

gs://attestor-505506-corporus/legal/data-retention-schedule.txt

[4] data-processing-agreement — 8. Deletion and return — relevance 0.73

8. Deletion and return

On termination, Customer may export its data through the Service for **30 days**. After that period Kestrel deletes Customer Personal Data within **90 days**, save where storage is required by law. Backups containing deleted data expire on the standard backup cycle, a maximum of **35 days** after deletion from primary storage. Certification of deletion is provided on wri

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[5] data-retention-schedule — 2. Kestrel-controlled data — relevance 0.71

2. Kestrel-controlled data

| Data class | Retention | Basis |

|---|---|---|

| Account and contact records | Term + 3 years | Contract, limitation periods |

| Billing and tax records | **7 years** | US and Irish tax law |

| Product telemetry | 24 months | Legitimate interests, reviewed annually |

| Support tickets | Term + 2 years | Contract |

| Marketing contacts | Until consent withdrawal +

gs://attestor-505506-corporus/legal/data-retention-schedule.txt

145. Which cloud service providers do you use?

engineering · Q145 · Vendor Security Review row 146

Kestrel's customer-facing production infrastructure runs entirely on Amazon Web Services (AWS) across two independent production instances: US in `us-east-1` (with backup replication to `us-west-2`) and EU in `eu-west-1` (with backup replication to `eu-central-1`) (Document: `infrastructure-architecture-overview`, Section: `1. Cloud footprint`). Additionally, network ingress is routed through Cloudflare (Document: `infrastructure-architecture-overview`, Section: `6. Network`). A small number of internal, non-customer-facing workloads run on Google Cloud for internal finance reporting using BigQuery; no customer data is processed on Google Cloud (Document: `infrastructure-architecture-overview`, Section: `1. Cloud footprint`).

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (5)

[1] infrastructure-architecture-overview — 1. Cloud footprint — relevance 0.59

1. Cloud footprint

Kestrel runs on **Amazon Web Services**. There are two independent production instances:

Instance	Region	Serves
US	`us-east-1` (3 AZs)	North America, and customers with no residency requirement
EU	`eu-west-1` (3 AZs)	EEA, UK, and Swiss customers electing EU residency

Backup replication targets `us-west-2` and `eu-central-1` respecti

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[2] infrastructure-architecture-overview — Infrastructure Architecture Overview — relevance 0.57

Infrastructure Architecture Overview

****Document ID:**** KD-ENG-003 · ****Version:**** 3.4 · ****Owner:**** Dana Whitfield, VP Engineering

****Last updated:**** 5 February 2026 · ****Classification:**** Confidential, NDA required

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[3] infrastructure-architecture-overview — 3. Compute — relevance 0.57

3. Compute

Amazon EKS (Kubernetes 1.31) with managed node groups spanning three availability zones. Workloads run as containers built from distroless base images, as non-root, with read-only root filesystems and dropped Linux capabilities. Pod Security Standards are enforced at the `restricted` level.

Node images are immutable; nodes are recycled with a maximum age of 30 days rather than pa

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[4] infrastructure-architecture-overview — 6. Network — relevance 0.57

6. Network

Private subnets for all compute and data. No public IP addresses on workload instances. Ingress is exclusively through Cloudflare, then an AWS Application Load Balancer, then the Istio ingress gateway. Egress is through NAT gateways with an allowlist for known destinations.

Security groups are managed in Terraform and default-deny. There are no `0.0.0.0/0` ingress rules in produc

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[5] infrastructure-architecture-overview — 7. Observability — relevance 0.56

7. Observability

Datadog for metrics, logs, APM, and security monitoring. Distributed tracing uses W3C Trace Context propagated across all services. Every log line carries `tenant\_id` and `request\_id`.

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

146. What is your personal data breach notification commitment to customers?

legal · Q146 · Vendor Security Review row 147

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

147. Do you use a VPN for internal application access, or a zero-trust approach?

security · Q147 · Vendor Security Review row 148

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

148. Have you completed a Transfer Impact Assessment?

legal · Q148 · Vendor Security Review row 149

Yes, Kestrel Data has completed a Transfer Impact Assessment (KD-LEG-010, Version 2.1), approved by the Data Protection Officer and most recently updated on 9 January 2026 (`transfer-impact-assessment`, section "Transfer Impact Assessment" and section "1. Status"). The assessment is refreshed annually and upon any material change to the transfer chain, the receiving country's law, or the supplementary measures relied upon. A copy of the Transfer Impact Assessment is available to customers under NDA (`transfer-impact-assessment`, section "1. Status").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] transfer-impact-assessment — Transfer Impact Assessment — relevance 0.71

Transfer Impact Assessment

Document ID: KD-LEG-010 · **Version:** 2.1 · **Owner:** Priya Raghunathan, DPO

Approved: 9 January 2026 · **Next review:** 9 January 2027

Maps to: GDPR Articles 44–49 · EDPB Recommendations 01/2020 · Schrems II (C-311/18)

gs://attestor-505506-corpus/legal/transfer-impact-assessment.txt

[2] transfer-impact-assessment — 1. Status — relevance 0.69

1. Status

Kestrel Data has completed a Transfer Impact Assessment, most recently updated on 9 January 2026. It is refreshed annually and on any material change to the transfer chain, the receiving country's law, or the supplementary measures relied on. A copy is available to customers under NDA.

gs://attestor-505506-corpus/legal/transfer-impact-assessment.txt

[3] transfer-impact-assessment — 6. Conclusion — relevance 0.67

6. Conclusion

For T1 and T2 the residual risk to data subjects is assessed as **low**: the data transferred is limited, pseudonymised where possible, encrypted with keys held outside the importer's jurisdiction, and unaccompanied by any customer content. For T3 and T4 the residual risk is **low** on the same basis, with the additional point that no customer content is transferred at all.

The asse

gs://attestor-505506-corpus/legal/transfer-impact-assessment.txt

[4] standard-contractual-clauses-summary — 4. Transfer Impact Assessment - conclusion — relevance 0.63

4. Transfer Impact Assessment - conclusion

A TIA was completed on 28 January 2026 covering transfers to the US. Summary of conclusions:

Assessment of US law. Kestrel assessed FISA 702 and EO 12333. Kestrel is not an "electronic communications service provider" as defined in 50 U.S.C. 1881(b)(4) and has never received a national security request of any kind, nor a National Security Letter

gs://attestor-505506-corpus/legal/standard-contractual-clauses-summary.txt

[5] transfer-impact-assessment — 3. Transfer mechanism — relevance 0.62

3. Transfer mechanism

The 2021 **Standard Contractual Clauses, Module Two (controller to processor)** apply between the customer and Kestrel, and **Module Three (processor to sub-processor)** between Kestrel and its US sub-processors. The **UK International Data Transfer Addendum** is incorporated for UK exports, and for Switzerland the SCCs are applied with the adaptations published by the Swiss

gs://attestor-505506-corpus/legal/transfer-impact-assessment.txt

149. Will you certify deletion of customer data on request? Provide supporting evidence.

legal · Q149 · Vendor Security Review row 150

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

150. Describe your secure development lifecycle.

engineering · Q150 · Vendor Security Review row 151

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (15)

[1] sdlc-policy — Secure Software Development Lifecycle Policy — relevance 0.71

Secure Software Development Lifecycle Policy

****Document ID:**** KD-ENG-001 · ****Version:**** 4.1 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 20 January 2026 · ****Next review:**** 20 January 2027

****Maps to:**** SOC 2 CC8.1 · ISO 27001:2022 A.8.25-A.8.31

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[2] sdlc-policy — no section recorded — relevance 0.68

Secure Software Development Lifecycle Policy ****Document ID:**** KD-ENG-001 · ****Version:**** 4.1 · ****Owner:**** Dana Whitfield, VP Engineering ****Approved:**** 20 ...

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[3] sdlc-policy — 4. Security in the pipeline — relevance 0.66

4. Security in the pipeline

Static analysis (Semgrep, CodeQL), dependency scanning (Snyk), IaC scanning (Checkov), and secret scanning (GitLeaks pre-commit plus GitHub push protection) all run on every pull request. A Critical or High dependency finding blocks the merge.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[4] third-party-library-policy — Third-Party Library Policy — relevance 0.65

Third-Party Library Policy

****Document ID:**** KD-ENG-008 · ****Version:**** 1.4 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 22 January 2026 · ****Maps to:**** SOC 2 CC7.1 · ISO 27001:2022 A.8.28

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[5] sdlc-policy — 1. Branching and review — relevance 0.61

1. Branching and review

`main` is protected and always releasable. All work happens on short-lived branches merged by pull request. `main` requires:

- At least ****one approving review**** from a engineer other than the author. Self-approval is blocked at the platform level.

- Two approvals for changes touching authentication, authorisation, tenant isolation, or cryptography. These paths ar

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[6] sdlc-policy — 7. Separation of duties — relevance 0.61

7. Separation of duties

Engineers cannot deploy their own change to production without the automated pipeline: no human has the ability to push a container image to the production registry directly. The deployment role is held by the CI service identity, which authenticates through OIDC and holds no long-lived credentials.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[7] service-operations-and-support — Service Operations, Maintenance and Support — relevance 0.61

Service Operations, Maintenance and Support

****Document ID:**** KD-ENG-009 · ****Version:**** 2.2 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 23 January 2026 · ****Next review:**** 23 January 2027

****Maps to:**** SOC 2 A1.1, A1.2, CC7.3, CC8.1 · ISO 27001:2022 A.5.29, A.8.6, A.8.32

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[8] third-party-library-policy — 4. Vulnerability response — relevance 0.61

4. Vulnerability response

Dependency vulnerabilities follow the SLAs in KD-SEC-006: Critical 7 days, High 30 days, Medium 90 days. Snyk runs on every pull request and daily against `main`. A Critical or High finding blocks merge.

Where no upstream fix exists within the SLA, the options in order of preference are: apply a vendored patch, replace the dependency, or accept the risk with a docum

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[9] change-management-procedure — Change Management Procedure — relevance 0.60

Change Management Procedure

****Document ID:**** KD-ENG-002 · ****Version:**** 3.0 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 20 January 2026 · ****Maps to:**** SOC 2 CC8.1 · ISO 27001:2022 A.8.32

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[10] cloud-exit-and-portability-plan — Cloud Exit and Portability Plan — relevance 0.60

Cloud Exit and Portability Plan

****Document ID:**** KD-ENG-010 · ****Version:**** 1.7 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 30 January 2026 · ****Next review:**** 30 January 2027

****Maps to:**** SOC 2 A1.2, CC9.1 · ISO 27001:2022 A.5.19, A.5.21, A.5.30 · EBA/DORA-aligned

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[11] secrets-management-standard — 1. Where secrets live — relevance 0.60

1. Where secrets live

| Secret class | Store | Rotation |

|---|---|---|

| Application secrets, API keys | AWS Secrets Manager | 90 days, automated |

| Database credentials | AWS Secrets Manager with RDS-managed rotation | 30 days, automated |

| Encryption keys | AWS KMS (key material never leaves KMS) | Annual, automated |

| TLS certificates | AWS Certificate Manager | Automatic before expiry

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

[12] sdlc-policy — 5. Dependency policy — relevance 0.59

5. Dependency policy

New third-party dependencies require review against the Third-Party Library Policy (KD-ENG-008). Lockfiles are committed. Renovate opens automated upgrade pull requests weekly; security patches are auto-merged when CI is green and the change is a patch-level bump.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[13] secrets-management-standard — Secrets Management Standard — relevance 0.59

Secrets Management Standard

****Document ID:**** KD-ENG-006 · ****Version:**** 2.1 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 22 January 2026 · ****Maps to:**** SOC 2 CC6.1 · ISO 27001:2022 A.8.24

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

[14] change-management-procedure — 6. Customer notification — relevance 0.58

6. Customer notification

Customers are notified at least ****7 days**** in advance of any change expected to cause degraded service or to require action on their part. Breaking API changes follow the deprecation policy: minimum ****12 months**** notice, with the deprecated version remaining available throughout.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[15] change-management-procedure — 2. Normal change requirements — relevance 0.57

2. Normal change requirements

A Normal change additionally requires a written rollback plan, a customer-impact assessment, and sign-off from the Change Advisory group (VP Engineering plus one SRE). Schema migrations must be backward compatible for at least one release, so that a rollback does not require a data migration.

gs://attestor-505506-corpus/engineering/change-management-procedure.txt

151. May a customer object to a new subprocessor? What is the remedy?

legal · Q151 · Vendor Security Review row 152

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] subprocessor-list — Subprocessor List — relevance 0.62

Subprocessor List

Document ID: KD-LEG-002 · **Version:** 6.4 · **Owner:** Priya Raghunathan, DPO
Last updated: 1 February 2026 · **Published at:** `kestreldata.com/subprocessors`
Change notice: 30 days, subscribe at `kestreldata.com/subprocessors/subscribe`

gs://attestor-505506-corpus/legal/subprocessor-list.txt

[2] subprocessor-list — Infrastructure subprocessors — relevance 0.62

Infrastructure subprocessors

Subprocessor	Purpose	Location of processing	Transfer mechanism	Engaged since
--------------	---------	------------------------	--------------------	---------------

---	---	---	---	---
-----	-----	-----	-----	-----

Amazon Web Services, Inc.	Cloud hosting, compute, storage, database	US (`us-east-1`, `us-west-2`); EU (`eu-west-1`, `eu-central-1`)		
---------------------------	---	---	--	--

SCCs + AWS DPA; EU data stays in EU	Mar 2019			
-------------------------------------	----------	--	--	--

Snowflake Inc.	Analytics data warehouse	US (AWS `us-east-1`);		
----------------	--------------------------	-----------------------	--	--

gs://attestor-505506-corpus/legal/subprocessor-list.txt

[3] subprocessor-list — Operational subprocessors — relevance 0.60

Operational subprocessors

Subprocessor	Purpose	Location	Transfer mechanism	Engaged since
--------------	---------	----------	--------------------	---------------

---	---	---	---	---
-----	-----	-----	-----	-----

Datadog, Inc.	Observability, logs, APM	US; EU site (`datadoghq.eu`) for EU customers	SCCs	Jun 2020
---------------	--------------------------	---	------	----------

Okta, Inc.	Identity and access management	US; EU cell for EU customers	SCCs	Feb 2021
------------	--------------------------------	------------------------------	------	----------

Twilio SendGrid	Transactional email delivery	US	SCCs	Ma
-----------------	------------------------------	----	------	----

gs://attestor-505506-corpus/legal/subprocessor-list.txt

[4] subprocessor-list — Changes in the last 12 months — relevance 0.52

Changes in the last 12 months

Date	Change	Notice given
------	--------	--------------

---	---	---
-----	-----	-----

12 Nov 2025	Added Cloudflare Zero Trust (existing vendor, new purpose)	30 days, no objections
-------------	--	------------------------

4 Jun 2025	Removed Segment, Inc. (product analytics discontinued)	N/A, removal
------------	--	--------------

18 Feb 2025	Added Snowflake EU deployment for EU instance	30 days, no objections
-------------	---	------------------------

gs://attestor-505506-corpus/legal/subprocessor-list.txt

[5] subprocessor-list — EU data residency — relevance 0.51

EU data residency

Customers on the EU instance have their data processed exclusively within the EEA for the infrastructure subprocessors above. Kestrel does **not** currently offer a UK-only, Swiss-only, Canadian, or Australian data residency option. Requests for those are recorded but not committed to.

gs://attestor-505506-corpus/legal/subprocessor-list.txt

152. What audit rights do you grant customers?

legal · Q152 · Vendor Security Review row 153

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] master-agreement-summary — 6. Audit rights — relevance 0.71

6. Audit rights

Customers may audit Kestrel's compliance with the DPA **once per twelve-month period on 30 days' written notice**, with additional audits permitted following a personal data breach affecting the customer or on a supervisory authority's instruction. Audits are conducted during business hours, must not unreasonably disrupt operations, and are subject to confidentiality.

Kestrel firs

gs://attestor-505506-corpus/legal/master-agreement-summary.txt

[2] data-processing-agreement — 9. Audit — relevance 0.70

9. Audit

Kestrel makes available its current SOC 2 Type II report and ISO 27001 certificate, which Customer accepts as satisfying Art. 28(3)(h) in the first instance. Where Customer has a documented, specific concern not addressed by those reports, Customer may conduct an audit no more than **once per twelve months**, on 30 days written notice, during business hours, subject to confidentiality

gs://attestor-505506-corpus/legal/data-processing-agreement.txt

[3] data-subject-rights-procedure — 9. Records — relevance 0.65

9. Records

Every request, its route, and its resolution date are recorded in the DSR register held by the DPO and retained for three years. The register is available to auditors and, in redacted form, to customers exercising their audit rights under the DPA.

gs://attestor-505506-corpus/legal/data-subject-rights-procedure.txt

[4] data-processing-agreement — 6. Data subject rights — relevance 0.64

6. Data subject rights

Kestrel provides self-service functionality allowing Customer to access, correct, export, and delete Personal Data within the Service. Where a data subject contacts Kestrel directly, Kestrel refers them to Customer and does not respond substantively, unless legally obliged to do so.

Where the Service functionality is insufficient, Kestrel assists Customer within **10**

gs://attestor-505506-corpus/legal/data-processing-agreement.txt

[5] data-subject-rights-procedure — 1. Which rights, and against whom — relevance 0.62

1. Which rights, and against whom

For customer content, Kestrel is the **processor** and the customer is the controller. A data subject who approaches Kestrel directly about customer content is redirected to the relevant customer without undue delay and, where Kestrel can identify the customer, within **3 business days**. Kestrel does not respond substantively on the controller's behalf.

For data

gs://attestor-505506-corpus/legal/data-subject-rights-procedure.txt

153. How do you support California consumer rights requests?

legal · Q153 · Vendor Security Review row 154

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (8)

[1] data-subject-rights-procedure — Data Subject Rights Procedure — relevance 0.71

Data Subject Rights Procedure

Document ID: KD-LEG-007 · **Version:** 2.3 · **Owner:** Priya Raghunathan, DPO

Approved: 20 January 2026 · **Next review:** 20 January 2027

Maps to: GDPR Articles 12, 15–22, 28(3)(e) · CCPA/CPRA §1798.100–130

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[2] data-subject-rights-procedure — 8. California and other US state rights — relevance 0.68

8. California and other US state rights

Kestrel acts as a **service provider** under the CCPA/CPRA in respect of customer content, and the DPA contains the required service provider terms: no sale, no sharing for cross-context behavioural advertising, no retention or use outside the business purpose, and no combining with data from other sources. The same terms are applied for the Virginia, Colora

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[3] data-subject-rights-procedure — 9. Records — relevance 0.68

9. Records

Every request, its route, and its resolution date are recorded in the DSR register held by the DPO and retained for three years. The register is available to auditors and, in redacted form, to customers exercising their audit rights under the DPA.

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[4] data-processing-agreement — 6. Data subject rights — relevance 0.67

6. Data subject rights

Kestrel provides self-service functionality allowing Customer to access, correct, export, and delete Personal Data within the Service. Where a data subject contacts Kestrel directly, Kestrel refers them to Customer and does not respond substantively, unless legally obliged to do so.

Where the Service functionality is insufficient, Kestrel assists Customer within **10**

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[5] privacy-policy — 5. Your rights — relevance 0.65

5. Your rights

Data subjects in the EEA, UK, and Switzerland have rights of access, rectification, erasure, restriction, portability, and objection, and the right to withdraw consent. California residents have rights under the CCPA as amended by the CPRA, including the right to know, delete, correct, and opt out of sharing.

Requests to `privacy@kestreldata.com` are acknowledged within 5 busi

gs://attestor-505506-corporus/legal/privacy-policy.txt

[6] data-subject-rights-procedure — 1. Which rights, and against whom — relevance 0.65

1. Which rights, and against whom

For customer content, Kestrel is the **processor** and the customer is the controller. A data subject who approaches Kestrel directly about customer content is redirected to the relevant customer without undue delay and, where Kestrel can identify the customer, within **3 business days**. Kestrel does not respond substantively on the controller's behalf.

For data

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[7] data-processing-agreement — 1. Roles — relevance 0.64

1. Roles

Customer is **Controller**. Kestrel Data, Inc. is **Processor**. Where Customer is itself a processor for its own customers, Kestrel is sub-processor and the same obligations apply down the chain.

Kestrel is **Controller** for a limited set of data it determines the purposes of: account administrator contact details, billing records, and product telemetry described in Annex 3.

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[8] privacy-policy — 3. What we do not do — relevance 0.57

3. What we do not do

- We do not sell personal data, and have never done so.
- We do not share personal data with advertising networks.
- We do not use customer content to train machine learning models, our own or anyone else. This is stated contractually in the MSA and is not merely a policy statement.
- We do not engage in automated decision-making producing legal or similarly significant

gs://attestor-505506-corporus/legal/privacy-policy.txt

154. Describe your security incident classification scheme.

security · Q154 · Vendor Security Review row 155

Kestrel Data classifies security incidents into a four-tier severity framework based on impact, paging requirements, and executive notification timelines (cited from `incident-response-runbook`, section `1. Severity definitions`): **SEV1**: Confirmed unauthorised access to customer production data, or a full platform outage. This triggers immediate 24/7 paging and notification of the CEO and CISO within 30 minutes. **SEV2**: Suspected compromise, a partial outage affecting more than 10% of tenants, or a confirmed data integrity fault. This triggers immediate 24/7 paging and notification of the CISO within 1 hour. **SEV3**: A security-relevant defect with no evidence of exploitation. This is addressed during business hours and tracked via a weekly report. **SEV4**: Informational or hygiene findings. This level requires no paging and is tracked via a monthly report.

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] incident-response-runbook — 1. Severity definitions — relevance 0.65

1. Severity definitions

Sev	Definition	Page	Exec notify
-----	------------	------	-------------

---	---	---	---
-----	-----	-----	-----

SEV1	Confirmed unauthorised access to customer production data, or full platform outage	Immediate, 24/7	CEO + CISO within 30 min
-------------	--	-----------------	--------------------------

SEV2	Suspected compromise, partial outage affecting more than 10% of tenants, or confirmed data integrity fault	Immediate, 24/7	CISO within 1 hour
-------------	--	-----------------	--------------------

SEV3			
-------------	--	--	--

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[2] incident-response-runbook — 3. Lifecycle — relevance 0.65

3. Lifecycle

Detect, triage, contain, eradicate, recover, learn.

Detection sources are Datadog Security Monitoring, AWS GuardDuty, AWS Security Hub, Okta ThreatInsight, Snyk, customer reports to `security@kestreldata.com`, and the disclosure address published at `kestreldata.com/.well-known/security.txt`.

Triage target is 15 minutes from alert to severity assignment for SEV1 and SEV2, meas

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[3] incident-response-runbook — 8. Post-incident review — relevance 0.64

8. Post-incident review

Every SEV1 and SEV2 requires a blameless post-incident review within 5 business days, published internally, with action items tracked to closure in Jira. Reviews are shared with affected customers on request.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[4] incident-response-runbook — 2. Roles — relevance 0.63

2. Roles

The Incident Commander owns the response and is deliberately not the person fixing the problem; ICs are drawn from a rota of 6 trained staff. The Communications Lead owns customer, internal, and regulator messaging. A Scribe maintains the timeline for every SEV1 and SEV2. Subject matter experts are pulled in as needed.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[5] incident-response-runbook — 6. Evidence handling — relevance 0.62

6. Evidence handling

The IC directs preservation before remediation wherever containment allows. EBS snapshots, memory captures where feasible, and relevant log ranges are exported to a dedicated forensics S3 bucket with Object Lock in compliance mode, retention 1 year. Chain of custody is recorded in the incident ticket.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

155. Will you certify deletion of customer data on request?

legal · Q155 · Vendor Security Review row 156

Yes. Kestrel Data provides certification of deletion upon written request (`data-processing-agreement`, Section 8, "Deletion and return"). When a deletion is executed, the automated `tenant-purge` job generates a structured completion record detailing every data store touched along with the row or object counts removed. This record is retained for seven years as evidence of deletion and serves as the formal artefact provided to customers requesting certification (`data-retention-schedule`, Section 4, "Deletion verification").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] data-retention-schedule — 4. Deletion verification — relevance 0.68

4. Deletion verification

The `tenant-purge` job emits a structured completion record listing every store touched and the row or object counts removed. That record is retained for 7 years as evidence of deletion and is the artefact provided when a customer requests certification of deletion.

Deletion was exercised 11 times in 2025 (customer churn). Median time from termination to completed pu

gs://attestor-505506-corporus/legal/data-retention-schedule.txt

[2] data-subject-rights-procedure — 5. Erasure (Article 17) — relevance 0.67

5. Erasure (Article 17)

Erasure of controller-side data is completed within 30 calendar days. Erasure of processor-side data is executed on customer instruction; deletion from live systems is immediate, and **encrypted backups containing the deleted data expire on the ordinary backup rotation within 35 days**. Kestrel does not selectively edit backups, and says so: surgical deletion inside an encr

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[3] data-processing-agreement — 8. Deletion and return — relevance 0.67

8. Deletion and return

On termination, Customer may export its data through the Service for **30 days**. After that period Kestrel deletes Customer Personal Data within **90 days**, save where storage is required by law. Backups containing deleted data expire on the standard backup cycle, a maximum of **35 days** after deletion from primary storage. Certification of deletion is provided on wri

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[4] data-retention-schedule — 1. Customer data — relevance 0.66

1. Customer data
| Data class | Active retention | Post-termination | Deletion mechanism |
|---|---|---|---|
| Customer records in the platform | Term of subscription | ****30 days**** export window, then deleted within ****90 days**** | Automated
`tenant-purge` job, nightly |
| Analytics warehouse (Snowflake) | Term | Deleted with tenant purge | Automated |
| Uploaded files (S3) | Term | Deleted with

gs://attestor-505506-corporus/legal/data-retention-schedule.txt

[5] data-retention-schedule — 6. Exceptions — relevance 0.66

6. Exceptions

Where a retention period conflicts with a customer contractual requirement, the shorter period applies unless law requires otherwise. Longer retention requires DPO approval, which has not been granted for any customer data class to date.

gs://attestor-505506-corporus/legal/data-retention-schedule.txt

156. How are security responsibilities communicated to personnel?

security · Q156 · Vendor Security Review row 157

Security responsibilities are communicated across four overlapping channels: 1. ****Offer Pack and Onboarding Session:**** Initial security expectations and responsibilities are provided in the offer pack and covered during onboarding. 2. ****Annual Policy Acknowledgement:**** Personnel complete a formal annual policy acknowledgement. 3. ****Monthly All-Hands Updates:**** The CISO delivers a standing security update as part of the company's monthly all-hands meeting. 4. ****Dedicated Security Channel (`#security`):**** The `#security` Slack channel serves as the documented channel for reporting suspicious activity, monitored during business hours with PagerDuty escalation outside business hours. ***(Personnel Security and Security Training Programme, Section 7: "How security responsibilities are communicated")***

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] personnel-security-and-training — 7. How security responsibilities are communicated — relevance 0.71

7. How security responsibilities are communicated

Responsibilities are communicated four ways, deliberately overlapping: the offer pack and onboarding session; the annual policy acknowledgement; a standing item in the monthly all-hands delivered by the CISO; and the `#security` Slack channel, which is the documented route for reporting anything suspicious and is monitored during business hours with

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[2] personnel-security-and-training — 4. Security awareness training — relevance 0.64

4. Security awareness training

Security awareness training is ****mandatory for all personnel, annually, plus at onboarding within the first 14 days****. Training is delivered through Curricula and runs approximately 45 minutes, covering phishing, credential handling, data classification, secure remote working, and incident reporting.

Measured completion for the 2025 cycle was ****99.5%**** (210 of 211 i

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[3] risk-management-and-governance — 8. Policy management — relevance 0.64

8. Policy management

All security policies carry a document ID, a version, a named owner, an approval date, and a review date. Policies are reviewed at least annually and on material change. The 2026 review cycle covered 14 policies between 8 January and 12 February 2026; three were revised, and the changes were communicated at the February all-hands and through the annual acknowledgement cycle.

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[4] personnel-security-and-training — Personnel Security and Security Training Programme — relevance 0.63

gs://attestor-505506-corporate/security/personnel-security-and-training.txt

[5] incident-response-runbook — 2. Roles — relevance 0.61

2. Roles

The Incident Commander owns the response and is deliberately not the person fixing the problem; ICs are drawn from a rota of 6 trained staff. The Communications Lead owns customer, internal, and regulator messaging. A Scribe maintains the timeline for every SEV1 and SEV2. Subject matter experts are pulled in as needed.

gs://attestor-505506-corporate/security/incident-response-runbook.txt

157. Who holds the encryption keys for customer data?

security · Q157 · Vendor Security Review row 158

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

158. Do you support SCIM user provisioning? Provide supporting evidence.

security · Q158 · Vendor Security Review row 159

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (7)

[1] access-control-standard — 3. Role-based access — relevance 0.66

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix (`SEC-GOV/access-matrix`), which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is just-in-time.

gs://attestor-505506-corporate/security/access-control-standard.txt

[2] access-control-standard — 7. Access reviews — relevance 0.63

7. Access reviews

Quarterly user access reviews cover all production systems, the AWS Organization, Snowflake, GitHub, and Okta itself. Reviews are performed by the system owner and attested in Vanta. The Q4 2025 review completed on 12 January 2026 and removed 23 entitlements, of which 9 were stale contractor accesses.

gs://attestor-505506-corporate/security/access-control-standard.txt

[3] access-control-standard — 1. Identity provider — relevance 0.59

1. Identity provider

All Kestrel Data systems authenticate through Okta (tenant `kestreldata.okta.com`). Local accounts on production systems are prohibited except for two documented break-glass accounts held in a sealed 1Password vault, whose use triggers a PagerDuty alert to the CISO. Both break-glass credentials were last rotated on 3 January 2026 and last used on 14 August 2025 during the

gs://attestor-505506-corporate/security/access-control-standard.txt

[4] access-control-standard — 6. Joiners, movers, leavers — relevance 0.59

6. Joiners, movers, leavers

Joiners are provisioned via Okta Lifecycle Management from Rippling (HRIS); no access is

granted before the background check clears. Movers have entitlements recalculated on role change, with the previous role revoked within 1 business day. Leavers have all access revoked automatically on the HRIS termination event: the target is 1 hour, and the measured median for

gs://attestor-505506-corpus/security/access-control-standard.txt

[5] access-control-standard — 5. Customer data access — relevance 0.57

5. Customer data access

Kestrel personnel do not access customer production data as a matter of routine. Access for support purposes requires explicit per-incident customer authorisation recorded in Zendesk, is limited to the specific tenant, and expires after 24 hours.

Between 1 January and 31 December 2025 there were 19 such authorised accesses across 7 customers, each evidenced in the SOC

gs://attestor-505506-corpus/security/access-control-standard.txt

[6] access-control-standard — 8. Service accounts and machine identity — relevance 0.56

8. Service accounts and machine identity

Workloads authenticate using short-lived credentials: AWS IAM Roles for Service Accounts (IRSA) in EKS, and Workload Identity Federation for GCP components. Long-lived static access keys are prohibited; the last was decommissioned on 17 November 2024. Automated detection for newly created static keys runs hourly and pages the on-call SRE.

gs://attestor-505506-corpus/security/access-control-standard.txt

[7] access-control-standard — 9. Password requirements — relevance 0.54

9. Password requirements

Where a password is used, minimum length is 14 characters, checked against the Have I Been Pwned breached-password corpus at set time. Rotation is not forced on a schedule, in line with NIST SP 800-63B guidance; rotation is forced on evidence of compromise.

gs://attestor-505506-corpus/security/access-control-standard.txt

159. Do you encrypt customer data at rest?

security · Q159 · Vendor Security Review row 160

Yes, all customer data at rest is encrypted using AES-256-GCM across all storage tiers; no customer data is stored unencrypted at any tier (Encryption Standard, Section 1. Data at rest; Information Security Policy, Section 8. Cryptography). Specific encryption controls and key custody across data stores include: - **Amazon RDS (PostgreSQL 16):** Storage-level encryption using per-environment AWS KMS Customer Managed Keys (CMKs). - **Amazon S3:** Server-side encryption with AWS KMS (SSE-KMS) using per-bucket AWS KMS CMKs. - **Snowflake:** Native encryption with Tri-Secret Secure using customer-managed keys in AWS KMS. - **Amazon EBS:** Volume-level encryption enforced at the AWS Organization level using AWS KMS CMKs. - **Backups:** Protected using the same CMK class as the source via AWS KMS (Encryption Standard, Section 1. Data at rest). Additionally, application-level field encryption is applied to authentication secrets, API tokens, and OAuth refresh tokens using AES-256-GCM, with keys managed in AWS Secrets Manager and rotated every 90 days (Encryption Standard, Section 1. Data at rest). Customer-facing encryption keys are AWS KMS Customer Managed Keys with automatic annual rotation enabled. Key usage is restricted to named service roles, and separation of duties between key administrators and key users is enforced at the AWS Organization level via Service Control Policies (Encryption Standard, Section 3. Key management).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] encryption-standard — 1. Data at rest — relevance 0.73

1. Data at rest

All customer data at rest is encrypted using **AES-256-GCM**. No customer data is stored unencrypted at any tier.

Store	Mechanism	Key custody

| Amazon RDS (PostgreSQL 16) | Storage-level encryption | AWS KMS CMK, per-environment |
| Amazon S3 | SSE-KMS | AWS KMS CMK, per-bucket |
| Snowflake | Native encryption, Tri-Secret Secure | Customer-managed key

gs://attestor-505506-corporus/security/encryption-standard.txt

[2] encryption-standard — 3. Key management — relevance 0.65

3. Key management

Customer-facing encryption keys are AWS KMS Customer Managed Keys. Key policies restrict use to named service roles. Key administrators and key users are disjoint sets: no individual holds both roles, enforced by a Service Control Policy at the AWS Organization level.

Automatic annual rotation is enabled on all CMKs. Manual rotation is triggered on suspected compromise. Ke

gs://attestor-505506-corporus/security/encryption-standard.txt

[3] physical-and-environmental-security — 1. Production infrastructure — relevance 0.65

1. Production infrastructure

Kestrel Data operates **no** owned or leased data centre. All production infrastructure runs in AWS: `us-east-1` for the US instance and `eu-west-1` for the EU instance. Physical and environmental controls for those facilities — perimeter security, biometric access, CCTV, fire suppression, power redundancy, environmental monitoring, and media destruction — are AWS's re

gs://attestor-505506-corporus/security/physical-and-environmental-security.txt

[4] information-security-policy — 8. Cryptography — relevance 0.64

8. Cryptography

Data at rest is encrypted with AES-256-GCM. Data in transit is protected with TLS 1.3; TLS 1.0 and 1.1 were disabled on 12 April 2024 and TLS 1.2 remains enabled only for a single legacy integration scheduled for removal in Q3 2026. Key management is described in the Encryption Standard (KD-SEC-003) and the Secrets Management Standard (KD-ENG-006).

gs://attestor-505506-corporus/security/information-security-policy.txt

[5] encryption-standard — Encryption Standard — relevance 0.62

Encryption Standard

Document ID: KD-SEC-003 · **Version:** 2.4 · **Owner:** Marcus Oyelaran, CISO
Approved: 8 January 2026 · **Next review:** 8 January 2027
Maps to: SOC 2 CC6.7 · ISO 27001:2022 A.8.24 · GDPR Art. 32(1)(a)

gs://attestor-505506-corporus/security/encryption-standard.txt

160. Do you offer EU data residency?

legal · Q160 · Vendor Security Review row 161

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] subprocessor-list — EU data residency — relevance 0.73

EU data residency

Customers on the EU instance have their data processed exclusively within the EEA for the infrastructure subprocessors above. Kestrel does **not** currently offer a UK-only, Swiss-only, Canadian, or Australian data residency option. Requests for those are recorded but not committed to.

gs://attestor-505506-corporus/legal/subprocessor-list.txt

[2] transfer-impact-assessment — 5. Supplementary measures relied on — relevance 0.70

5. Supplementary measures relied on
Technical:

1. **Data residency by default** — EU customer content, including backups and the replicated log ship, never leaves `eu-west-1`.
2. **Encryption in transit** — TLS 1.3 (1.2 minimum) on every hop, including between Kestrel and each sub-processor.
3. **Encryption at rest** — AES-256-GCM with keys in AWS KMS. Keys for the EU instance are held i

gs://attestor-505506-corpus/legal/transfer-impact-assessment.txt

[3] transfer-impact-assessment — 2. The transfers assessed — relevance 0.67

2. The transfers assessed

| # | Transfer | Exporter | Importer | Country | Data |

| ---|---|---|---|---|

| T1 | EU tenant support access | Kestrel EU instance | Kestrel Data, Inc. | United States | Account identity data, support correspondence |

| T2 | Product telemetry aggregation | Kestrel EU instance | Kestrel Data, Inc. | United States | Pseudonymised usage events |

| T3 | Error monitoring

gs://attestor-505506-corpus/legal/transfer-impact-assessment.txt

[4] dpia-register — 2. Completed assessments — relevance 0.66

2. Completed assessments

Four DPIAs have been completed, all reviewed and signed off by the DPO:

| ID | Subject | Completed | Residual risk | Outcome |

| ---|---|---|---|---|

| DPIA-2024-01 | Product telemetry collection and retention | 14 May 2024 | Low | Proceed. Event allowlist introduced; free-text fields excluded; retention set to 13 months |

| DPIA-2025-01 | EU instance and residency arc

gs://attestor-505506-corpus/legal/dpia-register.txt

[5] standard-contractual-clauses-summary — 2. UK and Switzerland — relevance 0.64

2. UK and Switzerland

- **UK** - the ICO International Data Transfer Addendum (version B1.0, in force 21 March 2022) is appended to the EU SCCs. UK GDPR references replace EU GDPR references; the competent authority is the ICO.

- **Switzerland** - the Swiss Annex applies. The FDPIC is the competent authority, and references to Member State law are read as references to Swiss law. The SCC

gs://attestor-505506-corpus/legal/standard-contractual-clauses-summary.txt

161. For each applicable system: How much notice is given before scheduled maintenance?

engineering · Q161 · Vendor Security Review row 162

For scheduled maintenance across Kestrel's production systems: * **Customer-Affecting Maintenance:** Customers receive at least **7 days' notice** for any scheduled maintenance expected to be customer-affecting or cause degraded service (KD-ENG-009, §2; KD-ENG-002, §6). The standard maintenance window is Sundays 06:00–10:00 UTC, though standard deployments are rolling and zero-downtime (KD-ENG-009, §2). * **Maintenance Requiring Customer Action:** When scheduled maintenance or changes require customer action, at least **30 days' notice** is provided (KD-ENG-009, §2). * **Breaking API Changes:** Breaking API modifications follow a formal deprecation policy requiring a minimum of **12 months' notice**, with the deprecated version remaining supported throughout that period (KD-ENG-002, §6). * **Emergency Maintenance:** Emergency maintenance (such as critical security fixes) may proceed under the emergency change path with shorter notice, and notifications are sent as soon as the maintenance is scheduled (KD-ENG-009, §2). All scheduled maintenance notices are communicated directly via email to tenant administrators and published on the independent status page at `status.kestreldata.com` (KD-ENG-009, §1, §2).

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (6)

[1] service-operations-and-support — 2. Scheduled maintenance — relevance 0.70

2. Scheduled maintenance

The standard maintenance window is **Sundays 06:00–10:00 UTC**. Most changes do not use it: deployments are rolling and zero-downtime, and 2025 saw 1,412 production deployments with no customer-visible downtime.

Customers receive at least 7 days' notice of scheduled maintenance expected to be customer-affecting, and 30 days' notice where the change requires customer a

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[2] change-management-procedure — 6. Customer notification — relevance 0.60

6. Customer notification

Customers are notified at least **7 days** in advance of any change expected to cause degraded service or to require action on their part. Breaking API changes follow the deprecation policy: minimum **12 months** notice, with the deprecated version remaining available throughout.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[3] service-operations-and-support — Service Operations, Maintenance and Support — relevance 0.60

Service Operations, Maintenance and Support

Document ID: KD-ENG-009 · **Version:** 2.2 · **Owner:** Dana Whitfield, VP Engineering

Approved: 23 January 2026 · **Next review:** 23 January 2027

Maps to: SOC 2 A1.1, A1.2, CC7.3, CC8.1 · ISO 27001:2022 A.5.29, A.8.6, A.8.32

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[4] service-operations-and-support — 1. Status page — relevance 0.57

1. Status page

Service status is published at **status.kestreldata.com**, hosted by Statuspage on infrastructure independent of Kestrel's own — a status page that shares a failure domain with the service is worthless during exactly the event it exists for. The page shows per-component status for the US and EU instances, current and historical incidents, and scheduled maintenance. Customers may s

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[5] service-operations-and-support — 7. Incident communication to customers — relevance 0.57

7. Incident communication to customers

Customer-facing incident communication is owned by the incident commander and follows the commitments in KD-SEC-008 §4. In practice: status page inside 15 minutes, direct email to affected tenant administrators inside 60 minutes for a Sev 1, and a written post-incident review within 5 business days for any Sev 1 or Sev 2, shared with affected customers on req

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[6] change-management-procedure — 7. Change freeze — relevance 0.55

7. Change freeze

A change freeze applies from 20 December to 2 January, and during any active SEV1. Only Emergency changes are permitted during a freeze.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

162. Is 24x7 support available for production-down incidents?

engineering · Q162 · Vendor Security Review row 163

Yes, 24x7 support is available for production-down incidents. For Enterprise-tier customers, production-down (Severity 1 / Urgent) incidents are supported 24x7 via an emergency pager, alongside 24x7 intake through email (**support@kestreldata.com**) and the in-product support widget. Additionally, support coverage for Urgent (production down) incidents operates on a 24x7 basis with a 1-hour first response target. Production-down incidents are also covered for all customers via 24x7 platform monitoring, ensuring platform-wide outages are detected and actively worked by the on-call Site Reliability Engineering (SRE) team regardless of whether a customer has submitted a report.

Citations: **service-operations-and-support**, Section 3: Support channels and hours - **availability-sla**, Section 6: Support response targets

Evidence (5)

[1] service-operations-and-support — 3. Support channels and hours — relevance 0.72

3. Support channels and hours

| Channel | Availability |

|---|---|

| Email `support@kestreldata.com` | 24x7 intake |

| In-product support widget | 24x7 intake |

| Named CSM (Enterprise tier) | Business hours, US Central |

| Emergency pager (Enterprise tier) | **24x7 for Severity 1** |

24x7 support is available for production-down incidents, through the emergency pager for Enterprise customers

gs://attestor-505506-corpus/engineering/service-operations-and-support.txt

[2] availability-sla — 6. Support response targets — relevance 0.70

6. Support response targets

Support targets are separate from this SLA and are not credit-bearing.

| Severity | First response | Coverage |

|---|---|---|

| Urgent (production down) | 1 hour | 24 x 7 |

| High (major feature impaired) | 4 business hours | Business hours |

| Normal | 1 business day | Business hours |

| Low | 3 business days | Business hours |

Business hours are 08:00-18:00

gs://attestor-505506-corpus/engineering/availability-sla.txt

[3] availability-sla — 3. Exclusions — relevance 0.65

3. Exclusions

Downtime does not include unavailability caused by:

- Scheduled maintenance, notified at least 7 days in advance, in the window Sundays 04:00-06:00 UTC, capped at 4 hours per month.

- Emergency maintenance to address a security vulnerability, notified as soon as practicable.

- Customer configuration, customer code, or customer exceeding documented rate limits.

- Failure o

gs://attestor-505506-corpus/engineering/availability-sla.txt

[4] service-operations-and-support — 7. Incident communication to customers — relevance 0.63

7. Incident communication to customers

Customer-facing incident communication is owned by the incident commander and follows the commitments in KD-SEC-008 §4. In practice: status page inside 15 minutes, direct email to affected tenant administrators inside 60 minutes for a Sev 1, and a written post-incident review within 5 business days for any Sev 1 or Sev 2, shared with affected customers on req

gs://attestor-505506-corpus/engineering/service-operations-and-support.txt

[5] service-operations-and-support — 2. Scheduled maintenance — relevance 0.62

2. Scheduled maintenance

The standard maintenance window is **Sundays 06:00–10:00 UTC**. Most changes do not use it: deployments are rolling and zero-downtime, and 2025 saw 1,412 production deployments with no customer-visible downtime.

Customers receive at least 7 days' notice of scheduled maintenance expected to be customer-affecting, and 30 days' notice where the change requires customer a

gs://attestor-505506-corpus/engineering/service-operations-and-support.txt

163. Provide your standard Data Processing Agreement.

legal · Q163 · Vendor Security Review row 164

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (7)

[1] master-agreement-summary — 9. Subcontracting — relevance 0.74

9. Subcontracting

Sub-processing is governed by the DPA: a public list (KD-LEG-006), ****30 days' notice**** before adding or replacing a sub-processor, a right to object on reasonable data protection grounds, and termination without penalty if the objection cannot be resolved.

gs://attestor-505506-corporus/legal/master-agreement-summary.txt

[2] master-agreement-summary — 1. Structure — relevance 0.74

1. Structure

A Kestrel engagement comprises the Master Subscription Agreement, an Order Form, the Data Processing Agreement (KD-LEG-001) with its Annex 2 technical measures (KD-LEG-003), and the Security Addendum (KD-LEG-005). The DPA and Security Addendum are incorporated by reference into every agreement; they are not optional extras negotiated case by case.

gs://attestor-505506-corporus/legal/master-agreement-summary.txt

[3] data-processing-agreement — 10. International transfers — relevance 0.73

10. International transfers

Where Personal Data is transferred out of the EEA, UK, or Switzerland, the parties enter into the ****2021 EU Standard Contractual Clauses**** (Commission Implementing Decision 2021/914), Module Two (Controller to Processor) or Module Three (Processor to Sub-processor) as applicable, incorporated by reference. The UK International Data Transfer Addendum and the Swiss An

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[4] gdpr-records-of-processing — Part A - Kestrel as Processor (Art. 30(2)) — relevance 0.73

Part A - Kestrel as Processor (Art. 30(2))

****Controller:**** each Kestrel customer, as identified in the applicable Order Form.

****Processor:**** Kestrel Data, Inc.

****DPO:**** Priya Raghunathan, `dpo@kestreldata.com`

| # | Processing activity | Categories of data subject | Categories of personal data | Transfers | Retention |

|---|---|---|---|---|---|

| P1 | Hosting and operating the Kestrel Insig

gs://attestor-505506-corporus/legal/gdpr-records-of-processing.txt

[5] data-processing-agreement — Data Processing Agreement (Template) — relevance 0.73

Data Processing Agreement (Template)

****Document ID:**** KD-LEG-001 · ****Version:**** 5.1 · ****Owner:**** Aaron Feldstein, General Counsel

****Effective:**** 1 February 2026 · ****Supersedes:**** v4.3 of 12 May 2025

****Governing law:**** Delaware, USA, save where the SCCs specify otherwise

This DPA forms part of the Kestrel Data Master Subscription Agreement and applies where Kestrel processes Personal Data on

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[6] data-processing-agreement — 2. Scope and duration — relevance 0.69

2. Scope and duration

Processing continues for the term of the Agreement plus the retention periods in Annex 2.

Kestrel processes Personal Data only on documented instructions from Customer. The Agreement, this DPA, and Customer configuration of the Service constitute those instructions.

If Kestrel is required by Union or Member State law to process beyond those instructions, it will inform

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[7] data-processing-agreement — 5. Sub-processing — relevance 0.69

5. Sub-processing

Customer grants general authorisation for the sub-processors listed at `kestreldata.com/subprocessors`. Kestrel gives **30 days** notice before adding or replacing a sub-processor. Customer may object on reasonable data-protection grounds within that period; if the objection cannot be resolved, Customer may terminate the affected Service without penalty for the remainder of t

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

164. Are backups replicated across regions? Do they leave the residency boundary?

engineering · Q164 · Vendor Security Review row 165

Yes, backups are replicated across regions while strictly maintaining data residency boundaries. Specifically, backups originating in `us-east-1` replicate to `us-west-2`, and backups originating in `eu-west-1` replicate to `eu-central-1` (`backup-restore-procedure`, Section 2: "Encryption and location"; `infrastructure-architecture-overview`, Section 1: "Cloud footprint"). Backups never leave their designated residency boundary, and EU customer data never leaves the European Economic Area (EEA), including in backups (`backup-restore-procedure`, Section 2: "Encryption and location").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] backup-restore-procedure — 2. Encryption and location — relevance 0.70

2. Encryption and location

All backups are encrypted with AES-256 using AWS KMS. The daily logical dump uses a **separate CMK** from the primary database, so that compromise of the primary key does not compromise the backups.

Cross-region replication stays inside the residency boundary: `us-east-1` replicates to `us-west-2`, `eu-west-1` replicates to `eu-central-1`. EU customer data never le

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[2] backup-restore-procedure — 1. What is backed up — relevance 0.63

1. What is backed up

Asset	Method	Frequency	Retention
-------	--------	-----------	-----------

---	---	---	---
-----	-----	-----	-----

RDS PostgreSQL	Automated snapshots + WAL archiving (PITR)	Continuous	35 days
----------------	--	------------	----------------

RDS logical dump	`pg_dump` to S3, encrypted with a separate CMK	Daily 03:00 UTC	90 days
------------------	--	-----------------	---------

S3 objects	Versioning + cross-region replication	Continuous	90 days for non-current versions
------------	---------------------------------------	------------	----------------------------------

Snowflake	Time Tr		
-----------	---------	--	--

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[3] infrastructure-architecture-overview — 1. Cloud footprint — relevance 0.61

1. Cloud footprint

Kestrel runs on **Amazon Web Services**. There are two independent production instances:

Instance	Region	Serves
----------	--------	--------

---	---	---
-----	-----	-----

US	`us-east-1` (3 AZs)	North America, and customers with no residency requirement
----	---------------------	--

EU	`eu-west-1` (3 AZs)	EEA, UK, and Swiss customers electing EU residency
----	---------------------	--

Backup replication targets `us-west-2` and `eu-central-1` respecti

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[4] backup-restore-procedure — 6. Backup deletion — relevance 0.59

6. Backup deletion

Backups expire automatically. When a customer terminates and the tenant purge runs, backups containing that data expire on the normal cycle, a maximum of **35 days** later. Kestrel does not selectively surgically remove a tenant from historical backup images, and says so rather than implying otherwise.

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[5] backup-restore-procedure — 4. Test results — relevance 0.58

4. Test results

Restore is tested **quarterly**, and the test is a real restore, not a backup-listing check.

Quarter	Date	Duration	Assertions	Outcome
Q1 2026	17 Jan 2026	2h 41m	1,240 / 1,240	Pass
Q4 2025	11 Oct 2025	3h 02m	1,238 / 1,240	Pass, 2 known-stale fixtures corrected
Q3 2025	19 Jul 2025	3h 20m	1,240 / 1,240	Pass

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

165. How much notice do you give customers before a breaking API change?

engineering · Q165 · Vendor Security Review row 166

Under Kestrel Data's deprecation policy, customers are provided a minimum of 12 months' notice for breaking changes affecting an entire API version, during which the deprecated version remains available. For deprecations of an individual endpoint or field, customers receive a minimum of 90 days' notice. Notifications are communicated via email to tenant administrators, through `Deprecation` and `Sunset` HTTP response headers, and posted on the developer changelog (Change Management Procedure, Section 6; API and Integration Standard, Section 7).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] change-management-procedure — 6. Customer notification — relevance 0.69

6. Customer notification

Customers are notified at least **7 days** in advance of any change expected to cause degraded service or to require action on their part. Breaking API changes follow the deprecation policy: minimum **12 months** notice, with the deprecated version remaining available throughout.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[2] api-and-integration-standard — 7. Versioning and deprecation — relevance 0.65

7. Versioning and deprecation

The API is versioned in the path (`/v1`, `/v2`). Backwards-incompatible changes are made only in a new version.

The deprecation policy is 12 months' notice for a whole API version and **90 days' notice** for an individual endpoint or field, delivered by email to tenant administrators, by a `Deprecation` and `Sunset` response header, and on the developer changelog

gs://attestor-505506-corporus/engineering/api-and-integration-standard.txt

[3] api-and-integration-standard — 3. Rate limiting — relevance 0.55

3. Rate limiting

Rate limits are enforced at Cloudflare, ahead of application code:

Surface	Limit
Public API, per tenant	120 requests/minute
Bulk export endpoint, per tenant	6 requests/minute
Authentication endpoints, per source address	10 attempts/5 minutes
Password reset, per account	5 attempts/hour (added 27 February 2026)

Exceeding a limit returns HTTP

gs://attestor-505506-corporate/engineering/api-and-integration-standard.txt

[4] api-and-integration-standard — 2. Customer control of API credentials — relevance 0.54

2. Customer control of API credentials

****Customers create, scope, rotate, and revoke their own API credentials**** from the tenant administrator console, without involving Kestrel support. A credential can be limited to read-only, to specific datasets, and to a source IP allowlist. Revocation takes effect within 30 seconds across all regions.

****Kestrel support cannot recover a customer API key.**** K

gs://attestor-505506-corporate/engineering/api-and-integration-standard.txt

[5] api-and-integration-standard — 9. Integration security review — relevance 0.54

9. Integration security review

A new first-party integration is reviewed against this standard before release, covering credential handling, scope minimisation, rate limiting, and audit event emission. The review is recorded in the pull request and is a required check on the `kd-api` repository.

gs://attestor-505506-corporate/engineering/api-and-integration-standard.txt

166. Describe your process for responding to government requests for customer data.

legal · Q166 · Vendor Security Review row 167

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (6)

[1] government-requests-and-transparency-report — Government Requests Policy and Transparency Report — relevance 0.68

Government Requests Policy and Transparency Report

****Document ID:**** KD-LEG-012 · ****Version:**** 2.0 · ****Owner:**** Aaron Feldstein, General Counsel

****Approved:**** 2 February 2026 · ****Next review:**** 2 February 2027

****Maps to:**** GDPR Articles 48, 28(3)(a) · SOC 2 CC2.3 · ISO 27001:2022 A.5.5, A.5.31, A.5.34

gs://attestor-505506-corporate/legal/government-requests-and-transparency-report.txt

[2] government-requests-and-transparency-report — 1. Who may receive a request — relevance 0.68

1. Who may receive a request

All law enforcement, regulatory, and national security requests for customer data must be directed to the General Counsel at `legal@kestreldata.com`. No other person at Kestrel is authorised to accept service or to disclose customer data to a government authority. Support, sales, and engineering personnel are trained to route any such approach to the General Counsel with

gs://attestor-505506-corporate/legal/government-requests-and-transparency-report.txt

[3] government-requests-and-transparency-report — 2. How a request is handled — relevance 0.66

2. How a request is handled

1. ****Log.**** The request is recorded in the government request register on the day of receipt, with the requesting authority, the legal instrument, and the data sought.

2. ****Validate.**** The General Counsel, with outside counsel where warranted, assesses whether the instrument is valid, whether it is binding on Kestrel in the jurisdiction concerned, and whether it

gs://attestor-505506-corporate/legal/government-requests-and-transparency-report.txt

[4] government-requests-and-transparency-report — 6. Records — relevance 0.66

6. Records

The government request register is retained for ten years and is available to the auditors and, in redacted form, to a customer exercising audit rights. Retention is longer than the ordinary schedule deliberately: the value of this record is precisely that it goes back further than anyone's memory.

gs://attestor-505506-corporate/legal/government-requests-and-transparency-report.txt

[5] data-subject-rights-procedure — 9. Records — relevance 0.64

9. Records

Every request, its route, and its resolution date are recorded in the DSR register held by the DPO and retained for three years. The register is available to auditors and, in redacted form, to customers exercising their audit rights under the DPA.

gs://attestor-505506-corpus/legal/data-subject-rights-procedure.txt

[6] government-requests-and-transparency-report — 5. Emergency disclosure requests — relevance 0.56

5. Emergency disclosure requests

An emergency request citing an imminent risk to life is escalated to the General Counsel immediately, at any hour, through the `legal-oncall` PagerDuty rotation. Disclosure in those circumstances is limited to what is necessary to address the emergency, is documented in the register, and the customer is notified afterwards unless prohibited. No emergency request ha

gs://attestor-505506-corpus/legal/government-requests-and-transparency-report.txt

167. Do you maintain Records of Processing Activities under Article 30?

legal · Q167 · Vendor Security Review row 168

Yes. Kestrel maintains formal Records of Processing Activities under GDPR Article 30 (document `gdpr-records-of-processing`, section "GDPR Records of Processing Activities (Art. 30)"). These records are maintained by the Data Protection Officer under Article 30(1) where Kestrel acts as a data controller and under Article 30(2) where Kestrel acts as a data processor, and they are made available to supervisory authorities upon request.

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] gdpr-records-of-processing — GDPR Records of Processing Activities (Art. 30) — relevance 0.73

GDPR Records of Processing Activities (Art. 30)

Document ID: KD-LEG-005 · **Version:** 3.0 · **Owner:** Priya Raghunathan, DPO

Last updated: 20 January 2026 · **Next review:** 20 July 2026

Maintained under Art. 30(1) where Kestrel is controller and Art. 30(2) where Kestrel is processor. Available to supervisory authorities on request.

gs://attestor-505506-corpus/legal/gdpr-records-of-processing.txt

[2] data-subject-rights-procedure — 9. Records — relevance 0.68

9. Records

Every request, its route, and its resolution date are recorded in the DSR register held by the DPO and retained for three years. The register is available to auditors and, in redacted form, to customers exercising their audit rights under the DPA.

gs://attestor-505506-corpus/legal/data-subject-rights-procedure.txt

[3] gdpr-records-of-processing — Part A - Kestrel as Processor (Art. 30(2)) — relevance 0.66

Part A - Kestrel as Processor (Art. 30(2))

Controller: each Kestrel customer, as identified in the applicable Order Form.

Processor: Kestrel Data, Inc.

DPO: Priya Raghunathan, `dpo@kestreldata.com`

| # | Processing activity | Categories of data subject | Categories of personal data | Transfers | Retention |

| ---|---|---|---|---|

| P1 | Hosting and operating the Kestrel Insig

gs://attestor-505506-corpus/legal/gdpr-records-of-processing.txt

[4] gdpr-records-of-processing — Part B - Kestrel as Controller (Art. 30(1)) — relevance 0.64

Part B - Kestrel as Controller (Art. 30(1))

| # | Purpose | Lawful basis | Data subjects | Personal data | Retention |

| ---|---|---|---|---|

| C1 | Account administration | Art. 6(1)(b) contract | Customer administrators | Name, work email, job title | Term + 3 years |

| C2 | Billing and tax | Art. 6(1)(b), 6(1)(c) | Billing contacts | Name, email, VAT, payment token | 7 years |

gs://attestor-505506-corporal/legal/gdpr-records-of-processing.txt

[5] dpia-register — Data Protection Impact Assessment Register — relevance 0.63

Data Protection Impact Assessment Register

Document ID: KD-LEG-011 · **Version:** 1.9 · **Owner:** Priya Raghunathan, DPO

Approved: 16 January 2026 · **Next review:** 16 January 2027

Maps to: GDPR Articles 35, 36, 9, 8, 22

gs://attestor-505506-corporal/legal/dpia-register.txt

168. Do you publish a modern slavery or supply chain labour statement?

legal · Q168 · Vendor Security Review row 169

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] security-addendum — 4. Incident notification — relevance 0.53

4. Incident notification

- Personal data breach: notification within **72 hours** of confirmation.
- Confirmed unauthorised access to customer production data: **24 hours**.
- Notification content as set out in the DPA Section 7.

gs://attestor-505506-corporal/legal/security-addendum.txt

[2] security-addendum — 3. Access commitments — relevance 0.50

3. Access commitments

- Multi-factor authentication mandatory for all Kestrel personnel with production access.
- Production access on a least-privilege, just-in-time basis, expiring within 8 hours.
- No routine Kestrel access to customer production data; support access requires per-incident customer authorisation.
- Access revoked within 24 hours of personnel departure. Measured median in 2

gs://attestor-505506-corporal/legal/security-addendum.txt

[3] security-addendum — 1. Certifications maintained — relevance 0.49

1. Certifications maintained

Kestrel will maintain, for the term of the Agreement, a SOC 2 Type II report covering Security, Availability, and Confidentiality, and ISO/IEC 27001:2022 certification. Current reports are made available annually within 30 days of issuance.

If a certification lapses or an audit opinion is qualified, Kestrel will notify affected customers within **10 business days**

gs://attestor-505506-corporal/legal/security-addendum.txt

[4] security-addendum — Security Addendum — relevance 0.49

Security Addendum

Document ID: KD-LEG-008 · **Version:** 3.1 · **Owner:** Marcus Oyelaran, CISO

Effective: 1 February 2026 · Forms part of the Master Subscription Agreement

This addendum states the security commitments Kestrel makes contractually. It is deliberately narrower than the Information Security Policy: everything here is an obligation, not an aspiration.

gs://attestor-505506-corporal/legal/security-addendum.txt

[5] security-addendum — 8. Changes — relevance 0.48

8. Changes

Kestrel may update this addendum, provided that no update materially reduces the commitments during a paid term. Material changes are notified 30 days in advance.

gs://attestor-505506-corporus/legal/security-addendum.txt

169. What authorisation is required for support access to customer data?

security · Q169 · Vendor Security Review row 170

Kestrel personnel do not access customer production data as a matter of routine. Access for support purposes requires explicit per-incident customer authorisation recorded in Zendesk. This access is restricted strictly to the specific tenant and automatically expires after 24 hours (Access Control Standard, Section 5, "Customer data access").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] access-control-standard — 5. Customer data access — relevance 0.66

5. Customer data access

Kestrel personnel do not access customer production data as a matter of routine. Access for support purposes requires explicit per-incident customer authorisation recorded in Zendesk, is limited to the specific tenant, and expires after 24 hours.

Between 1 January and 31 December 2025 there were 19 such authorised accesses across 7 customers, each evidenced in the SOC

gs://attestor-505506-corporus/security/access-control-standard.txt

[2] acceptable-use-policy — 4. Data handling — relevance 0.62

4. Data handling

Restricted data may not be copied to personal cloud storage, personal email, USB media, or unmanaged devices. USB mass storage is blocked at the OS level on all managed devices.

Screen sharing during customer calls must use a dedicated demo tenant, never production.

gs://attestor-505506-corporus/security/acceptable-use-policy.txt

[3] data-handling-standard — 2. Categories of customer data processed — relevance 0.61

2. Categories of customer data processed

Kestrel Insight processes exactly four categories of customer data, defined in the DPA and in the Records of Processing Activities (KD-LEG-004):

1. **Account identity data** — end-user name, business email address, role, tenant ID.
2. **Product usage events** — timestamps, feature identifiers, tenant ID, session ID.
3. **Customer-uploaded analytics dataset**

gs://attestor-505506-corporus/security/data-handling-standard.txt

[4] access-control-standard — 3. Role-based access — relevance 0.59

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix (`SEC-GOV/access-matrix`), which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is just-in-time.

gs://attestor-505506-corporus/security/access-control-standard.txt

[5] information-security-policy — 9. Incident response — relevance 0.58

9. Incident response

Security incidents are handled under the Incident Response Runbook (KD-SEC-005). Kestrel commits contractually to notifying affected customers within 72 hours of confirming a personal data breach, and within 24 hours for incidents involving confirmed unauthorised access to customer production data.

gs://attestor-505506-corporus/security/information-security-policy.txt

170. Summarise the supplementary measures identified in your Transfer Impact Assessment.

legal · Q170 · Vendor Security Review row 171

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] transfer-impact-assessment — Transfer Impact Assessment — relevance 0.68

Transfer Impact Assessment

Document ID: KD-LEG-010 · **Version:** 2.1 · **Owner:** Priya Raghunathan, DPO

Approved: 9 January 2026 · **Next review:** 9 January 2027

Maps to: GDPR Articles 44–49 · EDPB Recommendations 01/2020 · Schrems II (C-311/18)

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

[2] transfer-impact-assessment — 1. Status — relevance 0.65

1. Status

Kestrel Data has completed a Transfer Impact Assessment, most recently updated on 9 January 2026. It is refreshed annually and on any material change to the transfer chain, the receiving country's law, or the supplementary measures relied on. A copy is available to customers under NDA.

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

[3] standard-contractual-clauses-summary — Standard Contractual Clauses and Transfer Impact Assessment - Summary — relevance 0.65

Standard Contractual Clauses and Transfer Impact Assessment - Summary

Document ID: KD-LEG-006 · **Version:** 2.2 · **Owner:** Aaron Feldstein, General Counsel

Last updated: 28 January 2026 · **Next review:** 28 January 2027

gs://attestor-505506-corporus/legal/standard-contractual-clauses-summary.txt

[4] transfer-impact-assessment — 3. Transfer mechanism — relevance 0.61

3. Transfer mechanism

The 2021 **Standard Contractual Clauses, Module Two (controller to processor)** apply between the customer and Kestrel, and **Module Three (processor to sub-processor)** between Kestrel and its US sub-processors. The **UK International Data Transfer Addendum** is incorporated for UK exports, and for Switzerland the SCCs are applied with the adaptations published by the Swiss

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

[5] transfer-impact-assessment — 6. Conclusion — relevance 0.60

6. Conclusion

For T1 and T2 the residual risk to data subjects is assessed as **low**: the data transferred is limited, pseudonymised where possible, encrypted with keys held outside the importer's jurisdiction, and unaccompanied by any customer content. For T3 and T4 the residual risk is **low** on the same basis, with the additional point that no customer content is transferred at all.

The asse

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

171. For each applicable system: How do you support California consumer rights requests?

legal · Q171 · Vendor Security Review row 172

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

172. Do you hold HITRUST certification?

security · Q172 · Vendor Security Review row 173

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] information-security-policy — 3. Certifications and attestations — relevance 0.65

3. Certifications and attestations

| Framework | Status | Evidence |

|---|---|---|

| SOC 2 Type II | Current | Report issued 14 March 2026 by Prescient Assurance LLP, covering 1 January – 31 December 2025. No exceptions noted. |

| ISO/IEC 27001:2022 | Certified | Certificate IS-2025-44817, issued by BSI on 22 September 2025, valid to 21 September 2028 |

| ISO/IEC 27701:2019 | Certified | Extension

gs://attestor-505506-corporus/security/information-security-policy.txt

[2] company-and-security-programme-overview — 8. How to obtain evidence — relevance 0.64

8. How to obtain evidence

The SOC 2 Type II report, the ISO 27001 certificate, the penetration test executive summary, and the standard DPA are available to customers and prospects under NDA through the account team, usually within two business days. The certificate and the trust page are available without an NDA.

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[3] vendor-risk-management-policy — 5. Ongoing monitoring — relevance 0.61

5. Ongoing monitoring

Tier 1 vendors are monitored continuously through SecurityScorecard, with a score drop of more than 10 points in 30 days triggering review. Attestation expiry is tracked in Vanta, with a reminder at 60 days before lapse.

gs://attestor-505506-corporus/security/vendor-risk-management-policy.txt

[4] company-and-security-programme-overview — 6. Scope of certification — relevance 0.61

6. Scope of certification

The ISO 27001 certificate scope statement reads: *"The information security management system supporting the development, operation, and support of the Kestrel Insight analytics platform, including supporting corporate functions, at Austin, Texas and for remote personnel."* The SOC 2 report covers the Security, Availability, and Confidentiality Trust Services Criteria. Pr

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[5] vendor-risk-management-policy — 2. Onboarding requirements — relevance 0.61

2. Onboarding requirements

No Tier 1 vendor is engaged without: a current SOC 2 Type II report or ISO 27001 certificate reviewed by the Security team; an executed DPA including the 2021 EU Standard Contractual Clauses where personal data leaves the EEA; documented data flows and retention; and a recorded exit plan.

Reviews are recorded in Vanta with the reviewer, date, evidence reviewed, and

gs://attestor-505506-corporus/security/vendor-risk-management-policy.txt

173. Do you have a documented AI governance policy?

legal · Q173 · Vendor Security Review row 174

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

174. What is the minimum password length enforced?

security · Q174 · Vendor Security Review row 175

Where passwords are used, Kestrel Data enforces a minimum password length of 14 characters, which are checked against the Have I Been Pwned breached-password corpus at the time of creation (Access Control Standard, Section 9, "Password requirements"). In accordance with NIST SP 800-63B guidance, routine password rotation is not forced on a schedule, but rotation is mandatory upon any evidence of compromise.

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] access-control-standard — 9. Password requirements — relevance 0.70

9. Password requirements

Where a password is used, minimum length is 14 characters, checked against the Have I Been Pwned breached-password corpus at set time. Rotation is not forced on a schedule, in line with NIST SP 800-63B guidance; rotation is forced on evidence of compromise.

gs://attestor-505506-corporus/security/access-control-standard.txt

[2] access-control-standard — 2. Multi-factor authentication — relevance 0.59

2. Multi-factor authentication

Hardware-backed MFA (WebAuthn / FIDO2, YubiKey 5 series) is mandatory for every human account. SMS and TOTP were removed as acceptable factors on 30 June 2025 following the RISK-2025-0031 treatment plan. Coverage is 100% of the 187 active employee accounts and 100% of the 24 active contractor accounts, verified continuously by Vanta control AC-07.

gs://attestor-505506-corporus/security/access-control-standard.txt

[3] access-control-standard — 1. Identity provider — relevance 0.55

1. Identity provider

All Kestrel Data systems authenticate through Okta (tenant `kestreldata.okta.com`). Local accounts on production systems are prohibited except for two documented break-glass accounts held in a sealed 1Password vault, whose use triggers a PagerDuty alert to the CISO. Both break-glass credentials were last rotated on 3 January 2026 and last used on 14 August 2025 during the

gs://attestor-505506-corporus/security/access-control-standard.txt

[4] access-control-standard — Access Control Standard — relevance 0.55

Access Control Standard

****Document ID:**** KD-SEC-002 · ****Version:**** 3.1 · ****Owner:**** Sofia Brenner, Head of IT
****Approved:**** 8 January 2026 · ****Next review:**** 8 January 2027
****Maps to:**** SOC 2 CC6.1, CC6.2, CC6.3 · ISO 27001:2022 A.5.15, A.5.16, A.5.18, A.8.2

gs://attestor-505506-corporus/security/access-control-standard.txt

[5] access-control-standard — 3. Role-based access — relevance 0.53

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix (`SEC-GOV/access-matrix`), which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is just-in-time.

gs://attestor-505506-corporus/security/access-control-standard.txt

175. For each applicable system: How do you handle a vulnerability with no available upstream fix?

security · Q175 · Vendor Security Review row 176

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (9)

[1] cloud-security-posture-standard — 6. Handling a vulnerability with no upstream fix — relevance 0.76

6. Handling a vulnerability with no upstream fix

Where no upstream fix exists, the finding is recorded in the risk register with a named

owner and the mitigation is chosen from: removing the affected component, blocking the attack path at the network or WAF layer, or applying a vendored patch maintained by Kestrel (see KD-ENG-007 §7). The vulnerability is re-reviewed weekly until an upstream fix

gs://attestor-505506-corporus/security/cloud-security-posture-standard.txt

[2] vulnerability-management-policy — Vulnerability Management Policy — relevance 0.65

Vulnerability Management Policy

Document ID: KD-SEC-006 · **Version:** 3.3 · **Owner:** Dana Whitfield, VP Engineering

Approved: 22 January 2026 · **Next review:** 22 January 2027

Maps to: SOC 2 CC7.1, CC7.2 · ISO 27001:2022 A.8.8

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[3] network-security-standard — Network Security Standard — relevance 0.61

Network Security Standard

Document ID: KD-SEC-016 · **Version:** 2.0 · **Owner:** Dana Whitfield, VP Engineering

Approved: 5 February 2026 · **Next review:** 5 February 2027

Maps to: SOC 2 CC6.6, CC6.7, CC7.1 · ISO 27001:2022 A.8.20, A.8.21, A.8.22, A.8.23

gs://attestor-505506-corporus/security/network-security-standard.txt

[4] risk-management-and-governance — 5. Worked examples from the register — relevance 0.60

5. Worked examples from the register

| Risk | Description | Treatment | Residual |

|---|---|---|---|

| RISK-2025-0031 | SMS and TOTP factors phishable | Mitigate — hardware factors mandated 30 June 2025 | Low |

| RISK-2024-0017 | No file-scanning anti-malware on container hosts | Accept — immutable hosts, signed images, runtime detection | Low |

|

| RISK-2025-0044 | Single-cloud concentration on AWS

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[5] cloud-security-posture-standard — Cloud Security Posture and Configuration Standard — relevance 0.60

Cloud Security Posture and Configuration Standard

Document ID: KD-SEC-017 · **Version:** 1.8 · **Owner:** Dana Whitfield, VP Engineering

Approved: 29 January 2026 · **Next review:** 29 January 2027

Maps to: SOC 2 CC6.1, CC7.1, CC8.1 · ISO 27001:2022 A.8.9, A.8.19, A.8.32

gs://attestor-505506-corporus/security/cloud-security-posture-standard.txt

[6] vulnerability-management-policy — 1. Remediation SLAs — relevance 0.59

1. Remediation SLAs

Severity is assigned from CVSS v3.1 base score, adjusted for exploitability and exposure.

Internet-facing findings are escalated one level.

| Severity | CVSS | Remediation SLA | Measured 2025 compliance |

|---|---|---|---|

| Critical | 9.0-10.0 | **7 days** | 100% (11 of 11) |

| High | 7.0-8.9 | **30 days** | 96% (74 of 77) |

| Medium | 4.0-6.9 | **90 days** | 91% |

|

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[7] vulnerability-management-policy — 4. Penetration testing — relevance 0.59

4. Penetration testing

An independent penetration test is commissioned **annually** at minimum, and additionally

before any significant architectural change. The most recent was performed by Include

Security from 3 to 14 February 2026 (engagement INSEC-2026-0219). See the Penetration

Test Executive Summary (KD-SEC-007).

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[8] pen-test-executive-summary — 3. Findings summary — relevance 0.59

3. Findings summary
| Severity | Found | Remediated | Retest verified |
|---|---|---|---|
| Critical | 0 | - | - |
| High | 1 | 1 | 18 March 2026 |
| Medium | 4 | 4 | 18 March 2026 |
| Low | 7 | 5 | 18 March 2026 |
| Informational | 9 | Accepted / tracked | - |

****No cross-tenant data access was achieved.**** Tenant isolation held under every tested condition, including direct object refere

gs://attestor-505506-corpus/security/pen-test-executive-summary.txt

[9] pen-test-executive-summary — 5. Medium findings, in brief — relevance 0.58

5. Medium findings, in brief

1. Session cookie missing `SameSite=Strict` on one legacy subdomain. Fixed 2 March 2026.
2. Verbose error messages disclosing library versions on 4 API endpoints. Fixed 4 March 2026.
3. S3 bucket `kestrel-public-assets` permitted `s3:ListBucket` to authenticated AWS principals outside the Organization. Fixed 27 February 2026 with an explicit bucket policy den

gs://attestor-505506-corpus/security/pen-test-executive-summary.txt

176. What security evidence do you require from subprocessors before engagement?

security · Q176 · Vendor Security Review row 177

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (7)

[1] vendor-risk-management-policy — 2. Onboarding requirements — relevance 0.67

2. Onboarding requirements

No Tier 1 vendor is engaged without: a current SOC 2 Type II report or ISO 27001 certificate reviewed by the Security team; an executed DPA including the 2021 EU Standard Contractual Clauses where personal data leaves the EEA; documented data flows and retention; and a recorded exit plan.

Reviews are recorded in Vanta with the reviewer, date, evidence reviewed, and

gs://attestor-505506-corpus/security/vendor-risk-management-policy.txt

[2] vendor-risk-management-policy — 1. Tiering — relevance 0.66

1. Tiering

Vendors are tiered on data sensitivity and operational dependency.

| Tier | Definition | Diligence | Review |

|---|---|---|---|

| **Tier 1** | Processes customer production data, or an outage stops the platform | Full security review, SOC 2 or ISO 27001 evidence required, DPA required | Annual |

| **Tier 2** | Processes Kestrel internal or employee data | Security questionnaire, a

gs://attestor-505506-corpus/security/vendor-risk-management-policy.txt

[3] vendor-risk-management-policy — 5. Ongoing monitoring — relevance 0.64

5. Ongoing monitoring

Tier 1 vendors are monitored continuously through SecurityScorecard, with a score drop of more than 10 points in 30 days triggering review. Attestation expiry is tracked in Vanta, with a reminder at 60 days before lapse.

gs://attestor-505506-corpus/security/vendor-risk-management-policy.txt

[4] vendor-risk-management-policy — 3. Subprocessors — relevance 0.63

3. Subprocessors

Subprocessors engaged for customer personal data are listed publicly in the Subprocessor List (KD-LEG-002) at `kestreldata.com/subprocessors`. Customers may subscribe to change notifications and receive **30 days** advance notice of any addition, during which they may object on reasonable data-protection grounds.

gs://attestor-505506-corporate/security/vendor-risk-management-policy.txt

[5] company-and-security-programme-overview — 8. How to obtain evidence — relevance 0.62

8. How to obtain evidence

The SOC 2 Type II report, the ISO 27001 certificate, the penetration test executive summary, and the standard DPA are available to customers and prospects under NDA through the account team, usually within two business days. The certificate and the trust page are available without an NDA.

gs://attestor-505506-corporate/security/company-and-security-programme-overview.txt

[6] vendor-risk-management-policy — 6. Offboarding — relevance 0.61

6. Offboarding

On termination, the vendor must certify deletion of Kestrel and customer data within 30 days. Certification is filed in the vendor record. Access is revoked on the termination date through the standard leaver process.

gs://attestor-505506-corporate/security/vendor-risk-management-policy.txt

[7] vendor-risk-management-policy — Vendor Risk Management Policy — relevance 0.60

Vendor Risk Management Policy

Document ID: KD-SEC-008 · **Version:** 2.0 · **Owner:** Aaron Feldstein, General Counsel

Approved: 4 February 2026 · **Next review:** 4 February 2027

Maps to: SOC 2 CC9.2 · ISO 27001:2022 A.5.19-A.5.22 · GDPR Art. 28

gs://attestor-505506-corporate/security/vendor-risk-management-policy.txt

177. Describe how tenant isolation is enforced. If not, describe compensating controls.

engineering · Q177 · Vendor Security Review row 178

Kestrel Insight operates a multi-tenant architecture with logical isolation enforced across three distinct layers: 1.

Database Layer: PostgreSQL row-level security (RLS) policies are keyed on `tenant\_id` and applied at the connection level from an authenticated session variable. Application queries cannot opt out of these policies. 2.

Application Layer: Every incoming request carries a validated tenant claim. The data access layer enforces isolation programmatically via a repository base class—rather than relying on developer convention—refusing any query that lacks a tenant predicate. 3. **Storage Layer:** Amazon S3 object keys are tenant-prefixed, and IAM policies strictly constrain access by prefix. Tenant isolation is continuously validated via an 84-assertion automated test suite run on every build, and was independently verified during the February 2026 penetration test, where no cross-tenant access was achieved (`infrastructure-architecture-overview`, Section 5, "Tenant isolation").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] data-flow-and-shared-responsibility — 4. Complementary user entity controls — relevance 0.62

4. Complementary user entity controls

The SOC 2 report lists these as complementary user entity controls; they are restated here because a customer reading only this document should still see them. If a customer does not operate the controls in the second list, Kestrel's controls in the first do not compensate: Kestrel cannot detect that a departed employee of the customer still holds a valid sess

gs://attestor-505506-corporate/engineering/data-flow-and-shared-responsibility.txt

[2] infrastructure-architecture-overview — 5. Tenant isolation — relevance 0.62

5. Tenant isolation

Kestrel Insight is **multi-tenant** with logical isolation. There is no per-customer infrastructure, no single-tenant deployment option, and no customer-VPC option.

Isolation is enforced at three layers:

1. **Database** - PostgreSQL row-level security policies keyed on `tenant\_id`, applied at the connection level from an authenticated session variable. No application

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[3] data-flow-and-shared-responsibility — 3. The shared responsibility model — relevance 0.59

3. The shared responsibility model

Security of the platform is Kestrel's. Security of what the customer does with it is the customer's. The line is drawn here rather than left implicit, because an unstated boundary is where a breach lands on whoever is less able to argue.

Kestrel is responsible for:

* physical and environmental security of the infrastructure (through AWS), and the cloud
co

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[4] infrastructure-architecture-overview — 6. Network — relevance 0.58

6. Network

Private subnets for all compute and data. No public IP addresses on workload instances. Ingress is exclusively through Cloudflare, then an AWS Application Load Balancer, then the Istio ingress gateway. Egress is through NAT gateways with an allowlist for known destinations.

Security groups are managed in Terraform and default-deny. There are no `0.0.0.0/0` ingress rules in produc

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[5] infrastructure-architecture-overview — 2. Account structure — relevance 0.57

2. Account structure

AWS Organizations with 9 accounts: `management`, `security-tooling`, `log-archive`, `shared-services`, `prod-us`, `prod-eu`, `staging`, `dev`, `sandbox`. Service Control Policies enforce guardrails at the Organization level, including mandatory EBS encryption, denial of root user actions, and denial of CloudTrail or GuardDuty disablement.

The `log-archive` account has no

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

178. Please confirm: Provide your ISO 27001 certificate and its scope statement.

security · Q178 · Vendor Security Review row 179

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

179. In what year was the company founded, and where is it incorporated?

legal · Q179 · Vendor Security Review row 180

Kestrel Data, Inc. was incorporated on April 8, 2019, as a Delaware C-corporation (`legal-and-regulatory-history`, Section 4, "Corporate structure and change of control").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] legal-and-regulatory-history — 4. Corporate structure and change of control — relevance 0.74

4. Corporate structure and change of control

Kestrel Data, Inc. is a Delaware C-corporation incorporated on 8 April 2019, privately held, with a single class of common stock and two preferred series (Series A, 2021; Series B, 2023). There are no subsidiaries other than **Kestrel Data Ireland Limited** (company number 712884, registered in Dublin), which employs EU personnel and is the

gs://attestor-505506-corpus/legal/legal-and-regulatory-history.txt

[2] legal-and-regulatory-history — 1. Litigation — relevance 0.71

1. Litigation

****Kestrel Data is not a party to any pending litigation relating to data protection, privacy, or information security**, and has not been since incorporation in 2019.**

The company has been party to two commercial disputes in total, neither involving personal data, security, or availability:

Matter	Year	Nature	Outcome
---	---	---	---
Kestrel Data, Inc. v. Northbeam Anal			

gs://attestor-505506-corpus/legal/legal-and-regulatory-history.txt

[3] legal-and-regulatory-history — 2. Regulatory enforcement — relevance 0.68

2. Regulatory enforcement

****Kestrel Data has never been subject to a regulatory enforcement action, fine, consent decree, undertaking, or formal investigation** by any data protection authority, sectoral regulator, or competition authority. No supervisory authority has issued Kestrel a reprimand, order, or corrective measure under Article 58 of the GDPR.**

Kestrel has never made a personal data bre

gs://attestor-505506-corpus/legal/legal-and-regulatory-history.txt

[4] legal-and-regulatory-history — 5. Insolvency and going concern — relevance 0.68

5. Insolvency and going concern

Kestrel has never entered any insolvency, administration, receivership, or similar proceeding, and no such proceeding is threatened. The most recent audited financial statements were issued without a going-concern qualification.

gs://attestor-505506-corpus/legal/legal-and-regulatory-history.txt

[5] privacy-policy — Privacy Policy — relevance 0.68

Privacy Policy

****Document ID:** KD-LEG-003 · ****Version:** 4.0 · ****Owner:** Priya Raghunathan, DPO****
****Effective:** 15 January 2026 · ****Published at:** `kestreldata.com/privacy`******

This policy describes how Kestrel Data, Inc. handles personal data where Kestrel is the ****controller****. Where Kestrel processes personal data on behalf of a business customer, that customer is the controller and its own

gs://attestor-505506-corpus/legal/privacy-policy.txt

180. How frequently are user access reviews performed?

security · Q180 · Vendor Security Review row 181

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

181. For each applicable system: Do you operate active-active failover between regions?

engineering · Q181 · Vendor Security Review row 182

No, Kestrel Data does not operate active-active failover between AWS regions. According to KD-ENG-003 ***Infrastructure Architecture Overview*** (Section 1, "Cloud footprint" and Section 4, "Data layer"), Kestrel operates two independent production instances running in single primary regions across three availability zones (`us-east-1` for US/North America and `eu-west-1` for EU). High availability is handled intra-region using AWS Multi-AZ deployments, while secondary regions (`us-west-2` and `eu-central-1`) are used solely as cross-region backup replication targets

within their respective residency boundaries (KD-ENG-003, Section 1; KD-ENG-004 *Backup and Restore Procedure*, Section 2, "Encryption and location").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (10)

[1] backup-restore-procedure — 2. Encryption and location — relevance 0.63

2. Encryption and location

All backups are encrypted with AES-256 using AWS KMS. The daily logical dump uses a **separate CMK** from the primary database, so that compromise of the primary key does not compromise the backups.

Cross-region replication stays inside the residency boundary: `us-east-1` replicates to `us-west-2`, `eu-west-1` replicates to `eu-central-1`. EU customer data never le

gs://attestor-505506-corpus/engineering/backup-restore-procedure.txt

[2] backup-restore-procedure — 5. Tenant-scoped restore — relevance 0.59

5. Tenant-scoped restore

A single customer can be restored without affecting others, by restoring to an isolated account and exporting that tenant rows back. This was exercised once in production, on 22 September 2025, at a customer request following an erroneous bulk delete on their side. Time to complete was 5 hours 10 minutes.

gs://attestor-505506-corpus/engineering/backup-restore-procedure.txt

[3] backup-restore-procedure — 1. What is backed up — relevance 0.59

1. What is backed up

| Asset | Method | Frequency | Retention |

|---|---|---|---|

| RDS PostgreSQL | Automated snapshots + WAL archiving (PITR) | Continuous | **35 days** |

| RDS logical dump | `pg\_dump` to S3, encrypted with a separate CMK | Daily 03:00 UTC | 90 days |

| S3 objects | Versioning + cross-region replication | Continuous | 90 days for non-current versions |

| Snowflake | Time Tr

gs://attestor-505506-corpus/engineering/backup-restore-procedure.txt

[4] backup-restore-procedure — 4. Test results — relevance 0.58

4. Test results

Restore is tested **quarterly**, and the test is a real restore, not a backup-listing check.

| Quarter | Date | Duration | Assertions | Outcome |

|---|---|---|---|---|

| Q1 2026 | 17 Jan 2026 | 2h 41m | 1,240 / 1,240 | Pass |

| Q4 2025 | 11 Oct 2025 | 3h 02m | 1,238 / 1,240 | Pass, 2 known-stale fixtures corrected |

| Q3 2025 | 19 Jul 2025 | 3h 20m | 1,240 / 1,240 | Pass |

gs://attestor-505506-corpus/engineering/backup-restore-procedure.txt

[5] backup-restore-procedure — 3. Restore procedure — relevance 0.57

3. Restore procedure

1. Declare the restore scope: point in time, and whether tenant-scoped or full.

2. Provision an isolated restore account from the Terraform module `restore-target`.

3. Restore the RDS snapshot or PITR target into the isolated account.

4. Run the integrity suite: 1,240 assertions covering row counts, referential integrity, tenant isolation invariants, and known-value spo

gs://attestor-505506-corpus/engineering/backup-restore-procedure.txt

[6] infrastructure-architecture-overview — 1. Cloud footprint — relevance 0.57

1. Cloud footprint

Kestrel runs on **Amazon Web Services**. There are two independent production instances:

| Instance | Region | Serves |

|---|---|---|

| US | `us-east-1` (3 AZs) | North America, and customers with no residency requirement |

| EU | `eu-west-1` (3 AZs) | EEA, UK, and Swiss customers electing EU residency |

Backup replication targets `us-west-2` and `eu-central-1` respecti

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[7] infrastructure-architecture-overview — 3. Compute — relevance 0.57

3. Compute

Amazon EKS (Kubernetes 1.31) with managed node groups spanning three availability zones. Workloads run as containers built from distroless base images, as non-root, with read-only root filesystems and dropped Linux capabilities. Pod Security Standards are enforced at the `restricted` level.

Node images are immutable; nodes are recycled with a maximum age of 30 days rather than pa

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[8] infrastructure-architecture-overview — 4. Data layer — relevance 0.57

4. Data layer

| Store | Technology | Purpose |

|---|---|---|

| Primary OLTP | Amazon RDS PostgreSQL 16, Multi-AZ | Application state |

| Analytics | Snowflake | Customer analytics workloads |

| Object storage | Amazon S3 | Uploads, exports, backups |

| Cache | Amazon ElastiCache (Redis 7) | Session and query cache |

| Search | OpenSearch 2.13 | In-product search |

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[9] infrastructure-architecture-overview — Infrastructure Architecture Overview — relevance 0.56

Infrastructure Architecture Overview

Document ID: KD-ENG-003 · **Version:** 3.4 · **Owner:** Dana Whitfield, VP Engineering

Last updated: 5 February 2026 · **Classification:** Confidential, NDA required

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[10] infrastructure-architecture-overview — 6. Network — relevance 0.55

6. Network

Private subnets for all compute and data. No public IP addresses on workload instances. Ingress is exclusively through Cloudflare, then an AWS Application Load Balancer, then the Istio ingress gateway. Egress is through NAT gateways with an allowlist for known destinations.

Security groups are managed in Terraform and default-deny. There are no `0.0.0.0/0` ingress rules in produc

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

182. Please confirm: Do you encrypt customer data at rest?

security · Q182 · Vendor Security Review row 183

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

183. Do you have data loss prevention controls on endpoints?

security · Q183 · Vendor Security Review row 184

Yes, Kestrel Data enforces data loss prevention (DLP) controls on endpoints as part of a multi-layered DLP approach. According to the ****Endpoint Protection and Data Loss Prevention Standard (KD-SEC-015 §5)**** and the ****Asset Management Standard (§6)****: ****Removable Media Restrictions:**** Kandji policy blocks write access to USB mass storage across all managed laptops and endpoints, with no approved workflow for transferring customer data onto

removable media. * **Local Sharing Controls:** AirDrop to non-Kestrel devices is disabled via policy. These endpoint measures are complemented by email DLP through Google Workspace (inspecting and quarantining outbound messages containing sensitive patterns or credentials) and cloud egress monitoring on production data stores (**Endpoint Protection and Data Loss Prevention Standard §5**).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] endpoint-protection-standard — Endpoint Protection and Data Loss Prevention Standard — relevance 0.68

Endpoint Protection and Data Loss Prevention Standard

Document ID: KD-SEC-015 · **Version:** 2.2 · **Owner:** Sofia Brenner, Head of IT

Approved: 19 January 2026 · **Next review:** 19 January 2027

Maps to: SOC 2 CC6.6, CC6.8, CC7.1 · ISO 27001:2022 A.8.1, A.8.7, A.8.12, A.8.16

gs://attestor-505506-corporus/security/endpoint-protection-standard.txt

[2] endpoint-protection-standard — 5. Data loss prevention — relevance 0.66

5. Data loss prevention

DLP controls operate at three points rather than relying on a single agent:

* **Endpoint** — Kandji policy blocks USB mass storage write access on all laptops. AirDrop to non-Kestrel devices is disabled.

* **Email** — Google Workspace DLP inspects outbound mail for tenant identifiers, bulk personal data patterns, and credential-shaped strings, quarantining matches for

gs://attestor-505506-corporus/security/endpoint-protection-standard.txt

[3] asset-management-standard — 6. Removable media — relevance 0.65

6. Removable media

Write access to USB mass storage is blocked on all managed endpoints by policy. There is no approved workflow for moving customer data onto removable media, and none has been requested since the control was introduced in March 2024.

gs://attestor-505506-corporus/security/asset-management-standard.txt

[4] asset-management-standard — 3. Endpoint lifecycle — relevance 0.61

3. Endpoint lifecycle

Devices are procured centrally, enrolled in Kandji before issue, and issued with a recorded serial number against the person in Rippling. A device is never issued unenrolled, because an unenrolled device cannot be wiped remotely.

At offboarding the device is returned within 5 business days, remotely wiped, and either re-issued or disposed of. Where a remote contractor does n

gs://attestor-505506-corporus/security/asset-management-standard.txt

[5] endpoint-protection-standard — 4. Disk encryption — relevance 0.59

4. Disk encryption

FileVault 2 is enforced on all macOS devices, with recovery keys held in Kandji custody; LUKS is enforced on Linux workstations. Compliance is 100% of 174 devices, verified continuously by Vanta control DE-03.

gs://attestor-505506-corporus/security/endpoint-protection-standard.txt

184. How many security incidents were recorded in the last calendar year? If not, describe compensating controls.

security · Q184 · Vendor Security Review row 185

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

185. Do you retain an external incident response firm?

Yes, Kestrel retains Mandiant on a pre-negotiated incident response retainer (contract MNDT-2025-1180, effective 1 September 2025, 40 hours pre-paid annually) with a 4-hour response SLA for SEV1 incidents. Outside breach counsel is retained through Fenwick and West LLP (‘incident-response-runbook’, Section 7. External support).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] incident-response-runbook — 7. External support — relevance 0.67

7. External support

Kestrel retains **Mandiant** on a pre-negotiated incident response retainer (contract MNDT-2025-1180, effective 1 September 2025, 40 hours pre-paid annually) with a 4-hour response SLA for SEV1. Outside breach counsel is Fenwick and West LLP.

gs://attestor-505506-corpus/security/incident-response-runbook.txt

[2] incident-response-runbook — Incident Response Runbook — relevance 0.59

Incident Response Runbook

Document ID: KD-SEC-005 · **Version:** 5.0 · **Owner:** Marcus Oyelaran, CISO

Approved: 27 January 2026 · **Last exercised:** 3 December 2025 (tabletop)

Maps to: SOC 2 CC7.3, CC7.4, CC7.5 · ISO 27001:2022 A.5.24-A.5.28 · GDPR Art. 33, 34

gs://attestor-505506-corpus/security/incident-response-runbook.txt

[3] incident-response-runbook — 6. Evidence handling — relevance 0.59

6. Evidence handling

The IC directs preservation before remediation wherever containment allows. EBS snapshots, memory captures where feasible, and relevant log ranges are exported to a dedicated forensics S3 bucket with Object Lock in compliance mode, retention 1 year. Chain of custody is recorded in the incident ticket.

gs://attestor-505506-corpus/security/incident-response-runbook.txt

[4] incident-response-runbook — 2. Roles — relevance 0.58

2. Roles

The Incident Commander owns the response and is deliberately not the person fixing the problem; ICs are drawn from a rota of 6 trained staff. The Communications Lead owns customer, internal, and regulator messaging. A Scribe maintains the timeline for every SEV1 and SEV2. Subject matter experts are pulled in as needed.

gs://attestor-505506-corpus/security/incident-response-runbook.txt

[5] incident-response-runbook — 9. 2025 incident summary — relevance 0.57

9. 2025 incident summary

41 security events recorded. Zero SEV1. Two SEV2, both resolved without customer data exposure:

- **INC-2025-0044** (14 August 2025) - RDS failover fault causing 41 minutes of degraded service. No data loss; RPO and RTO both met. Root cause was a misconfigured connection pool ceiling.

- **INC-2025-0071** (2 November 2025) - a contractor account remained active f

gs://attestor-505506-corpus/security/incident-response-runbook.txt

186. What is your backup retention period?

engineering · Q186 · Vendor Security Review row 187

Backup retention periods vary depending on the specific asset and backup type: **RDS PostgreSQL**: Automated snapshots and Write-Ahead Log (WAL) archiving for Point-in-Time Recovery (PITR) are retained for 35 days. Daily logical dumps (‘pg_dump’ to S3, encrypted with a separate CMK) are retained for 90 days. **S3 Objects**: Non-current versions are retained for 90 days via versioning and cross-region replication. **Snowflake**: Data is retained for 90 days via Time Travel (Enterprise edition), followed by a 7-day Fail-safe period. **Secrets**: Prior versions in AWS Secrets Manager are retained for 30 days. **EKS Cluster State**: Terraform state stored in Terraform Cloud is versioned and retained indefinitely. Backups expire automatically, and when a tenant is purged

following customer termination, data in backups expires along the standard retention cycle up to a maximum of 35 days later. **Citations:** ``backup-restore-procedure``, Section 1. "What is backed up" ``backup-restore-procedure``, Section 6. "Backup deletion"

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] `backup-restore-procedure` — 6. Backup deletion — relevance 0.71

6. Backup deletion

Backups expire automatically. When a customer terminates and the tenant purge runs, backups containing that data expire on the normal cycle, a maximum of **35 days** later. Kestrel does not selectively surgically remove a tenant from historical backup images, and says so rather than implying otherwise.

`gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt`

[2] `backup-restore-procedure` — 1. What is backed up — relevance 0.68

1. What is backed up

| Asset | Method | Frequency | Retention |

|---|---|---|---|

| RDS PostgreSQL | Automated snapshots + WAL archiving (PITR) | Continuous | **35 days** |

| RDS logical dump | `pg_dump` to S3, encrypted with a separate CMK | Daily 03:00 UTC | 90 days |

| S3 objects | Versioning + cross-region replication | Continuous | 90 days for non-current versions |

| Snowflake | Time Tr

`gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt`

[3] `backup-restore-procedure` — 4. Test results — relevance 0.63

4. Test results

Restore is tested **quarterly**, and the test is a real restore, not a backup-listing check.

| Quarter | Date | Duration | Assertions | Outcome |

|---|---|---|---|

| Q1 2026 | 17 Jan 2026 | 2h 41m | 1,240 / 1,240 | Pass |

| Q4 2025 | 11 Oct 2025 | 3h 02m | 1,238 / 1,240 | Pass, 2 known-stale fixtures corrected |

| Q3 2025 | 19 Jul 2025 | 3h 20m | 1,240 / 1,240 | Pass |

`gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt`

[4] `backup-restore-procedure` — 5. Tenant-scoped restore — relevance 0.62

5. Tenant-scoped restore

A single customer can be restored without affecting others, by restoring to an isolated account and exporting that tenant rows back. This was exercised once in production, on 22 September 2025, at a customer request following an erroneous bulk delete on their side. Time to complete was 5 hours 10 minutes.

`gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt`

[5] `backup-restore-procedure` — Backup and Restore Procedure — relevance 0.60

Backup and Restore Procedure

Document ID: KD-ENG-004 · **Version:** 2.5 · **Owner:** Sofia Brenner, Head of IT

Approved: 29 January 2026 · **Maps to:** SOC 2 A1.2 · ISO 27001:2022 A.8.13

`gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt`

187. How frequently do you commission independent penetration testing?

security · Q187 · Vendor Security Review row 188

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] `vulnerability-management-policy` — 4. Penetration testing — relevance 0.68

4. Penetration testing

An independent penetration test is commissioned **annually** at minimum, and additionally before any significant architectural change. The most recent was performed by Include Security from 3 to 14 February 2026 (engagement INSEC-2026-0219). See the Penetration Test Executive Summary (KD-SEC-007).

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[2] network-security-standard — 10. Testing — relevance 0.62

10. Testing

Network controls are exercised annually by the external penetration test. The February 2026 test (Include Security, INSEC-2026-0219) attempted lateral movement from a compromised application container and did not achieve it; the finding raised was the rate limiting gap on the password reset endpoint, remediated on 27 February 2026.

gs://attestor-505506-corporus/security/network-security-standard.txt

[3] pen-test-executive-summary — Penetration Test Executive Summary — relevance 0.61

Penetration Test Executive Summary

Document ID: KD-SEC-007 · **Engagement:** INSEC-2026-0219

Tester: Include Security, Inc. · **Dates:** 3-14 February 2026

Report issued: 24 February 2026 · **Retest completed:** 18 March 2026

Classification: Confidential - shareable with customers under NDA

gs://attestor-505506-corporus/security/pen-test-executive-summary.txt

[4] company-and-security-programme-overview — 4. Governance — relevance 0.60

4. Governance

The CISO reports to the CEO and to the board quarterly. A Security Steering Group meets monthly. The risk register holds 41 open risks and is reviewed monthly and re-scored quarterly. Full detail is in KD-SEC-018.

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[5] company-and-security-programme-overview — 3. Security programme in summary — relevance 0.60

3. Security programme in summary

The programme is built on four commitments, each evidenced elsewhere in this corpus rather than asserted here:

1. **Independent verification:** SOC 2 Type II (Prescient Assurance LLP, report issued 14 March 2026 covering 1 January – 31 December 2025, **no exceptions**) and ISO 27001:2022 (BSI certificate 'IS-2025-44817', issued 22 September 2025, valid to 21

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

188. Do you carry professional indemnity insurance?

legal · Q188 · Vendor Security Review row 189

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

189. Do you operate anti-malware controls on servers?

security · Q189 · Vendor Security Review row 190

Traditional file-scanning anti-malware is not deployed on production server hosts. Production compute runs immutable, minimal container images on Bottlerocket hosts protected by compensating controls, which include: * Read-only root filesystems * No interactive shell access in normal operation * Image signing enforced at admission * The CrowdStrike Falcon sensor running in Linux mode across all production compute nodes for runtime behavioural detection This posture is documented as an accepted risk (RISK-2024-0017) and was reviewed without exception by auditors during the 2025 SOC 2 period (**endpoint-protection-standard**, Section 2: "Endpoint detection and response" and Section 3: "Anti-malware on servers").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by SecurityAgent

Evidence (5)

[1] endpoint-protection-standard — 3. Anti-malware on servers — relevance 0.68

3. Anti-malware on servers

Production compute runs immutable, minimal container images on Bottlerocket hosts. Traditional file-scanning anti-malware is not deployed on those hosts; the compensating controls are read-only root filesystems, no interactive shell access in normal operation, image signing enforced at admission, and the Falcon sensor running in Linux mode for runtime behavioural detecti

gs://attestor-505506-corporus/security/endpoint-protection-standard.txt

[2] endpoint-protection-standard — 4. Disk encryption — relevance 0.57

4. Disk encryption

FileVault 2 is enforced on all macOS devices, with recovery keys held in Kandji custody; LUKS is enforced on Linux workstations. Compliance is 100% of 174 devices, verified continuously by Vanta control DE-03.

gs://attestor-505506-corporus/security/endpoint-protection-standard.txt

[3] endpoint-protection-standard — 8. Patching of endpoints — relevance 0.57

8. Patching of endpoints

Operating system updates are enforced within 14 days of release for standard updates and 72 hours for updates addressing a Critical vulnerability, with a Kandji deferral window that cannot be extended by the user. Measured compliance at the last audit point (1 February 2026) was 168 of 174 devices within policy, the remaining six being on extended leave with access suspend

gs://attestor-505506-corporus/security/endpoint-protection-standard.txt

[4] endpoint-protection-standard — 5. Data loss prevention — relevance 0.55

5. Data loss prevention

DLP controls operate at three points rather than relying on a single agent:

* **Endpoint** — Kandji policy blocks USB mass storage write access on all laptops. AirDrop to non-Kestrel devices is disabled.

* **Email** — Google Workspace DLP inspects outbound mail for tenant identifiers, bulk personal data patterns, and credential-shaped strings, quarantining matches for

gs://attestor-505506-corporus/security/endpoint-protection-standard.txt

[5] endpoint-protection-standard — 2. Endpoint detection and response — relevance 0.55

2. Endpoint detection and response

CrowdStrike Falcon is deployed on 100% of managed endpoints and on all production compute nodes. Coverage is reconciled nightly against the Kandji and AWS inventories, and a device present in inventory but absent from Falcon raises a ticket to the Head of IT within one business day. The reconciliation found two gaps during 2025, both new contractor laptops, b

gs://attestor-505506-corporus/security/endpoint-protection-standard.txt

190. Do you share personal data with advertising networks?

legal · Q190 · Vendor Security Review row 191

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

191. Is there board-level oversight of information security? If not, describe compensating controls.

security · Q191 · Vendor Security Review row 192

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

192. Do you follow OWASP secure coding guidance?

engineering · Q192 · Vendor Security Review row 193

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (9)

[1] sdlc-policy — Secure Software Development Lifecycle Policy — relevance 0.70

Secure Software Development Lifecycle Policy

****Document ID:**** KD-ENG-001 · ****Version:**** 4.1 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 20 January 2026 · ****Next review:**** 20 January 2027

****Maps to:**** SOC 2 CC8.1 · ISO 27001:2022 A.8.25-A.8.31

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[2] api-and-integration-standard — 9. Integration security review — relevance 0.65

9. Integration security review

A new first-party integration is reviewed against this standard before release, covering credential handling, scope minimisation, rate limiting, and audit event emission. The review is recorded in the pull request and is a required check on the `kd-api` repository.

gs://attestor-505506-corporus/engineering/api-and-integration-standard.txt

[3] third-party-library-policy — Third-Party Library Policy — relevance 0.64

Third-Party Library Policy

****Document ID:**** KD-ENG-008 · ****Version:**** 1.4 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 22 January 2026 · ****Maps to:**** SOC 2 CC7.1 · ISO 27001:2022 A.8.28

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[4] secrets-management-standard — Secrets Management Standard — relevance 0.63

Secrets Management Standard

****Document ID:**** KD-ENG-006 · ****Version:**** 2.1 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 22 January 2026 · ****Maps to:**** SOC 2 CC6.1 · ISO 27001:2022 A.8.24

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

[5] api-and-integration-standard — API, Authentication and Integration Standard — relevance 0.63

API, Authentication and Integration Standard

****Document ID:**** KD-ENG-005 · ****Version:**** 2.6 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 21 January 2026 · ****Next review:**** 21 January 2027

****Maps to:**** SOC 2 CC6.1, CC6.6, CC8.1 · ISO 27001:2022 A.5.15, A.8.5, A.8.26

gs://attestor-505506-corporus/engineering/api-and-integration-standard.txt

[6] sdlc-policy — 4. Security in the pipeline — relevance 0.62

4. Security in the pipeline

Static analysis (Semgrep, CodeQL), dependency scanning (Snyk), IaC scanning (Checkov), and secret scanning (Gitleaks pre-commit plus GitHub push protection) all run on every pull request. A Critical or High dependency finding blocks the merge.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[7] change-management-procedure — Change Management Procedure — relevance 0.60

Change Management Procedure

****Document ID:**** KD-ENG-002 · ****Version:**** 3.0 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 20 January 2026 · ****Maps to:**** SOC 2 CC8.1 · ISO 27001:2022 A.8.32

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[8] third-party-library-policy — 4. Vulnerability response — relevance 0.59

4. Vulnerability response

Dependency vulnerabilities follow the SLAs in KD-SEC-006: Critical 7 days, High 30 days, Medium 90 days. Snyk runs on every pull request and daily against `main`. A Critical or High finding blocks merge.

Where no upstream fix exists within the SLA, the options in order of preference are: apply a vendored patch, replace the dependency, or accept the risk with a document

gs://attestor-505506-corporate/engineering/third-party-library-policy.txt

[9] change-management-procedure — 6. Customer notification — relevance 0.58

6. Customer notification

Customers are notified at least **7 days** in advance of any change expected to cause degraded service or to require action on their part. Breaking API changes follow the deprecation policy: minimum **12 months** notice, with the deprecated version remaining available throughout.

gs://attestor-505506-corporate/engineering/change-management-procedure.txt

193. Have you completed a cryptographic inventory?

security · Q193 · Vendor Security Review row 194

Yes. Kestrel completed a cryptographic inventory (`SEC-GOV/crypto-inventory`) on 19 January 2026 as an initial step toward post-quantum readiness (`encryption-standard`, Section 6: "Post-quantum posture").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by SecurityAgent

Evidence (5)

[1] encryption-standard — 6. Post-quantum posture — relevance 0.60

6. Post-quantum posture

Kestrel completed a cryptographic inventory (`SEC-GOV/crypto-inventory`, 19 January 2026) as the first step toward post-quantum readiness. TLS connections terminated at Cloudflare already negotiate the hybrid X25519MLKEM768 key agreement where the client supports it. No migration commitment date has been set for internal services.

gs://attestor-505506-corporate/security/encryption-standard.txt

[2] encryption-standard — 3. Key management — relevance 0.58

3. Key management

Customer-facing encryption keys are AWS KMS Customer Managed Keys. Key policies restrict use to named service roles. Key administrators and key users are disjoint sets: no individual holds both roles, enforced by a Service Control Policy at the AWS Organization level.

Automatic annual rotation is enabled on all CMKs. Manual rotation is triggered on suspected compromise. Key

gs://attestor-505506-corporate/security/encryption-standard.txt

[3] encryption-standard — Encryption Standard — relevance 0.57

Encryption Standard

Document ID: KD-SEC-003 · **Version:** 2.4 · **Owner:** Marcus Oyelaran, CISO
Approved: 8 January 2026 · **Next review:** 8 January 2027
Maps to: SOC 2 CC6.7 · ISO 27001:2022 A.8.24 · GDPR Art. 32(1)(a)

gs://attestor-505506-corporate/security/encryption-standard.txt

[4] encryption-standard — 5. Algorithm policy — relevance 0.57

5. Algorithm policy

Approved: AES-256-GCM, AES-256-CBC (legacy read paths only), RSA-2048 and above, ECDSA P-256 and P-384, SHA-256 and above, Argon2id and bcrypt (cost factor 12 or higher) for password hashing.

Prohibited: DES, 3DES, RC4, MD5 and SHA-1 for any security purpose, RSA below 2048 bits, and any custom cryptographic construction. Kestrel does not implement its own cryptographic

gs://attestor-505506-corporate/security/encryption-standard.txt

[5] encryption-standard — 1. Data at rest — relevance 0.56

1. Data at rest

All customer data at rest is encrypted using **AES-256-GCM**. No customer data is stored unencrypted at any tier.

| Store | Mechanism | Key custody |

|---|---|---|

| Amazon RDS (PostgreSQL 16) | Storage-level encryption | AWS KMS CMK, per-environment |

| Amazon S3 | SSE-KMS | AWS KMS CMK, per-bucket |

| Snowflake | Native encryption, Tri-Secret Secure | Customer-managed key

gs://attestor-505506-corporate/security/encryption-standard.txt

194. What is your target time to revoke access when personnel depart?

security · Q194 · Vendor Security Review row 195

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

195. How do you communicate security changes to customers?

security · Q195 · Vendor Security Review row 196

Material security changes are communicated through the trust page at `trust.kestreldata.com`, through the subprocessor change notice mailing list with 30 days' notice, and directly through the account team for changes affecting a specific contract (`company-and-security-programme-overview`, Section 7: "Communicating change to customers"). Incident-related communications follow separate established commitments, notifying affected customers within defined timeframes depending on the event (`incident-response-runbook`, Section 4: "Customer notification commitments").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] company-and-security-programme-overview — 7. Communicating change to customers — relevance 0.69

7. Communicating change to customers

Material security changes are communicated through the trust page at `trust.kestreldata.com`, through the subprocessor change notice mailing list (30 days' notice, see KD-LEG-001 §5), and through the account team for changes affecting a specific contract. Incident communications follow the commitments in KD-SEC-008 §4.

gs://attestor-505506-corporate/security/company-and-security-programme-overview.txt

[2] incident-response-runbook — 8. Post-incident review — relevance 0.58

8. Post-incident review

Every SEV1 and SEV2 requires a blameless post-incident review within 5 business days, published internally, with action items tracked to closure in Jira. Reviews are shared with affected customers on request.

gs://attestor-505506-corporate/security/incident-response-runbook.txt

[3] incident-response-runbook — 4. Customer notification commitments — relevance 0.58

4. Customer notification commitments

These are contractual and are reproduced in the DPA (KD-LEG-001) and the Security Addendum (KD-LEG-008):

- **Personal data breach** - affected customers notified without undue delay and in any event **within 72 hours** of Kestrel confirming the breach.

- **Confirmed unauthorised access to customer production data** - affected customers notified **with**

gs://attestor-505506-corporate/security/incident-response-runbook.txt

[4] risk-management-and-governance — 8. Policy management — relevance 0.57

8. Policy management

All security policies carry a document ID, a version, a named owner, an approval date, and a review date. Policies are reviewed at least annually and on material change. The 2026 review cycle covered 14 policies between 8 January and 12 February 2026; three were revised, and the changes were communicated at the February all-hands and through the annual acknowledgement cycle.

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[5] incident-response-runbook — 1. Severity definitions — relevance 0.56

1. Severity definitions

| Sev | Definition | Page | Exec notify |

|---|---|---|---|

| **SEV1** | Confirmed unauthorised access to customer production data, or full platform outage | Immediate, 24/7 | CEO + CISO within 30 min |

| **SEV2** | Suspected compromise, partial outage affecting more than 10% of tenants, or confirmed data integrity fault | Immediate, 24/7 | CISO within 1 hour |

| **SEV3

gs://attestor-505506-corporus/security/incident-response-runbook.txt

196. Provide the executive summary of your most recent penetration test.

security · Q196 · Vendor Security Review row 197

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

197. How frequently are production operating systems patched?

engineering · Q197 · Vendor Security Review row 198

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

198. Are there any unrestricted inbound network rules in production?

engineering · Q198 · Vendor Security Review row 199

No, there are no unrestricted inbound network rules in production. Security groups are managed via Terraform, are configured to default-deny, and contain no `0.0.0.0/0` ingress rules in production—a policy enforced by a Checkov rule that fails any build violating this constraint. Additionally, all compute and data resources reside in private subnets with no public IP addresses on workload instances, and ingress traffic is routed exclusively through Cloudflare, an AWS Application Load Balancer, and the Istio ingress gateway (Infrastructure Architecture Overview, Section 6: Network).

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (5)

[1] infrastructure-architecture-overview — Infrastructure Architecture Overview — relevance 0.63

Infrastructure Architecture Overview

Document ID: KD-ENG-003 · **Version:** 3.4 · **Owner:** Dana Whitfield, VP Engineering

Last updated: 5 February 2026 · **Classification:** Confidential, NDA required

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[2] infrastructure-architecture-overview — 6. Network — relevance 0.57

6. Network

Private subnets for all compute and data. No public IP addresses on workload instances. Ingress is exclusively through Cloudflare, then an AWS Application Load Balancer, then the Istio ingress gateway. Egress is through NAT gateways with an allowlist for known destinations.

Security groups are managed in Terraform and default-deny. There are no `0.0.0.0/0` ingress rules in produc

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[3] infrastructure-architecture-overview — 3. Compute — relevance 0.53

3. Compute

Amazon EKS (Kubernetes 1.31) with managed node groups spanning three availability zones. Workloads run as containers built from distroless base images, as non-root, with read-only root filesystems and dropped Linux capabilities. Pod Security Standards are enforced at the `restricted` level.

Node images are immutable; nodes are recycled with a maximum age of 30 days rather than pa

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[4] infrastructure-architecture-overview — 7. Observability — relevance 0.52

7. Observability

Datadog for metrics, logs, APM, and security monitoring. Distributed tracing uses W3C Trace Context propagated across all services. Every log line carries `tenant\_id` and `request\_id`.

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[5] infrastructure-architecture-overview — 4. Data layer — relevance 0.51

4. Data layer

| Store | Technology | Purpose |

|---|---|---|

| Primary OLTP | Amazon RDS PostgreSQL 16, Multi-AZ | Application state |

| Analytics | Snowflake | Customer analytics workloads |

| Object storage | Amazon S3 | Uploads, exports, backups |

| Cache | Amazon ElastiCache (Redis 7) | Session and query cache |

| Search | OpenSearch 2.13 | In-product search |

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

199. Do you perform software composition analysis for third-party dependencies?

engineering · Q199 · Vendor Security Review row 200

Yes, Kestrel Data performs software composition analysis for third-party dependencies using Snyk. Snyk runs automatically on every pull request and executes daily scans against the `main` branch. Any Critical or High vulnerability finding blocks pull request merges. Dependency vulnerabilities must be remediated according to defined service level agreements (7 days for Critical, 30 days for High, and 90 days for Medium) (`third-party-library-policy`, "4. Vulnerability response"). Additionally, Kestrel generates a CycloneDX Software Bill of Materials (SBOM) for every production container image at build time (`third-party-library-policy`, "3. Software Bill of Materials").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (5)

[1] third-party-library-policy — Third-Party Library Policy — relevance 0.59

Third-Party Library Policy

Document ID: KD-ENG-008 · **Version:** 1.4 · **Owner:** Dana Whitfield, VP Engineering

Approved: 22 January 2026 · **Maps to:** SOC 2 CC7.1 · ISO 27001:2022 A.8.28

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[2] third-party-library-policy — 4. Vulnerability response — relevance 0.58

4. Vulnerability response

Dependency vulnerabilities follow the SLAs in KD-SEC-006: Critical 7 days, High 30 days, Medium 90 days. Snyk runs on every pull request and daily against `main`. A Critical or High finding blocks merge.

Where no upstream fix exists within the SLA, the options in order of preference are: apply a vendored patch, replace the dependency, or accept the risk with a docum

gs://attestor-505506-corporate-engineering/third-party-library-policy.txt

[3] third-party-library-policy — 1. Adding a dependency — relevance 0.58

1. Adding a dependency

A new direct dependency requires a pull request that documents:

1. Why an existing dependency or the standard library is insufficient.
2. The licence, checked against the allowlist below.
3. Maintenance signal: last release date, open critical issues, number of maintainers.
4. Transitive dependency count added.

Review is by any engineer other than the author. Depend

gs://attestor-505506-corporate-engineering/third-party-library-policy.txt

[4] third-party-library-policy — 3. Software Bill of Materials — relevance 0.58

3. Software Bill of Materials

Kestrel generates a CycloneDX SBOM for every production container image at build time.

SBOMs are retained for 2 years and are provided to customers on request under NDA. The current production SBOM covers 1,184 components across 6 services.

gs://attestor-505506-corporate-engineering/third-party-library-policy.txt

[5] third-party-library-policy — 6. Unmaintained dependencies — relevance 0.57

6. Unmaintained dependencies

A dependency with no release in 24 months and no active maintainer is flagged for replacement. Three such dependencies were identified in the January 2026 review, all scheduled for replacement by Q3 2026.

gs://attestor-505506-corporate-engineering/third-party-library-policy.txt

200. Do you have a published responsible disclosure policy?

security · Q200 · Vendor Security Review row 201

Yes, Kestrel maintains a published responsible disclosure policy. Security contact information and disclosure guidelines are published at `kestreldata.com/.well-known/security.txt`. Under this policy, Kestrel commits to acknowledging reports within two business days and provides safe harbor ensuring that security researchers acting in good faith under the published policy will not be pursued legally. Kestrel does not currently operate a paid bug bounty program, handling all submissions through this responsible disclosure process (`vulnerability-management-policy`, §5. Responsible disclosure).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] vulnerability-management-policy — 5. Responsible disclosure — relevance 0.69

5. Responsible disclosure

Kestrel publishes a security contact at `kestreldata.com/.well-known/security.txt` and commits to acknowledging reports within 2 business days. Researchers acting in good faith under the published policy will not be pursued legally.

****Kestrel does not currently operate a paid bug bounty programme.**** Reports are handled through the responsible disclosure process above

gs://attestor-505506-corporate-engineering/security/vulnerability-management-policy.txt

[2] vulnerability-management-policy — Vulnerability Management Policy — relevance 0.65

Vulnerability Management Policy

****Document ID:**** KD-SEC-006 · ****Version:**** 3.3 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 22 January 2026 · ****Next review:**** 22 January 2027

****Maps to:**** SOC 2 CC7.1, CC7.2 · ISO 27001:2022 A.8.8

gs://attestor-505506-corporate-engineering/security/vulnerability-management-policy.txt

[3] company-and-security-programme-overview — 7. Communicating change to customers — relevance 0.61

7. Communicating change to customers

Material security changes are communicated through the trust page at `trust.kestreldata.com`, through the subprocessor change notice mailing list (30 days' notice, see KD-LEG-001 §5), and through the account team for changes affecting a specific contract. Incident communications follow the commitments in KD-SEC-008 §4.

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[4] vulnerability-management-policy — 2. Scanning coverage — relevance 0.61

2. Scanning coverage

| Layer | Tool | Cadence |

---|---|---

| Dependencies (SCA) | Snyk Open Source | Every pull request, plus daily on `main` |

| Static analysis (SAST) | Semgrep + GitHub CodeQL | Every pull request |

| Container images | Amazon ECR enhanced scanning (Inspector) | On push, plus continuous rescan |

| Infrastructure | AWS Inspector, AWS Security Hub | Continuous |

| IaC | C

gs://attestor-505506-corporus/security/vulnerability-management-policy.txt

[5] information-security-policy — 11. Enforcement — relevance 0.60

11. Enforcement

Violation of this policy may result in disciplinary action up to and including termination of employment or contract, and referral to law enforcement where warranted.

Kestrel Data, Inc. · 1401 Lavaca Street, Suite 210, Austin, TX 78701 · Delaware C-corporation, incorporated 2019

gs://attestor-505506-corporus/security/information-security-policy.txt

201. Do you offer source code escrow arrangements?

engineering · Q201 · Vendor Security Review row 202

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (10)

[1] api-and-integration-standard — 2. Customer control of API credentials — relevance 0.61

2. Customer control of API credentials

****Customers create, scope, rotate, and revoke their own API credentials**** from the tenant administrator console, without involving Kestrel support. A credential can be limited to read-only, to specific datasets, and to a source IP allowlist. Revocation takes effect within 30 seconds across all regions.

****Kestrel support cannot recover a customer API key.**** K

gs://attestor-505506-corporus/engineering/api-and-integration-standard.txt

[2] backup-restore-procedure — Backup and Restore Procedure — relevance 0.60

Backup and Restore Procedure

****Document ID:**** KD-ENG-004 · ****Version:**** 2.5 · ****Owner:**** Sofia Brenner, Head of IT

****Approved:**** 29 January 2026 · ****Maps to:**** SOC 2 A1.2 · ISO 27001:2022 A.8.13

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[3] api-and-integration-standard — 6. Customer access to audit logs — relevance 0.58

6. Customer access to audit logs

Tenant administrators can retrieve their own audit log from the console and from `GET /v2/audit-events`, covering: sign-in and sign-out, permission changes, dataset create/read/update/delete, export, API credential lifecycle, and configuration changes. Each entry records the actor, the action, the target, the source IP, and a UTC timestamp.

****Customer-accessible a**

gs://attestor-505506-corpus/engineering/api-and-integration-standard.txt

[4] backup-restore-procedure — 4. Test results — relevance 0.56

4. Test results

Restore is tested **quarterly**, and the test is a real restore, not a backup-listing check.

Quarter	Date	Duration	Assertions	Outcome
Q1 2026	17 Jan 2026	2h 41m	1,240 / 1,240	Pass
Q4 2025	11 Oct 2025	3h 02m	1,238 / 1,240	Pass, 2 known-stale fixtures corrected
Q3 2025	19 Jul 2025	3h 20m	1,240 / 1,240	Pass

gs://attestor-505506-corpus/engineering/backup-restore-procedure.txt

[5] api-and-integration-standard — 7. Versioning and deprecation — relevance 0.56

7. Versioning and deprecation

The API is versioned in the path (`/v1`, `/v2`). Backwards-incompatible changes are made only in a new version.

The deprecation policy is 12 months' notice for a whole API version and **90 days' notice** for an individual endpoint or field, delivered by email to tenant administrators, by a `Deprecation` and `Sunset` response header, and on the developer changelog

gs://attestor-505506-corpus/engineering/api-and-integration-standard.txt

[6] api-and-integration-standard — API, Authentication and Integration Standard — relevance 0.56

API, Authentication and Integration Standard

Document ID: KD-ENG-005 · **Version:** 2.6 · **Owner:** Dana Whitfield, VP Engineering

Approved: 21 January 2026 · **Next review:** 21 January 2027

Maps to: SOC 2 CC6.1, CC6.6, CC8.1 · ISO 27001:2022 A.5.15, A.8.5, A.8.26

gs://attestor-505506-corpus/engineering/api-and-integration-standard.txt

[7] backup-restore-procedure — 1. What is backed up — relevance 0.55

1. What is backed up

Asset	Method	Frequency	Retention
-------	--------	-----------	-----------

---	---	---	---
-----	-----	-----	-----

RDS PostgreSQL	Automated snapshots + WAL archiving (PITR)	Continuous	35 days
RDS logical dump	<code>pg_dump</code> to S3, encrypted with a separate CMK	Daily 03:00 UTC	90 days
S3 objects	Versioning + cross-region replication	Continuous	90 days for non-current versions
Snowflake	Time Tr		

gs://attestor-505506-corpus/engineering/backup-restore-procedure.txt

[8] api-and-integration-standard — 9. Integration security review — relevance 0.55

9. Integration security review

A new first-party integration is reviewed against this standard before release, covering credential handling, scope minimisation, rate limiting, and audit event emission. The review is recorded in the pull request and is a required check on the `kd-api` repository.

gs://attestor-505506-corpus/engineering/api-and-integration-standard.txt

[9] backup-restore-procedure — 5. Tenant-scoped restore — relevance 0.54

5. Tenant-scoped restore

A single customer can be restored without affecting others, by restoring to an isolated account and exporting that tenant rows back. This was exercised once in production, on 22 September 2025, at a customer request following an erroneous bulk delete on their side. Time to complete was 5 hours 10 minutes.

gs://attestor-505506-corpus/engineering/backup-restore-procedure.txt

[10] backup-restore-procedure — 2. Encryption and location — relevance 0.54

2. Encryption and location

All backups are encrypted with AES-256 using AWS KMS. The daily logical dump uses a **separate CMK** from the primary database, so that compromise of the primary key does not compromise the backups.

Cross-region replication stays inside the residency boundary: `us-east-1` replicates to `us-west-2`, `eu-west-1` replicates to `eu-central-1`. EU customer data never le

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

202. Is production data used in test environments?

engineering · Q202 · Vendor Security Review row 203

Production data is never used in lower environments or copied outside of production. According to Kestrel Data's Secure Software Development Lifecycle Policy (KD-ENG-001, Section 2, "Environments"), non-production environments are restricted to synthetic and anonymized data: * **Local and CI environments** use synthetic fixtures only. * **Staging environments** use synthetic and anonymized data, with fixtures generated synthetically via internal tooling (`tools/gen\_fixtures.py`). Kestrel Data does not maintain or allow any sanitized production dump processes for lower environments.

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] sdlc-policy — 2. Environments — relevance 0.70

2. Environments

Environment	Purpose	Data
-------------	---------	------

---	---	---
-----	-----	-----

`local`	Developer machines	Synthetic fixtures only
---------	--------------------	-------------------------

`ci`	Automated testing	Synthetic fixtures only
------	-------------------	-------------------------

`staging`	Pre-production verification	Synthetic and anonymised data
-----------	-----------------------------	-------------------------------

`production`	Live service	Customer data
--------------	--------------	---------------

Production data is never copied to a lower environment. Staging fixtures are generated

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[2] sdlc-policy — 3. Testing requirements — relevance 0.59

3. Testing requirements

- Unit test coverage gate at **80%** on changed lines, enforced in CI.
- Integration tests run against ephemeral infrastructure provisioned per pull request.
- Tenant isolation tests run on every build: a suite of 84 assertions attempting cross-tenant reads through every public API surface.
- Load tests before any release expected to change the performance profile.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[3] sdlc-policy — 6. Release — relevance 0.54

6. Release

Releases are continuous: merge to `main` triggers a deployment to staging, an automated verification suite, and then a progressive rollout to production. Rollout is canary-based: 5% of traffic for 15 minutes, then 25%, then 100%, with automatic rollback on error-rate or latency regression.

Median lead time from merge to production in 2025 was **34 minutes**. Change failure rate w

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[4] sdlc-policy — Secure Software Development Lifecycle Policy — relevance 0.52

Secure Software Development Lifecycle Policy

Document ID: KD-ENG-001 · **Version:** 4.1 · **Owner:** Dana Whitfield, VP Engineering

Approved: 20 January 2026 · **Next review:** 20 January 2027

Maps to: SOC 2 CC8.1 · ISO 27001:2022 A.8.25-A.8.31

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[5] sdlc-policy — 7. Separation of duties — relevance 0.51

7. Separation of duties

Engineers cannot deploy their own change to production without the automated pipeline: no human has the ability to push a container image to the production registry directly. The deployment role is held by the CI service identity, which authenticates through OIDC and holds no long-lived credentials.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

203. How do you manage cookie consent on your web properties?

legal · Q203 · Vendor Security Review row 204

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] privacy-policy — 4. Cookies — relevance 0.68

4. Cookies

The marketing site uses strictly necessary cookies plus, with consent, analytics cookies (Plausible, which is cookieless, and Google Analytics 4 where consent is given). The application uses only strictly necessary cookies: a session cookie and a CSRF token. A consent banner meeting EDPB guidance is served to EEA, UK, and Swiss visitors, with reject as prominent as accept.

gs://attestor-505506-corporus/legal/privacy-policy.txt

[2] privacy-policy — 6. International transfers — relevance 0.59

6. International transfers

Personal data is processed in the United States and the European Union. Transfers out of the EEA rely on the 2021 Standard Contractual Clauses with supplementary measures described in the Transfer Impact Assessment (KD-LEG-006).

gs://attestor-505506-corporus/legal/privacy-policy.txt

[3] privacy-policy — 2. What we collect as controller — relevance 0.59

2. What we collect as controller

| Category | Examples | Lawful basis | Retention |

|---|---|---|---|

| Account data | Name, work email, job title, company | Contract (Art. 6(1)(b)) | Term + 3 years |

| Billing data | Billing contact, VAT number, payment method token | Contract; legal obligation | 7 years (tax) |

| Product telemetry | Feature usage, page views, error events | Legitimate interest

gs://attestor-505506-corporus/legal/privacy-policy.txt

[4] privacy-policy — 5. Your rights — relevance 0.58

5. Your rights

Data subjects in the EEA, UK, and Switzerland have rights of access, rectification, erasure, restriction, portability, and objection, and the right to withdraw consent.

California residents have rights under the CCPA as amended by the CPRA, including the right to know, delete, correct, and opt out of sharing.

Requests to `privacy@kestreldata.com` are acknowledged within 5 business days.

gs://attestor-505506-corporus/legal/privacy-policy.txt

[5] privacy-policy — 1. Controller and contact — relevance 0.57

1. Controller and contact

Kestrel Data, Inc., 1401 Lavaca Street, Suite 210, Austin, TX 78701, USA.

EU representative under Art. 27 GDPR: Instant EU Rep Ltd, Dublin, Ireland.

Data Protection Officer: Priya Raghunathan, `dpo@kestreldata.com`.

Lead supervisory authority: Irish Data Protection Commission.

gs://attestor-505506-corporus/legal/privacy-policy.txt

204. How do you handle a vulnerability with no available upstream fix?

When no upstream fix exists within the required remediation SLA, Kestrel Data follows a prioritized set of options: 1. Apply a vendored patch. 2. Replace the dependency. 3. Accept the risk with a documented compensating control and CISO approval. *(Source: `third-party-library-policy`, Section 4. Vulnerability response)*

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] third-party-library-policy — 4. Vulnerability response — relevance 0.65

4. Vulnerability response

Dependency vulnerabilities follow the SLAs in KD-SEC-006: Critical 7 days, High 30 days, Medium 90 days. Snyk runs on every pull request and daily against `main`. A Critical or High finding blocks merge.

Where no upstream fix exists within the SLA, the options in order of preference are: apply a vendored patch, replace the dependency, or accept the risk with a docum

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[2] third-party-library-policy — 7. Internal forks — relevance 0.61

7. Internal forks

Forking a third-party library requires VP Engineering approval and creates an obligation to track upstream security advisories manually. Kestrel currently maintains **zero** internal forks, deliberately.

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[3] third-party-library-policy — 6. Unmaintained dependencies — relevance 0.60

6. Unmaintained dependencies

A dependency with no release in 24 months and no active maintainer is flagged for replacement. Three such dependencies were identified in the January 2026 review, all scheduled for replacement by Q3 2026.

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[4] third-party-library-policy — 5. Upgrades — relevance 0.55

5. Upgrades

Renovate opens upgrade pull requests weekly. Patch-level security upgrades auto-merge when CI is green. Minor and major upgrades are reviewed manually.

An explicit goal is to stay within one minor version of current for all direct dependencies. As of 1 February 2026, 94% of direct dependencies met that target; the 6% that did not are tracked with named owners.

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[5] third-party-library-policy — 1. Adding a dependency — relevance 0.54

1. Adding a dependency

A new direct dependency requires a pull request that documents:

1. Why an existing dependency or the standard library is insufficient.
2. The licence, checked against the allowlist below.
3. Maintenance signal: last release date, open critical issues, number of maintainers.
4. Transitive dependency count added.

Review is by any engineer other than the author. Depend

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

205. Do you perform static application security testing on every code change?

Yes. Static application security testing (SAST) is conducted on every pull request using Semgrep and GitHub CodeQL, as specified in the Vulnerability Management Policy (Section 2, "Scanning coverage").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by SecurityAgent

Evidence (5)

[1] vulnerability-management-policy — 2. Scanning coverage — relevance 0.64

2. Scanning coverage

| Layer | Tool | Cadence |

|---|---|---|

| Dependencies (SCA) | Snyk Open Source | Every pull request, plus daily on `main` |

| Static analysis (SAST) | Semgrep + GitHub CodeQL | Every pull request |

| Container images | Amazon ECR enhanced scanning (Inspector) | On push, plus continuous rescan |

| Infrastructure | AWS Inspector, AWS Security Hub | Continuous |

| IaC | C

gs://attestor-505506-corpus/security/vulnerability-management-policy.txt

[2] vulnerability-management-policy — 4. Penetration testing — relevance 0.57

4. Penetration testing

An independent penetration test is commissioned **annually** at minimum, and additionally before any significant architectural change. The most recent was performed by Include Security from 3 to 14 February 2026 (engagement INSEC-2026-0219). See the Penetration Test Executive Summary (KD-SEC-007).

gs://attestor-505506-corpus/security/vulnerability-management-policy.txt

[3] vulnerability-management-policy — Vulnerability Management Policy — relevance 0.55

Vulnerability Management Policy

Document ID: KD-SEC-006 · **Version:** 3.3 · **Owner:** Dana Whitfield, VP Engineering

Approved: 22 January 2026 · **Next review:** 22 January 2027

Maps to: SOC 2 CC7.1, CC7.2 · ISO 27001:2022 A.8.8

gs://attestor-505506-corpus/security/vulnerability-management-policy.txt

[4] vulnerability-management-policy — 5. Responsible disclosure — relevance 0.54

5. Responsible disclosure

Kestrel publishes a security contact at `kestreldata.com/.well-known/security.txt` and commits to acknowledging reports within 2 business days. Researchers acting in good faith under the published policy will not be pursued legally.

Kestrel does not currently operate a paid bug bounty programme. Reports are handled through the responsible disclosure process above

gs://attestor-505506-corpus/security/vulnerability-management-policy.txt

[5] vulnerability-management-policy — 1. Remediation SLAs — relevance 0.54

1. Remediation SLAs

Severity is assigned from CVSS v3.1 base score, adjusted for exploitability and exposure. Internet-facing findings are escalated one level.

| Severity | CVSS | Remediation SLA | Measured 2025 compliance |

|---|---|---|

| Critical | 9.0-10.0 | **7 days** | 100% (11 of 11) |

| High | 7.0-8.9 | **30 days** | 96% (74 of 77) |

| Medium | 4.0-6.9 | **90 days** | 91% |

|

gs://attestor-505506-corpus/security/vulnerability-management-policy.txt

206. Do you use customer content to train machine learning models?

legal · Q206 · Vendor Security Review row 207

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

207. Are manual production console changes permitted? If not, describe compensating controls.

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] change-management-procedure — 1. Change classes — relevance 0.56

1. Change classes

| Class | Definition | Approval | Example |

|---|---|---|---|

| **Standard** | Pre-approved, low risk, automated | PR review + CI | Application code, config change through IaC |

| **Normal** | Material risk or customer-visible | PR review + Change Advisory sign-off | Schema migration, dependency major version |

| **Emergency** | Fixing an active SEV1/SEV2 | Retrospective with

gs://attestor-505506-corpus/engineering/change-management-procedure.txt

[2] change-management-procedure — Change Management Procedure — relevance 0.56

Change Management Procedure

Document ID: KD-ENG-002 · **Version:** 3.0 · **Owner:** Dana Whitfield, VP Engineering

Approved: 20 January 2026 · **Maps to:** SOC 2 CC8.1 · ISO 27001:2022 A.8.32

gs://attestor-505506-corpus/engineering/change-management-procedure.txt

[3] change-management-procedure — 4. Infrastructure changes — relevance 0.56

4. Infrastructure changes

Infrastructure is managed exclusively through Terraform in the `kestrel-infra` repository.

Manual changes through the AWS console are prohibited in production; drift detection runs every 6 hours and raises a SEV3 on any unmanaged change. Drift was detected 4 times in 2025, all traced to AWS-initiated maintenance rather than human action.

gs://attestor-505506-corpus/engineering/change-management-procedure.txt

[4] change-management-procedure — 3. Emergency changes — relevance 0.55

3. Emergency changes

An Emergency change may bypass the Change Advisory step but never bypasses code review or CI. The Incident Commander authorises it, and a retrospective record is filed within one business day covering what changed, why the normal path was bypassed, and whether the change should be reworked.

All 9 Emergency changes in 2025 have completed retrospectives on file.

gs://attestor-505506-corpus/engineering/change-management-procedure.txt

[5] change-management-procedure — 2. Normal change requirements — relevance 0.55

2. Normal change requirements

A Normal change additionally requires a written rollback plan, a customer-impact assessment, and sign-off from the Change Advisory group (VP Engineering plus one SRE). Schema migrations must be backward compatible for at least one release, so that a rollback does not require a data migration.

gs://attestor-505506-corpus/engineering/change-management-procedure.txt

208. What is your Recovery Time Objective?

engineering · Q208 · Vendor Security Review row 209

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

209. How do you support customer responses to data subject access requests?

legal · Q209 · Vendor Security Review row 210

For customer content, Kestrel acts as a processor while the customer acts as the data controller. Kestrel supports customer responses to data subject requests through the following mechanisms: 1. **Self-Service Tooling:** Kestrel provides self-service functionality within the Service that allows customers to independently access, correct, export, and delete personal data (*Data Processing Agreement*, Section 6; *Data Subject Rights Procedure*, Section 2). 2. **Processor Assistance:** When self-service functionality is insufficient or when assistance is requested in writing, Kestrel provides support—such as pointing the customer to the appropriate tooling, producing an export of the identified data subject's records when the customer cannot isolate them, or executing tenant-level deletions at the customer's direction (*Data Subject Rights Procedure*, Section 2; *Data Processing Agreement*, Section 6). 3. **Direct Data Subject Inquiries:** If a data subject contacts Kestrel directly regarding customer content, Kestrel does not respond substantively on the controller's behalf (unless legally required) and redirects the individual to the relevant customer without undue delay, within 3 business days where the customer can be identified (*Data Subject Rights Procedure*, Section 1; *Data Processing Agreement*, Section 6). 4. **Audit and Record Keeping:** All requests, routes, and resolution dates are logged in a DSR register maintained by the Data Protection Officer (DPO) and retained for three years, which is accessible to auditors and, in redacted form, to customers exercising audit rights under the DPA (*Data Subject Rights Procedure*, Section 9).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] data-subject-rights-procedure — 9. Records — relevance 0.68

9. Records

Every request, its route, and its resolution date are recorded in the DSR register held by the DPO and retained for three years. The register is available to auditors and, in redacted form, to customers exercising their audit rights under the DPA.

gs://attestor-505506-corporate/legal/data-subject-rights-procedure.txt

[2] data-subject-rights-procedure — 2. Assisting customers as processor — relevance 0.67

2. Assisting customers as processor

Kestrel commits to assist a customer with a data subject request within 5 business days of a written request, which is the commitment in the DPA (KD-LEG-001 §6). Assistance means one of three things:

1. Pointing the customer at the self-service tooling that lets them do it themselves, which is the fastest route and covers the majority of requests;
2. Pro

gs://attestor-505506-corporate/legal/data-subject-rights-procedure.txt

[3] data-processing-agreement — 6. Data subject rights — relevance 0.66

6. Data subject rights

Kestrel provides self-service functionality allowing Customer to access, correct, export, and delete Personal Data within the Service. Where a data subject contacts Kestrel directly, Kestrel refers them to Customer and does not respond substantively, unless legally obliged to do so.

Where the Service functionality is insufficient, Kestrel assists Customer within **10**

gs://attestor-505506-corporate/legal/data-processing-agreement.txt

[4] government-requests-and-transparency-report — 2. How a request is handled — relevance 0.66

2. How a request is handled

1. **Log.** The request is recorded in the government request register on the day of receipt, with the requesting authority, the legal instrument, and the data sought.
2. **Validate.** The General Counsel, with outside counsel where warranted, assesses whether the instrument is valid, whether it is binding on Kestrel in the jurisdiction concerned, and whether i

gs://attestor-505506-corporate/legal/government-requests-and-transparency-report.txt

[5] data-subject-rights-procedure — 1. Which rights, and against whom — relevance 0.65

1. Which rights, and against whom

For customer content, Kestrel is the **processor** and the customer is the controller. A data subject who approaches Kestrel directly about customer content is redirected to the

relevant customer without undue delay and, where Kestrel can identify the customer, within ****3 business days****. Kestrel does not respond substantively on the controller's behalf.

For data

gs://attestor-505506-corpus/legal/data-subject-rights-procedure.txt

210. Which generative AI tools are approved for internal use?

security · Q210 · Vendor Security Review row 211

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] ai-governance-policy — 4. Approved generative AI tools for internal use — relevance 0.75

4. Approved generative AI tools for internal use

Personnel may use generative AI tools ****only**** from the approved list, and ****only**** with information classified Internal or Public. Restricted or Confidential information — including any customer content — must not be entered into any generative AI tool.

Approved as of 1 February 2026:

* GitHub Copilot Business (code completion; telemetry and code

gs://attestor-505506-corpus/security/ai-governance-policy.txt

[2] acceptable-use-policy — 2. Generative AI tools — relevance 0.70

2. Generative AI tools

Use of generative AI is permitted only with approved tools under a zero-retention agreement. As of 1 February 2026 the approved list is:

| Tool | Approved for | Data tier permitted |

|---|---|---|

| GitHub Copilot Business | Code completion | Confidential (source code) |

| Anthropic Claude (Team) | Analysis, drafting | Internal |

| OpenAI ChatGPT Enterprise | Analysis

gs://attestor-505506-corpus/security/acceptable-use-policy.txt

[3] ai-governance-policy — 5. Approving a new AI feature or tool — relevance 0.62

5. Approving a new AI feature or tool

A new AI feature or tool requires an assessment covering: what data it processes and at what classification, where the processing occurs, whether the provider trains on inputs, retention, the effect on the ROPA and the subprocessor list, human oversight, and failure behaviour. The assessment is reviewed by the CISO and DPO jointly and recorded in the Security

gs://attestor-505506-corpus/security/ai-governance-policy.txt

[4] ai-governance-policy — AI Governance Policy — relevance 0.59

AI Governance Policy

****Document ID:**** KD-SEC-019 · ****Version:**** 1.3 · ****Owner:**** Marcus Oyelaran, CISO

****Approved:**** 3 February 2026 · ****Next review:**** 3 August 2026

****Maps to:**** SOC 2 CC1.4, CC6.1, CC9.2 · ISO 27001:2022 A.5.10, A.5.19 · ISO/IEC 42001 (aligned, not certified)

gs://attestor-505506-corpus/security/ai-governance-policy.txt

[5] ai-governance-policy — 6. Human oversight — relevance 0.59

6. Human oversight

Output from the natural-language query feature is always shown alongside the generated query, so the customer can see what was actually run. No AI feature takes an action on a customer's data without the customer initiating it, and no AI feature can write to or delete customer data.

gs://attestor-505506-corporate/security/ai-governance-policy.txt

211. Can customers scope and revoke their own API credentials? Provide supporting evidence.

engineering · Q211 · Vendor Security Review row 212

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] api-and-integration-standard — 2. Customer control of API credentials — relevance 0.72

2. Customer control of API credentials

****Customers create, scope, rotate, and revoke their own API credentials**** from the tenant administrator console, without involving Kestrel support. A credential can be limited to read-only, to specific datasets, and to a source IP allowlist. Revocation takes effect within 30 seconds across all regions.

****Kestrel support cannot recover a customer API key.**** K

gs://attestor-505506-corporate/engineering/api-and-integration-standard.txt

[2] secrets-management-standard — 6. Customer-issued API credentials — relevance 0.67

6. Customer-issued API credentials

API keys issued to customers are stored as Argon2id hashes; Kestrel cannot recover the plaintext of a customer API key and will not do so on request. Keys are displayed once at creation. Customers can create, scope, and revoke keys through the console, and each key carries a last-used timestamp so stale keys are visible.

gs://attestor-505506-corporate/engineering/secrets-management-standard.txt

[3] api-and-integration-standard — 1. API authentication — relevance 0.61

1. API authentication

The public API at `https://api.kestreldata.com/v2` accepts two credential types:

****OAuth 2.0 bearer tokens**** issued through the client-credentials flow, valid for 60 minutes, scoped to a single tenant and to an explicit permission set. This is the recommended integration path.

****API keys**** for simple server-to-server use, presented as a bearer token, scoped the same

gs://attestor-505506-corporate/engineering/api-and-integration-standard.txt

[4] secrets-management-standard — 2. What is prohibited — relevance 0.58

2. What is prohibited

- Secrets in source code, including test fixtures, comments, and commit history.
- Secrets in environment files committed to a repository.
- Secrets in CI logs, container image layers, or Terraform state in plaintext.
- Long-lived static AWS access keys. The last was decommissioned 17 November 2024, and creation of a new one triggers an hourly detection that pages the owner

gs://attestor-505506-corporate/engineering/secrets-management-standard.txt

[5] api-and-integration-standard — 7. Versioning and deprecation — relevance 0.58

7. Versioning and deprecation

The API is versioned in the path (`/v1`, `/v2`). Backwards-incompatible changes are made only in a new version.

****The deprecation policy is 12 months' notice**** for a whole API version and ****90 days' notice**** for an individual endpoint or field, delivered by email to tenant administrators, by a `Deprecation` and `Sunset` response header, and on the developer changelog

gs://attestor-505506-corporate/engineering/api-and-integration-standard.txt

212. Provide your measured median access revocation time for the last 12 months.

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

213. Can customers scope and revoke their own API credentials?

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

214. Do you offer Canadian or Australian data residency?

No, Kestrel does not offer Canadian or Australian data residency. Data residency is currently offered only for the United States and the European Union (`subprocessor-list`, "EU data residency"; `security-addendum`, "7. What Kestrel does NOT commit to"). Requests for Canadian or Australian data residency are recorded but are not committed to (`subprocessor-list`, "EU data residency").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] subprocessor-list — EU data residency — relevance 0.70

EU data residency

Customers on the EU instance have their data processed exclusively within the EEA for the infrastructure subprocessors above. Kestrel does **not** currently offer a UK-only, Swiss-only, Canadian, or Australian data residency option. Requests for those are recorded but not committed to.

gs://attestor-505506-corporus/legal/subprocessor-list.txt

[2] subprocessor-list — Infrastructure subprocessors — relevance 0.60

Infrastructure subprocessors

| Subprocessor | Purpose | Location of processing | Transfer mechanism | Engaged since |

|---|---|---|---|---|

| Amazon Web Services, Inc. | Cloud hosting, compute, storage, database | US (`us-east-1`, `us-west-2`); EU (`eu-west-1`, `eu-central-1`)

| SCCs + AWS DPA; EU data stays in EU | Mar 2019 |

| Snowflake Inc. | Analytics data warehouse | US (AWS `us-east-1`);

gs://attestor-505506-corporus/legal/subprocessor-list.txt

[3] subprocessor-list — Operational subprocessors — relevance 0.57

Operational subprocessors

| Subprocessor | Purpose | Location | Transfer mechanism | Engaged since |

|---|---|---|---|---|

| Datadog, Inc. | Observability, logs, APM | US; EU site (`datadoghq.eu`) for EU customers | SCCs | Jun 2020 |

| Okta, Inc. | Identity and access management | US; EU cell for EU customers | SCCs | Feb 2021 |

| Twilio SendGrid | Transactional email delivery | US | SCCs | Ma

gs://attestor-505506-corporus/legal/subprocessor-list.txt

[4] security-addendum — 2. Encryption commitments — relevance 0.56

2. Encryption commitments

- Customer data encrypted at rest using AES-256 or stronger.

- Customer data encrypted in transit using TLS 1.2 or higher; TLS 1.3 is the default.

- Encryption keys managed in a dedicated key management service with role separation.

gs://attestor-505506-corporus/legal/security-addendum.txt

[5] security-addendum — 7. What Kestrel does NOT commit to — relevance 0.56

7. What Kestrel does NOT commit to

Stated explicitly, because a security addendum that omits its limits is misleading:

- **On-premises or self-hosted deployment is not offered.** Kestrel Insight is a multi-tenant SaaS product only. There is no single-tenant, private-cloud, air-gapped, or customer-VPC deployment option, and none is on the roadmap.
- **Customer-managed encryption keys** are

gs://attestor-505506-corporate/legal/security-addendum.txt

215. Do you perform automated decision-making with legal or significant effects?

legal · Q215 · Vendor Security Review row 216

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] dpia-register — 5. Automated decision-making — relevance 0.67

5. Automated decision-making

Kestrel performs **no automated decision-making producing legal effects or similarly significant effects** concerning data subjects, within the meaning of Article 22. The two machine learning features described in KD-SEC-019 §2 surface information to the customer's own analysts; the decisions that follow are made by people at the customer, using the customer's own data

gs://attestor-505506-corporate/legal/dpia-register.txt

[2] data-subject-rights-procedure — 7. Objection, restriction, and automated decision-making — relevance 0.61

7. Objection, restriction, and automated decision-making

Objection and restriction requests concerning customer content are directed to the controller. Kestrel performs no automated decision-making producing legal or similarly significant effects, so Article 22 is not engaged; the machine learning features in the product are described in KD-SEC-019 §2.

gs://attestor-505506-corporate/legal/data-subject-rights-procedure.txt

[3] dpia-register — Data Protection Impact Assessment Register — relevance 0.56

Data Protection Impact Assessment Register

Document ID: KD-LEG-011 · **Version:** 1.9 · **Owner:** Priya Raghunathan, DPO

Approved: 16 January 2026 · **Next review:** 16 January 2027

Maps to: GDPR Articles 35, 36, 9, 8, 22

gs://attestor-505506-corporate/legal/dpia-register.txt

[4] privacy-policy — 3. What we do not do — relevance 0.53

3. What we do not do

- We do not sell personal data, and have never done so.
- We do not share personal data with advertising networks.
- We do not use customer content to train machine learning models, our own or anyone else. This is stated contractually in the MSA and is not merely a policy statement.
- We do not engage in automated decision-making producing legal or similarly significant

gs://attestor-505506-corporate/legal/privacy-policy.txt

[5] dpia-register — 1. When Kestrel performs a DPIA — relevance 0.53

1. When Kestrel performs a DPIA

A DPIA is performed where processing is likely to result in a high risk to data subjects, and in every case triggered by the Article 35(3) list or the lead supervisory authority's own list. In practice Kestrel triggers an assessment for: a new machine learning feature processing customer data, a new sub-processor receiving customer content, a change to the residency

gs://attestor-505506-corporate/legal/dpia-register.txt

216. Describe your break-glass access procedure.

security · Q216 · Vendor Security Review row 217

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

217. Are you controller or processor for customer data?

legal · Q217 · Vendor Security Review row 218

For customer data and content, the customer is the Controller and Kestrel Data, Inc. is the Processor (or sub-processor where the customer acts as a processor for its own customers) (Data Processing Agreement, Section 1; GDPR Records of Processing Activities, Part A). Kestrel acts as Controller only for a limited set of data where it determines the purposes of processing, specifically account administrator contact details, billing records, and product telemetry (Data Processing Agreement, Section 1; Data Subject Rights Procedure, Section 1).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] data-processing-agreement — 1. Roles — relevance 0.76

1. Roles

Customer is **Controller**. Kestrel Data, Inc. is **Processor**. Where Customer is itself a processor for its own customers, Kestrel is sub-processor and the same obligations apply down the chain.

Kestrel is **Controller** for a limited set of data it determines the purposes of: account administrator contact details, billing records, and product telemetry described in Annex 3.

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[2] data-subject-rights-procedure — 1. Which rights, and against whom — relevance 0.73

1. Which rights, and against whom

For customer content, Kestrel is the **processor** and the customer is the controller. A data subject who approaches Kestrel directly about customer content is redirected to the relevant customer without undue delay and, where Kestrel can identify the customer, within **3 business days**. Kestrel does not respond substantively on the controller's behalf.

For data

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[3] gdpr-records-of-processing — Part A - Kestrel as Processor (Art. 30(2)) — relevance 0.72

Part A - Kestrel as Processor (Art. 30(2))

Controller: each Kestrel customer, as identified in the applicable Order Form.

Processor: Kestrel Data, Inc.

DPO: Priya Raghunathan, `dpo@kestreldata.com`

| # | Processing activity | Categories of data subject | Categories of personal data | Transfers | Retention |

| ---|---|---|---|---|

| P1 | Hosting and operating the Kestrel Insig

gs://attestor-505506-corporus/legal/gdpr-records-of-processing.txt

[4] gdpr-records-of-processing — GDPR Records of Processing Activities (Art. 30) — relevance 0.66

GDPR Records of Processing Activities (Art. 30)

Document ID: KD-LEG-005 · **Version:** 3.0 · **Owner:** Priya Raghunathan, DPO

Last updated: 20 January 2026 · **Next review:** 20 July 2026

Maintained under Art. 30(1) where Kestrel is controller and Art. 30(2) where Kestrel is processor. Available to supervisory authorities on request.

gs://attestor-505506-corporus/legal/gdpr-records-of-processing.txt

[5] data-processing-agreement — 5. Sub-processing — relevance 0.65

5. Sub-processing

Customer grants general authorisation for the sub-processors listed at `kestreldata.com/subprocessors`. Kestrel gives **30 days** notice before adding or replacing a sub-processor. Customer may object on reasonable data-protection grounds within that period; if the objection cannot be resolved, Customer may terminate the affected Service without penalty for the remainder of t

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

218. Provide the name and contact details of your primary security contact.

security · Q218 · Vendor Security Review row 219

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

219. Which Trust Services Criteria are in scope for your SOC 2 report?

security · Q219 · Vendor Security Review row 220

Kestrel Data's SOC 2 report covers the **Security**, **Availability**, and **Confidentiality** Trust Services Criteria (`soc2-control-matrix`, section **SOC 2 Control Matrix**; `company-and-security-programme-overview`, section **6. Scope of certification**). Privacy and Processing Integrity are not in scope for the current report (`soc2-control-matrix`, section **SOC 2 Control Matrix**).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] soc2-control-matrix — SOC 2 Control Matrix — relevance 0.70

SOC 2 Control Matrix

Document ID: KD-SEC-012 · **Version:** 2.1

Report period: 1 January - 31 December 2025 · **Report issued:** 14 March 2026

Auditor: Prescient Assurance LLP · **Opinion:** Unqualified, no exceptions noted

Trust Services Criteria in scope: Security, Availability, Confidentiality

Privacy and Processing Integrity are **not** in scope for the current report. Ke

gs://attestor-505506-corporus/security/soc2-control-matrix.txt

[2] company-and-security-programme-overview — 8. How to obtain evidence — relevance 0.66

8. How to obtain evidence

The SOC 2 Type II report, the ISO 27001 certificate, the penetration test executive summary, and the standard DPA are available to customers and prospects under NDA through the account team, usually within two business days. The certificate and the trust page are available without an NDA.

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[3] company-and-security-programme-overview — 6. Scope of certification — relevance 0.65

6. Scope of certification

The ISO 27001 certificate scope statement reads: **"The information security management system supporting the development, operation, and support of the Kestrel Insight analytics platform, including supporting corporate functions, at Austin, Texas and for remote personnel."** The SOC 2 report covers the Security, Availability, and Confidentiality Trust Services Criteria. Pr

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[4] soc2-control-matrix — Common Criteria — relevance 0.64

Common Criteria

| Control | Description | Evidence | Test result |

|---|---|---|---

| CC1.1 | Board oversight of security; Audit and Risk Committee meets quarterly | Committee minutes, 4 meetings in 2025 | No exceptions

|
| CC1.4 | Security awareness training at hire and annually | Curricula completion records, 100% of active staff | No exceptions |
| CC2.1 | Internal communication of securit

gs://attestor-505506-corporus/security/soc2-control-matrix.txt

[5] soc2-control-matrix — Complementary user entity controls — relevance 0.63

Complementary user entity controls

The report identifies 6 controls that remain the customer responsibility, including managing their own user accounts and entitlements within the Kestrel tenant, configuring SSO correctly, protecting API credentials issued to them, and reviewing their own audit logs. These are reproduced in full in Section 4 of the SOC 2 report.

gs://attestor-505506-corporus/security/soc2-control-matrix.txt

220. How many BAAs are currently executed?

legal · Q220 · Vendor Security Review row 221

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

221. How is cloud provider concentration risk managed?

engineering · Q221 · Vendor Security Review row 222

Kestrel runs entirely on Amazon Web Services (AWS). This concentration risk is formally recorded as `RISK-2025-0044` and has been accepted rather than mitigated through a multi-cloud deployment, based on the reasoning that operating two cloud environments poorly introduces greater risk than operating a single provider well at Kestrel's scale (`cloud-exit-and-portability-plan`, "1. Why this exists"). To manage this risk, Kestrel maintains and actively tests a comprehensive Cloud Exit and Portability Plan: * **Portability by Design:** The architecture intentionally favors portable and provider-independent technologies. Core workloads use standard Kubernetes manifests without AWS-specific APIs, data warehousing runs on multi-cloud-capable Snowflake, storage utilizes standard S3-compatible APIs, and infrastructure is managed via Terraform. Critical edge and access layers—such as Cloudflare for the edge and Okta for identity—are hosted outside AWS so that an exit does not disrupt authentication or edge routing (`cloud-exit-and-portability-plan`, "3. Portability by design"). * **Exit Triggers and Testing:** Clear triggers for executing a cloud exit are established, including sustained material service degradation, commercial or pricing breakdowns, regulatory directives, or uncompensable security failures at the provider (`cloud-exit-and-portability-plan`, "2. Exit triggers"). The exit plan is reviewed annually and was tested during a tabletop exercise on 19 November 2025 (`cloud-exit-and-portability-plan`, "1. Why this exists"). * **Execution and Customer Continuity:** The transition plan spans five phases with an estimated timeline of 5–6 months (`cloud-exit-and-portability-plan`, "4. Estimated exit timeline"). Cutover is planned instance-by-instance (separating EU and US regions), ensuring data residency commitments remain strictly preserved throughout the migration. Customers are provided a minimum of 90 days' notice for planned provider transitions while retaining full data export rights (`cloud-exit-and-portability-plan`, "5. Customer-facing continuity during an exit").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (7)

[1] cloud-exit-and-portability-plan — Cloud Exit and Portability Plan — relevance 0.75

Cloud Exit and Portability Plan

Document ID: KD-ENG-010 · **Version:** 1.7 · **Owner:** Dana Whitfield, VP Engineering

Approved: 30 January 2026 · **Next review:** 30 January 2027

Maps to: SOC 2 A1.2, CC9.1 · ISO 27001:2022 A.5.19, A.5.21, A.5.30 · EBA/DORA-aligned

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[2] cloud-exit-and-portability-plan — 4. Estimated exit timeline — relevance 0.69

4. Estimated exit timeline

The tabletop exercise produced these estimates, which are planning figures rather than commitments:

Phase	Work	Estimate
1	Target selection, landing zone, network and identity foundation	4–6 weeks
2	Terraform provider rewrite, CI/CD retargeting	6–8 weeks
3	Data migration — Snowflake region move, PostgreSQL logical replication, ob	

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[3] cloud-exit-and-portability-plan — 5. Customer-facing continuity during an exit — relevance 0.69

5. Customer-facing continuity during an exit

An exit would be executed instance by instance, with EU and US cut over separately, and **data residency commitments would be honoured throughout**: an EU tenant would move to an EU region of the target provider, never transiting a US region. Customers would be given a minimum of 90 days' notice of a planned provider change and would retain their export

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[4] cloud-exit-and-portability-plan — 2. Exit triggers — relevance 0.68

2. Exit triggers

The plan would be invoked on: sustained material degradation of AWS service, a commercial breakdown or unacceptable pricing change, a regulatory instruction, or a security failure at the provider that could not be compensated for.

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[5] cloud-exit-and-portability-plan — 1. Why this exists — relevance 0.66

1. Why this exists

Kestrel runs entirely on AWS. That is a concentration risk, recorded as `RISK-2025-0044` and **accepted** rather than mitigated by multi-cloud, on the reasoning that operating two clouds badly is worse than operating one well at this size. Accepting a risk obliges you to know what you would do if it materialised, which is what this document is. It is reviewed annually and was la

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[6] cloud-exit-and-portability-plan — 3. Portability by design — relevance 0.64

3. Portability by design

The architecture is deliberately biased toward portable components, and the exceptions are listed rather than glossed over:

Layer	Technology	Portability
Compute	Kubernetes (EKS)	High — standard manifests, no EKS-specific APIs in workloads
Container images	OCI in ECR	High — registry is a copy operation
Data warehouse	Snowflake	Hi

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[7] cloud-exit-and-portability-plan — 7. Dependency on other subprocessors — relevance 0.58

7. Dependency on other subprocessors

Equivalent substitution analysis exists for the operational subprocessors: Datadog (substitutable, 2–3 weeks), SendGrid (substitutable, 1 week), Zendesk (substitutable, 2 weeks), Stripe (substitutable, 3–4 weeks), Okta (substitutable, 4 weeks), Cloudflare (substitutable, 2 weeks). None of these holds customer-uploaded content, which is why their substitution is

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

222. What is your committed customer notification window for a personal data breach?

legal · Q222 · Vendor Security Review row 223

Kestrel commits to notify customers of a personal data breach affecting customer personal data without undue delay and in any event within **72 hours** of confirmation or becoming aware of the breach (`data-processing-agreement`, Section 7; `security-addendum`, Section 4). Additionally, where there is confirmed unauthorized access to customer production data, Kestrel commits to notify the customer within **24 hours** (`data-processing-agreement`, Section 7;

`security-addendum`, Section 4).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] security-addendum — 4. Incident notification — relevance 0.71

4. Incident notification

- Personal data breach: notification within ****72 hours**** of confirmation.
- Confirmed unauthorised access to customer production data: ****24 hours****.
- Notification content as set out in the DPA Section 7.

gs://attestor-505506-corporus/legal/security-addendum.txt

[2] data-processing-agreement — 7. Personal data breach — relevance 0.70

7. Personal data breach

Kestrel notifies Customer ****without undue delay and in any event within 72 hours**** of becoming aware of a Personal Data Breach affecting Customer Personal Data, and within ****24 hours**** where there is confirmed unauthorised access to Customer production data. Notification includes the information required by Art. 33(3) GDPR to the extent known.

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[3] data-subject-rights-procedure — 2. Assisting customers as processor — relevance 0.64

2. Assisting customers as processor

****Kestrel commits to assist a customer with a data subject request within 5 business days of a written request****, which is the commitment in the DPA (KD-LEG-001 §6). Assistance means one of three things:

1. Pointing the customer at the self-service tooling that lets them do it themselves, which is the fastest route and covers the majority of requests;
2. Pro

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[4] privacy-policy — 5. Your rights — relevance 0.64

5. Your rights

Data subjects in the EEA, UK, and Switzerland have rights of access, rectification, erasure, restriction, portability, and objection, and the right to withdraw consent. California residents have rights under the CCPA as amended by the CPRA, including the right to know, delete, correct, and opt out of sharing.

Requests to `privacy@kestreldata.com` are acknowledged within 5 busi

gs://attestor-505506-corporus/legal/privacy-policy.txt

[5] data-subject-rights-procedure — 1. Which rights, and against whom — relevance 0.63

1. Which rights, and against whom

For customer content, Kestrel is the ****processor**** and the customer is the controller. A data subject who approaches Kestrel directly about customer content is redirected to the relevant customer without undue delay and, where Kestrel can identify the customer, within ****3 business days****. Kestrel does not respond substantively on the controller's behalf.

For data

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

223. How frequently do you test restoration from backup?

engineering · Q223 · Vendor Security Review row 224

Kestrel Data tests restoration from backup on a quarterly basis. Each test executes an actual restore into an isolated environment rather than a backup-listing check, followed by an automated integrity suite of 1,240 assertions covering row counts, referential integrity, tenant isolation invariants, and known-value spot checks (`backup-restore-procedure`, Section 4: "Test results" and Section 3: "Restore procedure").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] backup-restore-procedure — 4. Test results — relevance 0.73

4. Test results

Restore is tested **quarterly**, and the test is a real restore, not a backup-listing check.

Quarter	Date	Duration	Assertions	Outcome
Q1 2026	17 Jan 2026	2h 41m	1,240 / 1,240	Pass
Q4 2025	11 Oct 2025	3h 02m	1,238 / 1,240	Pass, 2 known-stale fixtures corrected
Q3 2025	19 Jul 2025	3h 20m	1,240 / 1,240	Pass

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[2] backup-restore-procedure — 5. Tenant-scoped restore — relevance 0.63

5. Tenant-scoped restore

A single customer can be restored without affecting others, by restoring to an isolated account and exporting that tenant rows back. This was exercised once in production, on 22 September 2025, at a customer request following an erroneous bulk delete on their side. Time to complete was 5 hours 10 minutes.

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[3] backup-restore-procedure — 3. Restore procedure — relevance 0.61

3. Restore procedure

1. Declare the restore scope: point in time, and whether tenant-scoped or full.
2. Provision an isolated restore account from the Terraform module `restore-target`.
3. Restore the RDS snapshot or PITR target into the isolated account.
4. Run the integrity suite: 1,240 assertions covering row counts, referential integrity, tenant isolation invariants, and known-value spo

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[4] backup-restore-procedure — Backup and Restore Procedure — relevance 0.60

Backup and Restore Procedure

Document ID: KD-ENG-004 · **Version:** 2.5 · **Owner:** Sofia Brenner, Head of IT
Approved: 29 January 2026 · **Maps to:** SOC 2 A1.2 · ISO 27001:2022 A.8.13

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[5] backup-restore-procedure — 1. What is backed up — relevance 0.59

1. What is backed up

Asset	Method	Frequency	Retention
RDS PostgreSQL	Automated snapshots + WAL archiving (PITR)	Continuous	35 days
RDS logical dump	`pg_dump` to S3, encrypted with a separate CMK	Daily 03:00 UTC	90 days
S3 objects	Versioning + cross-region replication	Continuous	90 days for non-current versions
Snowflake	Time Tr		

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

224. Are workloads deployed with least-privilege container security contexts?

security · Q224 · Vendor Security Review row 225

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (10)

[1] cloud-security-posture-standard — 1. Account structure and guardrails — relevance 0.60

1. Account structure and guardrails

Kestrel runs an AWS Organization with six accounts and a dedicated management account that holds no workloads. **Organisation-level Service Control Policies enforce security configuration centrally**, so a misconfiguration in a member account is refused by the platform rather than caught later by a report. The enforced SCPs are:

```
| SCP | Effect |  
|---|---|  
| de
```

gs://attestor-505506-corpus/security/cloud-security-posture-standard.txt

[2] network-security-standard — 7. Container security — relevance 0.59

7. Container security

Workloads run on EKS with:

- * non-root user enforced (`runAsNonRoot: true`) and read-only root filesystems;
- * all Linux capabilities dropped except `NET\_BIND\_SERVICE`;
- * Pod Security Admission in `restricted` mode at the namespace level, which rejects a non-conforming workload at admission rather than reporting it later;
- * network policies denying pod-to-pod traffic by default

gs://attestor-505506-corpus/security/network-security-standard.txt

[3] cloud-security-posture-standard — 7. Cloud identity — relevance 0.57

7. Cloud identity

Human access to AWS is federated from Okta through IAM Identity Center; there are **no** IAM users with long-lived access keys in any account, and the SCP set prevents their creation. Workloads use IAM Roles for Service Accounts. The last static access key in the estate was decommissioned on 17 November 2024.

gs://attestor-505506-corpus/security/cloud-security-posture-standard.txt

[4] cloud-security-posture-standard — 5. Vulnerability and patch posture of cloud compute — relevance 0.56

5. Vulnerability and patch posture of cloud compute

Production compute nodes are immutable: they are replaced, never patched in place. The node group is recycled on a rolling basis so that **no** production compute node is older than 30 days; the measured maximum node age during 2025 was 27 days. Container base images are rebuilt nightly from upstream and redeployed if the digest changes.

Operati

gs://attestor-505506-corpus/security/cloud-security-posture-standard.txt

[5] cloud-security-posture-standard — Cloud Security Posture and Configuration Standard — relevance 0.56

Cloud Security Posture and Configuration Standard

Document ID: KD-SEC-017 · **Version:** 1.8 · **Owner:** Dana Whitfield, VP Engineering

Approved: 29 January 2026 · **Next review:** 29 January 2027

Maps to: SOC 2 CC6.1, CC7.1, CC8.1 · ISO 27001:2022 A.8.9, A.8.19, A.8.32

gs://attestor-505506-corpus/security/cloud-security-posture-standard.txt

[6] cloud-security-posture-standard — 8. Logging and evidence — relevance 0.55

8. Logging and evidence

CloudTrail (all regions, all accounts), VPC flow logs, GuardDuty findings, and Config history are delivered to a dedicated `kd-security` account that no engineering role can write to, with object lock set to 400 days. This is the arrangement that makes the audit trail defensible: the accounts that generate the evidence cannot alter it.

gs://attestor-505506-corpus/security/cloud-security-posture-standard.txt

[7] network-security-standard — 3. Segmentation — relevance 0.53

3. Segmentation

Each environment is a separate AWS account inside the AWS Organization (`kd-prod-us`, `kd-prod-eu`, `kd-staging`, `kd-dev`, `kd-security`, `kd-shared-services`). There is **no** VPC peering and no transit gateway route between production and non-production; the boundary is an account boundary, not a firewall rule that can be edited.

Within a production VPC there are three subnet t

gs://attestor-505506-corpus/security/network-security-standard.txt

[8] network-security-standard — 5. Egress — relevance 0.52

5. Egress

Production workloads egress through NAT gateways with a domain allowlist enforced by AWS Network Firewall. The allowlist contains 23 destinations, each with a named owner and a business justification. An attempted connection to a destination outside the allowlist is blocked and alerted; 61 such alerts in 2025 were all traced to dependency mirrors being retired upstream.

gs://attestor-505506-corporus/security/network-security-standard.txt

[9] network-security-standard — 4. Inbound rules — relevance 0.50

4. Inbound rules

There are no unrestricted inbound rules (`0.0.0.0/0`) in any production security group other than ports 80 and 443 on the load balancer security group, which are themselves restricted to Cloudflare ranges. SSH ingress is closed entirely; administrative access is through AWS Systems Manager Session Manager, which requires an IAM identity and produces a recorded session.

Config

gs://attestor-505506-corporus/security/network-security-standard.txt

[10] network-security-standard — Network Security Standard — relevance 0.49

Network Security Standard

Document ID: KD-SEC-016 · **Version:** 2.0 · **Owner:** Dana Whitfield, VP Engineering

Approved: 5 February 2026 · **Next review:** 5 February 2027

Maps to: SOC 2 CC6.6, CC6.7, CC7.1 · ISO 27001:2022 A.8.20, A.8.21, A.8.22, A.8.23

gs://attestor-505506-corporus/security/network-security-standard.txt

225. How long do elevated production access grants remain valid?

security · Q225 · Vendor Security Review row 226

Elevated production access grants expire automatically after 8 hours (`access-control-standard`, Section 4, "Just-in-time production access"). In practice, during Q4 2025, just-in-time elevations had a mean duration of 47 minutes.

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] access-control-standard — 4. Just-in-time production access — relevance 0.67

4. Just-in-time production access

Engineers request elevated production access through the `/access` Slack workflow. A request requires a written business justification, a linked incident or change ticket, and approval from a second engineer holding the SRE role. Self-approval is blocked.

Granted access expires automatically after **8 hours**. All commands executed in an elevated session are

gs://attestor-505506-corporus/security/access-control-standard.txt

[2] access-control-standard — 3. Role-based access — relevance 0.64

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix (`SEC-GOV/access-matrix`), which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is just-in-time.

gs://attestor-505506-corporus/security/access-control-standard.txt

[3] access-control-standard — 7. Access reviews — relevance 0.61

7. Access reviews

Quarterly user access reviews cover all production systems, the AWS Organization, Snowflake, GitHub, and Okta itself. Reviews are performed by the system owner and

attested in Vanta. The Q4 2025 review completed on 12 January 2026 and removed 23 entitlements, of which 9 were stale contractor accesses.

gs://attestor-505506-corporus/security/access-control-standard.txt

[4] access-control-standard — 8. Service accounts and machine identity — relevance 0.59

8. Service accounts and machine identity

Workloads authenticate using short-lived credentials: AWS IAM Roles for Service Accounts (IRSA) in EKS, and Workload Identity Federation for GCP components. Long-lived static access keys are prohibited; the last was decommissioned on 17 November 2024. Automated detection for newly created static keys runs hourly and pages the on-call SRE.

gs://attestor-505506-corporus/security/access-control-standard.txt

[5] access-control-standard — 6. Joiners, movers, leavers — relevance 0.58

6. Joiners, movers, leavers

Joiners are provisioned via Okta Lifecycle Management from Rippling (HRIS); no access is granted before the background check clears. Movers have entitlements recalculated on role change, with the previous role revoked within 1 business day. Leavers have all access revoked automatically on the HRIS termination event: the target is 1 hour, and the measured median for

gs://attestor-505506-corporus/security/access-control-standard.txt

226. For each applicable system: Describe your approach to environmental sustainability and carbon reporting.

unassigned · Q226 · Vendor Security Review row 227

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] infrastructure-architecture-overview — Infrastructure Architecture Overview — relevance 0.60

Infrastructure Architecture Overview

Document ID: KD-ENG-003 · **Version:** 3.4 · **Owner:** Dana Whitfield, VP Engineering
Last updated: 5 February 2026 · **Classification:** Confidential, NDA required

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[2] infrastructure-architecture-overview — 1. Cloud footprint — relevance 0.58

1. Cloud footprint

Kestrel runs on **Amazon Web Services**. There are two independent production instances:

| Instance | Region | Serves |

|---|---|---|

| US | `us-east-1` (3 AZs) | North America, and customers with no residency requirement |

| EU | `eu-west-1` (3 AZs) | EEA, UK, and Swiss customers electing EU residency |

Backup replication targets `us-west-2` and `eu-central-1` respecti

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[3] infrastructure-architecture-overview — 6. Network — relevance 0.57

6. Network

Private subnets for all compute and data. No public IP addresses on workload instances. Ingress is exclusively through Cloudflare, then an AWS Application Load Balancer, then the Istio ingress gateway. Egress is through NAT gateways with an allowlist for known destinations.

Security groups are managed in Terraform and default-deny. There are no `0.0.0.0/0` ingress rules in produc

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[4] infrastructure-architecture-overview — 3. Compute — relevance 0.57

3. Compute

Amazon EKS (Kubernetes 1.31) with managed node groups spanning three availability zones. Workloads run as containers built from distroless base images, as non-root, with read-only root filesystems and dropped Linux capabilities. Pod Security Standards are enforced at the `restricted` level.

Node images are immutable; nodes are recycled with a maximum age of 30 days rather than pa

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[5] infrastructure-architecture-overview — 4. Data layer — relevance 0.55

4. Data layer

| Store | Technology | Purpose |

|---|---|---|

| Primary OLTP | Amazon RDS PostgreSQL 16, Multi-AZ | Application state |

| Analytics | Snowflake | Customer analytics workloads |

| Object storage | Amazon S3 | Uploads, exports, backups |

| Cache | Amazon ElastiCache (Redis 7) | Session and query cache |

| Search | OpenSearch 2.13 | In-product search |

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

227. For each applicable system: Do you act as a service provider under the CCPA?

legal · Q227 · Vendor Security Review row 228

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

228. What is your remediation SLA for High severity vulnerabilities?

security · Q228 · Vendor Security Review row 229

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

229. Describe the shared responsibility model between you and your customers.

security · Q229 · Vendor Security Review row 230

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] incident-response-runbook — 8. Post-incident review — relevance 0.61

8. Post-incident review

Every SEV1 and SEV2 requires a blameless post-incident review within 5 business days, published internally, with action items tracked to closure in Jira. Reviews are shared with affected customers on request.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[2] incident-response-runbook — 2. Roles — relevance 0.61

2. Roles

The Incident Commander owns the response and is deliberately not the person fixing the problem; ICs are drawn from a rota of 6 trained staff. The Communications Lead owns customer, internal, and regulator messaging. A Scribe maintains the timeline for every SEV1 and SEV2. Subject matter experts are pulled in as needed.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[3] physical-and-environmental-security — 7. Equipment removal — relevance 0.55

7. Equipment removal

Company equipment may be removed from the office freely, as befits a remote-first company. Every device is enrolled in Kandji, encrypted, and remotely wipeable. Loss or theft must be reported to `#security` within 4 hours; the device is wiped remotely and the event recorded as a security incident. Three devices were reported lost or stolen in 2025, all wiped successfully, none

gs://attestor-505506-corporus/security/physical-and-environmental-security.txt

[4] physical-and-environmental-security — 1. Production infrastructure — relevance 0.54

1. Production infrastructure

Kestrel Data operates **no owned or leased data centre**. All production infrastructure runs in AWS: `us-east-1` for the US instance and `eu-west-1` for the EU instance. Physical and environmental controls for those facilities — perimeter security, biometric access, CCTV, fire suppression, power redundancy, environmental monitoring, and media destruction — are AWS's re

gs://attestor-505506-corporus/security/physical-and-environmental-security.txt

[5] incident-response-runbook — 4. Customer notification commitments — relevance 0.54

4. Customer notification commitments

These are contractual and are reproduced in the DPA (KD-LEG-001) and the Security Addendum (KD-LEG-008):

- **Personal data breach** - affected customers notified without undue delay and in any event **within 72 hours** of Kestrel confirming the breach.
- **Confirmed unauthorised access to customer production data** - affected customers notified **wit**

gs://attestor-505506-corporus/security/incident-response-runbook.txt

230. Describe your rollback capability and typical rollback time.

engineering · Q230 · Vendor Security Review row 231

Kestrel Data implements automated, canary-based progressive rollouts for production deployments. Releases roll out progressively—beginning with 5% of traffic for 15 minutes, moving to 25%, and then 100%—with automatic rollback triggered upon any error-rate or latency regression (`sdlc-policy`, Section 6, "Release"). To ensure rollbacks proceed smoothly without requiring data migrations, standard change management procedures require a written rollback plan and dictate that database schema migrations remain backward-compatible for at least one release (`change-management-procedure`, Section 2, "Normal change requirements"). For typical recovery timing, the mean time to restore (MTTR) in production was 18 minutes in 2025, with a change failure rate of 2.1% (`sdlc-policy`, Section 6, "Release").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (14)

[1] sdlc-policy — 6. Release — relevance 0.66

6. Release

Releases are continuous: merge to `main` triggers a deployment to staging, an automated verification suite, and then a progressive rollout to production. Rollout is canary-based: 5% of traffic for 15 minutes, then 25%, then 100%, with automatic rollback on error-rate or latency regression.

Median lead time from merge to production in 2025 was **34 minutes**. Change failure rate w

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[2] backup-restore-procedure — 4. Test results — relevance 0.66

4. Test results

Restore is tested **quarterly**, and the test is a real restore, not a backup-listing check.

Quarter	Date	Duration	Assertions	Outcome
Q1 2026	17 Jan 2026	2h 41m	1,240 / 1,240	Pass
Q4 2025	11 Oct 2025	3h 02m	1,238 / 1,240	Pass, 2 known-stale fixtures corrected
Q3 2025	19 Jul 2025	3h 20m	1,240 / 1,240	Pass

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[3] backup-restore-procedure — 5. Tenant-scoped restore — relevance 0.66

5. Tenant-scoped restore

A single customer can be restored without affecting others, by restoring to an isolated account and exporting that tenant rows back. This was exercised once in production, on 22 September 2025, at a customer request following an erroneous bulk delete on their side. Time to complete was 5 hours 10 minutes.

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[4] backup-restore-procedure — 3. Restore procedure — relevance 0.59

3. Restore procedure

1. Declare the restore scope: point in time, and whether tenant-scoped or full.
2. Provision an isolated restore account from the Terraform module `restore-target`.
3. Restore the RDS snapshot or PITR target into the isolated account.
4. Run the integrity suite: 1,240 assertions covering row counts, referential integrity, tenant isolation invariants, and known-value spo

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[5] backup-restore-procedure — 1. What is backed up — relevance 0.59

1. What is backed up

Asset	Method	Frequency	Retention
RDS PostgreSQL	Automated snapshots + WAL archiving (PITR)	Continuous	**35 days**
RDS logical dump	`pg_dump` to S3, encrypted with a separate CMK	Daily 03:00 UTC	90 days
S3 objects	Versioning + cross-region replication	Continuous	90 days for non-current versions
Snowflake	Time Tr		

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[6] sdlc-policy — 3. Testing requirements — relevance 0.57

3. Testing requirements

- Unit test coverage gate at **80%** on changed lines, enforced in CI.
- Integration tests run against ephemeral infrastructure provisioned per pull request.
- Tenant isolation tests run on every build: a suite of 84 assertions attempting cross-tenant reads through every public API surface.
- Load tests before any release expected to change the performance profile.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[7] sdlc-policy — 7. Separation of duties — relevance 0.56

7. Separation of duties

Engineers cannot deploy their own change to production without the automated pipeline: no human has the ability to push a container image to the production registry directly. The deployment role is held by the CI service identity, which authenticates through OIDC and holds no long-lived credentials.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[8] change-management-procedure — 2. Normal change requirements — relevance 0.56

2. Normal change requirements

A Normal change additionally requires a written rollback plan, a customer-impact assessment, and sign-off from the Change Advisory group (VP Engineering plus one SRE). Schema migrations must be backward compatible for at least one release, so that a rollback does not require a data migration.

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[9] change-management-procedure — 5. Database changes — relevance 0.53

5. Database changes

Migrations run through Atlas with a plan-and-approve step. Destructive operations (column drop, table drop) require a two-phase deployment separated by at least one release: the column is first stopped being read, then dropped in a later release.

gs://attestor-505506-corpus/engineering/change-management-procedure.txt

[10] sdlc-policy — 1. Branching and review — relevance 0.52

1. Branching and review

`main` is protected and always releasable. All work happens on short-lived branches merged by pull request. `main` requires:

- At least **one approving review** from a engineer other than the author. Self-approval is blocked at the platform level.
- Two approvals for changes touching authentication, authorisation, tenant isolation, or cryptography. These paths ar

gs://attestor-505506-corpus/engineering/sdlc-policy.txt

[11] sdlc-policy — 4. Security in the pipeline — relevance 0.51

4. Security in the pipeline

Static analysis (Semgrep, CodeQL), dependency scanning (Snyk), IaC scanning (Checkov), and secret scanning (Gitleaks pre-commit plus GitHub push protection) all run on every pull request. A Critical or High dependency finding blocks the merge.

gs://attestor-505506-corpus/engineering/sdlc-policy.txt

[12] change-management-procedure — 3. Emergency changes — relevance 0.51

3. Emergency changes

An Emergency change may bypass the Change Advisory step but never bypasses code review or CI. The Incident Commander authorises it, and a retrospective record is filed within one business day covering what changed, why the normal path was bypassed, and whether the change should be reworked.

All 9 Emergency changes in 2025 have completed retrospectives on file.

gs://attestor-505506-corpus/engineering/change-management-procedure.txt

[13] change-management-procedure — Change Management Procedure — relevance 0.50

Change Management Procedure

Document ID: KD-ENG-002 · **Version:** 3.0 · **Owner:** Dana Whitfield, VP Engineering
Approved: 20 January 2026 · **Maps to:** SOC 2 CC8.1 · ISO 27001:2022 A.8.32

gs://attestor-505506-corpus/engineering/change-management-procedure.txt

[14] change-management-procedure — 6. Customer notification — relevance 0.50

6. Customer notification

Customers are notified at least **7 days** in advance of any change expected to cause degraded service or to require action on their part. Breaking API changes follow the deprecation policy: minimum **12 months** notice, with the deprecated version remaining available throughout.

gs://attestor-505506-corpus/engineering/change-management-procedure.txt

231. Do you subscribe to threat intelligence feeds? If not, describe compensating controls.

security · Q231 · Vendor Security Review row 232

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (8)

[1] logging-monitoring-standard — 4. Alerting — relevance 0.63

4. Alerting

Detections run in Datadog Security Monitoring. Alert routing is by severity through PagerDuty. Current detection coverage includes impossible-travel sign-ins, MFA fatigue patterns, IAM policy changes granting broad permissions, disabling of CloudTrail or GuardDuty, unusual Snowflake export volume, and break-glass account use.

Alert quality is reviewed monthly. Alerts with a false

gs://attestor-505506-corpus/security/logging-monitoring-standard.txt

[2] cloud-security-posture-standard — 6. Handling a vulnerability with no upstream fix — relevance 0.58

6. Handling a vulnerability with no upstream fix

Where no upstream fix exists, the finding is recorded in the risk register with a named owner and the mitigation is chosen from: removing the affected component, blocking the attack path at the network or WAF layer, or applying a vendored patch maintained by Kestrel (see KD-ENG-007 §7). The vulnerability is re-reviewed weekly until an upstream fix

|

gs://attestor-505506-corpus/security/cloud-security-posture-standard.txt

[3] cloud-security-posture-standard — 4. Drift detection — relevance 0.57

4. Drift detection

Configuration drift is detected three ways:

1. **Terraform Cloud drift detection** runs every 24 hours against all 19 production workspaces and opens a PagerDuty ticket on any difference. Mean drift events per month in 2025: 1.4, nearly all from AWS-side attribute defaults changing.
2. **AWS Config** evaluates 147 rules continuously across every account, with the confo

gs://attestor-505506-corpus/security/cloud-security-posture-standard.txt

[4] cloud-security-posture-standard — 8. Logging and evidence — relevance 0.57

8. Logging and evidence

CloudTrail (all regions, all accounts), VPC flow logs, GuardDuty findings, and Config history are delivered to a dedicated `kd-security` account that no engineering role can write to, with object lock set to 400 days. This is the arrangement that makes the audit trail defensible: the accounts that generate the evidence cannot alter it.

gs://attestor-505506-corpus/security/cloud-security-posture-standard.txt

[5] logging-monitoring-standard — 5. Time synchronisation — relevance 0.54

5. Time synchronisation

All hosts synchronise to the Amazon Time Sync Service. Log timestamps are recorded in UTC in RFC 3339 format. Clock drift beyond 1 second triggers a SEV3.

gs://attestor-505506-corpus/security/logging-monitoring-standard.txt

[6] cloud-security-posture-standard — 1. Account structure and guardrails — relevance 0.54

1. Account structure and guardrails

Kestrel runs an AWS Organization with six accounts and a dedicated management account that holds no workloads. **Organisation-level Service Control Policies enforce security configuration centrally**, so a misconfiguration in a member account is refused by the platform rather than caught later by a report. The enforced SCPs are:

| SCP | Effect |

|---|---|

| `de

gs://attestor-505506-corpus/security/cloud-security-posture-standard.txt

[7] cloud-security-posture-standard — 7. Cloud identity — relevance 0.51

7. Cloud identity

Human access to AWS is federated from Okta through IAM Identity Center; there are **no IAM users with long-lived access keys in any account**, and the SCP set prevents their creation. Workloads use IAM Roles for Service Accounts. The last static access key in the estate was decommissioned on 17 November 2024.

gs://attestor-505506-corpus/security/cloud-security-posture-standard.txt

[8] cloud-security-posture-standard — 3. Manual console changes — relevance 0.51

3. Manual console changes

****Manual changes in the production AWS console are not permitted.**** Human IAM principals in production accounts hold read-only permissions by default; write access is obtained through the just-in-time process in KD-SEC-002 §4, is time-boxed to 8 hours, and is intended for incident response rather than routine change.

Any write action taken by a human principal in product

gs://attestor-505506-corpus/security/cloud-security-posture-standard.txt

232. Provide your ISO 27001 certificate and its scope statement.

security · Q232 · Vendor Security Review row 233

Kestrel Data holds an ISO 27001:2022 certification issued by BSI under certificate number `IS-2025-44817` (issued 22 September 2025, valid through 21 September 2028) (*Company and Security Programme Overview*, Section 3: "Security programme in summary"). The formal ISO 27001 certificate scope statement is: > ****The information security management system supporting the development, operation, and support of the Kestrel Insight analytics platform, including supporting corporate functions, at Austin, Texas and for remote personnel.**** (*Company and Security Programme Overview*, Section 6: "Scope of certification"). The ISO 27001 certificate is available without an NDA upon request through the account team or via the trust page (*Company and Security Programme Overview*, Section 8: "How to obtain evidence").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] company-and-security-programme-overview — 6. Scope of certification — relevance 0.69

6. Scope of certification

The ISO 27001 certificate scope statement reads: ****The information security management system supporting the development, operation, and support of the Kestrel Insight analytics platform, including supporting corporate functions, at Austin, Texas and for remote personnel.**** The SOC 2 report covers the Security, Availability, and Confidentiality Trust Services Criteria. Pr

gs://attestor-505506-corpus/security/company-and-security-programme-overview.txt

[2] risk-management-and-governance — Risk Management and Security Governance — relevance 0.66

Risk Management and Security Governance

****Document ID:**** KD-SEC-018 · ****Version:**** 3.0 · ****Owner:**** Marcus Oyelaran, CISO

****Approved:**** 26 January 2026 · ****Next review:**** 26 January 2027

****Maps to:**** SOC 2 CC1.1, CC1.2, CC1.3, CC3.1, CC3.2, CC3.4 · ISO 27001:2022 A.5.1–A.5.4, Clauses 5–6, 9

gs://attestor-505506-corpus/security/risk-management-and-governance.txt

[3] company-and-security-programme-overview — Company and Security Programme Overview — relevance 0.64

Company and Security Programme Overview

****Document ID:**** KD-SEC-021 · ****Version:**** 4.2 · ****Owner:**** Marcus Oyelaran, CISO

****Approved:**** 6 February 2026 · ****Next review:**** 6 February 2027

****Maps to:**** SOC 2 CC1.1, CC1.2, CC2.1, CC2.3 · ISO 27001:2022 Clauses 4–5

gs://attestor-505506-corpus/security/company-and-security-programme-overview.txt

[4] company-and-security-programme-overview — 8. How to obtain evidence — relevance 0.63

8. How to obtain evidence

The SOC 2 Type II report, the ISO 27001 certificate, the penetration test executive summary, and the standard DPA are available to customers and prospects under NDA through the account team, usually within two business days. The certificate and the trust page are available without an NDA.

gs://attestor-505506-corpus/security/company-and-security-programme-overview.txt

[5] company-and-security-programme-overview — 3. Security programme in summary — relevance 0.62

3. Security programme in summary

The programme is built on four commitments, each evidenced elsewhere in this corpus rather than asserted here:

1. ****Independent verification.**** SOC 2 Type II (Prescient Assurance LLP, report issued 14 March 2026 covering 1 January – 31 December 2025, ****no exceptions****) and ISO 27001:2022 (BSI certificate `IS-2025-44817`, issued 22 September 2025, valid to 21

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

233. Are passwords checked against known-breached credential lists?

security · Q233 · Vendor Security Review row 234

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] access-control-standard — 9. Password requirements — relevance 0.64

9. Password requirements

Where a password is used, minimum length is 14 characters, checked against the Have I Been Pwned breached-password corpus at set time. Rotation is not forced on a schedule, in line with NIST SP 800-63B guidance; rotation is forced on evidence of compromise.

gs://attestor-505506-corporus/security/access-control-standard.txt

[2] acceptable-use-policy — 3. Credentials — relevance 0.60

3. Credentials

Credentials are personal and may not be shared, including with other Kestrel staff. Shared team accounts are prohibited. Where a shared credential is unavoidable for a third-party service that does not support SSO, it is held in a 1Password shared vault with access logged, and the service is recorded on the SSO-gap register.

gs://attestor-505506-corporus/security/acceptable-use-policy.txt

[3] access-control-standard — 1. Identity provider — relevance 0.60

1. Identity provider

All Kestrel Data systems authenticate through Okta (tenant `kestreldata.okta.com`). Local accounts on production systems are prohibited except for two documented break-glass accounts held in a sealed 1Password vault, whose use triggers a PagerDuty alert to the CISO. Both break-glass credentials were last rotated on 3 January 2026 and last used on 14 August 2025 during the

gs://attestor-505506-corporus/security/access-control-standard.txt

[4] information-security-policy — 7. Access control — relevance 0.59

7. Access control

Access follows least privilege and is governed by the Access Control Standard (KD-SEC-002). Identity is federated through Okta with SAML 2.0. Hardware-backed multi-factor authentication (WebAuthn / FIDO2 security keys) is mandatory for all staff; SMS and TOTP were retired as authentication factors on 30 June 2025.

Production access requires a documented business justification, e

gs://attestor-505506-corporus/security/information-security-policy.txt

[5] access-control-standard — 2. Multi-factor authentication — relevance 0.59

2. Multi-factor authentication

Hardware-backed MFA (WebAuthn / FIDO2, YubiKey 5 series) is mandatory for every human account. SMS and TOTP were removed as acceptable factors on 30 June 2025 following the RISK-2025-0031 treatment plan. Coverage is 100% of the 187 active employee accounts and 100% of the 24 active contractor accounts, verified continuously by Vanta control AC-07.

gs://attestor-505506-corporus/security/access-control-standard.txt

234. What is your notification window for confirmed unauthorised access to production data? If not, describe compensating controls.

legal · Q234 · Vendor Security Review row 235

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

235. Describe your multi-region architecture.

engineering · Q235 · Vendor Security Review row 236

Kestrel operates on Amazon Web Services across two independent production instances deployed in distinct regions: ****US Instance:**** Hosted in `us-east-1` across three Availability Zones (AZs), serving North America and customers without specific data residency requirements. Backup replication targets `us-west-2`. ****EU Instance:**** Hosted in `eu-west-1` across three Availability Zones (AZs), serving EEA, UK, and Swiss customers electing EU data residency. Backup replication targets `eu-central-1`. Backup replication targets remain strictly within the respective geographic and residency boundaries (`infrastructure-architecture-overview`, Section 1, "Cloud footprint"). Routing to each region is determined at ingress via DNS and tenant configuration based on the instance selected at contract signature. Each production instance is completely independent, and tenant requests and data never cross between the US and EU instances (`data-flow-and-shared-responsibility`, Section 1, "Data flow, end to end"). Within each region, primary relational storage is deployed on Multi-AZ Amazon RDS PostgreSQL 16 (`infrastructure-architecture-overview`, Section 4, "Data layer").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] infrastructure-architecture-overview — 4. Data layer — relevance 0.64

4. Data layer
| Store | Technology | Purpose |
|---|---|---|
| Primary OLTP | Amazon RDS PostgreSQL 16, Multi-AZ | Application state |
| Analytics | Snowflake | Customer analytics workloads |
| Object storage | Amazon S3 | Uploads, exports, backups |
| Cache | Amazon ElastiCache (Redis 7) | Session and query cache |
| Search | OpenSearch 2.13 | In-product search |

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[2] infrastructure-architecture-overview — 1. Cloud footprint — relevance 0.64

1. Cloud footprint
Kestrel runs on ****Amazon Web Services****. There are two independent production instances:

Instance	Region	Serves
US	`us-east-1` (3 AZs)	North America, and customers with no residency requirement
EU	`eu-west-1` (3 AZs)	EEA, UK, and Swiss customers electing EU residency

Backup replication targets `us-west-2` and `eu-central-1` respectively

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[3] infrastructure-architecture-overview — Infrastructure Architecture Overview — relevance 0.62

Infrastructure Architecture Overview
****Document ID:**** KD-ENG-003 · ****Version:**** 3.4 · ****Owner:**** Dana Whitfield, VP Engineering
****Last updated:**** 5 February 2026 · ****Classification:**** Confidential, NDA required

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[4] data-flow-and-shared-responsibility — 1. Data flow, end to end — relevance 0.62

1. Data flow, end to end
1. ****Ingress:**** A customer's browser or API client resolves `app.kestreldata.com` or `api.kestreldata.com` to Cloudflare, which terminates TLS 1.3 (1.2 minimum) and applies

WAF and rate limiting.

2. ****Instance selection.**** DNS and tenant routing send the request to the instance chosen at contract signature: `us-east-1` or `eu-west-1`. ****A tenant's requests never c**

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[5] cloud-exit-and-portability-plan — 3. Portability by design — relevance 0.61

3. Portability by design

The architecture is deliberately biased toward portable components, and the exceptions are listed rather than glossed over:

| Layer | Technology | Portability |

|---|---|---|

| Compute | Kubernetes (EKS) | High — standard manifests, no EKS-specific APIs in workloads |

| Container images | OCI in ECR | High — registry is a copy operation |

| Data warehouse | Snowflake | Hi

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

236. Provide your measured availability for the last 3 years.

engineering · Q236 · Vendor Security Review row 237

Kestrel Data's measured availability over the last three years is as follows: * ****2025:**** 99.97% (0 months below 99.9%) * ****2024:**** 99.94% (1 month below 99.9%: March at 99.87%) * ****2023:**** 99.91% (1 month below 99.9%: August at 99.82%) These metrics are measured using independent third-party monitoring (Checkly, across 7 global locations at 30-second intervals) based on production API availability (Availability Service Level Agreement, "2. Definitions" and "5. Historical performance").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] availability-sla — 5. Historical performance — relevance 0.71

5. Historical performance

| Year | Measured availability | Months below 99.9% | Credits issued |

|---|---|---|

| 2025 | 99.97% | 0 | 0 |

| 2024 | 99.94% | 1 (March, 99.87%) | 1 customer, 10% |

| 2023 | 99.91% | 1 (August, 99.82%) | 3 customers, 10% |

gs://attestor-505506-corporus/engineering/availability-sla.txt

[2] availability-sla — 2. Definitions — relevance 0.68

2. Definitions

****Uptime**** is the percentage of minutes in a calendar month during which the Service is Available, calculated as:

$$\text{Uptime \%} = ((\text{Total Minutes} - \text{Downtime Minutes}) / \text{Total Minutes}) \times 100$$

****Downtime**** is any minute during which all requests to the production API from the external monitoring network return a 5xx error or fail to connect. Measurement is by independent third-p

gs://attestor-505506-corporus/engineering/availability-sla.txt

[3] service-operations-and-support — 8. Capacity and performance — relevance 0.66

8. Capacity and performance

Capacity is reviewed monthly against a 90-day forecast. Autoscaling handles ordinary variation; the review exists for the changes autoscaling cannot absorb, such as a large tenant onboarding. Two capacity increases were made ahead of demand in 2025, neither triggered by a saturation alert.

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[4] availability-sla — Availability Service Level Agreement — relevance 0.65

gs://attestor-505506-corporus/engineering/availability-sla.txt

[5] service-operations-and-support — 6. Monitoring and alerting — relevance 0.64

6. Monitoring and alerting

Datadog holds infrastructure metrics, application performance monitoring, and synthetic checks running every 60 seconds from five geographic locations against both instances.

Alerts are symptom-based — error rate, latency percentile, saturation, and synthetic failure — rather than cause-based, so a novel failure still pages someone.

Uptime is measured from the synthetic

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

237. Do Kestrel personnel routinely access customer production data?

security · Q237 · Vendor Security Review row 238

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

238. Do you maintain cyber liability insurance, and what are the coverage limits?

legal · Q238 · Vendor Security Review row 239

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

239. What is your scheduled maintenance window?

engineering · Q239 · Vendor Security Review row 240

The standard maintenance window is Sundays from 06:00 to 10:00 UTC (*Service Operations, Maintenance and Support (KD-ENG-009)*, "2. Scheduled maintenance"). Most changes do not require the use of this window, as deployments are rolling and zero-downtime. Customers receive at least 7 days' advance notice via email to tenant administrators and status page updates for any scheduled maintenance expected to be customer-affecting, and 30 days' notice when a change requires customer action (*Service Operations, Maintenance and Support (KD-ENG-009)*, "2. Scheduled maintenance").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] service-operations-and-support — 2. Scheduled maintenance — relevance 0.73

2. Scheduled maintenance

The standard maintenance window is ****Sundays 06:00–10:00 UTC****. Most changes do not use it: deployments are rolling and zero-downtime, and 2025 saw 1,412 production deployments with no customer-visible downtime.

****Customers receive at least 7 days' notice of scheduled maintenance expected to be customer-affecting**, and 30 days' notice where the change requires customer a**

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[2] availability-sla — 3. Exclusions — relevance 0.67

3. Exclusions

Downtime does not include unavailability caused by:

- Scheduled maintenance, notified at least 7 days in advance, in the window Sundays 04:00-06:00 UTC, capped at 4 hours per month.

- Emergency maintenance to address a security vulnerability, notified as soon as practicable.
- Customer configuration, customer code, or customer exceeding documented rate limits.
- Failure o

gs://attestor-505506-corporus/engineering/availability-sla.txt

[3] service-operations-and-support — Service Operations, Maintenance and Support — relevance 0.63

Service Operations, Maintenance and Support

Document ID: KD-ENG-009 · **Version:** 2.2 · **Owner:** Dana Whitfield, VP Engineering

Approved: 23 January 2026 · **Next review:** 23 January 2027

Maps to: SOC 2 A1.1, A1.2, CC7.3, CC8.1 · ISO 27001:2022 A.5.29, A.8.6, A.8.32

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[4] availability-sla — 6. Support response targets — relevance 0.61

6. Support response targets

Support targets are separate from this SLA and are not credit-bearing.

| Severity | First response | Coverage |

|---|---|---|

| Urgent (production down) | 1 hour | 24 x 7 |

| High (major feature impaired) | 4 business hours | Business hours |

| Normal | 1 business day | Business hours |

| Low | 3 business days | Business hours |

Business hours are 08:00-18:00

gs://attestor-505506-corporus/engineering/availability-sla.txt

[5] availability-sla — Availability Service Level Agreement — relevance 0.58

Availability Service Level Agreement

Document ID: KD-ENG-007 · **Version:** 3.0 · **Owner:** Aaron Feldstein, General Counsel

Effective: 1 January 2026 · Forms part of the Master Subscription Agreement

gs://attestor-505506-corporus/engineering/availability-sla.txt

240. Describe your vendor risk management programme and tiering approach.

security · Q240 · Vendor Security Review row 241

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

241. Are infrastructure configurations managed as code?

engineering · Q241 · Vendor Security Review row 242

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] change-management-procedure — no section recorded — relevance 0.68

Change Management ... code, config change through IaC | | **Normal ... Infrastructure changes Infrastructure is managed exclusively through Terraform in the ` ...

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[2] sdlc-policy — 7. Separation of duties — relevance 0.59

7. Separation of duties

Engineers cannot deploy their own change to production without the automated pipeline: no human has the ability to push a container image to the production registry directly. The

deployment role is held by the CI service identity, which authenticates through OIDC and holds no long-lived credentials.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[3] infrastructure-architecture-overview — Infrastructure Architecture Overview — relevance 0.57

Infrastructure Architecture Overview

****Document ID:**** KD-ENG-003 · ****Version:**** 3.4 · ****Owner:**** Dana Whitfield, VP Engineering

****Last updated:**** 5 February 2026 · ****Classification:**** Confidential, NDA required

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[4] infrastructure-architecture-overview — 3. Compute — relevance 0.57

3. Compute

Amazon EKS (Kubernetes 1.31) with managed node groups spanning three availability zones. Workloads run as containers built from distroless base images, as non-root, with read-only root filesystems and dropped Linux capabilities. Pod Security Standards are enforced at the `restricted` level.

Node images are immutable; nodes are recycled with a maximum age of 30 days rather than pa

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[5] secrets-management-standard — 4. Runtime access — relevance 0.57

4. Runtime access

Workloads obtain secrets at runtime through the AWS Secrets Manager CSI driver, mounted as in-memory `tmpfs` volumes. Secrets are never written to disk, never baked into container images, and never passed as environment variables where they could leak into a crash dump or a process listing.

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

242. Provide evidence of your most recent user access review.

security · Q242 · Vendor Security Review row 243

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

243. Describe your key rotation policy and frequency.

engineering · Q243 · Vendor Security Review row 244

Kestrel Data enforces automated key and credential rotation policies defined by secret classification: * ****Encryption Keys:**** Stored in AWS KMS (where key material never leaves KMS) and rotated automatically on an annual basis (`secrets-management-standard`, Section 1, "Where secrets live"). * ****Application Secrets & API Keys:**** Stored in AWS Secrets Manager and rotated automatically every 90 days (`secrets-management-standard`, Section 1, "Where secrets live"). * ****Database Credentials:**** Stored in AWS Secrets Manager using RDS-managed rotation and rotated automatically every 30 days (`secrets-management-standard`, Section 1, "Where secrets live"). * ****TLS Certificates:**** Managed via AWS Certificate Manager and renewed automatically prior to expiration (`secrets-management-standard`, Section 1, "Where secrets live"). * ****Human-Held Shared Credentials:**** Maintained in 1Password shared vaults and rotated upon any personnel change (`secrets-management-standard`, Section 1, "Where secrets live"). In addition to scheduled lifecycles, any suspected compromised secret is rotated immediately prior to completing an investigation following an "order to rotate, then investigate" policy (`secrets-management-standard`, Section 5, "Rotation on compromise"). Furthermore, if any secret is shared via unauthorized channels such as Slack, email, or ticketing systems, it is treated as compromised and rotated immediately (`secrets-management-standard`, Section 2, "What is prohibited").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] secrets-management-standard — 5. Rotation on compromise — relevance 0.63

5. Rotation on compromise

A suspected compromised secret is rotated immediately, before investigation completes.

The order is rotate, then investigate, then decide whether it was actually exposed:

delaying rotation while establishing certainty extends the exposure window for no benefit.

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

[2] secrets-management-standard — 1. Where secrets live — relevance 0.62

1. Where secrets live

| Secret class | Store | Rotation |

|---|---|---|

| Application secrets, API keys | AWS Secrets Manager | 90 days, automated |

| Database credentials | AWS Secrets Manager with RDS-managed rotation | 30 days, automated |

| Encryption keys | AWS KMS (key material never leaves KMS) | Annual, automated |

| TLS certificates | AWS Certificate Manager | Automatic before expiry

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

[3] secrets-management-standard — 6. Customer-issued API credentials — relevance 0.60

6. Customer-issued API credentials

API keys issued to customers are stored as Argon2id hashes; Kestrel cannot recover the plaintext of a customer API key and will not do so on request. Keys are displayed once at creation. Customers can create, scope, and revoke keys through the console, and each key carries a last-used timestamp so stale keys are visible.

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

[4] secrets-management-standard — 2. What is prohibited — relevance 0.60

2. What is prohibited

- Secrets in source code, including test fixtures, comments, and commit history.

- Secrets in environment files committed to a repository.

- Secrets in CI logs, container image layers, or Terraform state in plaintext.

- Long-lived static AWS access keys. The last was decommissioned 17 November 2024, and creation of a new one triggers an hourly detection that pages the o

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

[5] secrets-management-standard — Secrets Management Standard — relevance 0.55

Secrets Management Standard

Document ID: KD-ENG-006 · **Version:** 2.1 · **Owner:** Dana Whitfield, VP Engineering

Approved: 22 January 2026 · **Maps to:** SOC 2 CC6.1 · ISO 27001:2022 A.8.24

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

244. Please confirm: Do you accept SOC 2 and ISO 27001 reports in place of a customer audit?

legal · Q244 · Vendor Security Review row 245

Kestrel makes available its current SOC 2 Type II report, ISO 27001 certificate, penetration test executive summary, and completed CAIQ to satisfy customer audit requirements and GDPR Article 28(3)(h) obligations in the first instance (`data-processing-agreement`, Section 9; `master-agreement-summary`, Section 6). While these third-party assurance reports satisfy the majority of customer audit requests in practice, the report-first position serves as a starting point rather than a refusal of customer audits (`master-agreement-summary`, Section 6). If a customer has a documented, specific concern not addressed by these reports, or where a customer's regulator or internal policy requires an on-site or questionnaire-based audit, Kestrel will accommodate the audit (`data-processing-agreement`, Section 9; `master-agreement-summary`, Section 6). Direct customer audits are permitted once per twelve-month period upon 30 days' written notice, during business hours, subject to confidentiality, and at customer expense (with additional audits permitted following an affecting personal data breach or upon instruction from a supervisory authority) (`data-processing-agreement`, Section 9; `master-agreement-summary`, Section 6).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] data-processing-agreement — 9. Audit — relevance 0.74

9. Audit

Kestrel makes available its current SOC 2 Type II report and ISO 27001 certificate, which Customer accepts as satisfying Art. 28(3)(h) in the first instance. Where Customer has a documented, specific concern not addressed by those reports, Customer may conduct an audit no more than **once per twelve months**, on 30 days written notice, during business hours, subject to confidentiality

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[2] master-agreement-summary — 6. Audit rights — relevance 0.71

6. Audit rights

Customers may audit Kestrel's compliance with the DPA **once per twelve-month period** on 30 days' written notice, with additional audits permitted following a personal data breach affecting the customer or on a supervisory authority's instruction. Audits are conducted during business hours, must not unreasonably disrupt operations, and are subject to confidentiality.

Kestrel firs

gs://attestor-505506-corporus/legal/master-agreement-summary.txt

[3] security-addendum — 1. Certifications maintained — relevance 0.68

1. Certifications maintained

Kestrel will maintain, for the term of the Agreement, a SOC 2 Type II report covering Security, Availability, and Confidentiality, and ISO/IEC 27001:2022 certification. Current reports are made available annually within 30 days of issuance.

If a certification lapses or an audit opinion is qualified, Kestrel will notify affected customers within **10 business days**

gs://attestor-505506-corporus/legal/security-addendum.txt

[4] government-requests-and-transparency-report — Government Requests Policy and Transparency Report — relevance 0.65

Government Requests Policy and Transparency Report

Document ID: KD-LEG-012 · **Version:** 2.0 · **Owner:** Aaron Feldstein, General Counsel

Approved: 2 February 2026 · **Next review:** 2 February 2027

Maps to: GDPR Articles 48, 28(3)(a) · SOC 2 CC2.3 · ISO 27001:2022 A.5.5, A.5.31, A.5.34

gs://attestor-505506-corporus/legal/government-requests-and-transparency-report.txt

[5] master-agreement-summary — Master Subscription Agreement — Summary of Key Terms — relevance 0.62

Master Subscription Agreement — Summary of Key Terms

Document ID: KD-LEG-014 · **Version:** 3.2 · **Owner:** Aaron Feldstein, General Counsel

Approved: 28 January 2026 · **Next review:** 28 January 2027

Maps to: SOC 2 CC2.3, CC9.1 · GDPR Article 28

*A summary for review purposes. The executed agreement governs; where this summary and an executed contract differ, the contract prevails.

gs://attestor-505506-corporus/legal/master-agreement-summary.txt

245. Provide the technical and organisational measures annexed to your DPA.

legal · Q245 · Vendor Security Review row 246

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (10)

[1] dpa-annex-2-technical-measures — DPA Annex 2 - Technical and Organisational Measures — relevance 0.76

DPA Annex 2 - Technical and Organisational Measures

Document ID: KD-LEG-009 · **Version:** 4.0 · **Owner:** Marcus Oyelaran, CISO

Effective: 1 February 2026 · Annex to the DPA (KD-LEG-001)

Maps to: GDPR Art. 32

Measures are described at a level that allows a controller to assess adequacy under Art. 32 without exposing information that would itself create risk.

gs://attestor-505506-corporus/legal/dpa-annex-2-technical-measures.txt

[2] dpa-annex-2-technical-measures — 1. Pseudonymisation and encryption (Art. 32(1)(a)) — relevance 0.69

1. Pseudonymisation and encryption (Art. 32(1)(a))

Data at rest is encrypted with AES-256-GCM across RDS, S3, EBS, and Snowflake. Data in transit uses TLS 1.3 externally and mutual TLS internally within the service mesh.

Application logs are pseudonymised at emission: direct identifiers are replaced with opaque `tenant\_id` and `user\_id` values before the log leaves the process.

gs://attestor-505506-corporus/legal/dpa-annex-2-technical-measures.txt

[3] master-agreement-summary — 9. Subcontracting — relevance 0.67

9. Subcontracting

Sub-processing is governed by the DPA: a public list (KD-LEG-006), **30 days' notice** before adding or replacing a sub-processor, a right to object on reasonable data protection grounds, and termination without penalty if the objection cannot be resolved.

gs://attestor-505506-corporus/legal/master-agreement-summary.txt

[4] data-processing-agreement — 4. Security — relevance 0.66

4. Security

Kestrel implements the technical and organisational measures set out in **Annex 2**, including encryption at rest (AES-256-GCM) and in transit (TLS 1.3), least-privilege access control with mandatory hardware MFA, and continuous monitoring.

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[5] dpa-annex-2-technical-measures — 2. Confidentiality, integrity, availability, resilience (Art. 32(1)(b)) — relevance 0.66

2. Confidentiality, integrity, availability, resilience (Art. 32(1)(b))

Confidentiality. Least-privilege access via Okta with mandatory hardware MFA; just-in-time production elevation expiring in 8 hours; tenant isolation verified by independent penetration testing (no cross-tenant access achieved, February 2026).

Integrity. All changes reviewed and merged through pull request with a

gs://attestor-505506-corporus/legal/dpa-annex-2-technical-measures.txt

[6] transfer-impact-assessment — 5. Supplementary measures relied on — relevance 0.65

5. Supplementary measures relied on
Technical:

1. **Data residency by default** — EU customer content, including backups and the replicated log ship, never leaves `eu-west-1`.
2. **Encryption in transit** — TLS 1.3 (1.2 minimum) on every hop, including between Kestrel and each sub-processor.
3. **Encryption at rest** — AES-256-GCM with keys in AWS KMS. Keys for the EU instance are held i

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

[7] gdpr-records-of-processing — Part A - Kestrel as Processor (Art. 30(2)) — relevance 0.65

Part A - Kestrel as Processor (Art. 30(2))

Controller: each Kestrel customer, as identified in the applicable Order Form.

Processor: Kestrel Data, Inc.

DPO: Priya Raghunathan, `dpo@kestreldata.com`

| # | Processing activity | Categories of data subject | Categories of personal data | Transfers | Retention |

| --|--|--|--|--|--|

| P1 | Hosting and operating the Kestrel Insig

gs://attestor-505506-corporus/legal/gdpr-records-of-processing.txt

[8] master-agreement-summary — 1. Structure — relevance 0.65

1. Structure

A Kestrel engagement comprises the Master Subscription Agreement, an Order Form, the Data Processing Agreement (KD-LEG-001) with its Annex 2 technical measures (KD-LEG-003), and the Security Addendum (KD-LEG-005). The DPA and Security Addendum are incorporated by reference into every agreement; they are not optional extras negotiated case by case.

gs://attestor-505506-corporus/legal/master-agreement-summary.txt

[9] gdpr-records-of-processing — Data Protection Impact Assessments — relevance 0.61

Data Protection Impact Assessments

One DPIA is on file, covering the introduction of the anomaly detection feature

(`LEG-GOV/dpia-2025-01`, completed 8 September 2025). Conclusion: residual risk low, no prior consultation with the supervisory authority required.

gs://attestor-505506-corporus/legal/gdpr-records-of-processing.txt

[10] dpa-annex-2-technical-measures — 3. Restoring availability (Art. 32(1)(c)) — relevance 0.60

3. Restoring availability (Art. 32(1)(c))

RTO 4 hours, RPO 15 minutes. The 17 January 2026 full failover exercise achieved

2 hours 41 minutes and 4 minutes respectively. Results are documented in KD-SEC-010.

gs://attestor-505506-corporus/legal/dpa-annex-2-technical-measures.txt

246. What controls remain the responsibility of the customer?

security · Q246 · Vendor Security Review row 247

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

247. Which transfer mechanism do you rely on for transfers out of the EEA? Provide supporting evidence.

legal · Q247 · Vendor Security Review row 248

For transfers of personal data out of the EEA, Kestrel relies on the 2021 EU Standard Contractual Clauses (Commission Implementing Decision 2021/914), specifically Module Two (Controller to Processor) between customers and Kestrel, and Module Three (Processor to Sub-processor) between Kestrel and its sub-processors (*Data Processing Agreement*, Section "10. International transfers"; *Transfer Impact Assessment*, Section "3. Transfer mechanism"). Where relevant for UK exports, the UK International Data Transfer Addendum is incorporated, and for Switzerland, the Swiss Annex applies with the adaptations required by the Swiss FDPIC (*Data Processing Agreement*, Section "10. International transfers"; *Transfer Impact Assessment*, Section "3. Transfer mechanism"). Kestrel relies on the SCCs alongside supplementary technical, organizational, and contractual measures evaluated in its Transfer Impact Assessment rather than self-certification under the EU-US Data Privacy Framework (*Transfer Impact Assessment*, Section "3. Transfer mechanism"; *Privacy Policy*, Section "6. International transfers").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] data-processing-agreement — 10. International transfers — relevance 0.70

10. International transfers

Where Personal Data is transferred out of the EEA, UK, or Switzerland, the parties enter into the **2021 EU Standard Contractual Clauses** (Commission Implementing Decision 2021/914), Module Two (Controller to Processor) or Module Three (Processor to Sub-processor) as applicable, incorporated by reference. The UK International Data Transfer Addendum and the Swiss An

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[2] transfer-impact-assessment — 3. Transfer mechanism — relevance 0.70

3. Transfer mechanism

The 2021 **Standard Contractual Clauses, Module Two (controller to processor)** apply between the customer and Kestrel, and **Module Three (processor to sub-processor)** between

Kestrel and its US sub-processors. The **UK International Data Transfer Addendum** is incorporated for UK exports, and for Switzerland the SCCs are applied with the adaptations published by the Swiss

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

[3] transfer-impact-assessment — Transfer Impact Assessment — relevance 0.69

Transfer Impact Assessment

Document ID: KD-LEG-010 · **Version:** 2.1 · **Owner:** Priya Raghunathan, DPO

Approved: 9 January 2026 · **Next review:** 9 January 2027

Maps to: GDPR Articles 44–49 · EDPB Recommendations 01/2020 · Schrems II (C-311/18)

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

[4] privacy-policy — 6. International transfers — relevance 0.68

6. International transfers

Personal data is processed in the United States and the European Union. Transfers out of the EEA rely on the 2021 Standard Contractual Clauses with supplementary measures described in the Transfer Impact Assessment (KD-LEG-006).

gs://attestor-505506-corporus/legal/privacy-policy.txt

[5] standard-contractual-clauses-summary — 2. UK and Switzerland — relevance 0.68

2. UK and Switzerland

- **UK** - the ICO International Data Transfer Addendum (version B1.0, in force 21 March 2022) is appended to the EU SCCs. UK GDPR references replace EU GDPR references; the competent authority is the ICO.

- **Switzerland** - the Swiss Annex applies. The FDPIC is the competent authority, and references to Member State law are read as references to Swiss law. The SCC

gs://attestor-505506-corporus/legal/standard-contractual-clauses-summary.txt

248. Do you offer UK-only data residency?

legal · Q248 · Vendor Security Review row 249

No, Kestrel Data does not currently offer a UK-only data residency option. While customers on the EU instance have their data processed exclusively within the EEA (in `eu-west-1`), requests for UK-only data residency are recorded but not committed to (Subprocessor List, "EU data residency").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] subprocessor-list — EU data residency — relevance 0.72

EU data residency

Customers on the EU instance have their data processed exclusively within the EEA for the infrastructure subprocessors above. Kestrel does **not** currently offer a UK-only, Swiss-only, Canadian, or Australian data residency option. Requests for those are recorded but not committed to.

gs://attestor-505506-corporus/legal/subprocessor-list.txt

[2] transfer-impact-assessment — 5. Supplementary measures relied on — relevance 0.65

5. Supplementary measures relied on

Technical:

1. **Data residency by default** — EU customer content, including backups and the replicated log ship, never leaves `eu-west-1`.

2. **Encryption in transit** — TLS 1.3 (1.2 minimum) on every hop, including between Kestrel and each sub-processor.

3. **Encryption at rest** — AES-256-GCM with keys in AWS KMS. Keys for the EU instance are held i

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

[3] transfer-impact-assessment — 2. The transfers assessed — relevance 0.62

2. The transfers assessed

| # | Transfer | Exporter | Importer | Country | Data |

|---|---|---|---|---|---|

| T1 | EU tenant support access | Kestrel EU instance | Kestrel Data, Inc. | United States | Account identity data, support correspondence |

| T2 | Product telemetry aggregation | Kestrel EU instance | Kestrel Data, Inc. | United States | Pseudonymised usage events |

| T3 | Error monitoring

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

[4] transfer-impact-assessment — 6. Conclusion — relevance 0.60

6. Conclusion

For T1 and T2 the residual risk to data subjects is assessed as **low**: the data transferred is limited, pseudonymised where possible, encrypted with keys held outside the importer's jurisdiction, and unaccompanied by any customer content. For T3 and T4 the residual risk is **low** on the same basis, with the additional point that no customer content is transferred at all.

The asse

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

[5] transfer-impact-assessment — 1. Status — relevance 0.59

1. Status

Kestrel Data has completed a Transfer Impact Assessment, most recently updated on 9 January 2026. It is refreshed annually and on any material change to the transfer chain, the receiving country's law, or the supplementary measures relied on. A copy is available to customers under NDA.

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

249. Is tenant isolation tested continuously?

engineering · Q249 · Vendor Security Review row 250

Yes, tenant isolation is tested continuously. In our CI pipeline, a dedicated tenant isolation test suite of 84 assertions runs on every build, actively attempting cross-tenant reads across every public API surface (SDLC Policy, "3. Testing requirements"). In addition, isolation is verified through these continuous automated build tests and was independently validated during our February 2026 penetration test, where no cross-tenant access was achieved (Infrastructure Architecture Overview, "5. Tenant isolation").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] sdlc-policy — 3. Testing requirements — relevance 0.68

3. Testing requirements

- Unit test coverage gate at **80%** on changed lines, enforced in CI.
- Integration tests run against ephemeral infrastructure provisioned per pull request.
- Tenant isolation tests run on every build: a suite of 84 assertions attempting cross-tenant reads through every public API surface.
- Load tests before any release expected to change the performance profile.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[2] infrastructure-architecture-overview — 5. Tenant isolation — relevance 0.64

5. Tenant isolation

Kestrel Insight is **multi-tenant** with logical isolation. There is no per-customer infrastructure, no single-tenant deployment option, and no customer-VPC option.

Isolation is enforced at three layers:

1. **Database** - PostgreSQL row-level security policies keyed on `tenant\_id`, applied at the connection level from an authenticated session variable. No application

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[3] backup-restore-procedure — 5. Tenant-scoped restore — relevance 0.61

5. Tenant-scoped restore

A single customer can be restored without affecting others, by restoring to an isolated account and exporting that tenant rows back. This was exercised once in production, on 22 September 2025, at a customer request following an erroneous bulk delete on their side. Time to complete was 5 hours 10 minutes.

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[4] backup-restore-procedure — 3. Restore procedure — relevance 0.61

3. Restore procedure

1. Declare the restore scope: point in time, and whether tenant-scoped or full.
2. Provision an isolated restore account from the Terraform module `restore-target`.
3. Restore the RDS snapshot or PITR target into the isolated account.
4. Run the integrity suite: 1,240 assertions covering row counts, referential integrity, tenant isolation invariants, and known-value spo

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[5] cloud-exit-and-portability-plan — 8. Testing — relevance 0.59

8. Testing

The plan is exercised annually as a tabletop with the SRE team, the VP Engineering, and the CISO. The 19 November 2025 exercise identified two gaps — the SQS/SNS adapter was not in place, and the KMS re-encryption path was undocumented — and both were closed by 14 January 2026. The next exercise is scheduled for November 2026.

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

250. Do you publish a transparency report of government data requests? If not, describe compensating controls.

legal · Q250 · Vendor Security Review row 251

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

251. When was your Information Security Policy last reviewed and approved? If not, describe compensating controls.

security · Q251 · Vendor Security Review row 252

Kestrel Data's Information Security Policy (KD-SEC-001, Version 4.2) was last reviewed and approved on 11 February 2026 by the Board Audit & Risk Committee. The next scheduled review date is 11 February 2027, in accordance with our policy management requirement to review all security policies at least annually and upon material change.

****Citations:**** * `information-security-policy`, Section "Information Security Policy" *
`risk-management-and-governance`, Section "8. Policy management"

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] risk-management-and-governance — 8. Policy management — relevance 0.73

8. Policy management

All security policies carry a document ID, a version, a named owner, an approval date, and a review date. Policies are reviewed at least annually and on material change. The 2026 review cycle covered 14 policies between 8 January and 12 February 2026; three were revised, and the changes were communicated at the February all-hands and through the annual acknowledgement cycle.

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[2] information-security-policy — Information Security Policy — relevance 0.72

Information Security Policy

****Document ID:**** KD-SEC-001

****Version:**** 4.2

****Owner:**** Marcus Oyelaran, Chief Information Security Officer

****Approved by:**** Board Audit & Risk Committee, 11 February 2026
****Last review:**** 11 February 2026 · ****Next review:**** 11 February 2027
****Classification:**** Internal — may be shared with customers under NDA

gs://attestor-505506-corporus/security/information-security-policy.txt

[3] company-and-security-programme-overview — Company and Security Programme Overview — relevance 0.67

Company and Security Programme Overview

****Document ID:**** KD-SEC-021 · ****Version:**** 4.2 · ****Owner:**** Marcus Oyelaran, CISO

****Approved:**** 6 February 2026 · ****Next review:**** 6 February 2027

****Maps to:**** SOC 2 CC1.1, CC1.2, CC2.1, CC2.3 · ISO 27001:2022 Clauses 4–5

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[4] personnel-security-and-training — 3. Acceptable use and policy acknowledgement — relevance 0.66

3. Acceptable use and policy acknowledgement

Personnel acknowledge the Acceptable Use Policy (KD-SEC-005) and this standard at onboarding and annually thereafter. Acknowledgement is tracked in Vanta; the 2025 annual cycle closed on 30 November 2025 at ****100%**** completion across 187 employees and 24 contractors.

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[5] personnel-security-and-training — Personnel Security and Security Training Programme — relevance 0.66

Personnel Security and Security Training Programme

****Document ID:**** KD-SEC-013 · ****Version:**** 2.1 · ****Owner:**** Sofia Brenner, Head of IT

****Approved:**** 22 January 2026 · ****Next review:**** 22 January 2027

****Maps to:**** SOC 2 CC1.1, CC1.4, CC2.1, CC6.2 · ISO 27001:2022 A.6.1, A.6.2, A.6.3, A.6.6

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

252. Do you have a documented business continuity plan?

engineering · Q252 · Vendor Security Review row 253

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (7)

[1] backup-restore-procedure — Backup and Restore Procedure — relevance 0.59

Backup and Restore Procedure

****Document ID:**** KD-ENG-004 · ****Version:**** 2.5 · ****Owner:**** Sofia Brenner, Head of IT

****Approved:**** 29 January 2026 · ****Maps to:**** SOC 2 A1.2 · ISO 27001:2022 A.8.13

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[2] cloud-exit-and-portability-plan — 8. Testing — relevance 0.57

8. Testing

The plan is exercised annually as a tabletop with the SRE team, the VP Engineering, and the CISO. The 19 November 2025 exercise identified two gaps — the SQS/SNS adapter was not in place, and the KMS re-encryption path was undocumented — and both were closed by 14 January 2026. The next exercise is scheduled for November 2026.

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[3] cloud-exit-and-portability-plan — Cloud Exit and Portability Plan — relevance 0.57

Cloud Exit and Portability Plan

****Document ID:**** KD-ENG-010 · ****Version:**** 1.7 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 30 January 2026 · ****Next review:**** 30 January 2027

****Maps to:**** SOC 2 A1.2, CC9.1 · ISO 27001:2022 A.5.19, A.5.21, A.5.30 · EBA/DORA-aligned

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[4] cloud-exit-and-portability-plan — 2. Exit triggers — relevance 0.57

2. Exit triggers
The plan would be invoked on: sustained material degradation of AWS service, a commercial breakdown or unacceptable pricing change, a regulatory instruction, or a security failure at the provider that could not be compensated for.

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[5] cloud-exit-and-portability-plan — 5. Customer-facing continuity during an exit — relevance 0.54

5. Customer-facing continuity during an exit
An exit would be executed instance by instance, with EU and US cut over separately, and **data residency commitments would be honoured throughout**: an EU tenant would move to an EU region of the target provider, never transiting a US region. Customers would be given a minimum of 90 days' notice of a planned provider change and would retain their export

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[6] backup-restore-procedure — 5. Tenant-scoped restore — relevance 0.54

5. Tenant-scoped restore
A single customer can be restored without affecting others, by restoring to an isolated account and exporting that tenant rows back. This was exercised once in production, on 22 September 2025, at a customer request following an erroneous bulk delete on their side. Time to complete was 5 hours 10 minutes.

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[7] cloud-exit-and-portability-plan — 1. Why this exists — relevance 0.52

1. Why this exists
Kestrel runs entirely on AWS. That is a concentration risk, recorded as `RISK-2025-0044` and **accepted** rather than mitigated by multi-cloud, on the reasoning that operating two clouds badly is worse than operating one well at this size. Accepting a risk obliges you to know what you would do if it materialised, which is what this document is. It is reviewed annually and was la

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

253. Provide the results of your most recent disaster recovery test.

engineering · Q253 · Vendor Security Review row 254

Kestrel Data conducts quarterly disaster recovery and restore tests involving full, real restores into an isolated account rather than simple backup-listing checks (`backup-restore-procedure`, Section 4. Test results, and Section 3. Restore procedure). The most recent test was executed in Q1 2026 on **17 January 2026**, yielding the following results: - **Outcome:** Pass - **Duration:** 2 hours 41 minutes - **Integrity Assertions:** 1,240 / 1,240 passed (validating row counts, referential integrity, tenant isolation invariants, and known-value spot checks) Previous recent quarterly tests include: - **Q4 2025 (11 October 2025):** Pass (Duration: 3h 02m; Assertions: 1,238 / 1,240 passed, with 2 known-stale fixtures corrected) - **Q3 2025 (19 July 2025):** Pass (Duration: 3h 20m; Assertions: 1,240 / 1,240 passed) - **Q2 2025 (12 April 2025):** Pass (Duration: 3h 55m; Assertions: 1,240 / 1,240 passed) The continued reduction in restore duration reflects the parallelisation of the integrity verification suite implemented in Q3 2025 (`backup-restore-procedure`, Section 4. Test results).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (10)

[1] backup-restore-procedure — 4. Test results — relevance 0.71

4. Test results
Restore is tested **quarterly**, and the test is a real restore, not a backup-listing check.

Quarter	Date	Duration	Assertions	Outcome
Q1 2026	17 Jan 2026	2h 41m	1,240 / 1,240	Pass
Q4 2025	11 Oct 2025	3h 02m	1,238 / 1,240	Pass, 2 known-stale fixtures corrected
Q3 2025	19 Jul 2025	3h 20m	1,240 / 1,240	Pass

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[2] backup-restore-procedure — 5. Tenant-scoped restore — relevance 0.63

5. Tenant-scoped restore

A single customer can be restored without affecting others, by restoring to an isolated account and exporting that tenant rows back. This was exercised once in production, on 22 September 2025, at a customer request following an erroneous bulk delete on their side. Time to complete was 5 hours 10 minutes.

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[3] backup-restore-procedure — 3. Restore procedure — relevance 0.63

3. Restore procedure

1. Declare the restore scope: point in time, and whether tenant-scoped or full.
2. Provision an isolated restore account from the Terraform module `restore-target`.
3. Restore the RDS snapshot or PITR target into the isolated account.
4. Run the integrity suite: 1,240 assertions covering row counts, referential integrity, tenant isolation invariants, and known-value spo

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[4] cloud-exit-and-portability-plan — 8. Testing — relevance 0.60

8. Testing

The plan is exercised annually as a tabletop with the SRE team, the VP Engineering, and the CISO. The 19 November 2025 exercise identified two gaps — the SQS/SNS adapter was not in place, and the KMS re-encryption path was undocumented — and both were closed by 14 January 2026. The next exercise is scheduled for November 2026.

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[5] backup-restore-procedure — Backup and Restore Procedure — relevance 0.57

Backup and Restore Procedure

Document ID: KD-ENG-004 · **Version:** 2.5 · **Owner:** Sofia Brenner, Head of IT
Approved: 29 January 2026 · **Maps to:** SOC 2 A1.2 · ISO 27001:2022 A.8.13

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[6] backup-restore-procedure — 1. What is backed up — relevance 0.57

1. What is backed up

| Asset | Method | Frequency | Retention |

|---|---|---|---|

| RDS PostgreSQL | Automated snapshots + WAL archiving (PITR) | Continuous | ****35 days**** |

| RDS logical dump | `pg\_dump` to S3, encrypted with a separate CMK | Daily 03:00 UTC | 90 days |

| S3 objects | Versioning + cross-region replication | Continuous | 90 days for non-current versions |

| Snowflake | Time Tr

gs://attestor-505506-corporus/engineering/backup-restore-procedure.txt

[7] cloud-exit-and-portability-plan — 4. Estimated exit timeline — relevance 0.49

4. Estimated exit timeline

The tabletop exercise produced these estimates, which are planning figures rather than commitments:

| Phase | Work | Estimate |

|---|---|---|

| 1 | Target selection, landing zone, network and identity foundation | 4–6 weeks |

| 2 | Terraform provider rewrite, CI/CD retargeting | 6–8 weeks |

| 3 | Data migration — Snowflake region move, PostgreSQL logical replication, ob

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[8] cloud-exit-and-portability-plan — 1. Why this exists — relevance 0.48

1. Why this exists

Kestrel runs entirely on AWS. That is a concentration risk, recorded as `RISK-2025-0044` and ****accepted**** rather than mitigated by multi-cloud, on the reasoning that operating two clouds badly is worse than operating one well at this size. Accepting a risk obliges you to know what you would do if it materialised, which is what this document is. It is reviewed annually and was la

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[9] cloud-exit-and-portability-plan — 2. Exit triggers — relevance 0.45

2. Exit triggers

The plan would be invoked on: sustained material degradation of AWS service, a commercial breakdown or unacceptable pricing change, a regulatory instruction, or a security failure at the provider that could not be compensated for.

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[10] cloud-exit-and-portability-plan — Cloud Exit and Portability Plan — relevance 0.45

Cloud Exit and Portability Plan

Document ID: KD-ENG-010 · **Version:** 1.7 · **Owner:** Dana Whitfield, VP Engineering

Approved: 30 January 2026 · **Next review:** 30 January 2027

Maps to: SOC 2 A1.2, CC9.1 · ISO 27001:2022 A.5.19, A.5.21, A.5.30 · EBA/DORA-aligned

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

254. Describe your security monitoring and alerting capability.

security · Q254 · Vendor Security Review row 255

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

255. Please confirm: Can a developer approve their own pull request?

engineering · Q255 · Vendor Security Review row 256

No, developers cannot approve their own pull requests. In accordance with Kestrel Data's SDLC Policy (Section 1, "Branching and review"), pull requests merging into the protected `main` branch require at least one approving review from an engineer other than the author, and self-approval is blocked at the platform level. Furthermore, administrator bypass of branch protection is disabled.

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (5)

[1] sdlc-policy — 1. Branching and review — relevance 0.61

1. Branching and review

`main` is protected and always releasable. All work happens on short-lived branches merged by pull request. `main` requires:

- At least **one approving review** from an engineer other than the author. Self-approval is blocked at the platform level.
- Two approvals for changes touching authentication, authorisation, tenant isolation, or cryptography. These paths are

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[2] sdlc-policy — 4. Security in the pipeline — relevance 0.58

4. Security in the pipeline

Static analysis (Semgrep, CodeQL), dependency scanning (Snyk), IaC scanning (Checkov), and secret scanning (GitLeaks pre-commit plus GitHub push protection) all run on every pull request. A Critical or High dependency finding blocks the merge.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[3] sdlc-policy — 5. Dependency policy — relevance 0.54

5. Dependency policy

New third-party dependencies require review against the Third-Party Library Policy (KD-ENG-008). Lockfiles are committed. Renovate opens automated upgrade pull requests weekly; security patches are auto-merged when CI is green and the change is a patch-level bump.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[4] sdlc-policy — 7. Separation of duties — relevance 0.54

7. Separation of duties

Engineers cannot deploy their own change to production without the automated pipeline: no human has the ability to push a container image to the production registry directly. The deployment role is held by the CI service identity, which authenticates through OIDC and holds no long-lived credentials.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[5] api-and-integration-standard — 9. Integration security review — relevance 0.51

9. Integration security review

A new first-party integration is reviewed against this standard before release, covering credential handling, scope minimisation, rate limiting, and audit event emission. The review is recorded in the pull request and is a required check on the `kd-api` repository.

gs://attestor-505506-corporus/engineering/api-and-integration-standard.txt

256. Are long-lived static cloud access keys permitted?

security · Q256 · Vendor Security Review row 257

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

257. Are you PCI DSS compliant, and at what level?

security · Q257 · Vendor Security Review row 258

PCI DSS compliance is not applicable to Kestrel Data because we do not store, process, or transmit cardholder data. All payment processing is delegated entirely to Stripe, Inc. (Information Security Policy, Section 3. Certifications and attestations).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] information-security-policy — 3. Certifications and attestations — relevance 0.65

3. Certifications and attestations

| Framework | Status | Evidence |

|---|---|---|

| SOC 2 Type II | Current | Report issued 14 March 2026 by Prescient Assurance LLP, covering 1 January – 31 December 2025. No exceptions noted. |

| ISO/IEC 27001:2022 | Certified | Certificate IS-2025-44817, issued by BSI on 22 September 2025, valid to 21 September 2028 |

| ISO/IEC 27701:2019 | Certified | Extension

gs://attestor-505506-corporus/security/information-security-policy.txt

[2] network-security-standard — Network Security Standard — relevance 0.61

Network Security Standard

Document ID: KD-SEC-016 · **Version:** 2.0 · **Owner:** Dana Whitfield, VP Engineering

Approved: 5 February 2026 · **Next review:** 5 February 2027

Maps to: SOC 2 CC6.6, CC6.7, CC7.1 · ISO 27001:2022 A.8.20, A.8.21, A.8.22, A.8.23

gs://attestor-505506-corporus/security/network-security-standard.txt

[3] company-and-security-programme-overview — Company and Security Programme Overview — relevance 0.60

Company and Security Programme Overview

Document ID: KD-SEC-021 · **Version:** 4.2 · **Owner:** Marcus Oyelaran, CISO

Approved: 6 February 2026 · **Next review:** 6 February 2027

Maps to: SOC 2 CC1.1, CC1.2, CC2.1, CC2.3 · ISO 27001:2022 Clauses 4–5

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[4] company-and-security-programme-overview — 8. How to obtain evidence — relevance 0.59

8. How to obtain evidence

The SOC 2 Type II report, the ISO 27001 certificate, the penetration test executive summary, and the standard DPA are available to customers and prospects under NDA through the account team, usually within two business days. The certificate and the trust page are available without an NDA.

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[5] encryption-standard — Encryption Standard — relevance 0.59

Encryption Standard

Document ID: KD-SEC-003 · **Version:** 2.4 · **Owner:** Marcus Oyelaran, CISO

Approved: 8 January 2026 · **Next review:** 8 January 2027

Maps to: SOC 2 CC6.7 · ISO 27001:2022 A.8.24 · GDPR Art. 32(1)(a)

gs://attestor-505506-corporus/security/encryption-standard.txt

258. Please confirm: Do you use a VPN for internal application access, or a zero-trust approach?

security · Q258 · Vendor Security Review row 259

Kestrel Data does not use a traditional VPN. Internal application access is managed under a zero-trust model mediated by Cloudflare Access, where network position confers no access privileges (`network-security-standard`, Section 6, "Internal application access"). Every request requires Okta identity verification and device posture evaluation, ensuring that connecting endpoints have disk encryption enabled, run a current operating system, and are enrolled in mobile device management (`network-security-standard`, Section 6, "Internal application access"; `access-control-standard`, Section 10, "Remote access").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] network-security-standard — 6. Internal application access — relevance 0.73

6. Internal application access

There is no traditional VPN. Internal applications are published through Cloudflare Access with device posture and Okta identity required on every request. This is a zero-trust model in the practical sense: there is no network position that grants access, and being "inside" confers nothing.

gs://attestor-505506-corporus/security/network-security-standard.txt

[2] access-control-standard — 10. Remote access — relevance 0.57

10. Remote access

There is no traditional VPN. Access to internal applications is mediated by Cloudflare Access with device posture checks requiring disk encryption, a current OS, and an enrolled MDM profile (Kandji for macOS, 163 devices as of 1 February 2026).

gs://attestor-505506-corporus/security/access-control-standard.txt

[3] access-control-standard — 3. Role-based access — relevance 0.54

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix (`SEC-GOV/access-matrix`), which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is just-in-time.

gs://attestor-505506-corporus/security/access-control-standard.txt

[4] network-security-standard — 10. Testing — relevance 0.54

10. Testing

Network controls are exercised annually by the external penetration test. The February 2026 test (Include Security, INSEC-2026-0219) attempted lateral movement from a compromised application container and did not achieve it; the finding raised was the rate limiting gap on the password reset endpoint, remediated on 27 February 2026.

gs://attestor-505506-corporus/security/network-security-standard.txt

[5] network-security-standard — 8. Wireless — relevance 0.54

8. Wireless

The Austin office wireless network is WPA3-Enterprise with certificate-based authentication for the corporate SSID and a fully segregated guest SSID that routes straight to the internet. Neither network grants any access to production; production is reached the same way from the office as from a coffee shop, which is deliberate.

gs://attestor-505506-corporus/security/network-security-standard.txt

259. Have you completed any Data Protection Impact Assessments?

legal · Q259 · Vendor Security Review row 260

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] dpia-register — Data Protection Impact Assessment Register — relevance 0.70

Data Protection Impact Assessment Register

Document ID: KD-LEG-011 · **Version:** 1.9 · **Owner:** Priya Raghunathan, DPO

Approved: 16 January 2026 · **Next review:** 16 January 2027

Maps to: GDPR Articles 35, 36, 9, 8, 22

gs://attestor-505506-corporus/legal/dpia-register.txt

[2] transfer-impact-assessment — Transfer Impact Assessment — relevance 0.67

Transfer Impact Assessment

Document ID: KD-LEG-010 · **Version:** 2.1 · **Owner:** Priya Raghunathan, DPO

Approved: 9 January 2026 · **Next review:** 9 January 2027

Maps to: GDPR Articles 44–49 · EDPB Recommendations 01/2020 · Schrems II (C-311/18)

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

[3] dpia-register — 2. Completed assessments — relevance 0.67

2. Completed assessments

Four DPIAs have been completed, all reviewed and signed off by the DPO:

ID	Subject	Completed	Residual risk	Outcome
----	---------	-----------	---------------	---------

---	---	---	---	---
-----	-----	-----	-----	-----

DPIA-2024-01	Product telemetry collection and retention	14 May 2024	Low	Proceed. Event allowlist introduced; free-text fields excluded; retention set to 13 months
--------------	--	-------------	-----	--

DPIA-2025-01	EU instance and residency arc			
--------------	-------------------------------	--	--	--

gs://attestor-505506-corporus/legal/dpia-register.txt

[4] gdpr-records-of-processing — Data Protection Impact Assessments — relevance 0.66

Data Protection Impact Assessments

One DPIA is on file, covering the introduction of the anomaly detection feature

(`LEG-GOV/dpia-2025-01`, completed 8 September 2025). Conclusion: residual risk low, no prior consultation with the supervisory authority required.

gs://attestor-505506-corporus/legal/gdpr-records-of-processing.txt

[5] dpia-register — 1. When Kestrel performs a DPIA — relevance 0.66

1. When Kestrel performs a DPIA

A DPIA is performed where processing is likely to result in a high risk to data subjects, and in every case triggered by the Article 35(3) list or the lead supervisory authority's own list. In practice Kestrel triggers an assessment for: a new machine learning feature processing customer data, a new sub-processor receiving customer content, a change to the residency

gs://attestor-505506-corporus/legal/dpia-register.txt

260. Do you have a documented legal hold process?

legal · Q260 · Vendor Security Review row 261

Yes, Kestrel operates a documented legal hold process owned by the General Counsel (`legal-and-regulatory-history`, §6. Legal hold; `data-retention-schedule`, §5. Legal hold). Upon becoming aware of reasonably anticipated litigation or an investigation, the General Counsel issues a written hold notice that identifies custodians and data sources. Ordinary retention and deletion schedules are suspended for the identified data within Google Vault and by disabling the relevant retention jobs. Legal holds are recorded in `LEG-GOV/holds` (with scope, issuing date, and release date), reviewed quarterly, and formally released in writing (`legal-and-regulatory-history`, §6. Legal hold; `data-retention-schedule`, §5. Legal hold). A legal hold overrides standard retention schedules, and where a hold conflicts with a customer's deletion instruction, Kestrel notifies the customer that a hold applies and explains why (`legal-and-regulatory-history`, §6. Legal hold).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] legal-and-regulatory-history — 6. Legal hold — relevance 0.68

6. Legal hold

Kestrel operates a documented legal hold process, owned by the General Counsel. On becoming aware of reasonably anticipated litigation or an investigation, the General Counsel issues a written hold notice identifying custodians and data sources, and suspension of the ordinary retention schedule is applied in Google Vault and by disabling the relevant retention jobs. Holds are reviewed

gs://attestor-505506-corpus/legal/legal-and-regulatory-history.txt

[2] data-retention-schedule — 5. Legal hold — relevance 0.65

5. Legal hold

A legal hold issued by the General Counsel suspends deletion for the identified data. Holds are recorded in `LEG-GOV/holds` with scope, issuing date, and release date. Two holds were in force during 2025, both released before year end.

gs://attestor-505506-corpus/legal/data-retention-schedule.txt

[3] data-subject-rights-procedure — Data Subject Rights Procedure — relevance 0.60

Data Subject Rights Procedure

Document ID: KD-LEG-007 · **Version:** 2.3 · **Owner:** Priya Raghunathan, DPO
Approved: 20 January 2026 · **Next review:** 20 January 2027
Maps to: GDPR Articles 12, 15–22, 28(3)(e) · CCPA/CPRA §1798.100–130

gs://attestor-505506-corpus/legal/data-subject-rights-procedure.txt

[4] data-retention-schedule — Data Retention Schedule — relevance 0.59

Data Retention Schedule

Document ID: KD-LEG-004 · **Version:** 3.2 · **Owner:** Priya Raghunathan, DPO
Approved: 15 January 2026 · **Next review:** 15 January 2027
Maps to: GDPR Art. 5(1)(e) · SOC 2 C1.2 · ISO 27001:2022 A.5.33, A.8.10

gs://attestor-505506-corpus/legal/data-retention-schedule.txt

[5] government-requests-and-transparency-report — 5. Emergency disclosure requests — relevance 0.59

5. Emergency disclosure requests

An emergency request citing an imminent risk to life is escalated to the General Counsel immediately, at any hour, through the `legal-oncall` PagerDuty rotation. Disclosure in those circumstances is limited to what is necessary to address the emergency, is documented in the register, and the customer is notified afterwards unless prohibited. No emergency request has

gs://attestor-505506-corpus/legal/government-requests-and-transparency-report.txt

261. Please confirm: Do you retain an external incident response firm?

security · Q261 · Vendor Security Review row 262

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

262. What is your median time to triage a security alert?

security · Q262 · Vendor Security Review row 263

Across the 41 security events recorded in 2025, Kestrel Data's median time to triage was 6 minutes ('incident-response-runbook', Section 3, "Lifecycle"). Our operational triage target is 15 minutes from alert to severity assignment for SEV1 and SEV2 incidents, measured from PagerDuty acknowledgement ('incident-response-runbook', Section 3, "Lifecycle").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] incident-response-runbook — 3. Lifecycle — relevance 0.70

3. Lifecycle

Detect, triage, contain, eradicate, recover, learn.

Detection sources are Datadog Security Monitoring, AWS GuardDuty, AWS Security Hub, Okta ThreatInsight, Snyk, customer reports to `security@kestreldata.com`, and the disclosure address published at `kestreldata.com/.well-known/security.txt`.

Triage target is 15 minutes from alert to severity assignment for SEV1 and SEV2, meas

gs://attestor-505506-corpus/security/incident-response-runbook.txt

[2] vulnerability-management-policy — 1. Remediation SLAs — relevance 0.66

1. Remediation SLAs

Severity is assigned from CVSS v3.1 base score, adjusted for exploitability and exposure. Internet-facing findings are escalated one level.

Severity	CVSS	Remediation SLA	Measured 2025 compliance
---	---	---	---
Critical	9.0-10.0	**7 days**	100% (11 of 11)
High	7.0-8.9	**30 days**	96% (74 of 77)
Medium	4.0-6.9	**90 days**	91%

gs://attestor-505506-corpus/security/vulnerability-management-policy.txt

[3] incident-response-runbook — 1. Severity definitions — relevance 0.65

1. Severity definitions

Sev	Definition	Page	Exec notify
-----	------------	------	-------------

---	---	---	---
-----	-----	-----	-----

SEV1	Confirmed unauthorised access to customer production data, or full platform outage	Immediate, 24/7	CEO + CISO within 30 min
----------	--	-----------------	--------------------------

SEV2	Suspected compromise, partial outage affecting more than 10% of tenants, or confirmed data integrity fault	Immediate, 24/7	CISO within 1 hour
----------	--	-----------------	--------------------

**SEV3

gs://attestor-505506-corpus/security/incident-response-runbook.txt

[4] logging-monitoring-standard — 4. Alerting — relevance 0.63

4. Alerting

Detections run in Datadog Security Monitoring. Alert routing is by severity through PagerDuty. Current detection coverage includes impossible-travel sign-ins, MFA fatigue patterns, IAM policy changes granting broad permissions, disabling of CloudTrail or GuardDuty, unusual Snowflake export volume, and break-glass account use.

Alert quality is reviewed monthly. Alerts with a false

gs://attestor-505506-corpus/security/logging-monitoring-standard.txt

[5] incident-response-runbook — 8. Post-incident review — relevance 0.60

8. Post-incident review

Every SEV1 and SEV2 requires a blameless post-incident review within 5 business days, published internally, with action items tracked to closure in Jira. Reviews are shared with affected customers on request.

263. For each applicable system: Do you offer a single-tenant or dedicated instance deployment?

engineering · Q263 · Vendor Security Review row 264

Kestrel Insight is a multi-tenant platform with logical isolation. We do not offer per-customer infrastructure, single-tenant deployments, or customer-VPC deployment options ('infrastructure-architecture-overview', "5. Tenant isolation"). Logical tenant isolation is enforced across three layers: - **Database:** PostgreSQL row-level security policies keyed on `tenant\_id` are applied at the connection level via authenticated session variables, ensuring no application query can bypass them ('infrastructure-architecture-overview', "5. Tenant isolation"). - **Application:** Every request carries a validated tenant claim, and the repository base class enforces that the data access layer rejects any query without a tenant predicate ('infrastructure-architecture-overview', "5. Tenant isolation"). - **Storage:** S3 object keys are prefixed by tenant, and AWS IAM policies restrict access strictly by prefix ('infrastructure-architecture-overview', "5. Tenant isolation").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] infrastructure-architecture-overview — 5. Tenant isolation — relevance 0.63

5. Tenant isolation

Kestrel Insight is **multi-tenant** with logical isolation. There is no per-customer infrastructure, no single-tenant deployment option, and no customer-VPC option.

Isolation is enforced at three layers:

1. **Database** - PostgreSQL row-level security policies keyed on `tenant\_id`, applied at the connection level from an authenticated session variable. No application

gs://attestor-505506-corpus/engineering/infrastructure-architecture-overview.txt

[2] infrastructure-architecture-overview — 1. Cloud footprint — relevance 0.61

1. Cloud footprint

Kestrel runs on **Amazon Web Services**. There are two independent production instances:

Instance	Region	Serves
----------	--------	--------

---	---	---
-----	-----	-----

US	`us-east-1` (3 AZs)	North America, and customers with no residency requirement
----	---------------------	--

EU	`eu-west-1` (3 AZs)	EEA, UK, and Swiss customers electing EU residency
----	---------------------	--

Backup replication targets `us-west-2` and `eu-central-1` respecti

gs://attestor-505506-corpus/engineering/infrastructure-architecture-overview.txt

[3] infrastructure-architecture-overview — 3. Compute — relevance 0.59

3. Compute

Amazon EKS (Kubernetes 1.31) with managed node groups spanning three availability zones. Workloads run as containers built from distroless base images, as non-root, with read-only root filesystems and dropped Linux capabilities. Pod Security Standards are enforced at the `restricted` level.

Node images are immutable; nodes are recycled with a maximum age of 30 days rather than pa

gs://attestor-505506-corpus/engineering/infrastructure-architecture-overview.txt

[4] infrastructure-architecture-overview — 6. Network — relevance 0.57

6. Network

Private subnets for all compute and data. No public IP addresses on workload instances. Ingress is exclusively through Cloudflare, then an AWS Application Load Balancer, then the Istio ingress gateway. Egress is through NAT gateways with an allowlist for known destinations.

Security groups are managed in Terraform and default-deny. There are no `0.0.0.0/0` ingress rules in produc

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[5] service-operations-and-support — 8. Capacity and performance — relevance 0.56

8. Capacity and performance

Capacity is reviewed monthly against a 90-day forecast. Autoscaling handles ordinary variation; the review exists for the changes autoscaling cannot absorb, such as a large tenant onboarding. Two capacity increases were made ahead of demand in 2025, neither triggered by a saturation alert.

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

264. Do you perform background checks on all personnel before their start date?

security · Q264 · Vendor Security Review row 265

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] personnel-security-and-training — 1. Pre-employment screening — relevance 0.65

1. Pre-employment screening

Every employee and every contractor is background screened before their start date. No system access — including email — is provisioned until the check clears; Okta Lifecycle Management is gated on the Rippling "screening cleared" attribute, so this is enforced by the provisioning pipeline rather than by a checklist.

Screening is performed by Checkr and covers, to the

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[2] information-security-policy — 6. Personnel security — relevance 0.58

6. Personnel security

All employees and contractors undergo background screening appropriate to jurisdiction before their start date, conducted by Checkr. Screening covers identity verification, right to work, criminal records where lawful, and employment history for the preceding seven years.

Security awareness training is delivered through Curricula at onboarding and annually thereafter. Comple

gs://attestor-505506-corporus/security/information-security-policy.txt

[3] access-control-standard — 6. Joiners, movers, leavers — relevance 0.56

6. Joiners, movers, leavers

Joiners are provisioned via Okta Lifecycle Management from Rippling (HRIS); no access is granted before the background check clears. Movers have entitlements recalculated on role change, with the previous role revoked within 1 business day. Leavers have all access revoked automatically on the HRIS termination event: the target is 1 hour, and the measured median for

gs://attestor-505506-corporus/security/access-control-standard.txt

[4] information-security-policy — 11. Enforcement — relevance 0.56

11. Enforcement

Violation of this policy may result in disciplinary action up to and including termination of employment or contract, and referral to law enforcement where warranted.

Kestrel Data, Inc. · 1401 Lavaca Street, Suite 210, Austin, TX 78701 · Delaware C-corporation, incorporated 2019

gs://attestor-505506-corporus/security/information-security-policy.txt

[5] personnel-security-and-training — 2. Confidentiality obligations — relevance 0.55

2. Confidentiality obligations

All personnel sign a confidentiality agreement as a condition of employment or

engagement. **The confidentiality obligation survives termination indefinitely for customer data and for five years for other Kestrel confidential information.** Contractors sign the same obligation through their engagement contract, and the obligation flows down to any of their own person

gs://attestor-505506-corpus/security/personnel-security-and-training.txt

265. Can customers retrieve their own audit logs?

security · Q265 · Vendor Security Review row 266

Yes. Enterprise-tier customers can retrieve tenant-scoped audit events for their own organization through the Audit API (`GET /v2/audit/events`), covering the previous 365 days. Kestrel Data does not directly expose its internal infrastructure logs to customers, but relevant log extracts are provided upon request during incident response (logging-monitoring-standard, Section 6. Customer access to logs).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] logging-monitoring-standard — 6. Customer access to logs — relevance 0.73

6. Customer access to logs

Enterprise-tier customers can retrieve tenant-scoped audit events for their own organisation through the Audit API (`GET /v2/audit/events`), covering the previous 365 days. Kestrel does not expose its own infrastructure logs to customers; relevant extracts are provided during incident response on request.

gs://attestor-505506-corpus/security/logging-monitoring-standard.txt

[2] logging-monitoring-standard — 1. What is logged — relevance 0.63

1. What is logged

- **Authentication** - every Okta event: sign-in success and failure, MFA challenge, factor enrolment, admin action.
- **Authorisation** - every JIT production elevation, approval, and expiry.
- **Data access** - all queries against customer data in Snowflake, captured via `ACCESS\_HISTORY`, including the querying identity and the objects touched.
- **Infrastructure** - A

gs://attestor-505506-corpus/security/logging-monitoring-standard.txt

[3] cloud-security-posture-standard — 8. Logging and evidence — relevance 0.61

8. Logging and evidence

CloudTrail (all regions, all accounts), VPC flow logs, GuardDuty findings, and Config history are delivered to a dedicated `kd-security` account that no engineering role can write to, with object lock set to 400 days. This is the arrangement that makes the audit trail defensible: the accounts that generate the evidence cannot alter it.

gs://attestor-505506-corpus/security/cloud-security-posture-standard.txt

[4] logging-monitoring-standard — 3. Tamper resistance — relevance 0.60

3. Tamper resistance

The security archive bucket uses S3 Object Lock in **compliance mode**, which cannot be disabled or shortened by any principal including the AWS account root. CloudTrail log file integrity validation is enabled. The archive account is a separate AWS account with no human standing access; writes arrive only through the organisation trail.

gs://attestor-505506-corpus/security/logging-monitoring-standard.txt

[5] logging-monitoring-standard — 2. Retention — relevance 0.60

2. Retention

| Log class | Hot (searchable) | Archive | Total |

|---|---|---|---|

| Security and audit (CloudTrail, Okta) | 90 days in Datadog | 7 years in S3 Glacier | **7 years** |

| Application | 30 days in Datadog | 1 year in S3 | 1 year |

| Snowflake ACCESS_HISTORY | 365 days native | 7 years in S3 | 7 years |

| VPC Flow / WAF | 30 days | 1 year | 1 year |

gs://attestor-505506-corporus/security/logging-monitoring-standard.txt

266. How do you support erasure requests?

legal · Q266 · Vendor Security Review row 267

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

267. Describe your secure development lifecycle. If not, describe compensating controls.

engineering · Q267 · Vendor Security Review row 268

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] sdlc-policy — Secure Software Development Lifecycle Policy — relevance 0.69

Secure Software Development Lifecycle Policy

Document ID: KD-ENG-001 · **Version:** 4.1 · **Owner:** Dana Whitfield, VP Engineering

Approved: 20 January 2026 · **Next review:** 20 January 2027

Maps to: SOC 2 CC8.1 · ISO 27001:2022 A.8.25-A.8.31

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[2] sdlc-policy — 4. Security in the pipeline — relevance 0.66

4. Security in the pipeline

Static analysis (Semgrep, CodeQL), dependency scanning (Snyk), IaC scanning (Checkov), and secret scanning (GitLeaks pre-commit plus GitHub push protection) all run on every pull request. A Critical or High dependency finding blocks the merge.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[3] sdlc-policy — 1. Branching and review — relevance 0.62

1. Branching and review

`main` is protected and always releasable. All work happens on short-lived branches merged by pull request. `main` requires:

- At least **one approving review** from a engineer other than the author. Self-approval is blocked at the platform level.

- Two approvals for changes touching authentication, authorisation, tenant isolation, or cryptography. These paths ar

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[4] sdlc-policy — 7. Separation of duties — relevance 0.61

7. Separation of duties

Engineers cannot deploy their own change to production without the automated pipeline: no human has the ability to push a container image to the production registry directly. The deployment role is held by the CI service identity, which authenticates through OIDC and holds no long-lived credentials.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[5] secrets-management-standard — Secrets Management Standard — relevance 0.58

Secrets Management Standard

Document ID: KD-ENG-006 · **Version:** 2.1 · **Owner:** Dana Whitfield, VP Engineering

Approved: 22 January 2026 · **Maps to:** SOC 2 CC6.1 · ISO 27001:2022 A.8.24

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

268. Do you incorporate the UK International Data Transfer Addendum?

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

269. Provide your most recent SOC 2 Type II report.

security · Q269 · Vendor Security Review row 270

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

270. Is peer review mandatory for all code changes?

engineering · Q270 · Vendor Security Review row 271

Yes, peer review is mandatory for all code changes. All work is developed on short-lived branches and merged into the protected `main` branch via pull request. Platform-level branch protection rules enforce that every pull request must receive at least one approving review from an engineer other than the author, and self-approval is blocked at the platform level (`sdlc-policy`, Section 1. "Branching and review"). Changes touching authentication, authorisation, tenant isolation, or cryptography require two approving reviews enforced via `CODEOWNERS` (`sdlc-policy`, Section 1. "Branching and review"). Administrator bypass of branch protection is disabled, and even emergency changes are strictly prohibited from bypassing code review or continuous integration checks (`sdlc-policy`, Section 1. "Branching and review"; `change-management-procedure`, Section 3. "Emergency changes"). In 2025, 100% of all 3,847 merged pull requests carried at least one approving review (`sdlc-policy`, Section 1. "Branching and review").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] sdlc-policy — 1. Branching and review — relevance 0.66

1. Branching and review

`main` is protected and always releasable. All work happens on short-lived branches merged by pull request. `main` requires:

- At least **one approving review** from an engineer other than the author. Self-approval is blocked at the platform level.
- Two approvals for changes touching authentication, authorisation, tenant isolation, or cryptography. These paths ar

gs://attestor-505506-corpus/engineering/sdlc-policy.txt

[2] change-management-procedure — 3. Emergency changes — relevance 0.66

3. Emergency changes

An Emergency change may bypass the Change Advisory step but never bypasses code review or CI. The Incident Commander authorises it, and a retrospective record is filed within one business day covering what changed, why the normal path was bypassed, and whether the change should be reworked.

All 9 Emergency changes in 2025 have completed retrospectives on file.

gs://attestor-505506-corpus/engineering/change-management-procedure.txt

[3] change-management-procedure — 2. Normal change requirements — relevance 0.61

2. Normal change requirements

A Normal change additionally requires a written rollback plan, a customer-impact assessment, and sign-off from the Change Advisory group (VP Engineering plus one SRE). Schema migrations must be backward compatible for at least one release, so that a rollback does not require a data migration.

gs://attestor-505506-corpus/engineering/change-management-procedure.txt

[4] change-management-procedure — 1. Change classes — relevance 0.61

1. Change classes
| Class | Definition | Approval | Example |
|---|---|---|---|
| **Standard** | Pre-approved, low risk, automated | PR review + CI | Application code, config change through IaC |
| **Normal** | Material risk or customer-visible | PR review + Change Advisory sign-off | Schema migration, dependency major version |
| **Emergency** | Fixing an active SEV1/SEV2 | Retrospective with

gs://attestor-505506-corporus/engineering/change-management-procedure.txt

[5] sdlc-policy — 4. Security in the pipeline — relevance 0.61

4. Security in the pipeline
Static analysis (Semgrep, CodeQL), dependency scanning (Snyk), IaC scanning (Checkov), and secret scanning (Gitleaks pre-commit plus GitHub push protection) all run on every pull request. A Critical or High dependency finding blocks the merge.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

271. What are your support response targets by severity?

engineering · Q271 · Vendor Security Review row 272

According to the **Service Operations, Maintenance and Support** policy (*service-operations-and-support*, §4), support severity levels and first-response targets are defined as follows: ** **Sev 1 (Production down, or data loss affecting the customer):** First response target is **30 minutes** (available 24×7), with an update cadence of hourly. * **Sev 2 (Major feature unusable, no workaround):** First response target is **2 business hours***, with a daily update cadence. * **Sev 3 (Degraded or impaired function with a workaround):** First response target is **1 business day***, with updates provided every 3 business days. * **Sev 4 (Question, documentation, or enhancement request):** First response target is **2 business days***, with a weekly update cadence. These commitments represent first-response targets rather than resolution times. Additionally, standard SLA targets referenced under the **Availability SLA** policy (*availability-sla*, §6) define general first-response targets as 1 hour for Urgent (production down, 24×7 coverage), 4 business hours for High (major feature impaired), 1 business day for Normal, and 3 business days for Low, with business hours operating 08:00–18:00 US Central, Monday through Friday (excluding US public holidays).*

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] service-operations-and-support — 4. Support severity definitions and response targets — relevance 0.71

4. Support severity definitions and response targets
| Severity | Definition | First response | Update cadence |
|---|---|---|---|
| Sev 1 | Production down, or data loss affecting the customer | ****30 minutes****, 24×7 | Hourly |
| Sev 2 | Major feature unusable, no workaround | 2 business hours | Daily |
| Sev 3 | Degraded or impaired function with a workaround | 1 business day | Every 3 business d

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[2] availability-sla — 6. Support response targets — relevance 0.67

6. Support response targets
Support targets are separate from this SLA and are not credit-bearing.

Severity	First response	Coverage
Urgent (production down)	1 hour	24 x 7
High (major feature impaired)	4 business hours	Business hours
Normal	1 business day	Business hours
Low	3 business days	Business hours

Business hours are 08:00-18:00

gs://attestor-505506-corporus/engineering/availability-sla.txt

[3] service-operations-and-support — 7. Incident communication to customers — relevance 0.60

7. Incident communication to customers
Customer-facing incident communication is owned by the incident commander and follows the commitments in KD-SEC-008 §4. In practice: status page inside 15 minutes, direct email to

affected tenant administrators inside 60 minutes for a Sev 1, and a written post-incident review within 5 business days for any Sev 1 or Sev 2, shared with affected customers on req

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[4] service-operations-and-support — Service Operations, Maintenance and Support — relevance 0.58

Service Operations, Maintenance and Support

Document ID: KD-ENG-009 · **Version:** 2.2 · **Owner:** Dana Whitfield, VP Engineering

Approved: 23 January 2026 · **Next review:** 23 January 2027

Maps to: SOC 2 A1.1, A1.2, CC7.3, CC8.1 · ISO 27001:2022 A.5.29, A.8.6, A.8.32

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[5] service-operations-and-support — 8. Capacity and performance — relevance 0.55

8. Capacity and performance

Capacity is reviewed monthly against a 90-day forecast. Autoscaling handles ordinary variation; the review exists for the changes autoscaling cannot absorb, such as a large tenant onboarding. Two capacity increases were made ahead of demand in 2025, neither triggered by a saturation alert.

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

272. For each applicable system: Are passwords subject to a forced rotation schedule?

security · Q272 · Vendor Security Review row 273

Passwords are not subject to a periodic forced rotation schedule across Kestrel Data systems, in alignment with NIST SP 800-63B guidelines. Instead, password rotation is strictly required and forced upon any evidence of compromise ('access-control-standard', Section 9 "Password requirements"). Where passwords are used, they must have a minimum length of 14 characters and are validated against the Have I Been Pwned breached-password corpus at the time of creation ('access-control-standard', Section 9 "Password requirements"). Furthermore, all systems authenticate centrally through Okta, with local accounts prohibited except for two documented break-glass accounts held in a sealed vault ('access-control-standard', Section 1 "Identity provider").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by SecurityAgent

Evidence (5)

[1] access-control-standard — 9. Password requirements — relevance 0.66

9. Password requirements

Where a password is used, minimum length is 14 characters, checked against the Have I Been Pwned breached-password corpus at set time. Rotation is not forced on a schedule, in line with NIST SP 800-63B guidance; rotation is forced on evidence of compromise.

gs://attestor-505506-corporus/security/access-control-standard.txt

[2] access-control-standard — 2. Multi-factor authentication — relevance 0.58

2. Multi-factor authentication

Hardware-backed MFA (WebAuthn / FIDO2, YubiKey 5 series) is mandatory for every human account. SMS and TOTP were removed as acceptable factors on 30 June 2025 following the RISK-2025-0031 treatment plan. Coverage is 100% of the 187 active employee accounts and 100% of the 24 active contractor accounts, verified continuously by Vanta control AC-07.

gs://attestor-505506-corporus/security/access-control-standard.txt

[3] access-control-standard — 1. Identity provider — relevance 0.57

1. Identity provider

All Kestrel Data systems authenticate through Okta (tenant `kestreldata.okta.com`). Local accounts on production systems are prohibited except for two documented break-glass accounts held in a sealed 1Password vault, whose use triggers a PagerDuty alert to the CISO. Both break-glass credentials were last rotated on 3 January 2026 and last used on 14 August 2025 during the

gs://attestor-505506-corporus/security/access-control-standard.txt

[4] access-control-standard — 6. Joiners, movers, leavers — relevance 0.55

6. Joiners, movers, leavers

Joiners are provisioned via Okta Lifecycle Management from Rippling (HRIS); no access is granted before the background check clears. Movers have entitlements recalculated on role change, with the previous role revoked within 1 business day. Leavers have all access revoked automatically on the HRIS termination event: the target is 1 hour, and the measured median for

gs://attestor-505506-corporus/security/access-control-standard.txt

[5] access-control-standard — 3. Role-based access — relevance 0.55

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix (`SEC-GOV/access-matrix`), which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is just-in-time.

gs://attestor-505506-corporus/security/access-control-standard.txt

273. Do you address Swiss FADP requirements?

legal · Q273 · Vendor Security Review row 274

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

274. Do you conduct post-incident reviews, and are they shared with customers? Provide supporting evidence.

security · Q274 · Vendor Security Review row 275

Yes, Kestrel Data conducts blameless post-incident reviews for every SEV1 and SEV2 incident within five business days. These reviews are published internally, with identified action items tracked to closure in Jira, and are shared with affected customers upon request. **Supporting Evidence:** **Document:** `incident-response-runbook` **Section:** `8. Post-incident review`

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] incident-response-runbook — 8. Post-incident review — relevance 0.70

8. Post-incident review

Every SEV1 and SEV2 requires a blameless post-incident review within 5 business days, published internally, with action items tracked to closure in Jira. Reviews are shared with affected customers on request.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[2] incident-response-runbook — 6. Evidence handling — relevance 0.63

6. Evidence handling

The IC directs preservation before remediation wherever containment allows. EBS snapshots, memory captures where feasible, and relevant log ranges are exported to a dedicated forensics S3 bucket with Object Lock in compliance mode, retention 1 year. Chain of custody is recorded in the incident ticket.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[3] incident-response-runbook — 2. Roles — relevance 0.62

2. Roles

The Incident Commander owns the response and is deliberately not the person fixing the problem; ICs are drawn from a rota of 6 trained staff. The Communications Lead owns customer, internal, and regulator messaging. A Scribe maintains the timeline for every SEV1 and SEV2. Subject matter experts are pulled in as needed.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[4] incident-response-runbook — Incident Response Runbook — relevance 0.59

Incident Response Runbook

****Document ID:**** KD-SEC-005 · ****Version:**** 5.0 · ****Owner:**** Marcus Oyelaran, CISO

****Approved:**** 27 January 2026 · ****Last exercised:**** 3 December 2025 (tabletop)

****Maps to:**** SOC 2 CC7.3, CC7.4, CC7.5 · ISO 27001:2022 A.5.24-A.5.28 · GDPR Art. 33, 34

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[5] incident-response-runbook — 9. 2025 incident summary — relevance 0.58

9. 2025 incident summary

41 security events recorded. Zero SEV1. Two SEV2, both resolved without customer data exposure:

- ****INC-2025-0044**** (14 August 2025) - RDS failover fault causing 41 minutes of degraded service. No data loss; RPO and RTO both met. Root cause was a misconfigured connection pool ceiling.

- ****INC-2025-0071**** (2 November 2025) - a contractor account remained active f

gs://attestor-505506-corporus/security/incident-response-runbook.txt

275. Are all company devices centrally managed and encrypted?

security · Q275 · Vendor Security Review row 276

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

276. How many internal forks of third-party libraries do you maintain?

engineering · Q276 · Vendor Security Review row 277

Kestrel currently maintains zero internal forks of third-party libraries by deliberate policy. Forking a third-party library requires VP of Engineering approval and establishes an obligation to manually track upstream security advisories (‘third-party-library-policy’, Section 7: “Internal forks”).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] third-party-library-policy — 7. Internal forks — relevance 0.73

7. Internal forks

Forking a third-party library requires VP Engineering approval and creates an obligation to track upstream security advisories manually. Kestrel currently maintains ****zero**** internal forks, deliberately.

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[2] sdlc-policy — 5. Dependency policy — relevance 0.63

5. Dependency policy

New third-party dependencies require review against the Third-Party Library Policy (KD-ENG-008). Lockfiles are committed. Renovate opens automated upgrade pull requests weekly; security patches are auto-merged when CI is green and the change is a patch-level bump.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[3] third-party-library-policy — 1. Adding a dependency — relevance 0.63

1. Adding a dependency

A new direct dependency requires a pull request that documents:

1. Why an existing dependency or the standard library is insufficient.
2. The licence, checked against the allowlist below.
3. Maintenance signal: last release date, open critical issues, number of maintainers.
4. Transitive dependency count added.

Review is by any engineer other than the author. Depend

gs://attestor-505506-corporis/engineering/third-party-library-policy.txt

[4] third-party-library-policy — 6. Unmaintained dependencies — relevance 0.60

6. Unmaintained dependencies

A dependency with no release in 24 months and no active maintainer is flagged for replacement. Three such dependencies were identified in the January 2026 review, all scheduled for replacement by Q3 2026.

gs://attestor-505506-corporis/engineering/third-party-library-policy.txt

[5] third-party-library-policy — 5. Upgrades — relevance 0.59

5. Upgrades

Renovate opens upgrade pull requests weekly. Patch-level security upgrades auto-merge when CI is green. Minor and major upgrades are reviewed manually.

An explicit goal is to stay within one minor version of current for all direct dependencies. As of 1 February 2026, 94% of direct dependencies met that target; the 6% that did not are tracked with named owners.

gs://attestor-505506-corporis/engineering/third-party-library-policy.txt

277. Do you offer customer-managed encryption keys?

engineering · Q277 · Vendor Security Review row 278

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (10)

[1] backup-restore-procedure — 2. Encryption and location — relevance 0.66

2. Encryption and location

All backups are encrypted with AES-256 using AWS KMS. The daily logical dump uses a **separate CMK** from the primary database, so that compromise of the primary key does not compromise the backups.

Cross-region replication stays inside the residency boundary: `us-east-1` replicates to `us-west-2`, `eu-west-1` replicates to `eu-central-1`. EU customer data never le

gs://attestor-505506-corporis/engineering/backup-restore-procedure.txt

[2] data-flow-and-shared-responsibility — 1. Data flow, end to end — relevance 0.66

1. Data flow, end to end

1. **Ingress.** A customer's browser or API client resolves `app.kestreldata.com` or `api.kestreldata.com` to Cloudflare, which terminates TLS 1.3 (1.2 minimum) and applies WAF and rate limiting.
2. **Instance selection.** DNS and tenant routing send the request to the instance chosen at contract signature: `us-east-1` or `eu-west-1`. **A tenant's requests never c**

gs://attestor-505506-corporis/engineering/data-flow-and-shared-responsibility.txt

[3] secrets-management-standard — 6. Customer-issued API credentials — relevance 0.64

6. Customer-issued API credentials

API keys issued to customers are stored as Argon2id hashes; Kestrel cannot recover the plaintext of a customer API key and will not do so on request. Keys are displayed once at creation. Customers can create, scope, and revoke keys through the console, and each key carries a last-used timestamp so stale keys are visible.

gs://attestor-505506-corporis/engineering/secrets-management-standard.txt

[4] data-flow-and-shared-responsibility — 3. The shared responsibility model — relevance 0.64

3. The shared responsibility model

Security of the platform is Kestrel's. Security of what the customer does with it is the

customer's. The line is drawn here rather than left implicit, because an unstated boundary is where a breach lands on whoever is less able to argue.

****Kestrel is responsible for:****

* physical and environmental security of the infrastructure (through AWS), and the cloud
co

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[5] cloud-exit-and-portability-plan — 8. Testing — relevance 0.63

8. Testing

The plan is exercised annually as a tabletop with the SRE team, the VP Engineering, and the CISO. The 19 November 2025 exercise identified two gaps — the SQS/SNS adapter was not in place, and the KMS re-encryption path was undocumented — and both were closed by 14 January 2026. The next exercise is scheduled for November 2026.

gs://attestor-505506-corporus/engineering/cloud-exit-and-portability-plan.txt

[6] secrets-management-standard — 1. Where secrets live — relevance 0.61

1. Where secrets live

| Secret class | Store | Rotation |

|---|---|---|

| Application secrets, API keys | AWS Secrets Manager | 90 days, automated |

| Database credentials | AWS Secrets Manager with RDS-managed rotation | 30 days, automated |

| Encryption keys | AWS KMS (key material never leaves KMS) | Annual, automated |

| TLS certificates | AWS Certificate Manager | Automatic before expiry

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

[7] secrets-management-standard — 5. Rotation on compromise — relevance 0.61

5. Rotation on compromise

A suspected compromised secret is rotated immediately, before investigation completes.

The order is rotate, then investigate, then decide whether it was actually exposed:

delaying rotation while establishing certainty extends the exposure window for no benefit.

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

[8] secrets-management-standard — Secrets Management Standard — relevance 0.58

Secrets Management Standard

****Document ID:**** KD-ENG-006 · ****Version:**** 2.1 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 22 January 2026 · ****Maps to:**** SOC 2 CC6.1 · ISO 27001:2022 A.8.24

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

[9] data-flow-and-shared-responsibility — 6. Where processing occurs — relevance 0.58

6. Where processing occurs

Processing occurs in AWS `us-east-1` (US instance) and AWS `eu-west-1` (EU instance), by personnel located in the United States, the European Union, the United Kingdom, and Canada, under the access controls in KD-SEC-002. ****No processing occurs outside the stated regions****, and no support is subcontracted to a third-party provider in another jurisdiction.

gs://attestor-505506-corporus/engineering/data-flow-and-shared-responsibility.txt

[10] secrets-management-standard — 4. Runtime access — relevance 0.57

4. Runtime access

Workloads obtain secrets at runtime through the AWS Secrets Manager CSI driver, mounted as in-memory `tmpfs` volumes. Secrets are never written to disk, never baked into container images, and never passed as environment variables where they could leak into a crash dump or a process listing.

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

278. Can a pull request merge with an unresolved Critical dependency finding?

engineering · Q278 · Vendor Security Review row 279

No, a pull request cannot merge with an unresolved Critical dependency finding. Snyk runs on every pull request, and any Critical or High finding automatically blocks the merge (third-party-library-policy, Section 4. Vulnerability response). If no upstream fix is available within the required SLA, the issue must be resolved by applying a vendored patch, replacing the dependency, or accepting the risk with a documented compensating control and CISO approval (third-party-library-policy, Section 4. Vulnerability response).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] third-party-library-policy — 4. Vulnerability response — relevance 0.64

4. Vulnerability response

Dependency vulnerabilities follow the SLAs in KD-SEC-006: Critical 7 days, High 30 days, Medium 90 days. Snyk runs on every pull request and daily against `main`. A Critical or High finding blocks merge.

Where no upstream fix exists within the SLA, the options in order of preference are: apply a vendored patch, replace the dependency, or accept the risk with a docum

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[2] third-party-library-policy — 1. Adding a dependency — relevance 0.63

1. Adding a dependency

A new direct dependency requires a pull request that documents:

1. Why an existing dependency or the standard library is insufficient.
2. The licence, checked against the allowlist below.
3. Maintenance signal: last release date, open critical issues, number of maintainers.
4. Transitive dependency count added.

Review is by any engineer other than the author. Depend

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[3] third-party-library-policy — 6. Unmaintained dependencies — relevance 0.58

6. Unmaintained dependencies

A dependency with no release in 24 months and no active maintainer is flagged for replacement. Three such dependencies were identified in the January 2026 review, all scheduled for replacement by Q3 2026.

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[4] third-party-library-policy — 5. Upgrades — relevance 0.56

5. Upgrades

Renovate opens upgrade pull requests weekly. Patch-level security upgrades auto-merge when CI is green. Minor and major upgrades are reviewed manually.

An explicit goal is to stay within one minor version of current for all direct dependencies. As of 1 February 2026, 94% of direct dependencies met that target; the 6% that did not are tracked with named owners.

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[5] third-party-library-policy — 7. Internal forks — relevance 0.56

7. Internal forks

Forking a third-party library requires VP Engineering approval and creates an obligation to track upstream security advisories manually. Kestrel currently maintains **zero** internal forks, deliberately.

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

279. When was your Information Security Policy last reviewed and approved?

security · Q279 · Vendor Security Review row 280

Kestrel Data's Information Security Policy (Document ID: KD-SEC-001, Version 4.2) was last reviewed and approved on 11 February 2026 by the Board Audit & Risk Committee, with the next review scheduled for 11 February 2027

(*Information Security Policy*, section "Information Security Policy").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] risk-management-and-governance — 8. Policy management — relevance 0.73

8. Policy management

All security policies carry a document ID, a version, a named owner, an approval date, and a review date. Policies are reviewed at least annually and on material change. The 2026 review cycle covered 14 policies between 8 January and 12 February 2026; three were revised, and the changes were communicated at the February all-hands and through the annual acknowledgement cycle.

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[2] information-security-policy — Information Security Policy — relevance 0.72

Information Security Policy

Document ID: KD-SEC-001

Version: 4.2

Owner: Marcus Oyelaran, Chief Information Security Officer

Approved by: Board Audit & Risk Committee, 11 February 2026

Last review: 11 February 2026 · **Next review:** 11 February 2027

Classification: Internal — may be shared with customers under NDA

gs://attestor-505506-corporus/security/information-security-policy.txt

[3] company-and-security-programme-overview — Company and Security Programme Overview — relevance 0.67

Company and Security Programme Overview

Document ID: KD-SEC-021 · **Version:** 4.2 · **Owner:** Marcus Oyelaran, CISO

Approved: 6 February 2026 · **Next review:** 6 February 2027

Maps to: SOC 2 CC1.1, CC1.2, CC2.1, CC2.3 · ISO 27001:2022 Clauses 4–5

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[4] personnel-security-and-training — 3. Acceptable use and policy acknowledgement — relevance 0.66

3. Acceptable use and policy acknowledgement

Personnel acknowledge the Acceptable Use Policy (KD-SEC-005) and this standard at onboarding and annually thereafter. Acknowledgement is tracked in Vanta; the 2025 annual cycle closed on 30 November 2025 at **100%** completion across 187 employees and 24 contractors.

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[5] personnel-security-and-training — Personnel Security and Security Training Programme — relevance 0.66

Personnel Security and Security Training Programme

Document ID: KD-SEC-013 · **Version:** 2.1 · **Owner:** Sofia Brenner, Head of IT

Approved: 22 January 2026 · **Next review:** 22 January 2027

Maps to: SOC 2 CC1.1, CC1.4, CC2.1, CC6.2 · ISO 27001:2022 A.6.1, A.6.2, A.6.3, A.6.6

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

280. For each applicable system: Is multi-factor authentication enforced for all personnel with production access?

security · Q280 · Vendor Security Review row 281

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] access-control-standard — 2. Multi-factor authentication — relevance 0.70

2. Multi-factor authentication

Hardware-backed MFA (WebAuthn / FIDO2, YubiKey 5 series) is mandatory for every human account. SMS and TOTP were removed as acceptable factors on 30 June 2025 following the

RISK-2025-0031 treatment plan. Coverage is 100% of the 187 active employee accounts and 100% of the 24 active contractor accounts, verified continuously by Vanta control AC-07.

gs://attestor-505506-corporus/security/access-control-standard.txt

[2] access-control-standard — 3. Role-based access — relevance 0.67

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix (`SEC-GOV/access-matrix`), which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is just-in-time.

gs://attestor-505506-corporus/security/access-control-standard.txt

[3] information-security-policy — 7. Access control — relevance 0.67

7. Access control

Access follows least privilege and is governed by the Access Control Standard (KD-SEC-002). Identity is federated through Okta with SAML 2.0. Hardware-backed multi-factor authentication (WebAuthn / FIDO2 security keys) is mandatory for all staff; SMS and TOTP were retired as authentication factors on 30 June 2025.

Production access requires a documented business justification, e

gs://attestor-505506-corporus/security/information-security-policy.txt

[4] access-control-standard — 9. Password requirements — relevance 0.62

9. Password requirements

Where a password is used, minimum length is 14 characters, checked against the Have I Been Pwned breached-password corpus at set time. Rotation is not forced on a schedule, in line with NIST SP 800-63B guidance; rotation is forced on evidence of compromise.

gs://attestor-505506-corporus/security/access-control-standard.txt

[5] information-security-policy — 6. Personnel security — relevance 0.62

6. Personnel security

All employees and contractors undergo background screening appropriate to jurisdiction before their start date, conducted by Checkr. Screening covers identity verification, right to work, criminal records where lawful, and employment history for the preceding seven years.

Security awareness training is delivered through Curricula at onboarding and annually thereafter. Comple

gs://attestor-505506-corporus/security/information-security-policy.txt

281. Is automatic email forwarding to external addresses permitted?

security · Q281 · Vendor Security Review row 282

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] acceptable-use-policy — 5. Email and communications — relevance 0.62

5. Email and communications

Kestrel uses Google Workspace with DMARC set to `p=reject`, SPF, and DKIM enforced on all sending domains. External email is banner-tagged. Automatic forwarding to external addresses is disabled at the tenant level and cannot be enabled by end users.

gs://attestor-505506-corporus/security/acceptable-use-policy.txt

[2] acceptable-use-policy — Acceptable Use Policy — relevance 0.54

Acceptable Use Policy

****Document ID:**** KD-SEC-011 · ****Version:**** 2.3 · ****Owner:**** Sofia Brenner, Head of IT

****Approved:**** 15 January 2026 · ****Next review:**** 15 January 2027

****Applies to:**** all employees, contractors, and anyone issued Kestrel credentials

gs://attestor-505506-corporus/security/acceptable-use-policy.txt

[3] acceptable-use-policy — 3. Credentials — relevance 0.54

3. Credentials

Credentials are personal and may not be shared, including with other Kestrel staff.

Shared team accounts are prohibited. Where a shared credential is unavoidable for a third-party service that does not support SSO, it is held in a 1Password shared vault with access logged, and the service is recorded on the SSO-gap register.

gs://attestor-505506-corporus/security/acceptable-use-policy.txt

[4] acceptable-use-policy — 4. Data handling — relevance 0.54

4. Data handling

Restricted data may not be copied to personal cloud storage, personal email, USB media, or unmanaged devices. USB mass storage is blocked at the OS level on all managed devices.

Screen sharing during customer calls must use a dedicated demo tenant, never production.

gs://attestor-505506-corporus/security/acceptable-use-policy.txt

[5] acceptable-use-policy — 6. Monitoring — relevance 0.51

6. Monitoring

Kestrel monitors use of its systems for security purposes as described in the Logging and Monitoring Standard. Monitoring is proportionate, is not used for productivity surveillance, and is disclosed to staff at onboarding.

gs://attestor-505506-corporus/security/acceptable-use-policy.txt

282. What is your turnaround commitment for data subject request assistance?

legal · Q282 · Vendor Security Review row 283

When acting as a data processor, Kestrel commits to assist customers with data subject requests within 5 business days of receiving a written request (`data-subject-rights-procedure`, Section 2). This assistance entails providing guidance on self-service tooling, producing exports of identified records when the customer cannot isolate them, or executing tenant deletions under customer direction. In practice, assistance requests in 2025 achieved a measured median turnaround of 2 business days and a maximum of 5 business days (`data-subject-rights-procedure`, Section 2). For situations where Kestrel acts as a data controller, access requests are acknowledged within 5 business days and fulfilled within 30 calendar days, with a possible 60-day extension for complex requests upon notice (`data-subject-rights-procedure`, Section 4).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] data-subject-rights-procedure — 2. Assisting customers as processor — relevance 0.71

2. Assisting customers as processor

****Kestrel commits to assist a customer with a data subject request within 5 business days of a written request**, which is the commitment in the DPA (KD-LEG-001 §6). Assistance means one of three things:**

1. Pointing the customer at the self-service tooling that lets them do it themselves, which is the fastest route and covers the majority of requests;
2. Pro

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[2] data-subject-rights-procedure — 4. Access requests (Article 15) — relevance 0.65

4. Access requests (Article 15)

Where Kestrel acts as controller, an access request is acknowledged within 5 business days and answered within ****30 calendar days****, extendable by a further 60 days for complex requests with notice to the data subject. Identity is verified through the requester's

registered email address plus one additional factor; where identity cannot be established, the request i

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[3] data-subject-rights-procedure — 9. Records — relevance 0.65

9. Records

Every request, its route, and its resolution date are recorded in the DSR register held by the DPO and retained for three years. The register is available to auditors and, in redacted form, to customers exercising their audit rights under the DPA.

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[4] data-subject-rights-procedure — Data Subject Rights Procedure — relevance 0.65

Data Subject Rights Procedure

****Document ID:**** KD-LEG-007 · ****Version:**** 2.3 · ****Owner:**** Priya Raghunathan, DPO

****Approved:**** 20 January 2026 · ****Next review:**** 20 January 2027

****Maps to:**** GDPR Articles 12, 15–22, 28(3)(e) · CCPA/CPRA §1798.100–130

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[5] data-processing-agreement — 6. Data subject rights — relevance 0.64

6. Data subject rights

Kestrel provides self-service functionality allowing Customer to access, correct, export, and delete Personal Data within the Service. Where a data subject contacts Kestrel directly, Kestrel refers them to Customer and does not respond substantively, unless legally obliged to do so.

Where the Service functionality is insufficient, Kestrel assists Customer within ****10**

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

283. Have you completed a Transfer Impact Assessment? Provide supporting evidence.

legal · Q283 · Vendor Security Review row 284

Kestrel Data has completed a Transfer Impact Assessment (TIA), Document ID KD-LEG-010 (Version 2.1), approved on 9 January 2026 by Data Protection Officer Priya Raghunathan (`transfer-impact-assessment`, "Transfer Impact Assessment", "1. Status"). The assessment is conducted in accordance with GDPR Articles 44–49, EDPB Recommendations 01/2020, and the **Schrems II** ruling (C-311/18). It evaluates cross-border data flows governed by the 2021 Standard Contractual Clauses (Modules Two and Three), the UK International Data Transfer Addendum, and Swiss adaptations (`transfer-impact-assessment`, "Transfer Impact Assessment", "3. Transfer mechanism"). The TIA concludes that the residual risk to data subjects is low across all evaluated transfer scenarios, supported by supplementary measures including encryption in transit (TLS 1.3) and at rest (AES-256-GCM) with keys managed outside the importer's jurisdiction, regional data residency options, customer-managed key capabilities (Tri-Secret Secure for Snowflake), and documented government-access challenge procedures (`transfer-impact-assessment`, "6. Conclusion"; `standard-contractual-clauses-summary`, "4. Transfer Impact Assessment - conclusion"). The assessment is reviewed annually—with the next formal review scheduled for 9 January 2027—or upon any material change in transfer architecture or applicable surveillance laws. A complete copy of the TIA document is available to customers under NDA (`transfer-impact-assessment`, "1. Status", "6. Conclusion").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] transfer-impact-assessment — Transfer Impact Assessment — relevance 0.71

Transfer Impact Assessment

****Document ID:**** KD-LEG-010 · ****Version:**** 2.1 · ****Owner:**** Priya Raghunathan, DPO

****Approved:**** 9 January 2026 · ****Next review:**** 9 January 2027

****Maps to:**** GDPR Articles 44–49 · EDPB Recommendations 01/2020 · Schrems II (C-311/18)

gs://attestor-505506-corporus/legal/transfer-impact-assessment.txt

[2] transfer-impact-assessment — 1. Status — relevance 0.69

1. Status

Kestrel Data has completed a Transfer Impact Assessment², most recently updated on 9 January 2026. It is refreshed annually and on any material change to the transfer chain, the receiving country's law, or the supplementary measures relied on. A copy is available to customers under NDA.

gs://attestor-505506-corpus/legal/transfer-impact-assessment.txt

[3] transfer-impact-assessment — 6. Conclusion — relevance 0.67

6. Conclusion

For T1 and T2 the residual risk to data subjects is assessed as **low**: the data transferred is limited, pseudonymised where possible, encrypted with keys held outside the importer's jurisdiction, and unaccompanied by any customer content. For T3 and T4 the residual risk is **low** on the same basis, with the additional point that no customer content is transferred at all.

The asse

gs://attestor-505506-corpus/legal/transfer-impact-assessment.txt

[4] standard-contractual-clauses-summary — 4. Transfer Impact Assessment - conclusion — relevance 0.63

4. Transfer Impact Assessment - conclusion

A TIA was completed on 28 January 2026 covering transfers to the US. Summary of conclusions:

Assessment of US law. Kestrel assessed FISA 702 and EO 12333. Kestrel is not an "electronic communications service provider" as defined in 50 U.S.C. 1881(b)(4) and has never received a national security request of any kind, nor a National Security Letter

gs://attestor-505506-corpus/legal/standard-contractual-clauses-summary.txt

[5] transfer-impact-assessment — 3. Transfer mechanism — relevance 0.62

3. Transfer mechanism

The 2021 **Standard Contractual Clauses, Module Two (controller to processor)** apply between the customer and Kestrel, and **Module Three (processor to sub-processor)** between Kestrel and its US sub-processors. The **UK International Data Transfer Addendum** is incorporated for UK exports, and for Switzerland the SCCs are applied with the adaptations published by the Swiss

gs://attestor-505506-corpus/legal/transfer-impact-assessment.txt

284. Do you enforce API rate limiting?

engineering · Q284 · Vendor Security Review row 285

Yes, Kestrel Data enforces API rate limits at Cloudflare ahead of application code. Standard rate limits include: - **Public API:** 120 requests per minute per tenant - **Bulk export endpoint:** 6 requests per minute per tenant - **Authentication endpoints:** 10 attempts per 5 minutes per source address - **Password reset:** 5 attempts per hour per account When a rate limit is exceeded, the service returns an HTTP 429 status code with a `Retry-After` header. Enterprise tenants may request higher limits through their account team (`api-and-integration-standard`, Section 3, "Rate limiting").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by EngineeringAgent

Evidence (5)

[1] api-and-integration-standard — 3. Rate limiting — relevance 0.71

3. Rate limiting

Rate limits are enforced at Cloudflare, ahead of application code:

Surface	Limit
Public API, per tenant	120 requests/minute
Bulk export endpoint, per tenant	6 requests/minute
Authentication endpoints, per source address	10 attempts/5 minutes
Password reset, per account	5 attempts/hour (added 27 February 2026)

Exceeding a limit returns HTTP

gs://attestor-505506-corporate-engineering/api-and-integration-standard.txt

[2] availability-sla — 3. Exclusions — relevance 0.58

3. Exclusions

Downtime does not include unavailability caused by:

- Scheduled maintenance, notified at least 7 days in advance, in the window Sundays 04:00-06:00 UTC, capped at 4 hours per month.
- Emergency maintenance to address a security vulnerability, notified as soon as practicable.
- Customer configuration, customer code, or customer exceeding documented rate limits.
- Failure o

gs://attestor-505506-corporate-engineering/availability-sla.txt

[3] availability-sla — 2. Definitions — relevance 0.58

2. Definitions

Uptime is the percentage of minutes in a calendar month during which the Service is Available, calculated as:

$$\text{Uptime \%} = ((\text{Total Minutes} - \text{Downtime Minutes}) / \text{Total Minutes}) \times 100$$

Downtime is any minute during which all requests to the production API from the external monitoring network return a 5xx error or fail to connect. Measurement is by independent third-p

gs://attestor-505506-corporate-engineering/availability-sla.txt

[4] api-and-integration-standard — 2. Customer control of API credentials — relevance 0.58

2. Customer control of API credentials

Customers create, scope, rotate, and revoke their own API credentials from the tenant administrator console, without involving Kestrel support. A credential can be limited to read-only, to specific datasets, and to a source IP allowlist. Revocation takes effect within 30 seconds across all regions.

Kestrel support cannot recover a customer API key. K

gs://attestor-505506-corporate-engineering/api-and-integration-standard.txt

[5] api-and-integration-standard — 7. Versioning and deprecation — relevance 0.57

7. Versioning and deprecation

The API is versioned in the path (`/v1`, `/v2`). Backwards-incompatible changes are made only in a new version.

The deprecation policy is 12 months' notice for a whole API version and **90 days' notice** for an individual endpoint or field, delivered by email to tenant administrators, by a `Deprecation` and `Sunset` response header, and on the developer changelog

gs://attestor-505506-corporate-engineering/api-and-integration-standard.txt

285. Are development, staging, and production environments separated?

engineering · Q285 · Vendor Security Review row 286

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (8)

[1] sdlc-policy — 2. Environments — relevance 0.69

2. Environments

| Environment | Purpose | Data |

|---|---|---|

`local`	Developer machines	Synthetic fixtures only
`ci`	Automated testing	Synthetic fixtures only
`staging`	Pre-production verification	Synthetic and anonymised data
`production`	Live service	Customer data

****Production data is never copied to a lower environment.**** Staging fixtures are generated

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[2] sdlc-policy — 7. Separation of duties — relevance 0.64

7. Separation of duties

Engineers cannot deploy their own change to production without the automated pipeline: no human has the ability to push a container image to the production registry directly. The deployment role is held by the CI service identity, which authenticates through OIDC and holds no long-lived credentials.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[3] infrastructure-architecture-overview — 6. Network — relevance 0.63

6. Network

Private subnets for all compute and data. No public IP addresses on workload instances. Ingress is exclusively through Cloudflare, then an AWS Application Load Balancer, then the Istio ingress gateway. Egress is through NAT gateways with an allowlist for known destinations.

Security groups are managed in Terraform and default-deny. There are no `0.0.0.0/0` ingress rules in produc

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[4] infrastructure-architecture-overview — 3. Compute — relevance 0.61

3. Compute

Amazon EKS (Kubernetes 1.31) with managed node groups spanning three availability zones. Workloads run as containers built from distroless base images, as non-root, with read-only root filesystems and dropped Linux capabilities. Pod Security Standards are enforced at the `restricted` level.

Node images are immutable; nodes are recycled with a maximum age of 30 days rather than pa

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[5] infrastructure-architecture-overview — Infrastructure Architecture Overview — relevance 0.60

Infrastructure Architecture Overview

****Document ID:**** KD-ENG-003 · ****Version:**** 3.4 · ****Owner:**** Dana Whitfield, VP Engineering

****Last updated:**** 5 February 2026 · ****Classification:**** Confidential, NDA required

gs://attestor-505506-corporus/engineering/infrastructure-architecture-overview.txt

[6] sdlc-policy — 6. Release — relevance 0.58

6. Release

Releases are continuous: merge to `main` triggers a deployment to staging, an automated verification suite, and then a progressive rollout to production. Rollout is canary-based: 5% of traffic for 15 minutes, then 25%, then 100%, with automatic rollback on error-rate or latency regression.

Median lead time from merge to production in 2025 was ****34 minutes****. Change failure rate w

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[7] sdlc-policy — 4. Security in the pipeline — relevance 0.56

4. Security in the pipeline

Static analysis (Semgrep, CodeQL), dependency scanning (Snyk), IaC scanning (Checkov), and secret scanning (Gitleaks pre-commit plus GitHub push protection) all run on every pull request. A Critical or High dependency finding blocks the merge.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[8] sdlc-policy — 3. Testing requirements — relevance 0.56

3. Testing requirements

- Unit test coverage gate at **80%** on changed lines, enforced in CI.
- Integration tests run against ephemeral infrastructure provisioned per pull request.
- Tenant isolation tests run on every build: a suite of 84 assertions attempting cross-tenant reads through every public API surface.
- Load tests before any release expected to change the performance profile.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

286. Are customer API keys recoverable by your support team?

engineering · Q286 · Vendor Security Review row 287

No, customer API keys cannot be recovered by Kestrel support or engineering. Keys are displayed only once at creation and stored exclusively as cryptographic hashes. Consequently, there is no technical path to retrieve or return the plaintext key. If a customer API key is lost, it cannot be recovered and must be replaced via the tenant administrator console (`api-and-integration-standard`, Section 2: "Customer control of API credentials"; `secrets-management-standard`, Section 6: "Customer-issued API credentials").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] api-and-integration-standard — 2. Customer control of API credentials — relevance 0.69

2. Customer control of API credentials

Customers create, scope, rotate, and revoke their own API credentials from the tenant administrator console, without involving Kestrel support. A credential can be limited to read-only, to specific datasets, and to a source IP allowlist. Revocation takes effect within 30 seconds across all regions.

Kestrel support cannot recover a customer API key. K

gs://attestor-505506-corporus/engineering/api-and-integration-standard.txt

[2] secrets-management-standard — 6. Customer-issued API credentials — relevance 0.67

6. Customer-issued API credentials

API keys issued to customers are stored as Argon2id hashes; Kestrel cannot recover the plaintext of a customer API key and will not do so on request. Keys are displayed once at creation. Customers can create, scope, and revoke keys through the console, and each key carries a last-used timestamp so stale keys are visible.

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

[3] api-and-integration-standard — 1. API authentication — relevance 0.59

1. API authentication

The public API at `https://api.kestreldata.com/v2` accepts two credential types:

OAuth 2.0 bearer tokens issued through the client-credentials flow, valid for 60 minutes, scoped to a single tenant and to an explicit permission set. This is the recommended integration path.

API keys for simple server-to-server use, presented as a bearer token, scoped the same

gs://attestor-505506-corporus/engineering/api-and-integration-standard.txt

[4] secrets-management-standard — 2. What is prohibited — relevance 0.59

2. What is prohibited

- Secrets in source code, including test fixtures, comments, and commit history.
- Secrets in environment files committed to a repository.
- Secrets in CI logs, container image layers, or Terraform state in plaintext.
- Long-lived static AWS access keys. The last was decommissioned 17 November 2024, and creation of a new one triggers an hourly detection that pages the owner.

gs://attestor-505506-corporus/engineering/secrets-management-standard.txt

[5] api-and-integration-standard — 3. Rate limiting — relevance 0.58

3. Rate limiting

Rate limits are enforced at Cloudflare, ahead of application code:

Surface	Limit
Public API, per tenant	120 requests/minute
Bulk export endpoint, per tenant	6 requests/minute
Authentication endpoints, per source address	10 attempts/5 minutes
Password reset, per account	5 attempts/hour (added 27 February 2026)

Exceeding a limit returns HTTP

gs://attestor-505506-corpus/engineering/api-and-integration-standard.txt

287. Please confirm: Do you offer customer-managed encryption keys?

security · Q287 · Vendor Security Review row 288

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

288. Describe your change management process.

engineering · Q288 · Vendor Security Review row 289

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (7)

[1] change-management-procedure — Change Management Procedure — relevance 0.69

Change Management Procedure
Document ID: KD-ENG-002 · **Version:** 3.0 · **Owner:** Dana Whitfield, VP Engineering
Approved: 20 January 2026 · **Maps to:** SOC 2 CC8.1 · ISO 27001:2022 A.8.32

gs://attestor-505506-corpus/engineering/change-management-procedure.txt

[2] change-management-procedure — 2. Normal change requirements — relevance 0.65

2. Normal change requirements
A Normal change additionally requires a written rollback plan, a customer-impact assessment, and sign-off from the Change Advisory group (VP Engineering plus one SRE). Schema migrations must be backward compatible for at least one release, so that a rollback does not require a data migration.

gs://attestor-505506-corpus/engineering/change-management-procedure.txt

[3] change-management-procedure — 3. Emergency changes — relevance 0.64

3. Emergency changes
An Emergency change may bypass the Change Advisory step but never bypasses code review or CI. The Incident Commander authorises it, and a retrospective record is filed within one business day covering what changed, why the normal path was bypassed, and whether the change should be reworked.

All 9 Emergency changes in 2025 have completed retrospectives on file.

gs://attestor-505506-corpus/engineering/change-management-procedure.txt

[4] change-management-procedure — 7. Change freeze — relevance 0.62

7. Change freeze
A change freeze applies from 20 December to 2 January, and during any active SEV1. Only Emergency changes are permitted during a freeze.

gs://attestor-505506-corpus/engineering/change-management-procedure.txt

[5] change-management-procedure — 1. Change classes — relevance 0.61

1. Change classes

| Class | Definition | Approval | Example |

|---|---|---|---|

| **Standard** | Pre-approved, low risk, automated | PR review + CI | Application code, config change through IaC |

| **Normal** | Material risk or customer-visible | PR review + Change Advisory sign-off | Schema migration, dependency major version |

| **Emergency** | Fixing an active SEV1/SEV2 | Retrospective with

gs://attestor-505506-corpus/engineering/change-management-procedure.txt

[6] sdlc-policy — 7. Separation of duties — relevance 0.59

7. Separation of duties

Engineers cannot deploy their own change to production without the automated pipeline: no human has the ability to push a container image to the production registry directly. The deployment role is held by the CI service identity, which authenticates through OIDC and holds no long-lived credentials.

gs://attestor-505506-corpus/engineering/sdlc-policy.txt

[7] change-management-procedure — 5. Database changes — relevance 0.53

5. Database changes

Migrations run through Atlas with a plan-and-approve step. Destructive operations (column drop, table drop) require a two-phase deployment separated by at least one release: the column is first stopped being read, then dropped in a later release.

gs://attestor-505506-corpus/engineering/change-management-procedure.txt

289. Please confirm: What is the export window available after termination?

legal · Q289 · Vendor Security Review row 290

Upon termination, customers are provided a **30-day window** to export their data through the platform ('data-processing-agreement', Section 8; 'master-agreement-summary', Section 7; 'data-retention-schedule', Section 1). Following this 30-day export period, customer data is purged from primary systems in accordance with our deletion timelines, and backups expire naturally within 35 days on standard rotation cycles. Certification of deletion is available upon written request.

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by LegalAgent

Evidence (5)

[1] data-processing-agreement — 8. Deletion and return — relevance 0.70

8. Deletion and return

On termination, Customer may export its data through the Service for **30 days**. After that period Kestrel deletes Customer Personal Data within **90 days**, save where storage is required by law. Backups containing deleted data expire on the standard backup cycle, a maximum of **35 days** after deletion from primary storage. Certification of deletion is provided on wri

gs://attestor-505506-corpus/legal/data-processing-agreement.txt

[2] master-agreement-summary — 7. Term, termination and transition — relevance 0.68

7. Term, termination and transition

The standard term is 12 months with automatic renewal on 30 days' notice of non-renewal. Either party may terminate for material breach uncured after 30 days, or immediately on the other's insolvency.

On termination the customer retains access to export their data for **30 days**, after which live data is deleted within 30 days and backups expire on the ordinar

gs://attestor-505506-corpus/legal/master-agreement-summary.txt

[3] data-retention-schedule — 1. Customer data — relevance 0.66

1. Customer data

| Data class | Active retention | Post-termination | Deletion mechanism |

|---|---|---|---|

| Customer records in the platform | Term of subscription | **30 days** export window, then deleted within **90 days** | Automated

`tenant-purge` job, nightly |
| Analytics warehouse (Snowflake) | Term | Deleted with tenant purge | Automated |
| Uploaded files (S3) | Term | Deleted with

gs://attestor-505506-corporus/legal/data-retention-schedule.txt

[4] data-retention-schedule — 4. Deletion verification — relevance 0.65

4. Deletion verification

The `tenant-purge` job emits a structured completion record listing every store touched and the row or object counts removed. That record is retained for 7 years as evidence of deletion and is the artefact provided when a customer requests certification of deletion.

Deletion was exercised 11 times in 2025 (customer churn). Median time from termination to completed pu

gs://attestor-505506-corporus/legal/data-retention-schedule.txt

[5] data-subject-rights-procedure — 5. Erasure (Article 17) — relevance 0.63

5. Erasure (Article 17)

Erasure of controller-side data is completed within 30 calendar days. Erasure of processor-side data is executed on customer instruction; deletion from live systems is immediate, and **encrypted backups containing the deleted data expire on the ordinary backup rotation within 35 days**. Kestrel does not selectively edit backups, and says so: surgical deletion inside an encr

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

290. What is the lawful basis for your product telemetry processing?

legal · Q290 · Vendor Security Review row 291

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] gdpr-records-of-processing — GDPR Records of Processing Activities (Art. 30) — relevance 0.65

GDPR Records of Processing Activities (Art. 30)

Document ID: KD-LEG-005 · **Version:** 3.0 · **Owner:** Priya Raghunathan, DPO
Last updated: 20 January 2026 · **Next review:** 20 July 2026

Maintained under Art. 30(1) where Kestrel is controller and Art. 30(2) where Kestrel is processor. Available to supervisory authorities on request.

gs://attestor-505506-corporus/legal/gdpr-records-of-processing.txt

[2] dpia-register — 5. Automated decision-making — relevance 0.65

5. Automated decision-making

Kestrel performs **no automated decision-making producing legal effects or similarly significant effects** concerning data subjects, within the meaning of Article 22. The two machine learning features described in KD-SEC-019 §2 surface information to the customer's own analysts; the decisions that follow are made by people at the customer, using the customer's own data

gs://attestor-505506-corporus/legal/dpia-register.txt

[3] gdpr-records-of-processing — Part A - Kestrel as Processor (Art. 30(2)) — relevance 0.65

Part A - Kestrel as Processor (Art. 30(2))

Controller: each Kestrel customer, as identified in the applicable Order Form.

Processor: Kestrel Data, Inc.

DPO: Priya Raghunathan, `dpo@kestreldata.com`

| # | Processing activity | Categories of data subject | Categories of personal data | Transfers | Retention |
|---|---|---|---|---|

| P1 | Hosting and operating the Kestrel Insig

gs://attestor-505506-corporus/legal/gdpr-records-of-processing.txt

[4] transfer-impact-assessment — 5. Supplementary measures relied on — relevance 0.65

5. Supplementary measures relied on
Technical:

1. **Data residency by default** — EU customer content, including backups and the replicated log ship, never leaves `eu-west-1`.
2. **Encryption in transit** — TLS 1.3 (1.2 minimum) on every hop, including between Kestrel and each sub-processor.
3. **Encryption at rest** — AES-256-GCM with keys in AWS KMS. Keys for the EU instance are held i

gs://attestor-505506-corpus/legal/transfer-impact-assessment.txt

[5] data-processing-agreement — 1. Roles — relevance 0.64

1. Roles

Customer is **Controller**. Kestrel Data, Inc. is **Processor**. Where Customer is itself a processor for its own customers, Kestrel is sub-processor and the same obligations apply down the chain.

Kestrel is **Controller** for a limited set of data it determines the purposes of: account administrator contact details, billing records, and product telemetry described in Annex 3.

gs://attestor-505506-corpus/legal/data-processing-agreement.txt

291. Do you operate active-active failover between regions?

engineering · Q291 · Vendor Security Review row 292

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] backup-restore-procedure — 2. Encryption and location — relevance 0.59

2. Encryption and location

All backups are encrypted with AES-256 using AWS KMS. The daily logical dump uses a **separate CMK** from the primary database, so that compromise of the primary key does not compromise the backups.

Cross-region replication stays inside the residency boundary: `us-east-1` replicates to `us-west-2`, `eu-west-1` replicates to `eu-central-1`. EU customer data never le

gs://attestor-505506-corpus/engineering/backup-restore-procedure.txt

[2] backup-restore-procedure — 3. Restore procedure — relevance 0.57

3. Restore procedure

1. Declare the restore scope: point in time, and whether tenant-scoped or full.
2. Provision an isolated restore account from the Terraform module `restore-target`.
3. Restore the RDS snapshot or PITR target into the isolated account.
4. Run the integrity suite: 1,240 assertions covering row counts, referential integrity, tenant isolation invariants, and known-value spo

gs://attestor-505506-corpus/engineering/backup-restore-procedure.txt

[3] infrastructure-architecture-overview — 1. Cloud footprint — relevance 0.56

1. Cloud footprint

Kestrel runs on **Amazon Web Services**. There are two independent production instances:

Instance	Region	Serves
----------	--------	--------

---	---	---
-----	-----	-----

US	`us-east-1` (3 AZs)	North America, and customers with no residency requirement
----	---------------------	--

EU	`eu-west-1` (3 AZs)	EEA, UK, and Swiss customers electing EU residency
----	---------------------	--

Backup replication targets `us-west-2` and `eu-central-1` respecti

gs://attestor-505506-corporis/engineering/infrastructure-architecture-overview.txt

[4] infrastructure-architecture-overview — 3. Compute — relevance 0.56

3. Compute

Amazon EKS (Kubernetes 1.31) with managed node groups spanning three availability zones. Workloads run as containers built from distroless base images, as non-root, with read-only root filesystems and dropped Linux capabilities. Pod Security Standards are enforced at the `restricted` level.

Node images are immutable; nodes are recycled with a maximum age of 30 days rather than pa

gs://attestor-505506-corporis/engineering/infrastructure-architecture-overview.txt

[5] backup-restore-procedure — 5. Tenant-scoped restore — relevance 0.54

5. Tenant-scoped restore

A single customer can be restored without affecting others, by restoring to an isolated account and exporting that tenant rows back. This was exercised once in production, on 22 September 2025, at a customer request following an erroneous bulk delete on their side. Time to complete was 5 hours 10 minutes.

gs://attestor-505506-corporis/engineering/backup-restore-procedure.txt

292. Have you ever received a national security request or National Security Letter?

legal · Q292 · Vendor Security Review row 293

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

293. What service credits apply if the availability commitment is missed?

legal · Q293 · Vendor Security Review row 294

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] master-agreement-summary — 10. Service levels — relevance 0.72

10. Service levels

The availability commitment, service credits, and support response targets are in the Availability SLA (KD-ENG-001). Service credits are the sole remedy for missed availability, with a termination right if the monthly commitment is missed in three consecutive months.

gs://attestor-505506-corporis/legal/master-agreement-summary.txt

[2] master-agreement-summary — 3. Liability — relevance 0.58

3. Liability

The standard limitation of liability is **12 months' fees paid** in the preceding twelve months. A **super-cap of 3x fees** applies to breaches of confidentiality, breaches of the data protection obligations, and Kestrel's indemnities. Liability for gross negligence, wilful misconduct, death or personal injury, and each party's indemnification obligations is uncapped to the extent the

gs://attestor-505506-corporis/legal/master-agreement-summary.txt

[3] master-agreement-summary — 7. Term, termination and transition — relevance 0.56

7. Term, termination and transition

The standard term is 12 months with automatic renewal on 30 days' notice of non-renewal. Either party may terminate for material breach uncured after 30 days, or immediately on the other's insolvency.

On termination the customer retains access to export their data for **30 days**, after

which live data is deleted within 30 days and backups expire on the ordinary

gs://attestor-505506-corporate/legal/master-agreement-summary.txt

[4] master-agreement-summary — 8. Assignment and change of control — relevance 0.55

8. Assignment and change of control

Neither party may assign without the other's consent, except to a successor in a merger or sale of substantially all assets, subject to notice. Where the acquirer is a competitor of the customer, the customer may terminate within 30 days of notice.

gs://attestor-505506-corporate/legal/master-agreement-summary.txt

[5] master-agreement-summary — Master Subscription Agreement — Summary of Key Terms — relevance 0.51

Master Subscription Agreement — Summary of Key Terms

Document ID: KD-LEG-014 · **Version:** 3.2 · **Owner:** Aaron Feldstein, General Counsel

Approved: 28 January 2026 · **Next review:** 28 January 2027

Maps to: SOC 2 CC2.3, CC9.1 · GDPR Article 28

*A summary for review purposes. The executed agreement governs; where this summary and an executed contract differ, the contract prevails.

gs://attestor-505506-corporate/legal/master-agreement-summary.txt

294. What open source licences are prohibited in your codebase?

engineering · Q294 · Vendor Security Review row 295

No supporting evidence was found in the corpus for this question.

Release status: No — no supporting evidence found · confidence low · drafted by EvidenceAgent

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

295. Do you conduct post-incident reviews, and are they shared with customers?

security · Q295 · Vendor Security Review row 296

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] incident-response-runbook — 8. Post-incident review — relevance 0.72

8. Post-incident review

Every SEV1 and SEV2 requires a blameless post-incident review within 5 business days, published internally, with action items tracked to closure in Jira. Reviews are shared with affected customers on request.

gs://attestor-505506-corporate/security/incident-response-runbook.txt

[2] incident-response-runbook — 2. Roles — relevance 0.61

2. Roles

The Incident Commander owns the response and is deliberately not the person fixing the problem; ICs are drawn from a rota of 6 trained staff. The Communications Lead owns customer, internal, and regulator messaging. A Scribe maintains the timeline for every SEV1 and SEV2. Subject matter experts are pulled in as needed.

gs://attestor-505506-corporate/security/incident-response-runbook.txt

[3] company-and-security-programme-overview — 8. How to obtain evidence — relevance 0.58

8. How to obtain evidence

The SOC 2 Type II report, the ISO 27001 certificate, the penetration test executive summary, and the standard DPA are available to customers and prospects under NDA through the account team, usually within two business days. The certificate and the trust page are available without an NDA.

gs://attestor-505506-corporate/security/company-and-security-programme-overview.txt

[4] incident-response-runbook — 9. 2025 incident summary — relevance 0.58

9. 2025 incident summary

41 security events recorded. Zero SEV1. Two SEV2, both resolved without customer data exposure:

- **INC-2025-0044** (14 August 2025) - RDS failover fault causing 41 minutes of degraded service. No data loss; RPO and RTO both met. Root cause was a misconfigured connection pool ceiling.

- **INC-2025-0071** (2 November 2025) - a contractor account remained active f

gs://attestor-505506-corporus/security/incident-response-runbook.txt

[5] logging-monitoring-standard — 6. Customer access to logs — relevance 0.58

6. Customer access to logs

Enterprise-tier customers can retrieve tenant-scoped audit events for their own organisation through the Audit API (`GET /v2/audit/events`), covering the previous 365 days. Kestrel does not expose its own infrastructure logs to customers; relevant extracts are provided during incident response on request.

gs://attestor-505506-corporus/security/logging-monitoring-standard.txt

296. Please confirm: How are security responsibilities communicated to personnel?

security · Q296 · Vendor Security Review row 297

Security responsibilities are communicated to personnel through four deliberately overlapping channels: 1. **Offer Pack and Onboarding Session:** Initial expectations and responsibilities are introduced during hiring and the formal onboarding process. 2. **Annual Policy Acknowledgement:** Personnel review and acknowledge security policies annually. 3. **Monthly All-Hands:** A standing security update is delivered directly by the CISO during monthly company all-hands meetings. 4. **Dedicated #security Slack Channel:** Serves as the documented route for reporting suspicious activity, monitored during business hours with PagerDuty escalation outside business hours. ***(Citation: personnel-security-and-training, Section 7. How security responsibilities are communicated)***

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] personnel-security-and-training — 7. How security responsibilities are communicated — relevance 0.71

7. How security responsibilities are communicated

Responsibilities are communicated four ways, deliberately overlapping: the offer pack and onboarding session; the annual policy acknowledgement; a standing item in the monthly all-hands delivered by the CISO; and the `#security` Slack channel, which is the documented route for reporting anything suspicious and is monitored during business hours wit

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[2] personnel-security-and-training — 4. Security awareness training — relevance 0.64

4. Security awareness training

Security awareness training is **mandatory for all personnel, annually, plus at onboarding within the first 14 days**. Training is delivered through Curricula and runs approximately 45 minutes, covering phishing, credential handling, data classification, secure remote working, and incident reporting.

Measured completion for the 2025 cycle was **99.5%** (210 of 211 i

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[3] risk-management-and-governance — 8. Policy management — relevance 0.64

8. Policy management

All security policies carry a document ID, a version, a named owner, an approval date, and a review date. Policies are reviewed at least annually and on material change. The 2026 review cycle covered 14 policies between 8 January and 12 February 2026; three were revised, and the changes were communicated at the February all-hands and through the annual acknowledgement cycle.

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[4] personnel-security-and-training — Personnel Security and Security Training Programme — relevance 0.63

Personnel Security and Security Training Programme

****Document ID:**** KD-SEC-013 · ****Version:**** 2.1 · ****Owner:**** Sofia Brenner, Head of IT

****Approved:**** 22 January 2026 · ****Next review:**** 22 January 2027

****Maps to:**** SOC 2 CC1.1, CC1.4, CC2.1, CC6.2 · ISO 27001:2022 A.6.1, A.6.2, A.6.3, A.6.6

gs://attestor-505506-corporus/security/personnel-security-and-training.txt

[5] incident-response-runbook — 2. Roles — relevance 0.61

2. Roles

The Incident Commander owns the response and is deliberately not the person fixing the problem; ICs are drawn from a rota of 6 trained staff. The Communications Lead owns customer, internal, and regulator messaging. A Scribe maintains the timeline for every SEV1 and SEV2. Subject matter experts are pulled in as needed.

gs://attestor-505506-corporus/security/incident-response-runbook.txt

297. Is multi-factor authentication enforced for all personnel with production access?

security · Q297 · Vendor Security Review row 298

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

298. When does your ISO 27001 certification expire?

security · Q298 · Vendor Security Review row 299

Kestrel Data's ISO/IEC 27001:2022 certification (Certificate IS-2025-44817, issued by BSI on 22 September 2025) is valid through 21 September 2028 (Information Security Policy, Section 3: "Certifications and attestations").

Release status: Yes — drafted with citations, not individually reviewed · confidence medium · drafted by SecurityAgent

Evidence (10)

[1] risk-management-and-governance — Risk Management and Security Governance — relevance 0.62

Risk Management and Security Governance

****Document ID:**** KD-SEC-018 · ****Version:**** 3.0 · ****Owner:**** Marcus Oyelaran, CISO

****Approved:**** 26 January 2026 · ****Next review:**** 26 January 2027

****Maps to:**** SOC 2 CC1.1, CC1.2, CC1.3, CC3.1, CC3.2, CC3.4 · ISO 27001:2022 A.5.1–A.5.4, Clauses 5–6, 9

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[2] vendor-risk-management-policy — 5. Ongoing monitoring — relevance 0.61

5. Ongoing monitoring

Tier 1 vendors are monitored continuously through SecurityScorecard, with a score drop of more than 10 points in 30 days triggering review. Attestation expiry is tracked in Vanta, with a reminder at 60 days before lapse.

gs://attestor-505506-corporus/security/vendor-risk-management-policy.txt

[3] company-and-security-programme-overview — 6. Scope of certification — relevance 0.61

6. Scope of certification

The ISO 27001 certificate scope statement reads: **"The information security management system supporting the development, operation, and support of the Kestrel Insight analytics platform, including supporting corporate functions, at Austin, Texas and for remote personnel."** The SOC 2 report covers the Security, Availability, and Confidentiality Trust Services Criteria. Pr

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[4] risk-management-and-governance — 9. Exceptions — relevance 0.59

9. Exceptions

Exceptions to policy require: a written business justification, a compensating control, CISO approval, and an expiry date no later than 90 days out. Exceptions above residual score 12 additionally require Security Steering Group approval. Two exceptions were open

as of 1 February 2026.

gs://attestor-505506-corporus/security/risk-management-and-governance.txt

[5] company-and-security-programme-overview — Company and Security Programme Overview — relevance 0.59

Company and Security Programme Overview

Document ID: KD-SEC-021 · **Version:** 4.2 · **Owner:** Marcus Oyelaran, CISO

Approved: 6 February 2026 · **Next review:** 6 February 2027

Maps to: SOC 2 CC1.1, CC1.2, CC2.1, CC2.3 · ISO 27001:2022 Clauses 4–5

gs://attestor-505506-corporus/security/company-and-security-programme-overview.txt

[6] information-security-policy — 10. Exceptions — relevance 0.59

10. Exceptions

Exceptions to this policy require written approval from the CISO, a documented compensating control, and an expiry date not exceeding 180 days. Four exceptions are open as of 11 February 2026, all tracked in Vanta and all with expiry dates before 30 September 2026.

gs://attestor-505506-corporus/security/information-security-policy.txt

[7] information-security-policy — 3. Certifications and attestations — relevance 0.55

3. Certifications and attestations

| Framework | Status | Evidence |

|---|---|---|

| SOC 2 Type II | Current | Report issued 14 March 2026 by Prescient Assurance LLP, covering 1 January – 31 December 2025. No exceptions noted. |

| ISO/IEC 27001:2022 | Certified | Certificate IS-2025-44817, issued by BSI on 22 September 2025, valid to 21 September 2028 |

| ISO/IEC 27701:2019 | Certified | Extension

gs://attestor-505506-corporus/security/information-security-policy.txt

[8] information-security-policy — Information Security Policy — relevance 0.53

Information Security Policy

Document ID: KD-SEC-001

Version: 4.2

Owner: Marcus Oyelaran, Chief Information Security Officer

Approved by: Board Audit & Risk Committee, 11 February 2026

Last review: 11 February 2026 · **Next review:** 11 February 2027

Classification: Internal — may be shared with customers under NDA

gs://attestor-505506-corporus/security/information-security-policy.txt

[9] information-security-policy — 8. Cryptography — relevance 0.51

8. Cryptography

Data at rest is encrypted with AES-256-GCM. Data in transit is protected with TLS 1.3; TLS 1.0 and 1.1 were disabled on 12 April 2024 and TLS 1.2 remains enabled only for a single legacy integration scheduled for removal in Q3 2026. Key management is described in the Encryption Standard (KD-SEC-003) and the Secrets Management Standard (KD-ENG-006).

gs://attestor-505506-corporus/security/information-security-policy.txt

[10] information-security-policy — 6. Personnel security — relevance 0.50

6. Personnel security

All employees and contractors undergo background screening appropriate to jurisdiction before their start date, conducted by Checkr. Screening covers identity verification, right to work, criminal records where lawful, and employment history for the preceding seven years.

Security awareness training is delivered through Curricula at onboarding and annually thereafter. Comple

gs://attestor-505506-corporus/security/information-security-policy.txt

299. How many secrets have been committed to your repositories in the last year?

engineering · Q299 · Vendor Security Review row 300

Quarantined: Model Armor blocked this question.

Release status: No — quarantined by the guardrail · confidence low · drafted by ArmorGuard

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

300. Do you generate a Software Bill of Materials for production builds?

engineering · Q300 · Vendor Security Review row 301

Yes, Kestrel generates a CycloneDX Software Bill of Materials (SBOM) for every production container image at build time. These SBOMs are retained for two years and are made available to customers upon request under NDA (Third-Party Library Policy, Section 3, "Software Bill of Materials").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by EngineeringAgent

Evidence (5)

[1] third-party-library-policy — 3. Software Bill of Materials — relevance 0.73

3. Software Bill of Materials

Kestrel generates a CycloneDX SBOM for every production container image at build time. SBOMs are retained for 2 years and are provided to customers on request under NDA. The current production SBOM covers 1,184 components across 6 services.

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

[2] sdlc-policy — Secure Software Development Lifecycle Policy — relevance 0.58

Secure Software Development Lifecycle Policy

Document ID: KD-ENG-001 · **Version:** 4.1 · **Owner:** Dana Whitfield, VP Engineering
Approved: 20 January 2026 · **Next review:** 20 January 2027
Maps to: SOC 2 CC8.1 · ISO 27001:2022 A.8.25-A.8.31

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[3] sdlc-policy — 3. Testing requirements — relevance 0.54

3. Testing requirements

- Unit test coverage gate at **80%** on changed lines, enforced in CI.
- Integration tests run against ephemeral infrastructure provisioned per pull request.
- Tenant isolation tests run on every build: a suite of 84 assertions attempting cross-tenant reads through every public API surface.
- Load tests before any release expected to change the performance profile.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[4] sdlc-policy — 4. Security in the pipeline — relevance 0.54

4. Security in the pipeline

Static analysis (Semgrep, CodeQL), dependency scanning (Snyk), IaC scanning (Checkov), and secret scanning (Gitleaks pre-commit plus GitHub push protection) all run on every pull request. A Critical or High dependency finding blocks the merge.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[5] third-party-library-policy — Third-Party Library Policy — relevance 0.54

Third-Party Library Policy

Document ID: KD-ENG-008 · **Version:** 1.4 · **Owner:** Dana Whitfield, VP Engineering
Approved: 22 January 2026 · **Maps to:** SOC 2 CC7.1 · ISO 27001:2022 A.8.28

gs://attestor-505506-corporus/engineering/third-party-library-policy.txt

301. For each applicable system: Can an engineer deploy directly to production, bypassing the pipeline?

engineering · Q301 · Vendor Security Review row 302

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] sdlc-policy — 7. Separation of duties — relevance 0.65

7. Separation of duties

Engineers cannot deploy their own change to production without the automated pipeline: no human has the ability to push a container image to the production registry directly. The deployment role is held by the CI service identity, which authenticates through OIDC and holds no long-lived credentials.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[2] sdlc-policy — 4. Security in the pipeline — relevance 0.61

4. Security in the pipeline

Static analysis (Semgrep, CodeQL), dependency scanning (Snyk), IaC scanning (Checkov), and secret scanning (Gitleaks pre-commit plus GitHub push protection) all run on every pull request. A Critical or High dependency finding blocks the merge.

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[3] sdlc-policy — 6. Release — relevance 0.59

6. Release

Releases are continuous: merge to `main` triggers a deployment to staging, an automated verification suite, and then a progressive rollout to production. Rollout is canary-based: 5% of traffic for 15 minutes, then 25%, then 100%, with automatic rollback on error-rate or latency regression.

Median lead time from merge to production in 2025 was **34 minutes**. Change failure rate w

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[4] sdlc-policy — 2. Environments — relevance 0.58

2. Environments

| Environment | Purpose | Data |

|---|---|---|

| `local` | Developer machines | Synthetic fixtures only |

| `ci` | Automated testing | Synthetic fixtures only |

| `staging` | Pre-production verification | Synthetic and anonymised data |

| `production` | Live service | Customer data |

****Production data is never copied to a lower environment.**** Staging fixtures are generated

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

[5] sdlc-policy — 1. Branching and review — relevance 0.56

1. Branching and review

`main` is protected and always releasable. All work happens on short-lived branches merged by pull request. `main` requires:

- At least **one approving review** from a engineer other than the author. Self-approval is blocked at the platform level.

- Two approvals for changes touching authentication, authorisation, tenant isolation, or cryptography. These paths ar

gs://attestor-505506-corporus/engineering/sdlc-policy.txt

302. Is the platform accessible from the public internet without authentication?

security · Q302 · Vendor Security Review row 303

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

303. Is security awareness training mandatory, and at what frequency?

Security awareness training is mandatory for all personnel. Training is required during onboarding within the first 14 days of employment and annually thereafter (`personnel-security-and-training`, Section 4. "Security awareness training"; `information-security-policy`, Section 6. "Personnel security"). The training is delivered through Curricula, takes approximately 45 minutes, and covers topics including phishing, credential handling, data classification, secure remote working, and incident reporting. Completion is monitored via Vanta control AC-19, and failure to complete the training after 14 days of reminders results in automatic access suspension (`personnel-security-and-training`, Section 4. "Security awareness training").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] personnel-security-and-training — 4. Security awareness training — relevance 0.70

4. Security awareness training

Security awareness training is **mandatory** for all personnel, annually, plus at onboarding within the first 14 days. Training is delivered through Curricula and runs approximately 45 minutes, covering phishing, credential handling, data classification, secure remote working, and incident reporting.

Measured completion for the 2025 cycle was **99.5%** (210 of 211 i

gs://attestor-505506-corpus/security/personnel-security-and-training.txt

[2] personnel-security-and-training — Personnel Security and Security Training Programme — relevance 0.60

Personnel Security and Security Training Programme

Document ID: KD-SEC-013 · **Version:** 2.1 · **Owner:** Sofia Brenner, Head of IT

Approved: 22 January 2026 · **Next review:** 22 January 2027

Maps to: SOC 2 CC1.1, CC1.4, CC2.1, CC6.2 · ISO 27001:2022 A.6.1, A.6.2, A.6.3, A.6.6

gs://attestor-505506-corpus/security/personnel-security-and-training.txt

[3] information-security-policy — 6. Personnel security — relevance 0.59

6. Personnel security

All employees and contractors undergo background screening appropriate to jurisdiction before their start date, conducted by Checkr. Screening covers identity verification, right to work, criminal records where lawful, and employment history for the preceding seven years.

Security awareness training is delivered through Curricula at onboarding and annually thereafter. Comple

gs://attestor-505506-corpus/security/information-security-policy.txt

[4] personnel-security-and-training — 5. Simulated phishing — relevance 0.59

5. Simulated phishing

Kestrel runs simulated phishing exercises **quarterly** through Curricula, targeting all personnel with a Kestrel mailbox. Results for 2025:

Quarter	Sent	Click rate	Credential submission	Reported to security
Q1 2025	198	6.1%	1.0%	41%
Q2 2025	203	4.4%	0.5%	52%
Q3 2025	208	3.4%	0.0%	58%
Q4 2025	211			

---|---|---|---|

| Q1 2025 | 198 | 6.1% | 1.0% | 41% |

| Q2 2025 | 203 | 4.4% | 0.5% | 52% |

| Q3 2025 | 208 | 3.4% | 0.0% | 58% |

| Q4 2025 | 211 | **2**

gs://attestor-505506-corpus/security/personnel-security-and-training.txt

[5] personnel-security-and-training — 6. Secure development training — relevance 0.58

6. Secure development training

Engineers complete role-specific secure development training annually, in addition to the general awareness training. The 2025 curriculum was Secure Code Warrior's OWASP Top 10 path plus an internal module on tenant isolation written by the platform team after the INSEC-2026-0219 penetration test. Completion for the 63 engineers in scope was 100% as of 19 December 20

gs://attestor-505506-corporate/security/personnel-security-and-training.txt

304. Is automatic email forwarding to external addresses permitted? If not, describe compensating controls.

security · Q304 · Vendor Security Review row 305

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

305. Describe the data flow for customer data through your platform.

engineering · Q305 · Vendor Security Review row 306

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (8)

[1] data-flow-and-shared-responsibility — Data Flow and Shared Responsibility Model — relevance 0.75

Data Flow and Shared Responsibility Model

Document ID: KD-ENG-011 · **Version:** 2.0 · **Owner:** Dana Whitfield, VP Engineering

Approved: 2 February 2026 · **Next review:** 2 February 2027

Maps to: SOC 2 CC2.3, CC3.2, CC6.1 · ISO 27001:2022 A.5.2, A.5.8, A.8.9 · GDPR Article 28

gs://attestor-505506-corporate/engineering/data-flow-and-shared-responsibility.txt

[2] infrastructure-architecture-overview — 4. Data layer — relevance 0.67

4. Data layer

| Store | Technology | Purpose |

|---|---|---|

| Primary OLTP | Amazon RDS PostgreSQL 16, Multi-AZ | Application state |

| Analytics | Snowflake | Customer analytics workloads |

| Object storage | Amazon S3 | Uploads, exports, backups |

| Cache | Amazon ElastiCache (Redis 7) | Session and query cache |

| Search | OpenSearch 2.13 | In-product search |

gs://attestor-505506-corporate/engineering/infrastructure-architecture-overview.txt

[3] data-flow-and-shared-responsibility — 1. Data flow, end to end — relevance 0.67

1. Data flow, end to end

1. **Ingress.** A customer's browser or API client resolves `app.kestreldata.com` or `api.kestreldata.com` to Cloudflare, which terminates TLS 1.3 (1.2 minimum) and applies WAF and rate limiting.

2. **Instance selection.** DNS and tenant routing send the request to the instance chosen at contract signature: `us-east-1` or `eu-west-1`. A tenant's requests never c

gs://attestor-505506-corporate/engineering/data-flow-and-shared-responsibility.txt

[4] infrastructure-architecture-overview — Infrastructure Architecture Overview — relevance 0.63

Infrastructure Architecture Overview

Document ID: KD-ENG-003 · **Version:** 3.4 · **Owner:** Dana Whitfield, VP Engineering

Last updated: 5 February 2026 · **Classification:** Confidential, NDA required

gs://attestor-505506-corporate/engineering/infrastructure-architecture-overview.txt

[5] data-flow-and-shared-responsibility — 3. The shared responsibility model — relevance 0.63

3. The shared responsibility model

Security of the platform is Kestrel's. Security of what the customer does with it is the customer's. The line is drawn here rather than left implicit, because an unstated boundary is where a breach lands on whoever is less able to argue.

Kestrel is responsible for:

* physical and environmental security of the infrastructure (through AWS), and the cloud
co

gs://attestor-505506-corporate-engineering/data-flow-and-shared-responsibility.txt

[6] infrastructure-architecture-overview — 7. Observability — relevance 0.60

7. Observability

Datadog for metrics, logs, APM, and security monitoring. Distributed tracing uses W3C Trace Context propagated across all services. Every log line carries `tenant\_id` and `request\_id`.

gs://attestor-505506-corporate-engineering/infrastructure-architecture-overview.txt

[7] data-flow-and-shared-responsibility — 2. What crosses a boundary, and what does not — relevance 0.60

2. What crosses a boundary, and what does not

| Data | Leaves the tenant's region? |

|---|---|

| Customer-uploaded analytics datasets | **No** |

| Backups of customer content | **No** |

| Account identity data (EU tenants) | Only for support access, under §4 of KD-SEC-002 |

| Pseudonymised product telemetry | Yes — aggregated to the US, assessed in KD-LEG-010 |

| Operational logs (content-redacted)

gs://attestor-505506-corporate-engineering/data-flow-and-shared-responsibility.txt

[8] data-flow-and-shared-responsibility — 6. Where processing occurs — relevance 0.56

6. Where processing occurs

Processing occurs in AWS `us-east-1` (US instance) and AWS `eu-west-1` (EU instance), by personnel located in the United States, the European Union, the United Kingdom, and Canada, under the access controls in KD-SEC-002. **No processing occurs outside the stated regions**, and no support is subcontracted to a third-party provider in another jurisdiction.

gs://attestor-505506-corporate-engineering/data-flow-and-shared-responsibility.txt

306. Are audit logs tamper-resistant? Describe the mechanism.

security · Q306 · Vendor Security Review row 307

Yes, audit logs are tamper-resistant through several technical and architectural controls: 1. **S3 Object Lock in Compliance Mode:** Audit logs are stored in a security archive bucket with S3 Object Lock configured in compliance mode with a 400-day retention period. This setting cannot be disabled, shortened, or overridden by any principal, including the AWS account root (`logging-monitoring-standard`, Section 3. Tamper resistance; `cloud-security-posture-standard`, Section 8. Logging and evidence). 2. **Dedicated, Isolated Security Archive Account:** Audit evidence—including CloudTrail logs across all regions and accounts, VPC flow logs, GuardDuty findings, and AWS Config history—is delivered to a dedicated `kd-security` account. No engineering roles can write to this account, and there is no human standing access; writes arrive exclusively through the organization trail. This separation ensures that the accounts generating the logs cannot alter or delete them (`logging-monitoring-standard`, Section 3. Tamper resistance; `cloud-security-posture-standard`, Section 8. Logging and evidence). 3. **Log File Integrity Validation:** AWS CloudTrail log file integrity validation is enabled to provide cryptographic verification that log files have not been modified or deleted after delivery (`logging-monitoring-standard`, Section 3. Tamper resistance).

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] logging-monitoring-standard — 3. Tamper resistance — relevance 0.69

3. Tamper resistance

The security archive bucket uses S3 Object Lock in **compliance mode**, which cannot be disabled or shortened by any principal including the AWS account root. CloudTrail log file integrity validation is enabled. The archive account is a separate AWS account with no human standing access; writes arrive only through the organisation trail.

gs://attestor-505506-corporate-security/logging-monitoring-standard.txt

[2] cloud-security-posture-standard — 8. Logging and evidence — relevance 0.64

8. Logging and evidence

CloudTrail (all regions, all accounts), VPC flow logs, GuardDuty findings, and Config history are delivered to a dedicated `kd-security` account that no engineering role can write to, with object lock set to 400 days. This is the arrangement that makes the audit trail defensible: the accounts that generate the evidence cannot alter it.

gs://attestor-505506-corporus/security/cloud-security-posture-standard.txt

[3] logging-monitoring-standard — 5. Time synchronisation — relevance 0.59

5. Time synchronisation

All hosts synchronise to the Amazon Time Sync Service. Log timestamps are recorded in UTC in RFC 3339 format. Clock drift beyond 1 second triggers a SEV3.

gs://attestor-505506-corporus/security/logging-monitoring-standard.txt

[4] logging-monitoring-standard — Logging and Monitoring Standard — relevance 0.58

Logging and Monitoring Standard

Document ID: KD-SEC-009 · **Version:** 2.2 · **Owner:** Sofia Brenner, Head of IT

Approved: 15 January 2026 · **Next review:** 15 January 2027

Maps to: SOC 2 CC7.2 · ISO 27001:2022 A.8.15, A.8.16

gs://attestor-505506-corporus/security/logging-monitoring-standard.txt

[5] logging-monitoring-standard — 6. Customer access to logs — relevance 0.57

6. Customer access to logs

Enterprise-tier customers can retrieve tenant-scoped audit events for their own organisation through the Audit API (`GET /v2/audit/events`), covering the previous 365 days. Kestrel does not expose its own infrastructure logs to customers; relevant extracts are provided during incident response on request.

gs://attestor-505506-corporus/security/logging-monitoring-standard.txt

307. Provide your measured median access revocation time for the last 12 months. Provide supporting evidence.

security · Q307 · Vendor Security Review row 308

For leavers, all access is revoked automatically upon the HRIS termination event. Against a target revocation time of 1 hour, our measured median access revocation time for 2025 was 4 minutes, with a maximum recorded time of 38 minutes (Access Control Standard, Section 6, "Joiners, movers, leavers").

Release status: Yes — drafted with citations, not individually reviewed · confidence high · drafted by SecurityAgent

Evidence (5)

[1] access-control-standard — 6. Joiners, movers, leavers — relevance 0.65

6. Joiners, movers, leavers

Joiners are provisioned via Okta Lifecycle Management from Rippling (HRIS); no access is granted before the background check clears. Movers have entitlements recalculated on role change, with the previous role revoked within 1 business day. Leavers have all access revoked automatically on the HRIS termination event: the target is 1 hour, and the measured median for

gs://attestor-505506-corporus/security/access-control-standard.txt

[2] access-control-standard — 7. Access reviews — relevance 0.63

7. Access reviews

Quarterly user access reviews cover all production systems, the AWS Organization, Snowflake, GitHub, and Okta itself. Reviews are performed by the system owner and attested in Vanta. The Q4 2025 review completed on 12 January 2026 and removed 23 entitlements, of which 9 were stale contractor accesses.

gs://attestor-505506-corporus/security/access-control-standard.txt

[3] access-control-standard — 9. Password requirements — relevance 0.61

9. Password requirements

Where a password is used, minimum length is 14 characters, checked against the Have I Been Pwned breached-password corpus at set time. Rotation is not forced on a schedule, in

line with NIST SP 800-63B guidance; rotation is forced on evidence of compromise.

gs://attestor-505506-corporus/security/access-control-standard.txt

[4] access-control-standard — 3. Role-based access — relevance 0.59

3. Role-based access

Access is granted to Okta groups, never to individuals. There are 41 defined roles, each mapping to a documented entitlement set in the Access Matrix (`SEC-GOV/access-matrix`), which is the authoritative record reviewed during audit. Standing production access is limited to 11 named Site Reliability Engineers. All other production access is just-in-time.

gs://attestor-505506-corporus/security/access-control-standard.txt

[5] access-control-standard — 4. Just-in-time production access — relevance 0.59

4. Just-in-time production access

Engineers request elevated production access through the `/access` Slack workflow. A request requires a written business justification, a linked incident or change ticket, and approval from a second engineer holding the SRE role. Self-approval is blocked.

Granted access expires automatically after **8 hours**. All commands executed in an elevated session are

gs://attestor-505506-corporus/security/access-control-standard.txt

308. Are backups replicated across regions? Do they leave the residency boundary? Provide supporting evidence.

legal · Q308 · Vendor Security Review row 309

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

309. Provide your measured SLA compliance rate for the last 12 months.

engineering · Q309 · Vendor Security Review row 310

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] availability-sla — 2. Definitions — relevance 0.72

2. Definitions

Uptime is the percentage of minutes in a calendar month during which the Service is Available, calculated as:

$$\text{Uptime \%} = ((\text{Total Minutes} - \text{Downtime Minutes}) / \text{Total Minutes}) \times 100$$

Downtime is any minute during which all requests to the production API from the external monitoring network return a 5xx error or fail to connect. Measurement is by independent third-p

gs://attestor-505506-corporus/engineering/availability-sla.txt

[2] availability-sla — 4. Service credits — relevance 0.68

4. Service credits

| Monthly uptime | Credit (% of monthly fee) |

|---|---|

| Below 99.9% but at or above 99.0% | 10% |

| Below 99.0% but at or above 95.0% | 25% |

| Below 95.0% | 50% |

Credits are the sole and exclusive remedy for failure to meet this SLA. A claim must be submitted within **30 days** of the end of the affected month, with supporting detail. Credits are applied to the next

gs://attestor-505506-corporus/engineering/availability-sla.txt

[3] availability-sla — 5. Historical performance — relevance 0.66

5. Historical performance

| Year | Measured availability | Months below 99.9% | Credits issued |

|---|---|---|---|

| 2025 | 99.97% | 0 | 0 |

| 2024 | 99.94% | 1 (March, 99.87%) | 1 customer, 10% |

| 2023 | 99.91% | 1 (August, 99.82%) | 3 customers, 10% |

gs://attestor-505506-corporus/engineering/availability-sla.txt

[4] service-operations-and-support — 8. Capacity and performance — relevance 0.64

8. Capacity and performance

Capacity is reviewed monthly against a 90-day forecast. Autoscaling handles ordinary variation; the review exists for the changes autoscaling cannot absorb, such as a large tenant onboarding. Two capacity increases were made ahead of demand in 2025, neither triggered by a saturation alert.

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[5] availability-sla — 1. Commitment — relevance 0.63

1. Commitment

Kestrel commits to **99.9% monthly uptime** for the Kestrel Insight platform on the Enterprise and Growth tiers.

The **Starter tier** carries no availability commitment. It is offered on a reasonable efforts basis and is excluded from service credits.

gs://attestor-505506-corporus/engineering/availability-sla.txt

310. Have you completed any Data Protection Impact Assessments? If not, describe compensating controls.

legal · Q310 · Vendor Security Review row 311

No answer was produced for this question in this round.

Release status: No — not answered in this round

Evidence: none. No retrieved passage supports this answer, which is why it must not be sent to a customer as one.

311. How frequently may a customer audit, and on what notice?

legal · Q311 · Vendor Security Review row 312

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] data-processing-agreement — 9. Audit — relevance 0.71

9. Audit

Kestrel makes available its current SOC 2 Type II report and ISO 27001 certificate, which Customer accepts as satisfying Art. 28(3)(h) in the first instance. Where Customer has a documented, specific concern not addressed by those reports, Customer may conduct an audit no more than **once per twelve months**, on 30 days written notice, during business hours, subject to confidentiality

gs://attestor-505506-corporus/legal/data-processing-agreement.txt

[2] master-agreement-summary — 6. Audit rights — relevance 0.69

6. Audit rights

Customers may audit Kestrel's compliance with the DPA **once per twelve-month period on 30 days' written notice**, with additional audits permitted following a personal data breach affecting the customer or on a supervisory authority's instruction. Audits are conducted during business hours, must not unreasonably disrupt operations, and are subject to confidentiality.

Kestrel firs

gs://attestor-505506-corporus/legal/master-agreement-summary.txt

[3] data-subject-rights-procedure — 9. Records — relevance 0.64

9. Records

Every request, its route, and its resolution date are recorded in the DSR register held by the DPO and retained for three years. The register is available to auditors and, in redacted form, to customers exercising their audit rights under the DPA.

gs://attestor-505506-corporus/legal/data-subject-rights-procedure.txt

[4] security-addendum — 5. Testing commitments — relevance 0.62

5. Testing commitments

- Independent penetration test at least **annually**; executive summary available under NDA.
- Vulnerability remediation to the SLAs in KD-SEC-006: Critical 7 days, High 30 days.
- Disaster recovery restore tested at least **quarterly**.

gs://attestor-505506-corporus/legal/security-addendum.txt

[5] security-addendum — 4. Incident notification — relevance 0.61

4. Incident notification

- Personal data breach: notification within **72 hours** of confirmation.
- Confirmed unauthorised access to customer production data: **24 hours**.
- Notification content as set out in the DPA Section 7.

gs://attestor-505506-corporus/legal/security-addendum.txt

312. What is your scheduled maintenance window? Provide supporting evidence.

engineering · Q312 · Vendor Security Review row 313

Held for a human. The department engine retrieved supporting passages for this question but returned no drafted answer, so there is evidence to work from and no draft to review. The passages are cited below.

Release status: No — held for a human · confidence low · drafted by RemoteDraftingPipeline

Evidence (5)

[1] service-operations-and-support — 2. Scheduled maintenance — relevance 0.73

2. Scheduled maintenance

The standard maintenance window is **Sundays 06:00–10:00 UTC**. Most changes do not use it: deployments are rolling and zero-downtime, and 2025 saw 1,412 production deployments with no customer-visible downtime.

Customers receive at least 7 days' notice of scheduled maintenance expected to be customer-affecting, and 30 days' notice where the change requires customer a

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[2] availability-sla — 3. Exclusions — relevance 0.67

3. Exclusions

Downtime does not include unavailability caused by:

- Scheduled maintenance, notified at least 7 days in advance, in the window Sundays 04:00-06:00 UTC, capped at 4 hours per month.
- Emergency maintenance to address a security vulnerability, notified as soon as practicable.
- Customer configuration, customer code, or customer exceeding documented rate limits.
- Failure o

gs://attestor-505506-corporus/engineering/availability-sla.txt

[3] service-operations-and-support — Service Operations, Maintenance and Support — relevance 0.63

Service Operations, Maintenance and Support

****Document ID:**** KD-ENG-009 · ****Version:**** 2.2 · ****Owner:**** Dana Whitfield, VP Engineering

****Approved:**** 23 January 2026 · ****Next review:**** 23 January 2027

****Maps to:**** SOC 2 A1.1, A1.2, CC7.3, CC8.1 · ISO 27001:2022 A.5.29, A.8.6, A.8.32

gs://attestor-505506-corporus/engineering/service-operations-and-support.txt

[4] availability-sla — 6. Support response targets — relevance 0.61

6. Support response targets

Support targets are separate from this SLA and are not credit-bearing.

| Severity | First response | Coverage |

|---|---|---|

| Urgent (production down) | 1 hour | 24 x 7 |

| High (major feature impaired) | 4 business hours | Business hours |

| Normal | 1 business day | Business hours |

| Low | 3 business days | Business hours |

Business hours are 08:00-18:00

gs://attestor-505506-corporus/engineering/availability-sla.txt

[5] availability-sla — Availability Service Level Agreement — relevance 0.58

Availability Service Level Agreement

****Document ID:**** KD-ENG-007 · ****Version:**** 3.0 · ****Owner:**** Aaron Feldstein, General Counsel

****Effective:**** 1 January 2026 · Forms part of the Master Subscription Agreement

gs://attestor-505506-corporus/engineering/availability-sla.txt